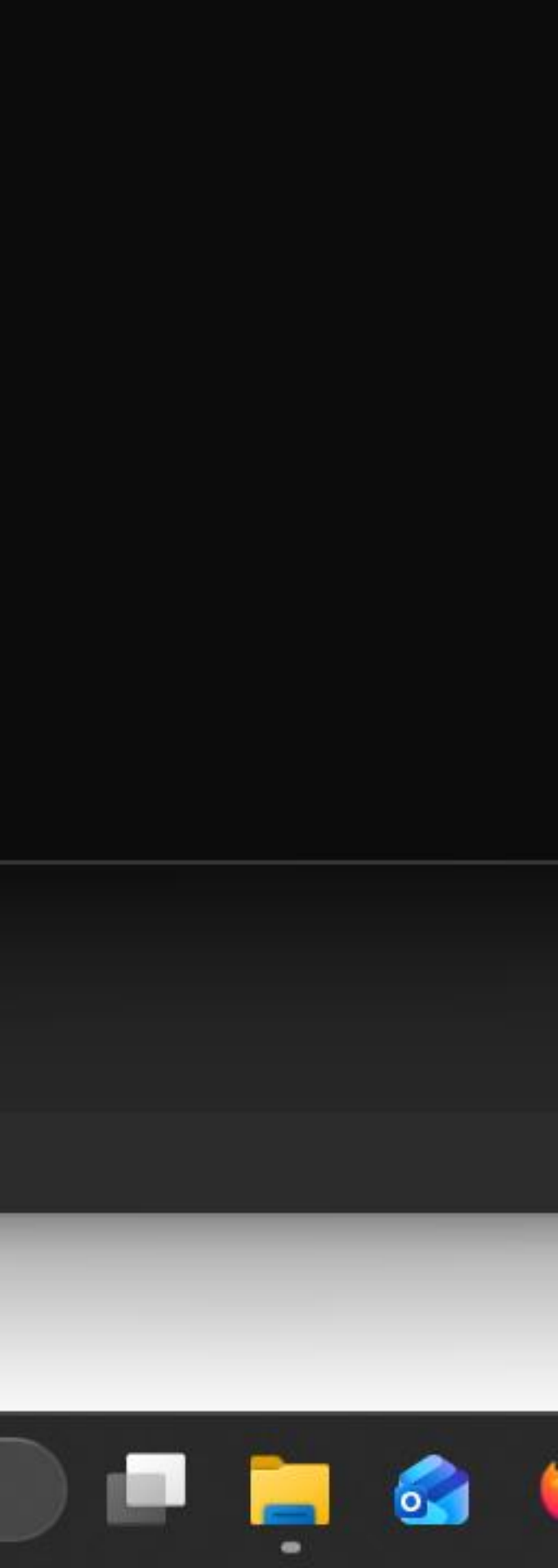


Nanna Gorm Boman
Mette Dreisler Dirac

Cybersikkerhed — *helt sikkert!*

En praktisk grundbog

Djøf Forlag

Nanna Gorm Boman
Mette Dreisler Dirac

Cybersikkerhed — *helt sikkert!*

En praktisk grundbog

DJØF FORLAG
2024

Nanna Gorm Boman og Mette Dreisler Dirac
Cybersikkerhed – helt sikkert!
En praktisk grundbog

1. udgave, 1. oplag

© 2024 by Djøf Forlag

Alle rettigheder forbeholdes. Mekanisk, elektronisk, fotografisk eller anden gengivelse af eller kopiering fra denne bog eller dele heraf er ifølge gældende dansk lov om ophavsret ikke tilladt uden forlagets skriftlige samtykke eller aftale med Copy-Dan.

Sats: Mette Schou, gipsy graphics
Figurer: Implement Consulting Group

Printed in EU 2024

ISBN: 978-87-574-5989-0
e-ISBN: 978-87-574-5991-3

Indhold

Forord **8**

Introduktion

Cybersikkerhed er fundamentet for vores digitale dagligdag **12**

Danmark er digital frontløber 13

Et stærkt cyber- og informationssikkerheds-setup fokuserer på både teknologi og mennesker 23

Om denne bog 27

Litteraturliste 39

Kapitel 1 Strategi og Sikkerhedshuset

Beskyt din organisation fra kælder til kvist **42**

Hvorfor er strategi vigtigt? 43

Sikkerhedshuset sikrer overblik 48

Cybersikkerhed og målepunkter 67

Hvad betyder alt dette for dig, som læser denne bog? 68

Litteraturliste 73

Kapitel 2 Indsigt og prioritering

Cyber- og informationssikkerheden skal gå i takt med den digitale udvikling **76**

Man skal kende sin organisation, før man kan beskytte den 77

Forudsætningerne for det effektive cyber- og informationssikkerhedsarbejde 79

Forstå organisationens overordnede strategiske retning og mål 82
Afdæk organisationens risikoappetit 83
Kerneprocesser, der støtter målopnåelsen 88
Forstå den digitale understøttelse af forretningsprocesserne 92
Litteraturliste 99

Kapitel 3 Lovgivning, standarder og politikker 102
Cybersikkerhed som en konkurrencefordel 103
Lovgivning på cyber- og informationssikkerhedsområdet 105
Er vores organisation omfattet? 115
Internationale standarder og effektiv styring af cyber- og informationssikkerhedsarbejdet 117
Politikker for cyber- og informationssikkerhed 126
Sikkerhedsforanstaltninger og kontroller 130
Litteraturliste 135

Kapitel 4 Risikostyring:
Sæt ind, hvor det er vigtigst 138
Risikostyring i en kompleks og omskiftelig verden 139
Begrebsafklaring: Risici, trusler, sårbarheder og aktiver 142
Risikostyring på det rette niveau 146
Risikostyringsprocessen – fire faser til effektiv risikostyring 150
Roller, ansvar og effektiv kommunikation 163
Monitorering og rapportering 164
Litteraturliste 170

Kapitel 5 Roller og ansvar:
Cybersikkerhed som holdsport 174
Enighed om roller og ansvar er med til at skabe fremdrift 175
Internationale aktører 176
Nationale aktører 177
Cyber- og informationssikkerhed på organisationsniveau 178
De tre forsvarslinjer – en måde at organisere risikostyringsarbejdet på 179

RACI – et kringlet, men godt værktøj til at skabe overblik 192
Format for et godt leverandørsamarbejde 194
Litteraturliste 201

Kapitel 6 IT-beredskab:
Vær klar, når stormen kommer 204
Når tid er penge 205
IT-beredskab som en del af det generelle beredskab 208
IT-beredskab ved brug af plan-do-check-act 211
Litteraturliste 234

Kapitel 7 Cybersikkerhed:
Skab fremdrift med adfærdsdesign 236
Adfærdsdesign som den hemmelige ingrediens 237
Når den ønskede adfærd møder motivation, friktion og trigger 241
Struktureret metode til adfærdsdesign 244
Fem faser (og en case) 245
Husk: Det må gerne være sjovt! 248
Hvilke roller findes der i jagten på en god sikkerhedskultur? 249
Litteraturliste 254

Tak 256

Fororд

Vi har aldrig investeret flere penge og ressourcer i ambitiøse cybersikkerheds-programmer end i dag. Og alligevel ser vi ikke en tilsvarende reduktion i antallet af alvorlige sikkerhedsbrister som følge af cyberangreb. Hvordan kan det være? Et oplagt svar er, at cyberkriminalitet er i stærk vækst og at de cyberkriminelle bliver stadig dygtigere og mere velorganiserede. Det er ganske givet også en del af sandheden, men hvad der betyder langt mere, er den måde vi betragter, og arbejder med, cybersikkerhed.

Jeg har ofte hørt både ledere og medarbejdere omtale det som "brandslukning", og det er for så vidt også rigtigt nok – når ulykken først er sket. Men for at blive i metaforen er forebyggelse altid bedre end behandling og her viser det sig desværre ofte at mange organisationer er bygget af brandfarlige materialer og mangler røgalarmer og evakueringsplaner. Samt, ikke mindst, at de har forsømt at uddanne husets beboere i hvad man bør, og ikke bør gøre, for at undgå brand. Og hvis det alligevel sker, for at slukke den.

I et solidt bygget hus er eksperter taget med på råd hele vejen, fra de første tanker om at bygge huset, til det står færdigt og beboerne er flyttet ind. Her skal alle ikke være specialiserede røgdykkere, men alle skal vide, hvad det indebærer at opføre sig ansvarligt, hvor brandslukkeren står, og hvem man skal ringe til, når der lugter af røg. På samme måde skal et moderne cybersikkerhedsforsvar gennemsyre hele organisationen på en måde, så alle ved, hvilken rolle de spiller.

Selvfølgelig er systemer og governance modeller vigtige at få på plads. Det skal de være, og det skal vores konsulenter være de bedste til at sikre. Men de skal være lige så gode til at opbygge en stærk sikkerhedskultur og en fælles

bevidsthed om, at kæden ikke er stærkere end det svageste led. At den enkeltes uforsigtige adfærd risikerer at kompromittere fællesskabets eksistensgrundlag. For ikke at tale om de personlige konsekvenser for dem, der bliver ramt af en datalæk.

Her kommer denne bog ind i billedet. I min optik skaber den, for første gang, et holistisk billede af et moderne cybersikkerheds set-up, præsenteret på en lettilgængelig måde, og den inviterer en bredere kreds til at interessere sig for dette vigtige område. Den er gennemsyret af dyb faglig viden og bærer præg af, at dens konklusioner og anvisninger er understøttet af erfaringer og input fra en bred vifte af kundeprojekter. Den er både en introduktionsbog for dem, som ønsker et samlet billede af cyber- og informationsikkerhed og en praktisk grundbog, for dem der helt konkret skal implementere det i deres organisation.

Hvis der er en ting, der kan holde mig vågen om natten er det truslen om cyberangreb, og jeg ved, at mange andre ledere har det på samme måde. Her har bogen også en vigtig funktion, idet den giver en bedre forståelse for, hvad det reelt indebærer at arbejde med cyber- og informationssikkerhed, og hvordan vi kan målrette dette arbejde, så vi får maksimal værdi af vores investering. Jeg er stolt af, at Implement kan være en lille del af at bidrage til denne agenda.

God læselyst!

September 2024
Niels Ahrengot, Managing Partner, Implement Consulting Group

Introduktion

Cybersikkerhed er fundamentet for vores digitale dagligdag

CFCS hæver trusselsniveauet for destruktive cyberangreb for Danmark generelt. CFCS vurderer, at mange typer af organisationer i samfundsvigtige sektorer vil kunne blive udvalgt som mål for eventuelle destruktive cyberangreb".

Center for Cybersikkerhed, 2024

Danmark er digital frontløber

I internationale sammenligninger ligger Danmark ofte i top, når det handler om digitaliseringsgrad. Det være sig både i forhold til, hvordan offentlige myndigheder, erhvervslivet og vi som borgere anvender digitale redskaber i vores dagligdag. Ikke en dag går, uden at vi bruger teknologi til at udføre aktiviteter, transaktioner eller til kommunikation. I EU bliver Danmark ofte fremhævet som digitalt foregangsland, både når det handler om offentlige digitale services, infrastruktur og erhvervslivets brug af digitale teknologier. I Digital Economy and Society Index 2022 fra Europa-Kommissionen kommer Danmark f.eks. ind på en andenplads blandt alle lande i EU, som sammenligner de europæiske lande i forhold til deres digitaliseringsgrad, kun overgået af Finland (Europa-Kommissionen, 2022).

I Danmark knuselsker vi altså teknologi og er blevet dybt afhængige af den digitale understøttelse af vores dagligdag. Tænk bare på, hvor ofte du benytter mobilen til betaling i en butik – online eller fysisk, og hvor dejligt det er, at hvis du kommer til skade, så står der et sygehus klar, hvor du kan scanne din Sundhedskort-app. På samme vis er vores kritiske infrastruktur koblet op på digitale teknologier, der gør, at vi har rent vand i vandhanerne, strøm i stikkontakterne og trafiksignaler, der fungerer efter hensigten. Hele den digitale understøttelse af vores samfund er altså kritisk for vores dagligdag, for at vores virksomheder og myndigheder kan fungere optimalt, og for vores samfunds virke som helhed.

Jo mere digitale vi er, jo vigtigere er cyber- og informationssikkerhed

Den høje grad af afhængighed af teknologi og digital understøttelse i vores hverdag efterlader os dog sårbare overfor cyberkriminalitet, cyberterror og hybridkrig, enten fra aktører, der ønsker at få fat i vores penge eller forstyrre vores samfundsorden. Center for Cybersikkerhed har i sommeren 2024 f.eks. hævet trusselsniveauet for destruktive cyberangreb mod Danmark fra "lav" til "middel" (se citat i starten af dette kapitel). Det skyldes geopolitiske spændinger, som vurderes at sætte Danmark på skydeskiven. Forskere på området kalder endda cybertrusler for det digitale samfunds skyggeside (Jacobsen og Liebetrau, 2022). Regeringens sikkerhedspolitiske analysegruppe uddyber: *"Danmark er et af de mest digitaliserede lande i verden, hvilket har medført store gevinster for det danske samfund og gjort hverdagen nemmere for den enkelte dansker. Men det har samtidig gjort Danmark særdeles sårbar overfor cyberangreb, der kan gøre skade på kritiske statslige og private it-systemer"* (2022).

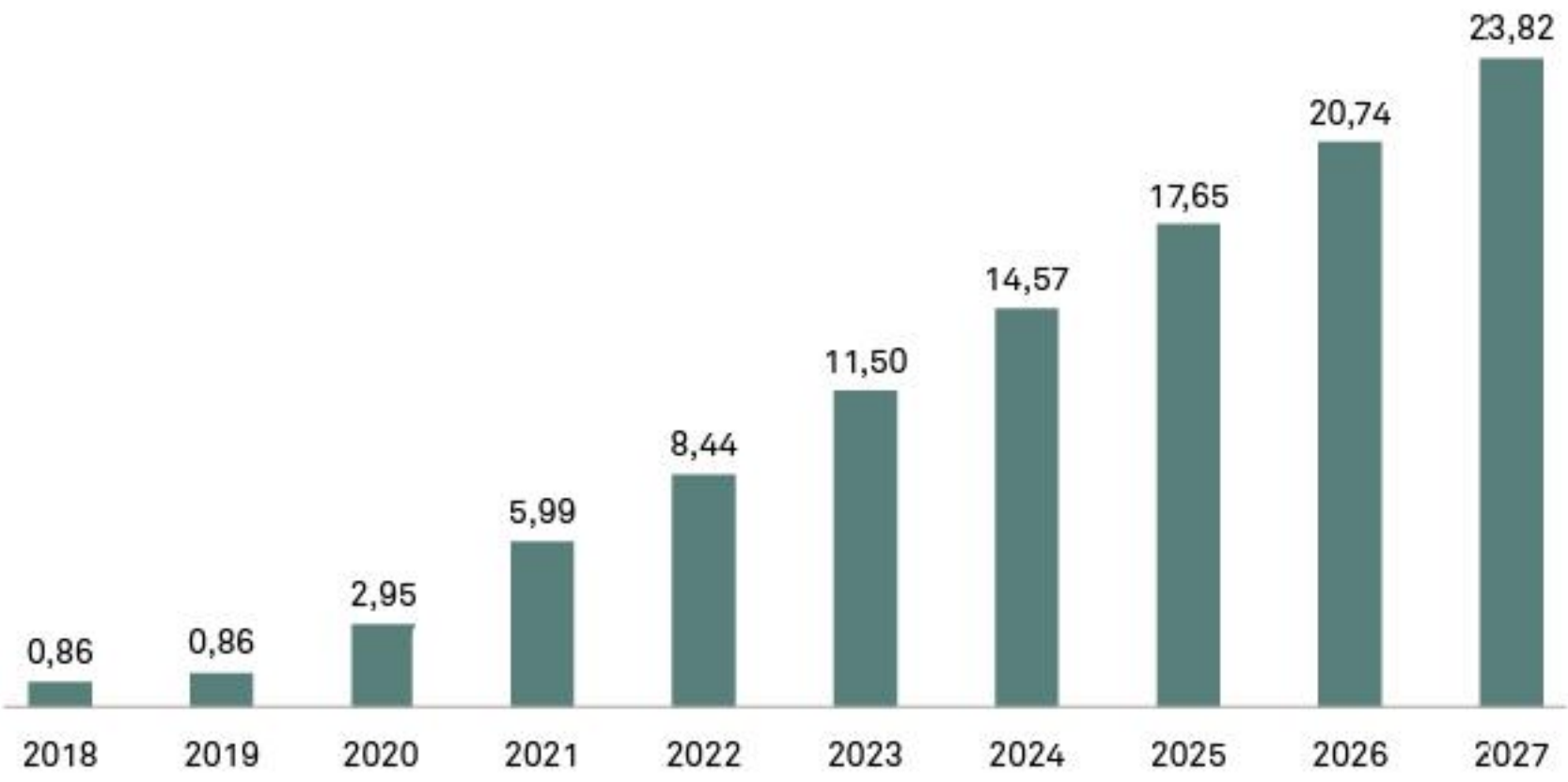
Cyberkriminalitet er en således væsentlig trussel (Finansministeriet, 2021), men det er vigtigt at forstå, at trusler kan være både intentionelle, og ikke-intentionelle. Det vil sige, at dét, der kan skade en organisation, enten kan ske på baggrund af en planlagt handling fra en trusselsaktør, eller det kan ske på baggrund af menneskelige fejl eller f.eks. naturkatastrofer (som når et serverrum oversvømmes ved skybrud, eller der sker skader på grund af jordskælv). Det er nødvendigt at orientere sig i, hvilket trusselsbillede den konkrete virksomhed eller myndighed står overfor, for at man kan etablere et relevant billede af den kontekst, man arbejder i, og hvad der skal gøres for at skabe et passende sikkerhedsniveau. Derudover ændrer trusselsbilledet sig konstant i takt med udviklingen i verden i forhold til f.eks. krig og den konkurrencesituation, organisationen befinder sig i. En løbende vurdering af trusler, og hvilke risici de afstedkommer, er derfor nødvendig (se mere i kapitel 4).

Følgende tabel giver et par nedslag i typer af trusler og trusselsaktører, som virksomheder og myndigheder i dag kan stå overfor. Bemærk, at listen ikke skal ses som udtømmende, men er samlet for at give et kort overblik over de væsentligste typer af trusler og trusselsaktører (bl.a. CFCS, 2019, 2024, u.å.).

Typer af trusler	Trusselsaktør	Forklaring
Intentionel	Hackere	En hacker har de tekniske kapabiliteter, der gør ham/hende i stand til at få adgang til et netværk eller IT-systemer. Der findes også etiske hackere (white hats), der arbejder på at finde svagheder i systemerne og få disse udbedret, inden andre finder dem.
	Cyberkriminelle	Cyberkriminelle kan bruge samme tekniske metoder som en hacker, men kan også "blot" gøre brug af social engineering-strategier til at få tilraget sig penge eller informationer. Formålet er ofte finansielt, men angrebsmetoderne er mange, og de kan have både virksomheder, myndigheder eller privatpersoner som mål. Det kan også omfatte cyberspionage og konkurrenter, som ønsker adgang til særlige informationer.
	Cyberaktivisme	Aktivisme i cyberverdenen har samme formål som aktivisme i den "fysiske verden", nemlig at et individ eller en gruppering ønsker at få skabt opmærksomhed om et specifikt emne.
	Cyberterrorister	Her er, ofte, tale om statsstøttede grupper af højst organiserede kriminelle, som med f.eks. statsstøtte har til formål at skade og nedlægge kritisk infrastruktur i bestemte lande.
	Statssponsorerede formelle tjenester	Fremmede landes efterretningstjenester og militære cyberhære, som har til formål at udføre defensive såvel som offensive operationer.
	Interne trusler	Medarbejdere, der har set sig sure på deres arbejdsplads og aktivt arbejder for enten at ødelægge, lække eller indefryse data til skade for organisationen.
	Amatører	Såkaldte "script kiddies", der udnytter simple, men desværre ofte effektive, programmer og angrebsmetoder. Amatører kan være motiveret af, hvordan de anses af deres online fællesskaber, og kan forvolde langt større skade, end de måske selv i første omgang havde til formål.
Ikke-intentionel	Naturkatastrofe	Oversvømmelser eller brand kan forvolde store skader på den tekniske infrastruktur. Den fysiske lokation af f.eks. kontorer og serverrum bør overvejes og sikres til passende niveau.
	Manglende tilgængelig infrastruktur	Hvis strømmen går, eller internettet er nede, kan det påvirke virksomhedens daglige operationelle processer. Afhængig af hvilke opgaver virksomheden varetager, og hvilke aktiver der skal beskyttes, bør der sikres alternativ infrastruktur.
	Menneskelige fejl	Alle mennesker begår fejl og kan f.eks. komme til at slette data utilsigtet, dele data med andre end dem, der burde se det, eller ødelægge vigtig hardware.

Hvis vi blindt kører ned ad den digitale motorvej uden at sørge for tilstrækkelig beskyttelse, så er vi sårbare overfor aktører, der vil os det ondt. Samtidig er organisationer unødigt sårbare over for ikke-intentionelle trusler. Der er talrige eksempler på, at cyber- og informationssikkerhed ikke er blevet taget tilstrækkeligt alvorligt, og hvor det er endt med store regninger til virksomheder eller skatteydere. På globalt plan anslår World Economic Forum, at omkostninger relatereret til cyberkriminalitet er 11,5 billioner US dollars, hvor lande med høj digitaliseringsgrad står for de største udgifter. Tallet forventes i øvrigt nærmest fordoblet frem mod 2027 – og husk, at dette kun er udgiften for cyberkriminalitet – hertil kommer udgifter til håndtering af hændelser opstået på baggrund af ikke-intentionelle handlinger!

Estimeret økonomiske tab grundet cyberkriminalitet på verdensplan (angivet i billioner US dollars). Data fra 2022.



Figur 0.1. World Economic Forum. 2024.

Vi hører ofte organisationer og ledelser fortælle, at de synes, det er dyrt at arbejde med cybersikkerhed. *"Cybersikkerhed ses som en udgift og et teknisk irritationsmoment snarere end et strategisk nødvendigt indsatsområde"*, oplever Thomas Lund-Sørensen, som er tidligere Chef for Center for Cybersikkerhed (Jacobsen og Liebetrau, 2022). Det kan have sin rigtighed, at cyber- og infor-

mationssikkerhed koster penge, da det i sagens natur koster noget at højne et sikkerhedsniveau. Men det er altså intet imod de udgifter, der kan være forbundet med cyberangreb. For nogle organisationer ender angreb endda i konkurs (Devantier, 2024). Med de rette prioriteringer og værktøjer kan de rigtige investeringer i cyber- og informationssikkerhed altså give god mening – også i en økonomisk cost-benefit-analyse.

I svaret på at håndtere truslerne kommer cyber- og informationssikkerhed ind i billedet. I nedenstående tekstboks udfolder vi de tre begreber.

Cybersikkerhed vs. informationssikkerhed vs. IT-sikkerhed

I daglig tale høres ordene "cybersikkerhed" og "informationssikkerhed" brugt i flæng eller ofte sammen, når man siger " cyber- og informationssikkerhed". I vores forståelse er der dog forskel på de to, og der er en god pointe i at holde tungen lige i munden og vide, hvornår de bruges.

informationssikkerhed er den disciplin, der handler om at beskytte fortroligheden, integriteten og tilgængeligheden (se mere senere i dette kapitel) af alle de informationer, der har værdi for en virksomhed eller myndighed. Dette gælder således information af værdi, ligegyldigt i hvilket "format" det er. Det vil sige, hvad enten disse informationer er i fysisk format (f.eks. i arkiver), i OT-systemer (produktionsenheder), som ikke nødvendigvis er internetopkoblede, eller om informationerne befinder sig online.

I dette perspektiv er **cybersikkerhed** en delmængde af informationssikkerhed, med fokus på de data, der er i "cyber" (dvs. netværksforbundne, eller som gør brug af internetopkobling). I dag er rigtig meget information, for rigtig mange organisationer, netværksforbundet eller internetopkoblet på den ene eller den anden måde.

Der er en god pointe i at holde fast i "informationssikkerhed", fordi fokus er at højne sikkerhed for værdifulde informationer, ligegyldigt hvilket format eller hvilken platform de har. Dog har cybersikkerhed unægtelig en coolness-faktor over sig og pryder derfor forsiden på denne bog. I kapitlerne i denne bog forsøger vi dog at holde tungen lige i munden og bruge hele cyber- og informationssikkerhedstermen, når vi taler om feltet i sin helhed. Cybersikkerhed bruger vi så, når vi specifikt henviser til den del af informationssikkerhedsarbejdet, der beskæftiger sig med netværksforbundne systemer.

»

IT-sikkerhed omfatter, i hvert fald i udgangspunktet og som oftest, et specifikt fokus på hardware og software og de data, der behandles her. Igen kan man altså anskue IT-sikkerhed som en delmængde af infomationssikkerhed. I mange virksomheder er cybersikkerhedsområdet udsprunget fra IT-afdelingen, hvilket kan give nogle rolle- og ansvarsmæssige udfordringer (se kap. 5: Roller og ansvar).

Disse definitioner lægger sig i tråd med de officielle definitioner fra Center for Cybersikkerhed (CFCS, u.å.).

Som en krølle på halen oplever vi, at i engelsktalende lande, særligt i USA, er det "information security", der ses som en delmængde af "cyber security". Dette kan være værd at holde sig for øje, hvis man drøfter cybersikkerhed med amerikanske aktører.

Lovgivningen er med til at svinge taktstokken for cyber- og informationssikkerhedsarbejdet

At cyber- og informationssikkerhed koster dyrt for virksomheder, og samfundet som helhed, er heller ikke gået politikernes næse forbi. Igennem de sidste særligt 20 år er kravene til digital sikkerhed derfor kun vokset. Særligt EU har været drivende i at stille flere krav til, hvordan virksomheder og myndigheder beskytter deres digitale aktiver. De fleste af os har hørt om eller arbejdet med GDPR-forordningen fra EU, der stiller krav til beskyttelse af persondata. Et af de nyere skud på stammen fra EU er det såkaldte NIS2-direktiv, som skal sikre et højt fælles cybersikkerhedsniveau i hele unionen. Da direktivet blev lanceret, sagde Europas konkurrencekommissær, Margrethe Vestager, at:

> *"Jeg tror, at disse (red.: cyber-) angreb har vist alle, der før har været i tvivl, at prisen for et angreb er så meget større end prisen for at beskytte sig selv ... Det går for langsomt. Der er mange sektorer, både offentlige og private, som hurtigst muligt bliver nødt til at investere markant i at kunne forsvare sig selv mod et voksende antal cyberangreb."* (Vestager, 2022).

Lovgivningen har altså været og er med til at drive udviklingen i retning mod øget opmærksomhed på og professionalisme i arbejde med cyber- og informationssikkerhed. I takt med at de, som vil os det ondt, bliver dygtigere til at ramme os, bliver lovgiverne også ved med at øge kravene til virksomheder og myndigheder for at beskytte vores digitale dagligdag.

Cyber- og informationssikkerhed er andet og mere end krav og regler

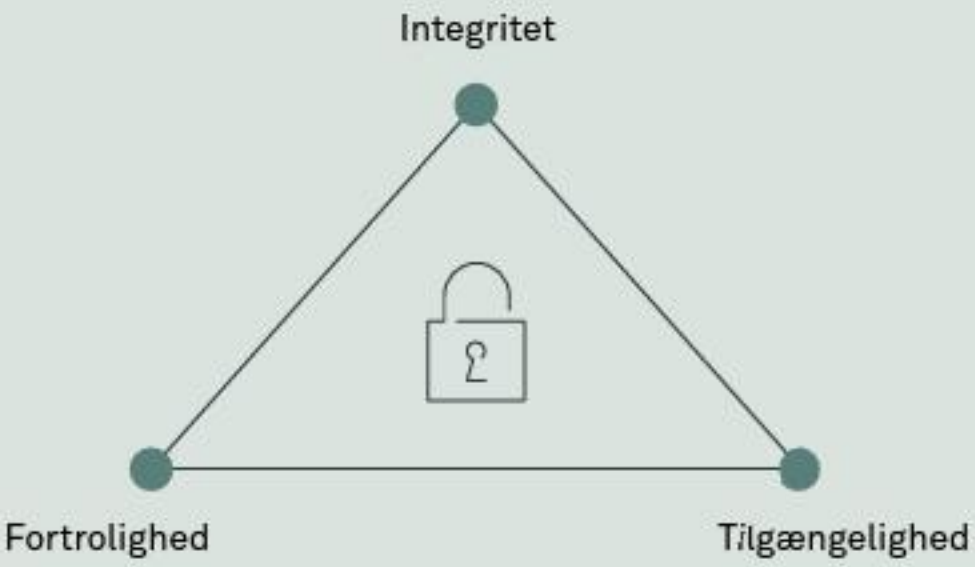
Et for ensidigt fokus på krav og regler kan dog tage pusten og energien ud af sikkerhedsarbejdet. Det er derfor også vigtigt at understrege, at cyber- og informationssikkerhed ikke kun skal være en øvelse, som virksomheder eller myndigheder påtager sig, fordi de er juridisk forpligtede til det.

Det er afgørende er, at cyber- og informationssikkerhed indtænkes som en helt naturlig del af arbejdet med at udvikle vores virksomheder og myndigheder digitalt. Cyber- og informationssikkerhed skal gå hånd i hånd med alle de gode ideer, vi får til at gøre tingene smartere, hurtigere og lettere for os selv med digitale redskaber og ny teknologi. Det skal det, fordi vi er nødt til at beskytte vores organisationer digitalt, hvis vi skal høste alle fordelene ved at bruge ny teknologi. Hvis vi er skarpe på, hvilke systemer og data der er vigtige for vores organisation, kan vi prioritere sikkerhedsindsatserne og dermed opnå et passende niveau af sikkerhed. Uden det er der risiko for, at vores systemer og data bliver kompromitteret i forhold til fortrolighed, integritet og/eller tilgængelighed. Nedenstående tekstboks udfolder de tre meget centrale begreber i arbejdet med cyber- og informationssikkerhed.

Tænk "FIT", når du tænker på cyber- og informationssikkerhed

Hvordan man når frem til et "passende" cybersikkerhedsniveau, er netop det, som denne bog handler om. For at vurdere, hvad "passende" er, introducerer vi her et centralt begreb, nemlig "FIT". FIT står for fortrolighed, integritet og tilgængelighed, på engelsk også kendt som CIA (forkortelse for "Confidentiality", "Integrity" og "Availability") (Nweke, 2017).

Cyber- og informationssikkerhed er den metodiske tilgang til at beskytte en virksomheds eller myndigheds vigtigste aktiver (det vil sige både information, men også fysiske ting såsom bygninger, computere, telefoner, osv.) på en måde, således at et passende niveau af fortrolighed, integritet og tilgængelighed opretholdes. Dette lyder måske simpelt, men er lettere sagt end gjort.



Fortrolighed drejer sig om at sikre, at man kan stole på, at data kun kan tilgås af de rette personer. Her er det essentielt, at man har viden om, hvilke data der gerne må tilgås af f.eks. alle medarbejdere (dagens kantinemenu), og hvilke data der er fortrolige og kun skal deles med udvalgte personer (tænk på f.eks. HR-informationer eller en virksomheds patenter/forretningshemmeligheder).

I jagten på det passende niveau af cybersikkerhed må man heller ikke glemme at forholde sig til **integriteten** af data. Et eksempel her er, at man ikke uden videre kan "komme til" at ændre ved eller rette på data, der ikke skal kunne rettes. En læge skal f.eks. kunne tilgå og indskrive visse notater og data, men skal ikke ved enten menneskelig fejl eller med vilje kunne komme til at påvirke "rigtigheden" af andre dele af patientens data.

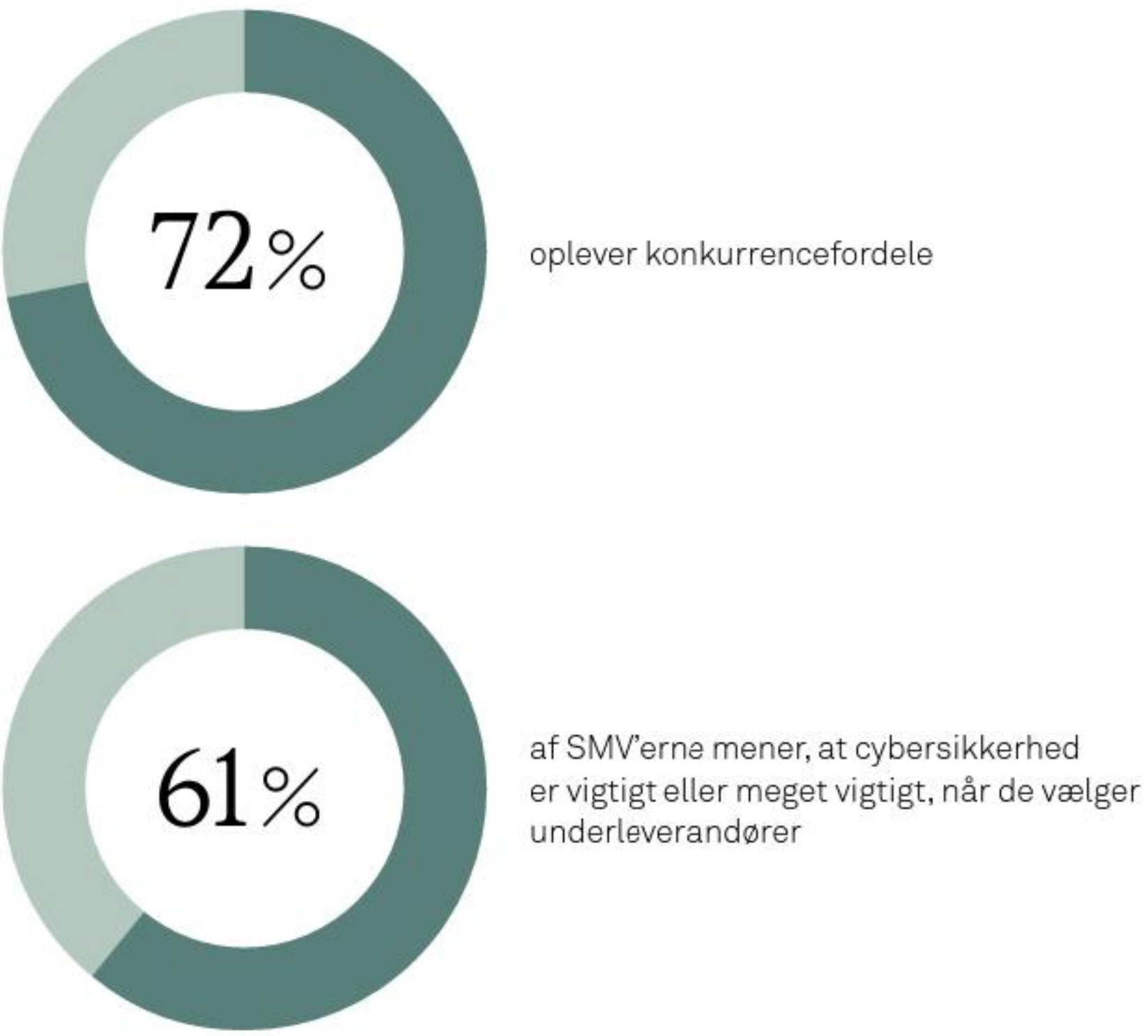
Selvom fortrolighed og integritet er essentielt, må man ikke glemme, at en løsning også skal være **tilgængelig** for dem, der skal bruge den.

En konkurrencemæssig fordel

Når organisationer formår at anskue cyber- og informationssikkerhedsområdet som mere end blot et dyrt og lovgivningstungt emne, kan det faktisk lede til konkurrencemæssige fordele. *"Vi kan se det, og vi får det bekræftet i vores netværk. Cybersikkerhed på et passende niveau giver en konkurrencefordel, som flere og flere kan se stor værdi i. Samtidig bliver man stadigt mere opmærksom på, hvad det kan betyde på både image og bundlinjen – og meget andet, ikke at have styr på cybersikkerheden"*, fortæller Kirsten Hede fra Bestyrelsesforeningens Center for Cyberkompetencer.

Tal fra Industriens Fonds undersøgelse "Cyberbarometer", der undersøger SMV'ers arbejde med cyber- og informationssikkerhed, støtter den pointe. De peger på, at der en sammenhæng mellem cybersikkerhed og konkurrenceevne. I undersøgelsen svarer knap tre fjerdedele af de danske SMV'er, at de oplever en sammenhæng mellem investeringer i cybersikkerhed og konkurrencefordele. Ligeledes erklærer over halvdelen af virksomhederne sig enige i, at cybersikkerhed er vigtigt eller meget vigtigt, når de vælger underleverandører (Industriens Fonds Cyberprogram, u.å.).

> *"Når man får styr på sin cyber- og informationssikkerhed og kan demonstrere sine gode tiltag og lovmedholdelighed gennem mærkningsordninger, certificeringer og revisionserklæringer, kan man skyde genvej til og fokusere på at etablere en god sund konkurrencedygtig forretning. De formelle barrierer, som kan koste meget ævl, kævl og omkostninger, bliver automatisk ryddet af vejen"*,
> fortæller Henning Mortensen, der er CISO og formand for Rådet for Digital Sikkerhed.



Figur 0.2. Resultater fra Industriens Fonds Cyberprograms Cyberbarometer (2023).

De fleste, der læser denne bog, har formentlig en forståelse af, at cyber- og informationssikkerhed er vigtig, og har forstået, at der er ganske store konsekvenser, når organisationer bliver ramt af cyberangreb. At sige, at cyber- og informationssikkerhed er et nødvendigt punkt på agendaen for alle organisationer i dag, er dog ikke det samme som at sige, at så skal alle have den helt store pakke og alle de dyreste cyber- og informationssikkerhedsløsninger. Slet ikke. Risikobaseret cyber- og informationssikkerhed handler om at have *passende* sikkerhedsniveau på de *vigtigste* dele af ens virksomhed.

Tre eksempler på konkrete fordele, der er ved at arbejde struktureret, risikobaseret og effektivt med cyber- og informationssikkerhed

1. En struktureret og risikobaseret tilgang til cyber- og informationssikkerhed kan være med til at sikre, at organisationen lettere opnår fastsatte mål, fordi sikkerhed ikke ses som et irriterende element, men som en støtte.
2. Der kan opnås konkurrencemæssige fordele ved at arbejde struktureret med cybersikkerhed, blandt andet på grund af øget tillid fra brugere og/eller kunder.
3. Cyberangreb kan være både målrettet mod specifikke organisationer, men også ramme andre på vejen – og hændelser kan skyldes både intentionelle og ikke-intentionelle handlinger. Med en struktureret og risikobaseret tilgang til cyber- og informationssikkerhed er forsvaret stærkest der, hvor behovet er størst.

Et stærkt cyber- og informationssikkerheds-setup fokuserer på både teknologi og mennesker

Begge forfattere til denne bog er konsulenter indenfor cyber- og informationssikkerhed, hvilket ofte giver anledning til svar a la "Wow, det må der være gang i", eller "Hold da op, det er jo oppe i tiden". Herefter følger ikke flere spørgsmål, men vi kan ofte fornemme en stille undren over, hvad det mon præcis er, vi laver. Vi har baggrunde som samfundsfaglige generalister – henholdsvis kandidat i statskundskab og en master i sikkerhedsstudier (Mette), og ph.d. med fokus på sundhedstracking og dataetik (Nanna), så hvordan hænger det nu sammen?

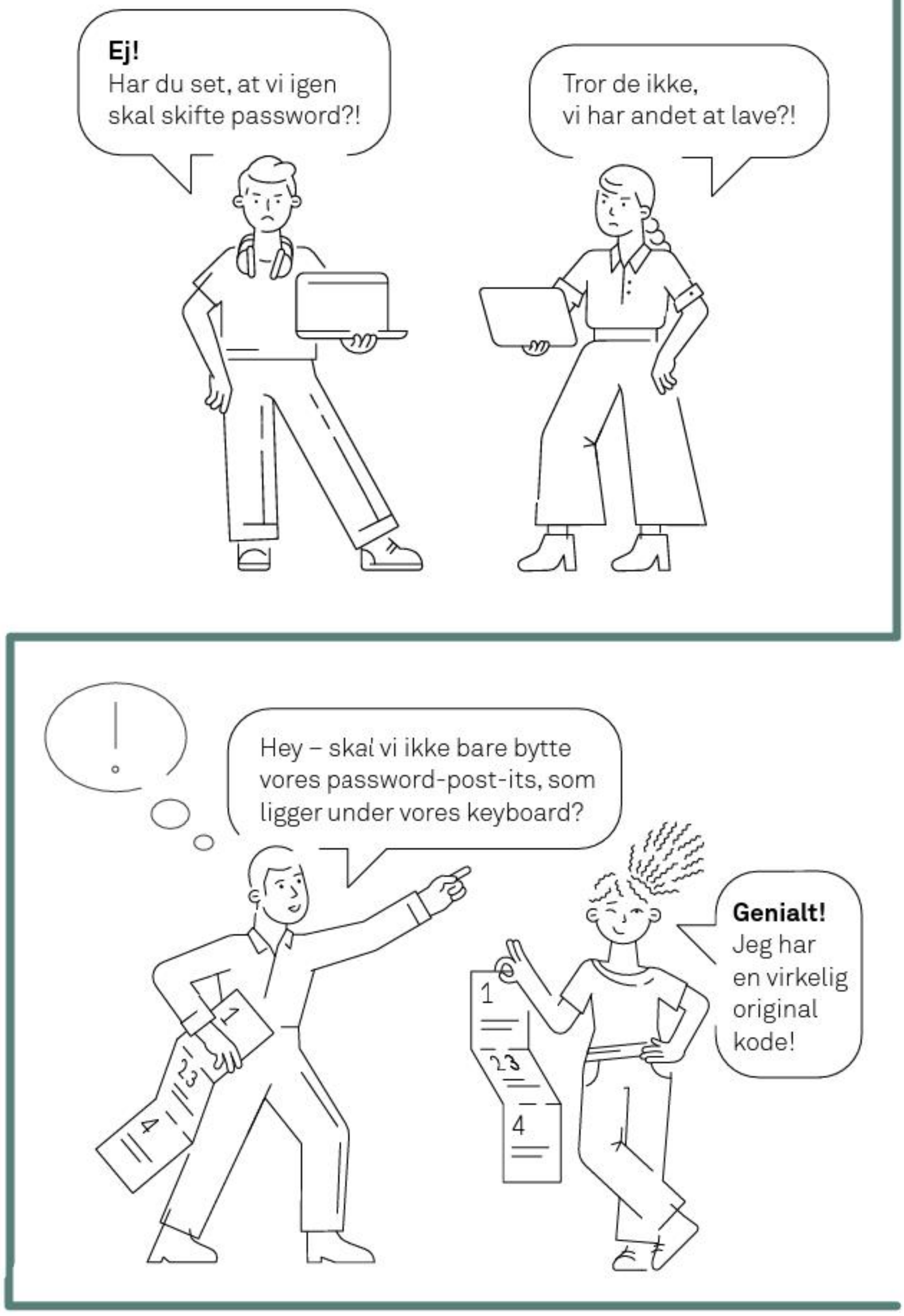
Det gør det, fordi cyber- og informationssikkerhed er langt mere end "blot" det tekniske. Det handler om at forstå organisationer, ledelse og ikke mindst menneskelig adfærd. Emner, som vi i vores uddannelser og karrierer i den grad beskæftiger os med.

En af vores yndlingshistorier, der illustrerer, hvordan sikkerhed og menneskelig adfærd hænger sammen, handler om passwords. Dette er stadig et af de mest brugte værktøjer til at holde vores informationer sikre, men som bruger er det efterhånden umuligt at holde styr på alle de kodeord, man har, og endnu mere umuligt, da de ofte skal skiftes.

Jo længere og mere komplekst et password er, jo sværere er det for uvedkommende at gætte det. Men som medarbejder er det superirriterende at have lange kodeord, og mange vælger derfor fødselsdatoer eller andre nemme koder. Måske skrives kodeordet endda ned på en lille post-it og gemmes under måtten til computermusen. Hvordan kan man som virksomhed eller myndighed overtale sine medarbejdere til, at det umiddelbart "besværlige" kodeord faktisk er noget af det vigtigste forsvar, der findes? Det er samtidig et emne, der kræver både tekniske indstillinger og forståelse for menneskelig adfærd. Hos en kunde, vi arbejdede for, blev det indført, at skærmen automatisk låste efter 5 min., så koden skulle tastes igen. Men hvad fandt de effektive medarbejdere på? Ja, de downloadede såmænd bare en "mouse jiggle", som er et stykke software, der sørger for, at musen registrerer en bevægelse hver 4. min. Bum – og så skal man aldrig taste koden igen. Til gengæld står computeren nu ulåst hen, og næste gang medarbejderen forlader den, har man – så at sige – åbnet hoveddøren for enhver uvedkommende, der kommer forbi. Her er det altså ikke nok med "blot" de tekniske indstillinger, og at computeren f.eks. låses efter et par minutter, hvor den ikke er i brug. Det er derimod tvingende nødvendigt, at medarbejderne også bliver mødt med træning, som skaber forståelse for cybersikkerhed, og at medarbejderne aktivt indgår i at beskytte virksomheden. Dertil kommer så de mere tekniske løsninger, der skal støtte op om den ønskede adfærd – herunder password tools, multifaktorgodkendelse (MFA) eller f.eks. FaceID.

I Implement, som er et dansk funderet konsulenthus, hvor begge forfattere er ansat, går vi så langt som at kalde det "the human firewall". Oversat med lidt flere ord til dansk betyder det, at medarbejderne kan udgøre både beskyttelse – men i høj grad også en sårbarhed – for organisationen. Det gælder om at finde den gyldne middelvej, hvor de tekniske foranstaltninger rent faktisk giver mening for dem, der skal bruge dem, så de ikke "springer over" og ender med at gøre det hele endnu mere usikkert, end det var til at starte med.

"The human firewall"



Figur 0.3. The human firewall.

Et effektivt set-up på cyber- og informationssikkerhedsområdet kræver, at organisationer sætter ind med både tekniske og ikke-tekniske discipliner.

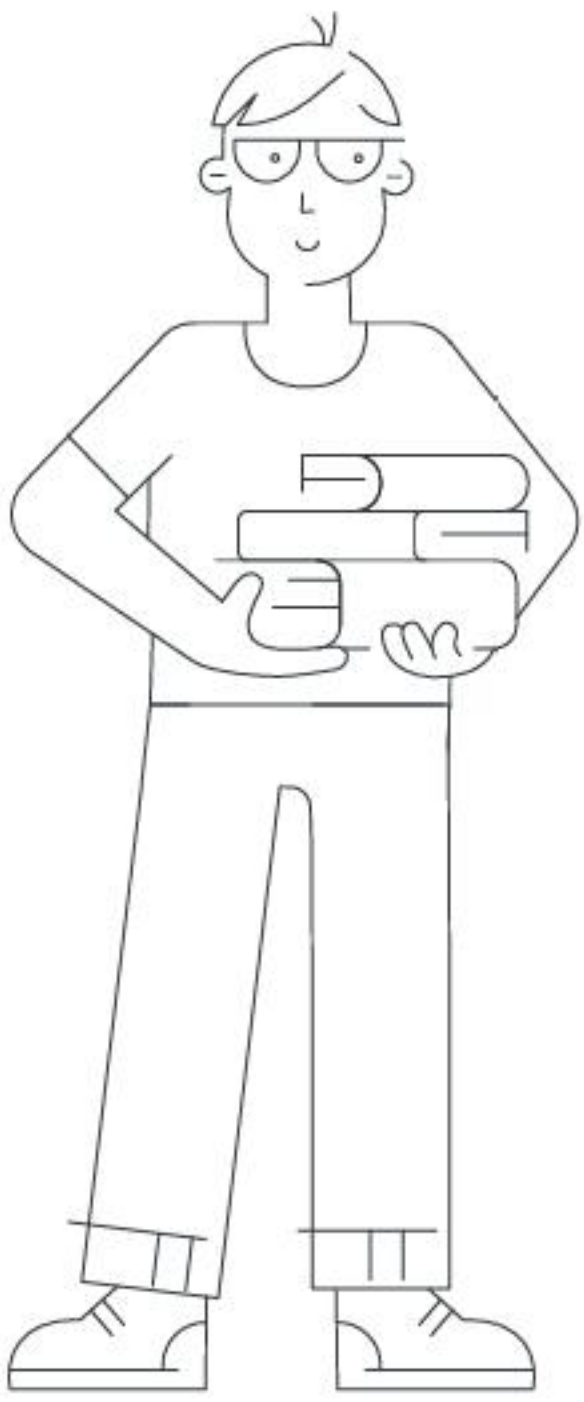
Det er ingen hemmelighed, at der er en stor efterspørgsel efter kompetencer på området for cyber- og informationssikkerhed. F.eks. estimerer Rådet for Digital Sikkerhed, at Danmark i 2030 vil mangle 15-20.000 fuldtidsressourcer inden for cyber- og informationssikkerhed, og i en analyse om informationssikkerhedskompetencer i Danmark, siger 22 pct. af de adspurgte myndigheder og virksomheder, der har forsøgt at rekruttere medarbejdere til området, at de enten ikke har kunnet ansætte en ny ressource eller at de måtte ansætte en, som ikke havde alle de ønskede kompetencer.

22%

af de virksomheder og myndigheder, der har forsøgt at rekruttere informationssikkerhedsarbejdskraft, har enten ikke kunnet ansætte eller har måttet ansætte en profil, som ikke havde alle de ønskede kompetencer.

15-20.000

Så mange fuldtidsressourcer estimeres det, at Danmark vil mangle i 2030 indenfor cyber- og informationssikkerhedsområdet (DI Digital, 2023).



Figur 0.4. Højbjerre et al., 2019, og DI Digital, 2023.

Nu har vi vist fået det slået fast med syvtommersøm: Cyber- og informationssikkerhed er vigtigt for alle organisationer at beskæftige sig med (på passende niveau), og der er behov for samarbejde på tværs af mange fagligheder. Der er

altså brug for alle mand på dæk. Både de som er tekniske eksperter, og dem som forstår sig på organisationer, processer og menneskelig adfærd. Cyber- og informationssikkerhed er langt mere end teknisk kunnen og kodning. Det er kommunikation, det er ledelse, og det er forståelse for både lovgivning og menneskelig adfærd. Dette er netop baggrunden for tilblivelsen af denne bog.

Om denne bog

At arbejde med cyber- og informationssikkerhed, synes vi, er noget af det allermest spændende og givende overhovedet- fordi det er et felt i evig bevægelse og med utallige og aktuelle udfordringer, som kræver samarbejde på tværs af mange fagligheder. Men vi ved også, at det er netop dette, der kan gøre det svært for nye medarbejdere på feltet at få overblik. Som undervisere på dette felt er vi ofte blevet spurgt om vi mon kunne sende noget mere materiale inden undervisningsstart, eller om der var noget tekst på mere indledende niveau. Mange kurser og bøger på området forudsætter, at man allerede kender forskel på de mange forkortelser og engelske begreber, og at man ved hvor i kæden de forskellige arbejdsopgaver passer ind henne. Vi oplever, at der på dansk endnu ikke findes litteratur, der løfter denne opgave- og dermed blev ideen til denne bog født!

Vi vil med bogen samtidigt gerne være med til at sætte fokus på, hvorfor cyber- og informationssikkerhed er vigtigt, og hvorfor digital forretningsudvikling og sikkerhed er to sider ad samme mønt. Den ene kan ikke fungere uden den anden. Det er vores tilgang, at de metoder og redskaber, der bliver præsenteret kan bruges i både offentlige myndigheder og private virksomheder – store som små.

Denne bog præsenterer grundredskaber og tilgange til cyber- og informationssikkerhed, der er brugbare, hvad end man arbejder i en privat virksomhed eller offentlig myndighed. I bogen anvender vi således for nemhedens skyld betegnelsen "organisation" samlet om både private virksomheder og myndigheder.

De steder, hvor der alligevel er forskel på, hvad man som myndighed eller privat virksomhed f.eks. er underlagt af lovkrav, vil det tydeligt fremgå af teksten.

Målgruppen for denne bog

Måske du læser dette afsnit for at være sikker på, om denne bog er noget for dig. Vi møder nemlig mange, som ikke er helt sikre på, at cyber- og informationssikkerhed er noget, de enten vil have interesse for, eller noget, som de, uden en teknisk baggrund, vil kunne indgå i.

Denne bog er skrevet til dig, som enten allerede arbejder med eller studerer noget relateret til cybersikkerhed, eller til dig, som på den ene eller den anden måde indimellem bliver involveret i informationssikkerhedsrelaterede opgaver på dit arbejde.

Hvis du føler, at du med din baggrund måske er et skævt match i forhold til cybersikkerhed, kan vi fortælle dig, at du ikke er alene! Der er rigtig mange med ikke-teknisk baggrund, der bevæger sig i retning af cybersikkerhed. En-

ten fordi der på deres arbejdsplads er behov for, at flere går ind i det arbejde, eller fordi den retning virker spændende. Blandt vores omkring 100 kollegaer i Implement, der er eksperter i forskellige dele af cyber- og informationssikkerhedsområdet, finder vi foruden de teknisk tunge eksperter kollegaer, som kommer med en anderledes baggrund. Vi har f.eks. både en tidligere pilot, soldater, en cand.mag. i koreansk, kandidater i statskundskab og en pærevælling af andre uddannelser – men som alle har arbejdet med feltet i en årrække og giver det værdi, fordi cybersikkerhed indeholder utrolig mange facetter, der gør, at man skal forstå processer, mennesker og teknik. Rådet for Digital Sikkerhed bifalder tendensen med, at flere faggrupper indgår i arbejdet. De siger f.eks. at: *"Cyber- og informationssikkerhed er meget mere end bare teknik (ingeniører, datamatikere). Der er også karrieremuligheder indenfor f.eks. jura, etik, governance, risikostyring, kommunikation, formidling, strategi, og politik. Derfor skal området tænkes bredt, og mulighederne for at tilføre kompetencer til professionelle indenfor forskellige faggrupper bør styrkes"* (2023).

Cyber- og informationssikkerhed er altså et område, der indeholder mange facetter og discipliner, og derfor er der også behov for at tilgå emnet fra forskellige vinkler.

Efterhånden ser vi selvfølgelig også flere og flere med uddannelser, der decideret handler om informations- og cybersikkerhed. Men tendensen lige nu – og et godt stykke frem i tiden – er, at der simpelthen ikke uddannes nok kandidater med dette som hovedområde. Men det er ikke blot en nødvendighed at opkvalificere kollegaer med forskellige faglige baggrunde – det er faktisk også en fordel.

> *"Det er jo en kæmpe force, at man har en anden baggrund og så "topper op" med cybersikkerhed. Mange tænker "jeg er generalist", eller "jeg har en helt anden faglighed", det her føles måske alt for komplekst. Men der er så meget brug for dig, og det er en styrke at du har netop din faglighed med i arbejdet og vurderingerne."*
> - Nadika Bulathsinhala, projektleder Industriens Fond

Denne bog er derfor skrevet, så forhåbentlig så mange som muligt vil få noget ud af at læse den. Vi er dog også klar over, at da målgruppen er forholdsvis bred,

vil man få noget meget forskelligt ud af læsningen alt efter ens udgangspunkt og situation. I nedenstående figur viser vi, hvad man med forskellige baggrunde med fordel kan fokusere på i læsningen af denne bog (se figur nedenfor).

Bogens målgrupper:

- Til dig, som har en anden faglighed, men har cyber- og informationssikkerhed på dit skrivebord indimellem
- Til dig, som er studerende eller nysgerrig på en karriere indenfor cyber- og informationssikkerhed
- Til dig, som allerede har en del erfaring på feltet, men ønsker mere kontekst.

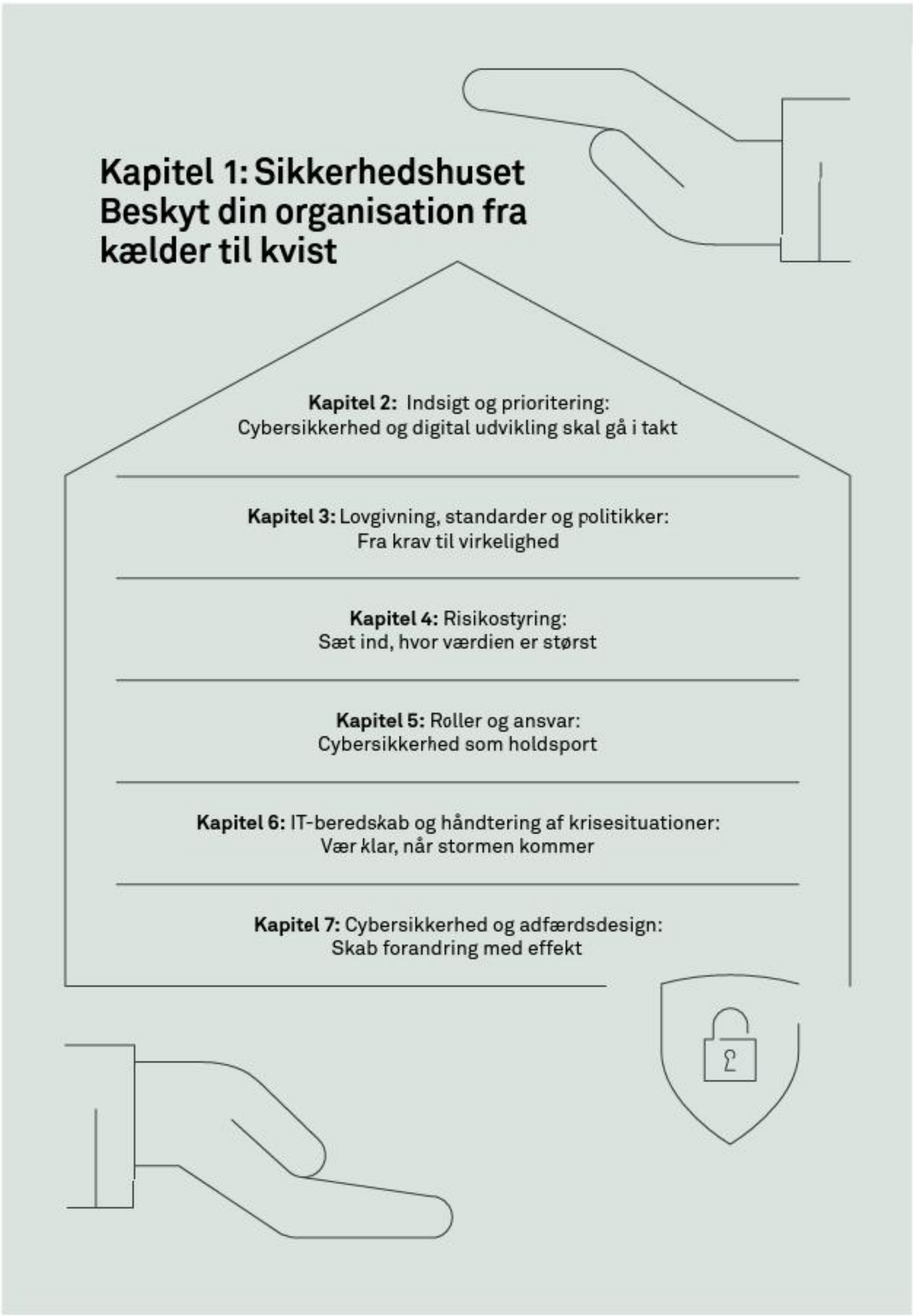
	Anden faglig baggrund	Studerende	Autodidakt
Denne bog er til dig, som:	... Har en anden faglighed, men har cyber- og informationssikkerhed på dit skrivebord indimellem.	... Er studerende eller nysgerrig på en karriere indenfor cyber- og informationssikkerhed.	... Allerede har en del erfaring på feltet, men ønsker mere kontekst.
Måske du oplever, at:	... Du mangler vigtig viden for at kunne indgå i konstruktiv dialog med dine cybersikkerhedskollegaer.	... Det er svært at finde lettilgængeligt materiale på dansk, som ikke forudsætter teknisk kendskab og viden om alle forkortelser.	... Du er blevet oplært af gode, erfarne kollegaer, men ofte mangler kontekst og det "store billede".
Disse dele af bogen er særligt relevante for dig:	Kapitel 1-5, så du forstår de vigtigste kernebegreber og roller/ansvar. Kapitel 7, hvis du er involveret i kommunikationsindsatser.	Kapitel 1-7, med særligt fokus og tid til casearbejde.	Kapitel 3-6, med særligt fokus på, hvordan du kan bringe risikostyringsværktøjer og IT-beredskabsplaner ind i din virksomhed.
Din hemmelige superpower, efter du har læst denne bog:	... Du forstår, hvorfor dine cybersikkerhedskollegaer siger, at du er "first line of defense", og kan indgå i konstruktiv dialog om, hvilke sikkerhedsforanstaltninger der er nødvendige, uden af forstyrre arbejdet unødigt.	... Du har et samlet overblik og erfaring med at gennemtænke konkrete cybersikkerhedsrelaterede cases. Du vil ikke gå arbejdsløs længe!	... Du har de bedste værktøjer til rådighed og din konkrete erfaring. Du vil være en nøgleperson i din virksomheds cybersikkerhed!

En kærlig hilsen til vores tekniske kollegaer

Med vores valg af målgruppe har vi også taget et klart fravalg, nemlig de mere "tekniske profiler". Så, kære tekniske kollegaer: Jer, som elsker at nørde netværksprotokoller og kender alle forkortelserne, og som nok mest er overraskede over, at vi er mange, som først kommer med på cybersikkerhedsbussen nu; denne bog er ikke til jer. Vi håber selvfølgelig, at I vil læse bogen og måske alligevel lære en ting eller to om de mindre tekniske, men lige så vigtige, domæner, og hvilket perspektiv ikke-tekniske kollegaer bringer med. Men vi må på forhånd bede om tilgivelse for de mange tekniske detaljer, som vi ikke her i bogen dykker ned i. Cyber- og informationssikkerhed er ingenting uden den dybt tekniske og faglige viden. Men vi har også brug for flere kollegaer, der kan indgå i arbejdet, og vi er overbeviste om, at med både et teknisk tungt og et stærkt organisatorisk blik vil sikkerheden i organisationen stå bedre.

Overblik over bogens indhold

Cyber- og informationssikkerhedsområdet er et utroligt stort fagområde, som vi går til med største ydmyghed. Formålet med denne bog er først og fremmest at forsøge at danne et samlet billede af feltet for nye medarbejdere eller studerende. Når vi selv danner os et overblik, og i arbejdet med vores kunder, gør vi brug af vores model "Sikkerhedshuset" (nedenfor), som derfor også danner grundlag for bogen.



Figur 0.5. Bogen er baseret på vores model for et holistisk syn på cybersikkerhed kaldet "Sikkerhedshuset". Hver kapitel i bogen afspejler et af emnerne i Sikkerhedshuset.

Sikkerhedshuset er et opkog af anerkendte standarder og rammeværk (herunder ISO 27001 og NIST CFS 2.0), men opsummeret på en sådan måde, at det er lettere at skabe overblik og fælles forståelse for, hvor man som organisation har brug for at prioritere sit arbejde. Hvad end man er en stor organisation eller myndighed eller en lille familieejet virksomhed, præsenterer Sikkerhedshuset de emner, som bør indgå i et stærkt cybersikkerhedsarbejde. De præsenterer således også de emner, man som medarbejder kan blive bedt om at byde ind i. I store virksomheder vil der være indtil flere fuldtidsansatte på hvert af emnerne, hvor man i en mindre virksomhed typisk har fingrene nede i flere af emnerne på samme tid.

Ikke alle medarbejdere skal være eksperter på alle områder – det vil nok være nærmest umuligt. Men hvis flere medarbejdere har en grundlæggende forståelse for hvert af disse emner og forstår, hvor netop deres arbejde passer ind i hele modellen, så foregår samarbejde på tværs af organisationen langt bedre.

Hvert emne i Sikkerhedshuset er uddybet i et separat kapitel. Denne bog er skrevet, så den kan læses kronologisk fra start til slut, men det er bestemt også muligt at udvælge netop det kapitel, der er relevant for præcis den udfordring, du står overfor, og så nøjes med at dykke ned i det. I nedenstående oversigt opsummerer vi kort indholdet i bogens syv kapitler:

- **Kapitel 1: Strategi og sikkerhedshuset**
  I bogens første kapitel ser vi nærmere på Sikkerhedshuset. Vi præsenterer, hvordan emnerne i Sikkerhedshuset kan være med til at sætte strategisk retning i arbejdet med at sikre et passende niveau af cyber- og informationssikkerhed.

- **Kapitel 2: Indsigt og prioritering**
  Kapitlet handler om vigtigheden af at have en dyb forståelse for ens organisation for at kunne beskytte den mod cybertrusler. Kapitlet fokuserer således på behovet for at forstå den digitale understøttelse af kerneopgaverne i virksomheder og myndigheder. Desuden introducerer kapitlet fem områder for sikkerhedsarbejde, herunder den overordnede

strategiske retning, risikoappetit, kerneprocesser, den digitale understøttelse og IT-understøttelse.

- **Kapitel 3: Lovgivning, standarder og politikker**
  Lovgivningen udvikler sig hele tiden, og det er nødvendigt løbende at vurdere, hvilke krav ens organisation er underlagt. Det er en fordel at tage udgangspunkt i anerkendte standarder og rammeværk som ISO 27001 eller NIST CSF 2.0, som derfor introduceres i kapitlet. Kapitlet præsenterer en tilgang til at udarbejde effektive styringsdokumenter (politikker), som sikrer, at alle i organisationen kender retningen for cybersikkerhed og ved, hvad der skal gøres.

- **Kapitel 4: Risikostyring**
  Risikostyring indenfor cybersikkerhed er en kompleks opgave for virksomheder og myndigheder. For at kunne gå til opgaven er det vigtigt at forstå begreber som aktiver, trusler, sårbarheder og risici samt at anvende rammeværker og standarder som f.eks. ISO 27005. Risici på cyber- og informationssikkerhedsområdet udgør en delmængde af organisationens samlede risici, og kapitlet præsenterer en tilgang, der baserer sig på klare processer, samarbejde på tværs af organisationen og involvering af de rette ressourcer. Slutteligt giver kapitlet et bud på, hvordan man kan strukturere effektiv ledelsesrapportering, og hvordan et årshjul kan gøre arbejdet med risikostyring lettere.

- **Kapitel 5: Roller og ansvar**
  Dette kapitel præsenterer først de vigtigste aktører på både internationalt og nationalt niveau og understreger behovet for klarhed i fordelingen af roller og ansvarsområder indenfor organisationer. Kapitlet præsenterer to centrale modeller, "Three Layers of Defense"-modellen og "RACI"-modellen, for at støtte en struktureret tilgang til fordeling af roller og ansvarsområder. Derudover dykker kapitlet ned i kompleksiteten ved at håndtere relationer med leverandører og vigtigheden af at integrere IT-sikkerhedsperspektiver i indkøbsprocessen. Samlet set giver kapitlet indblik i, hvordan organisationer kan navigere i det komplekse

netværk af roller og ansvarsområder indenfor cyber- og informationssikkerhed.

- **Kapitel 6: IT-beredskab**
  I kapitel 6 fokuserer vi på IT-beredskabsstyring og forretningskontinuitet som centrale begreber og viser, hvordan arbejdet med dette kan ruste organisationer til at stå stærkere i tilfælde af en IT-relateret krise. Kapitlet præsenterer metoder, redskaber og værktøjer, herunder business impact analysis, der er helt essentielle for at bygge og vedligeholde et passende beredskab.

- **Kapitel 7: Cybersikkerhed og adfærdsdesign**
  I det sidste kapitel i bogen stiller vi skarpt på adfærdsdesign som et centralt emne i at arbejde med effektive cybersikkerhedsindsatser. Vi gennemgår 5D-modellen, som er en model, der gør det muligt at arbejde systematisk med at undersøge, hvad der skal til for at understøtte den ønskede adfærd. Kapitlet giver desuden en række eksempler på, hvordan cybersikkerhedsindsatser kan gøres mere interessante og involverende, samt hvilke roller der findes i jagten på at skabe reelle adfærdsændringer.

Hvis du er forholdsvis ny på området, vil vi anbefale at læse bogen fra start til slut, men samtidig at tage dig god tid til de cases, hvert kapitel byder på. Det er netop, når tekst omsættes til praksis, at der opstår reel værdi. Vi opfordrer derfor også til, at du tager et par kollegaer eller medstuderende med under armen i casearbejdet. Spørgsmålene til hver case kan enten drøftes i jeres næste kaffepause, eller hvis det er et emne af særlig relevans, kan det være omdrejningspunkt for et afdelingsmøde. Vores første case herunder kan også hjælpe til at give dig et fingerpeg i forhold til, hvilke kapitler der er særligt relevante for dig.

En kort opsummering:

Cybersikkerhed er fundamentet for vores digitale dagligdag

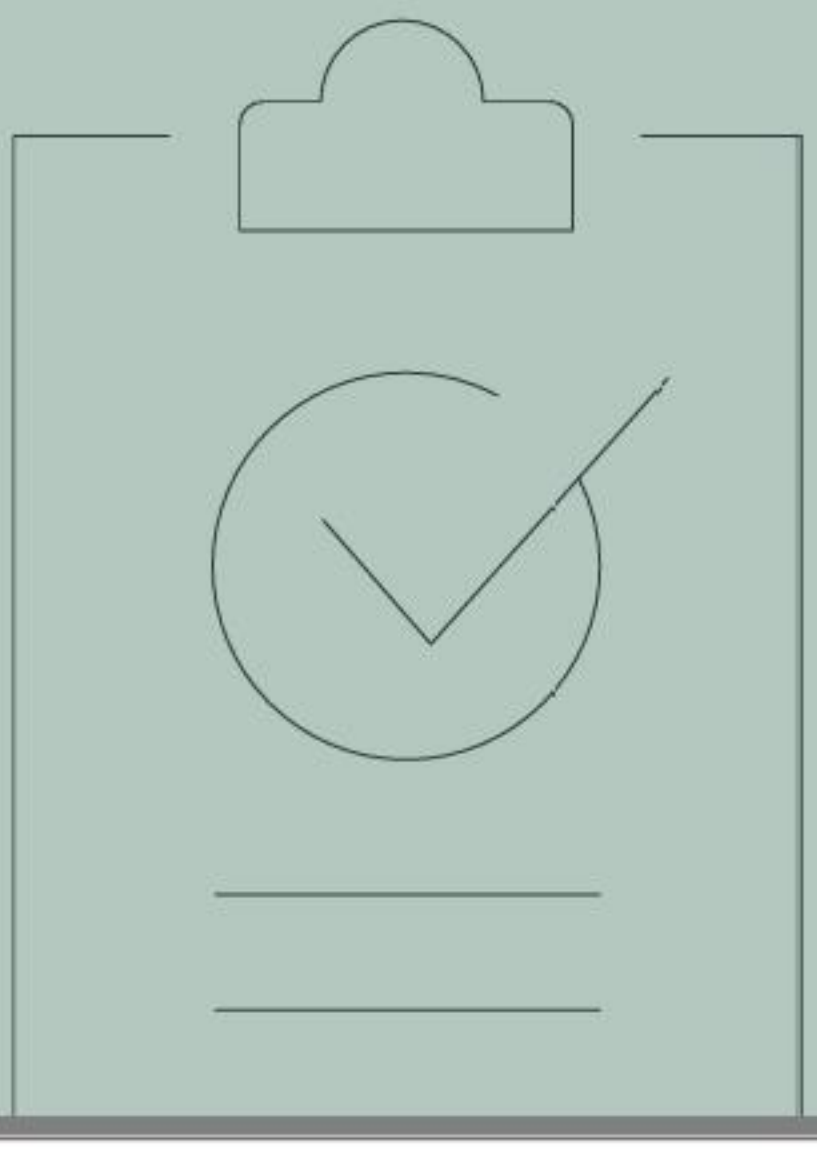
- Den danske forkærlighed for digitalisering giver os en effektiv og IT-understøttet hverdag, men efterlader os sårbare overfor aktører, der vil os det ondt, hvis vi ikke følger med i forhold til cyber- og informationssikkerhed.

- Omvendt så må cyber- og informationssikkerhed aldrig være målet i sig selv – cybersikkerhed bør have fokus på at understøtte organisationens mål og kan – hvis dette gøres korrekt – vise sig at være en konkurrencefordel.

- Målet skal være et "passende" cybersikkerhedsniveau og gerne med udgangspunkt i en analyse af behovet for fortrolighed, integritet og tilgængelighed.

- Virksomheder, der arbejder med cyber- og informationssikkerhed, har brug for *både* medarbejdere, der er "teknisk tunge", men også medarbejdere, der forstår forretningens behov, er skarpe til kommunikation, og som kan forstå og har interesse for menneskelig adfærd.

- Vores model, Sikkerhedshuset, præsenterer de vigtigste emner, som alle organisationer bør beskæftige sig med i forhold til cyber- og informationssikkerhed. Hvert emne i Sikkerhedshuset bliver yderligere beskrevet i hver sit kapitel.



Case:

Plastikhandske-leverandør til hospitaler lagt ned af hackerangreb

På en mark lidt udenfor en lille by i Midtjylland ligger den danske succes-historie "GloveTech". De har specialiseret sig i at levere engangshandsker til hospitaler og klinikker i hele landet og har ekspanderet til Norden og Tyskland. Virksomheden har på kort tid opnået stor succes og etableret sig som en pålidelig leverandør af kvalitetsprodukter. Dog har GloveTech haft stort fokus på deres kerneprodukt, på bekostning af betydningen af IT-sikkerhed i deres drift. "Vi sælger engangshandsker, det er jo ikke ligefrem sundhedsoplysninger", som deres CEO ofte siger med et lille grin. IT-chefen er travlt optaget af at få IT-systemerne til at følge med den voldsomme vækst, men stoler på, at de indkøbte systemer er sikre nok. Dette viser sig at have alvorlige konsekvenser.

En dag bliver GloveTechs IT-systemer angrebet af en ondsindet hackergruppe, der formår at få adgang til virksomhedens fortrolige oplysninger. Hackerne får adgang til følsomme data såsom produktionsprocesser, salgsoplysninger og kundeoplysninger. Dette skaber panik i virksomheden, og kundeservice bliver samtidig kimet ned af bekymrede kunder, der er bange for ikke at kunne gennemføre operationer eller anden medicinsk behandling på grund af handskemangel. Det ses hurtigt på onlineanmeldelser, at virksomhedens forretningsmæssige omdømme er på spil.

Efter at have indset alvoren af situationen indkalder GloveTechs ledelse til et møde for at diskutere problemet og finde en løsning. Mødet er præget af intense diskussioner og bekymring over virksomhedens manglende fokus på cybersikkerhed. Ledelsen når til enighed om, at noget må gøres. IT-chefen får nu tildelt en ekstra fuldtidsmedarbejder til at "få styr på sikkerheden".

Arbejdsspørgsmål

Følgende arbejdsspørgsmål kan give dig en idé om, hvilke dele af denne bog der kan være særligt relevante for dig. Hvis du har et klart og tydeligt svar til alle følgende spørgsmål, så kan du hurtigt skimme igennem denne bog og fortsætte det gode arbejde! Hvis du alligevel gerne vil dykke lidt dybere ned i hvert spørgsmål, kan du ved hvert spørgsmål finde henvisning til, hvilket kapitel der kan give mere kontekst og svar.

- Hvis du var den nye fuldtidsmedarbejder, der bliver sat til at få "styr på sikkerheden", hvad ville du så drøfte med din leder som det naturlige første skridt? (Kapitel 1: Strategi og Sikkerhedshuset)

- Hvordan ville du sikre dig, at der er det rette fokus i sikkerhedsarbejdet, så investeringerne bliver foretaget på de rigtige områder? (Kapitel 2: Indsigt og prioritering)

- Hvordan ville du undersøge, hvilken lovgivning virksomheden eventuelt er omfattet af, og hvilken standard kunne eventuelt hjælpe virksomheden i deres rejse mod et passende niveau for cybersikkerhed? (Kapitel 3: Lovgivning, standarder og politikker)

- Hvordan kan en virksomhed som GloveTech holde styr på, hvilke risici de står overfor, og hvordan de skal prioritere? (Kapitel 4: Risikostyring)

- Hvilket ansvar har henholdsvis ledelsen og IT-chefen for cybersikkerhed? Er der en tydelig ansvarsplacering, og hvad mangler eventuelt? (Kapitel 5: Roller og ansvar)

- Hvordan kan GloveTech sikre sig, at erfaringerne fra angrebet bliver indarbejdet i deres beredskab, så de er bedre rustet til et angreb i fremtiden? (Kapitel 6: IT-beredskab)

- Hvordan ville du sikre, at uddannelse af med arbejdere og adfærdsdesign bliver en integreret del af et stærkt cybersikkerheds-setup i GloveTech? (Kapitel 7: Cybersikkerhed og adfærdsdesign)

Litteraturliste

Europa-Kommisionen (2022, juli): Digital Economy and Society Index (DESI) 2022. Lokaliseret på: https://digital-strategy.ec.europa.eu/en/library/digital-economy-and-society-index-desi-2022

Center for Cybersikkerhed (2024, 4. juli). Trusselsvurdering.

Center for Cybersikkerhed (2019, marts). Trusselsvurdering.

Center for Cybersikkerhed (u.å.). Ordforklaringer. Lokaliseret på: www.cfcs.dk/da/cybertruslen/ordforklaringer/

Devantier (2024, 19. april). Efter et ransomware-angreb i 2023: Nu lukker Cloudnordic helt ned. ITWatch. Lokaliseret på: itwatch.dk/ITNyt/Brancher/hosting/article17033746.ece

Den sikkerhedspolitiske analysegruppe (2022, september). Dansk sikkerhed og forsvar frem mod 2035.

DI Digital (2023, 2. januar). Danmark har akut brug for styrkede cyber- og informationssikkerhedskompetencer.

Finansministeriet (2021, december). National Strategi for cyber- og informationssikkerhed 2022-2024.

Højbjerre Brauer Schultz (2019, december). Arbejdsmarkedet for informationssikkerhedskompetencer i Danmark.

Industriens Fonds Cyberprogram (2023). Cyberbarometeret 2023. Lokaliseret på: www.cyberbarometer.dk/

Ingeniøren, Version 2 (2017, august). NotPetya-cyberangreb koster Mærsk milliardbeløb. Lokaliseret på: www.version2.dk/artikel/notpetya-cyberangreb-koster-maersk-milliardbeloeb

Jacobsen, J. T., & Liebetrau, T. (2022). Cybertrusler: Det digitale samfunds skyggeside. DJØF Forlag.

Nweke, L. O. (2017). Using the CIA and AAA models to explain cybersecurity activities. PM World Journal, 6(12), 1-3.

Rådet for Digital Sikkerhed (2023, 30. januar). Manglende cyber- og informationssikkerhedskompetencer.

Vestager (2022, 10. november). EU pressemøde den 10. november 2022.

World Economic Forum (2024, Januar): 2023 was a big year for cybercrime – here's how we can make our systems safer. Lokaliseret på: www.weforum.org/agenda/2024/01/cybersecurity-cybercrime-system-safety/

Kapitel 1

Kapitel 1

Strategi og Sikkerhedshuset: Beskyt din organisation fra kælder til kvist

> Cyber- og informationssikkerhed er den metodiske tilgang til at sikre et passende niveau af fortrolighed, integritet og tilgængelighed for de vigtigste informationer og aktiver i en given virksomhed eller myndighed."
>
> **Christian Ehlers Mikkelsen, cybersikkerhedskonsulent og partner, Implement Consulting Group**

Hvorfor er strategi vigtigt?

Hvert år bliver virksomheder og myndigheder ramt af cyberangreb og informationssikkerhedshændelser, der ikke blot koster dyrt på bundlinjen (Huang et al., 2023), men som også kan skade omdømme eller forårsage fysiske skader og gener (Lohrke, et al., 2023). Datasikkerhedsbrud kan desuden have store personlige konsekvenser for de kunder eller borgere, hvis informationer bliver kompromitteret. Der findes derfor nok næppe den CEO, departementschef, styrelsesdirektør, regions- eller kommunaldirektør, som ikke har gjort sig nogle nervøse tanker om, hvordan netop deres organisation er rustet til at modstå et eventuelt angreb. Alle medarbejdere er efterhånden også med på, at sikkerhed skal tages alvorligt, og at det ikke nytter noget at lade stå til. Alligevel kan det være en udfordring at få skabt enighed omkring niveauet for cyber- og informationssikkerhed, for hvornår er det, man gør, så egentlig godt nok? Hvor skal vi sætte ind først?

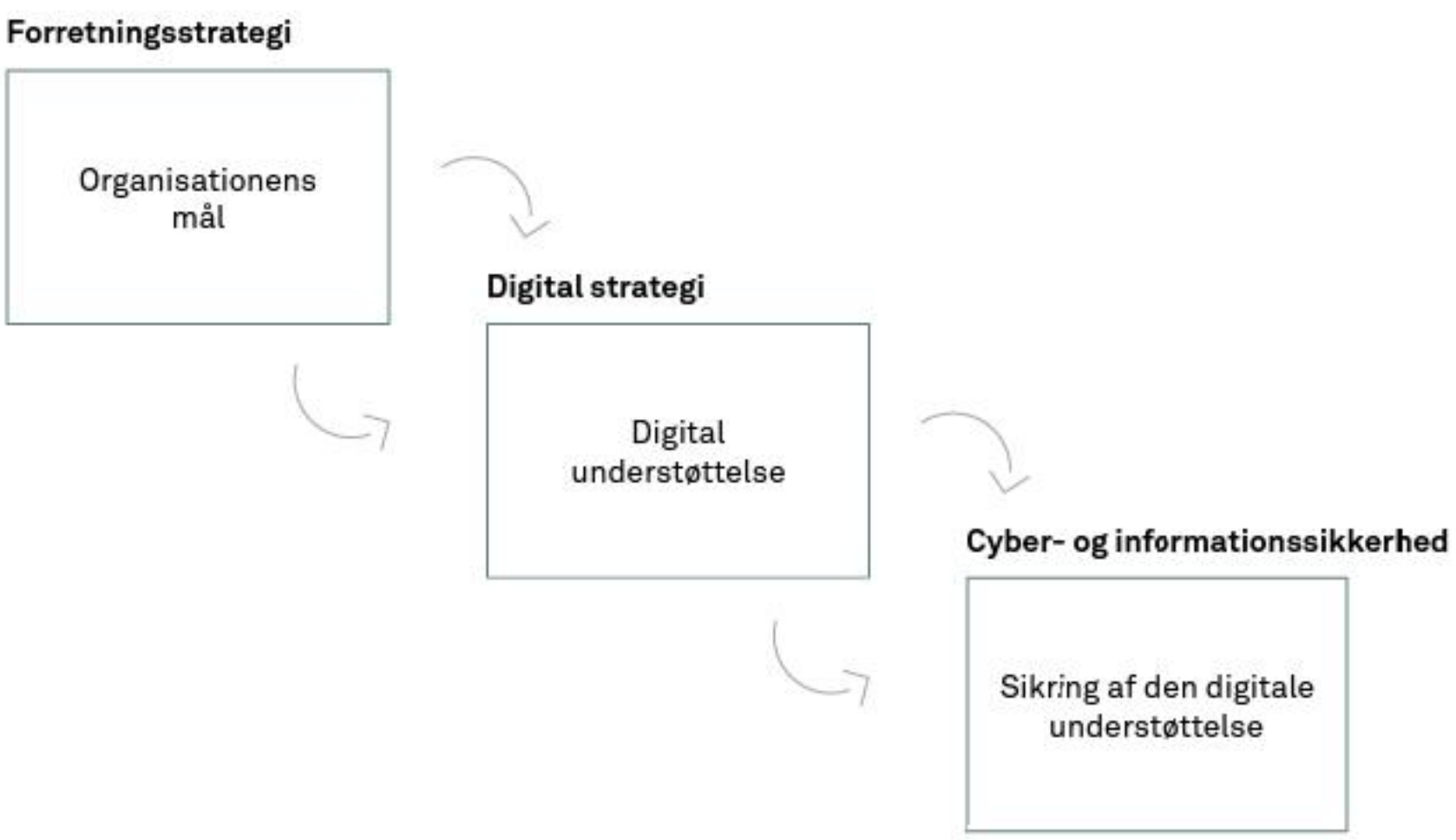
Både virksomheder og offentlige myndigheder oplever dilemmaer. Som privat virksomhed kan man på den ene side ønske at sikre sine aktiver og på den anden side ønske at bibeholde en fleksibel og veldrevet organisation, der kan tilpasse sig efterspørgsel på nye produkter, andre og grønnere måder at producere på eller ny lovgivning at leve op til. Derfor ser vi på den ene side ofte en sikkerhedsfunktion, der (med rette) ønsker at højne sikkerhedsniveauet, og på den anden side en forretning, der oplever, at nye sikkerhedsforanstaltninger er i vejen for dem i deres daglige arbejde (Hepfer, 2020). Vores erfaringer viser dog, at med en målrettet cybersikkerhedsstrategi, som spiller sammen med forretningens målsætninger og generelle strategi, kan cybersikkerhed være

med til at understøtte, at organisationen kan udvikle sig med den takt og hast, som forretningsmæssigt giver mening – og endda giver konkurrencemæssige fordele. Kirsten Hede, projektdirektør for Bestyrelsesforeningens Center for Cyberkompetencer, fremhæver: *"Vi kan se det, og vores deltagere på både bestyrelsesuddannelserne og i vores Træningscenter bekræfter det: Det er en konkurrencefordel, hvis man har et vist niveau af cybersikkerhed."* For at opnå de konkurrencemæssige fordele ved arbejdet med cybersikkerhed kræver det, at man arbejder strategisk og struktureret med, hvad man gerne vil opnå med cyber- og informationssikkerhed.

På samme vis kan strategisk og struktureret arbejde med cyber- og informationssikkerhed hos statslige myndigheder, regioner og kommuner være med til at sikre, at man når sine politisk fastsatte mål og samtidig ikke gambler med borgeres og virksomheders tillid til den offentlige sektor.

Konkret er det vores erfaring, at disse fordele kan opnås, hvis der er en tæt sammenkobling mellem:

- den overordnede forretningsstrategi (der siger noget om, hvor man som organisation skal bevæge sig hen)
- den digitale strategi (der siger noget om, hvordan organisationen kan realisere sine ambitioner via digitale løsninger), og
- cyber- og informationssikkerhedsstrategien (som siger, hvordan rejsen bliver sikret tilstrækkeligt).



Figur 1.1. Sammenkobling mellem organisationens mål, den digitale understøttelse og sikring af den digitale understøttelse.

En sammenkobling mellem de tre strategier understøtter nemlig, at man kan have en fleksibel og veldrevet organisation, der kan udvikle sig med den takt og hast, der giver forretningsmæssig mening, samtidig med at man på tilstrækkelig vis beskytter sine aktiver. Herved kan der arbejdes holistisk med cyber- og informationssikkerhed i organisationen.

Formålet med en cyber- og informationssikkerhedsstrategi er at fastsætte en retning og ikke mindst prioritering i arbejdet på området (Huang et al., 2023). En cyber- og informationssikkerhedsstrategi kan derfor bidrage til, at der kommer en klarhed over, hvor, hvordan og hvornår der skal investeres på området. Endelig bør strategien også skabe en fælles forståelse for governance på området – og altså bidrage med svaret på, hvem der gør hvad helt overordnet set.

"Nogle gange kan ledelsens visioner og strategier forekomme at være en noget fluffy størrelse, som det er svært at se sig selv i og omsætte til dagligt arbejde. Man kan derfor prøve at tænke på, om man kan formulere sin egen vision for sikkerhedsarbejdet, som understøtter den overordnede vision og strategi. Det kunne f.eks. være at 'sikkerhedsarbejdet skal

> *beskytte forretningen og sikre tillid hos alle samarbejdspartnere*'." fortæller Henning Mortensen, der er CISO og formand for Rådet for Digital Sikkerhed.

Dette kapitel stiller skarpt på, hvorfor alle bør arbejde strategisk med cyber- og informationssikkerhed, og hvad en strategi for cyber- og informationssikkerhed bør indeholde. Kapitlet tager udgangspunkt i Sikkerhedshuset, som vi kort præsenterede i bogens introduktionskapitel. Vi går igennem hvert lag (eller etage, hvis man vil blive i metaforen) i huset på et strategisk niveau. I bogens øvrige kapitler udfolder vi hvert emne og viser, hvordan man taktisk og operationelt kan arbejde med dem. Vi præsenterer også en række konkrete værktøjer og metoder til hvert emne i bogens øvrige kapitler.

Hvad er en cyber- og informationssikkerhedsstrategi?

Helt kort kan man sige, at en strategi er: *"en langsigtet planlægning, som fører til eller mod et mål"* (Wikipedia, u.å.). Området for cyber- og informationssikkerhed er ingen undtagelse, men cybersikkerhed bør aldrig være et mål i sig selv. Derimod er en effektiv cybersikkerhedsstrategi *"en plan, der styrer de organisatoriske sikkerhedsrisici, så de er i tråd med organisationens fastsatte risikotolerance, således at organisationens mål understøttes"* (Ozkaya, 2022). Det er vigtigt her, at det er forretningens (overordnede) mål, der understøttes af et passende cybersikkerhedsniveau – og ikke cybersikkerhed, der er styrende for forretningens mål. Strategiprocesser bør altid forankres hos topledelsen, ligesom det også er topledelsen, der sætter den overordnede strategiske retning for, hvor myndigheden eller virksomheden skal bevæge sig hen, og som løbende skal få niveauet for cybersikkerhed til at "matche" den ønskede retning.

Der findes en del teoretisk litteratur om, hvordan man som organisation kan udarbejde strategier, f.eks. Roger L. Martins "Playing to Win – How Strategy Really Works", eller Michael E. Porters "The Five Competitive Forces That Shape Strategy". Tankerne i disse eller lignende rammeværk kan også benyttes, når man skriver en strategi for cyber- og informationssikkerhedsområdet. Vi vil dog ikke dykke dybere ned i disse rammeværker i denne bog, men i stedet fokusere på, hvad der gør arbejdet med en cyber- og informationssikkerhedsstrategi særligt.

Ikke alle organisationer er ens. Der er derfor også stor forskel på, hvor omfattende en cyber- og informationssikkerhedsstrategi skal være. Det europæiske agentur for cybersikkerhed, ENISA, stiller f.eks. krav om, at alle lande i EU skal have en national strategi for cyber- og informationssikkerhed. Den danske nationale strategi for cyber- og informationssikkerhed har også stillet krav om, at kritiske sektorer såsom tele, energi og sundhed skal udarbejde strategier for arbejdet med cyber- og informationssikkerhed (Finansministeriet, 2018 og 2021). På lignende vis kan der være sektorspecifik lovgivning, der sætter rammen for, hvordan virksomheder og myndigheder skal arbejde strategisk med cyber- og informationssikkerhed. Uagtet politiske og lovgivningsmæssige krav til det strategiske cyber- og informationssikkerhedsarbejde mener vi, at en strategi på området kan være et godt og stærkt fundament for arbejdet med cyber- og informationssikkerhed. Dette gælder for organisationer af enhver størrelse.

> *"Vores erfaring viser, at de store virksomheder generelt er gode til at have cybersikkerhed som strategisk fokus, også selvom det kræver vedvarende fokus og arbejde. I de mindre virksomheder er bestyrelsen ofte lidt mindre opmærksomme på deres ansvar. Men på det her område er der skærpet bestyrelsesansvar – man må ikke længere overse dette emne, heller ikke selvom man er en lille eller mellemstor virksomhed, som ikke ser sig selv som særlig digital. For sandheden er, at det er kritisk for en virksomhed, hvis f.eks. en leverandør pludselig ikke kan levere på grund af f.eks. et cyberangreb, eller andet i værdikæden bryder sammen"*, fortæller Jens Stener, administrerende direktør, Bestyrelsesforeningens Center for Cyberkompetencer.

Vi bruger Sikkerhedshuset som model til at sikre en cyber- og informationssikkerhedsstrategi, der dækker alle de nødvendige emner. Dette uddybes i følgende afsnit.

Hvad indeholder en cybersikkerhedsstrategi typisk?

1. En indholdsfortegnelse. Giver overblik og gør det lettere at bruge som "arbejdsdokument" senere.
2. En indledning fra ledelsen. Slår retningen an og giver mandat til at udføre strategien.
3. En kort analyse eller evaluering af udviklingen siden sidste strategiperiode, hvis dette er relevant.
4. Beskrivelse af strategiske indsatsområder, f.eks. udarbejdet på baggrund af "Sikkerhedshuset", som uddybes nedenfor. Eventuelt med klare målsætninger og målepunkter, særligt for modne organisationer.
5. Organisering og tidslinje for arbejdet med de strategiske indsatsområder.

Godt at huske:

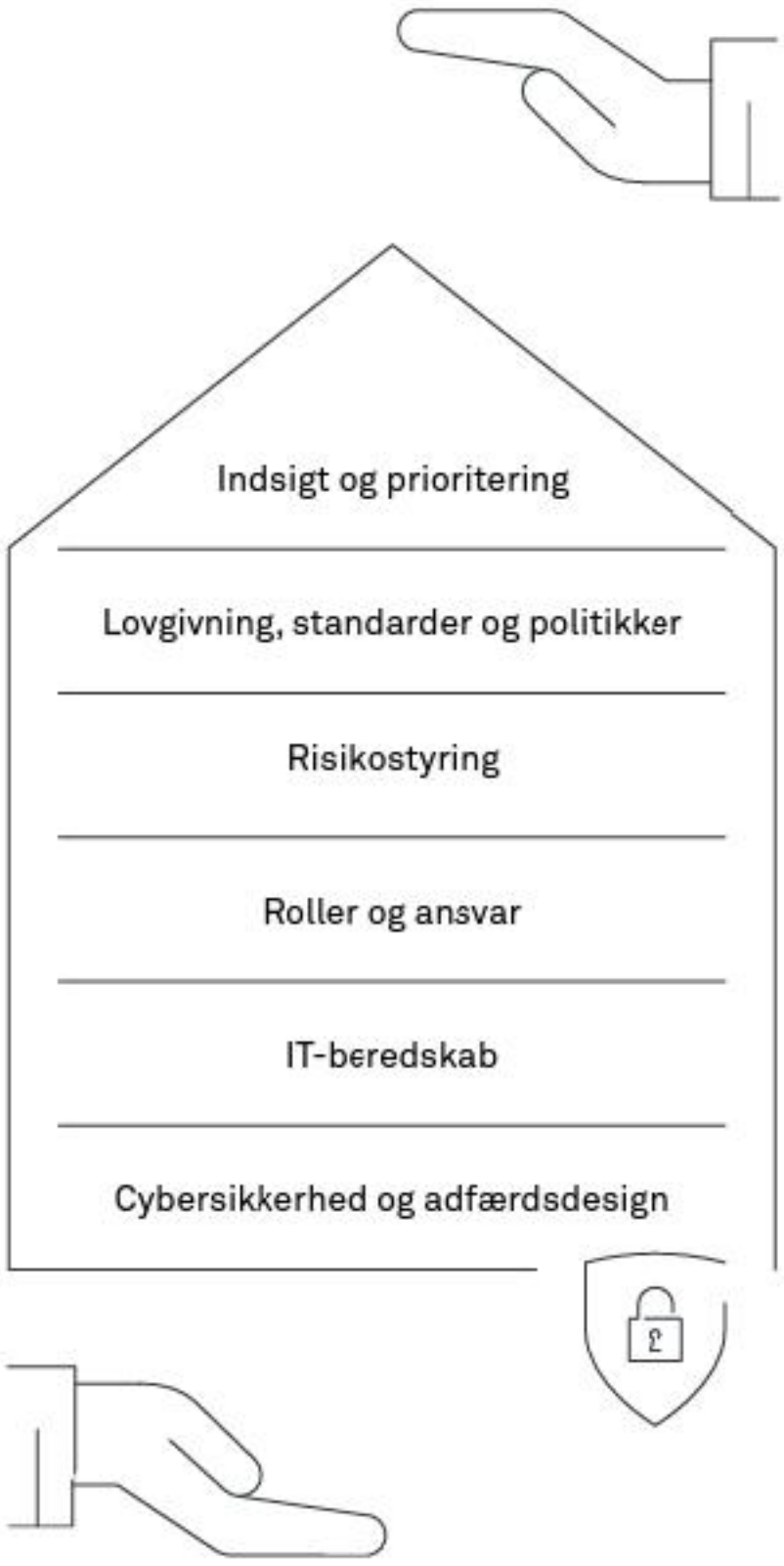
En strategi er ofte maksimalt 10-20 sider i Word, evt. PowerPoint for at gøre det mere visuelt. Strategien skal vise en prioritering i cybersikkerhedsarbejdet, have en klar tidsplan og meget gerne også tage stilling til, hvordan der sikres finansiering og af hvem i organisationen. En cybersikkerhedsstrategi bør opdateres med passende tidsintervaller, da udviklingen indenfor cyberområdet går stærkt, og strategier kan forældes.

Sikkerhedshuset sikrer overblik

Som vi skrev i introduktionskapitlet til denne bog, så er cyber- og informationssikkerhedsområdet kendetegnet ved at være multidisciplinært og består af mange forskellige tekniske såvel som ikke-tekniske facetter. Et samlet overblik er dog essentielt.

For at skabe overblik over området har vi udviklet og anvender i praksis Sikkerhedshuset, når vi som konsulenter bistår virksomheder og myndigheder i at højne deres sikkerhed. Sikkerhedshuset anvender vi ofte, når vi hjælper med at udarbejde cyber- og informationssikkerhedsstrategier. Modellen indeholder seks områder (eller etager, for at blive i metaforen), som sikrer, at man som organisation kan arbejde holistisk med cyber- og informationssikkerhed i sin organisation. Det er ikke sikkert, at alle emner skal have samme vægtning,

når man udarbejder de endelige indsatsområder, men de bør alle overvejes og vurderes med passende tidsintervaller.



Sikkerhedshuset er baseret på standarden ISO 27001 og NIST CSF 2.0 (se mere om standarder, lovgivning og politikker i kapitel 3). Vores oplevelse er, at det kan give et hurtigere overblik, og dermed fremdrift, at arbejde med Sikkerhedshuset i forbindelse med strategiudvikling, fordi domænerne fra standarderne er opsummeret. Dette sikrer, at man kommer rundt om emnerne, men uden at fortabe sig i detaljer (og pointen er her i strategiarbejdet netop at fastlægge *retningen*; selve arbejdet med emnet skal komme senere).

I cyber- og informationssikkerheds-strategien skal der tages stilling til hvert emne i Sikkerhedshuset: Hvordan forholder organisationen sig til dette emne, og hvordan skal der prioriteres?

Hvert emne i Sikkerhedshuset udfoldes yderligere i de kommende kapitler i denne bog, således at det for de udførende medarbejdere er så let som muligt at koble strategiske prioriteringer til reelle handlinger.

I de kommende afsnit gennemgår vi hver etage i sikkerhedshuset. Fokus i dette kapitel er på, hvordan man arbejder med det strategisk. I bogens kommende kapitler udfolder vi, hvordan man rent faktisk kan arbejde med temaerne i praksis, og viser konkrete værktøjer og metoder, man kan tage i anvendelse.

Indsigt og prioritering: Cyber- og informationssikkerhed skal gå i takt med den digitale udvikling

En vigtig pointe i denne bog og i alt cybersikkerhedsarbejde er, at cybersikkerhed aldrig må stå alene. Forstået på den måde, at cyber- og informationssikkerheden skal understøtte opgavevaretagelsen i virksomheden eller myndigheden, og ikke omvendt. Det er derfor vigtigt at gøre sig klart, hvad det er for en opgavevaretagelse, der er tale om. Kort sagt: Hvad er det, man ønsker at beskytte? Og hvilke risici kan man tolerere? Det kræver altså, at vi har indsigt, før vi kan prioritere ordentligt på området for cyber- og informationssikkerhed.

Overordnet set skal man spørge sig selv, hvad ville der ske for vores dagli-ge mulighed for at løse vores opgaver, hvis en proces eller et system ikke var tilgængeligt, hvis vi ikke kunne stole på data i systemet, eller hvis data blev offentliggjort eller på anden vis lækket. Altså hvis tilgængelighed, integritet eller fortrolighed bliver kompromitteret. Ved at gennemgå forskellige områder i virksomheden eller myndigheden med de briller på kan man se og få klarhed over, hvilke områder der er særligt kritiske. Her er det altså en fordel at gå sce-nariebaseret til værks for at være så konkret som overhovedet muligt.

For at nå til et svar på de spørgsmål så er det relevant at forholde sig til henholdsvis, hvilke mål man har som organisation, hvordan man når de mål, og hvilken risikoappetit man har. Denne proces er naturligvis mere omsiggri-bende, jo større en organisation man arbejder i. Men hvad enten man arbejder i en lille, mellemstor eller stor organisation, bør det være tydeligt for alle, hvad der er organisationens "kerneprocesser" (se kap. 2), og hvilke aktiver man som organisation har brug for at beskytte for at kunne udføre sine opgaver. Hvis man ikke endnu er så langt i sit cybersikkerhedsarbejde, er det her, der først skal sættes ind, og det bør prioriteres højt i organisationens strategi. I kapitel 2 beskriver vi nærmere, hvordan man praktisk går til arbejdet med at koble orga-nisationens overordnede mål, hvordan man kan identificere kerneprocesser, den digitale forretningsunderstøttelse, samt hvordan man fastsætter organi-sationens risikoappetit.

Indsigt og prioritering: Cybersikkerhed og digital udvikling skal gå i takt

Læs mere i kapitel 2

Fokus: Forstå din organisation for at prioritere indsatserne på cyber- og informationssikkerhedsområdet.

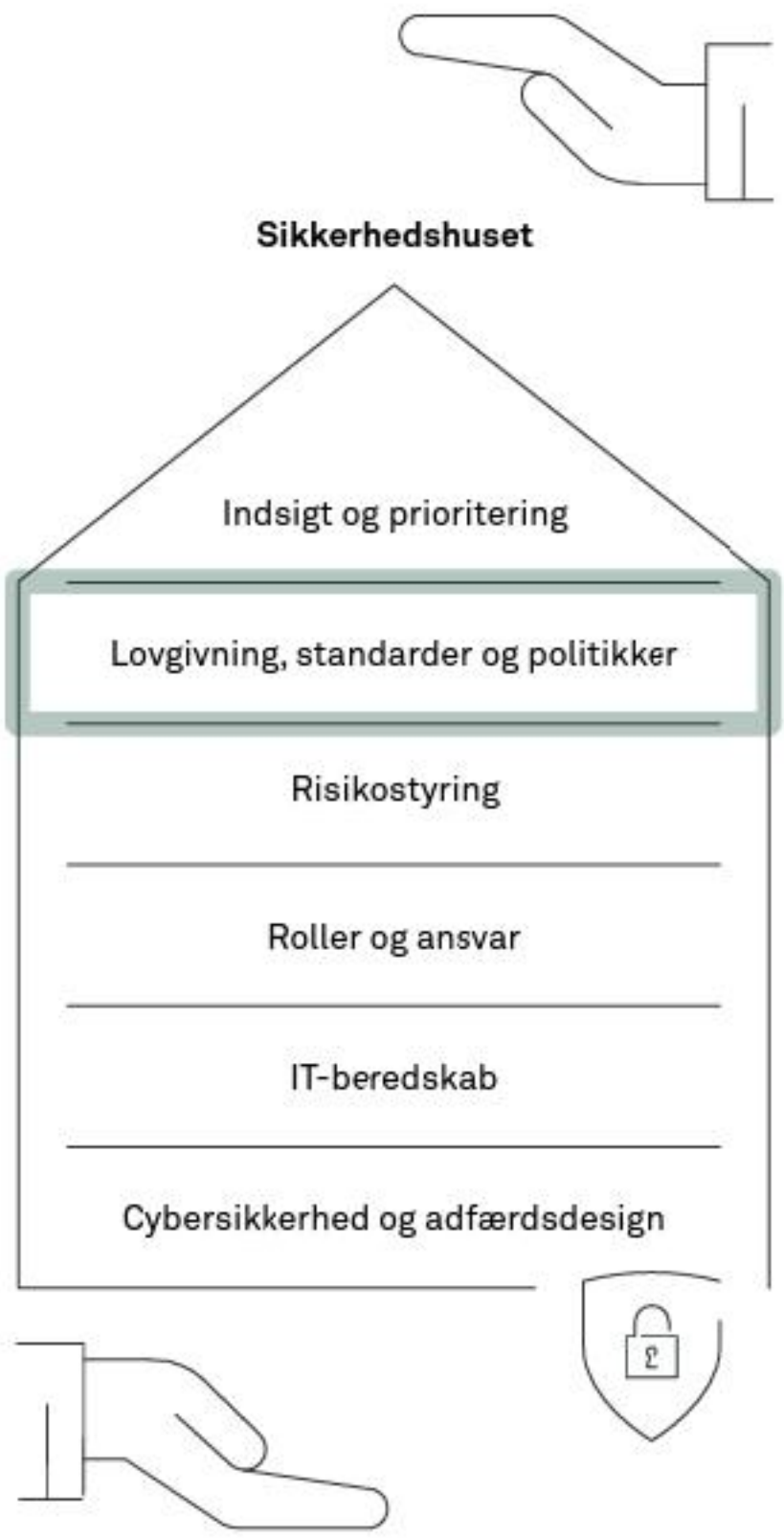
Vigtigste emner:

- Identifikation af områder, hvor der skal arbejdes med cyber- og informations-sikkerhed i form af processer eller investeringer.
- Afdækning af risikoappetit med ledelsen og balancering af risikostyringen i overens-stemmelse hermed.

Tjekliste

- Er organisationens vigtigste arbejdsprocesser kortlagt?
- Er viden om forretnings-mæssig kritikalitet omsat til sikkerhedstiltag, der effektivt beskytter eller opretholder de vigtigste elementer i opgavevaretagelsen?
- Er der klarhed over ledelsens risikoappetit?

Lovgivning, standarder og politikker: Fra krav til virkelighed



Cyber- og informationssikkerhedsområdet er underlagt en række forskellige lovgivninger, som varierer alt efter sektor, hvor kritisk organisationen er for samfundet som helhed, og organisationens størrelse. Det er vores erfaring, at der er behov for strategisk stillingtagen til, hvor organisationen placerer sig selv i forhold til både gældende og kommende lovgivning. Det kan give god arbejdsro i organisationen, at der "en gang for alle" er taget stilling til, hvordan organisationen placerer sig, eller hvornår og med hvilken kadence analyser af de lovgivningsmæssige rammer vil finde sted. Arbejdet for at sikre efterlevelse af relevant lovgivning (også ofte kaldet "compliance") er ikke en statisk stør-

relse, og det er derfor vigtigt, at man indtænker, hvordan man løbende holder sig ajour med nyudviklingen på lovgivningsområdet, som kan påvirke den virksomhed eller myndighed, man arbejder i (Lee, 2024).

Det kan også give mening, at man som virksomhed eller myndighed ser på, hvilke internationale standarder man vil følge. Her kan f.eks. ISO 27001 eller NIST CSF 2.0 være gode at gøre brug af. Vi udfolder mere om, hvilke overvejelser man som organisation bør gøre sig i forhold til internationale standarder og rammeværk, i kapitel 3.

Endelig er der også behov for at skabe operationelle politikker og processer, der understøtter sikkerhedsarbejdet og sikrer, at der kan følges op. Det kan give rigtig god mening at få dette cementeret som en tydelig prioritet i cybersikkerhedsstrategien, så det er tydeligt for alle, at dette har ledelsens opbakning.

Hvorvidt en strategi direkte nævner arbejdet med f.eks. at få udarbejdet relevante politikker, kommer helt an på organisationens modenhed. En stor organisation, som i årevis har arbejdet struktureret med et ledelsessystem som f.eks. ISO 27001 (se mere i kapitel 3), vil ikke skulle prioritere at udvikle politikkerne, da dette arbejde allerede er i gang. For en mindre moden virksomhed kan det dog give god mening, at man strategisk set prioriterer at få fokuseret på politikker, som skal være de gældende regler i netop denne virksomhed. Når emnet her er taget med som selvstændigt punkt i Sikkerhedshuset, og som relevant for modne såvel som mindre modne organisationer, er det, fordi man op imod hver ny strategiperiode bør analysere nøje, om der er ændringer i netop lovgivning eller organisationens kontekst (f.eks. opkøb af virksomheder i andre lande), der gør det relevant for organisationens cybersikkerhedsstrategi at sætte dette som en prioritet. Man må altså ikke falde tilbage på at tænke, at man allerede har vurderet, om noget lovgivning er relevant eller ej, for både lovgivning og konteksten for forretningen kan udvikle sig.

I kapitel 3 går vi dybere ned i eksempler på lovgivning, der er relevant for langt de fleste, der arbejder med cybersikkerhed, at kende til. Vi ser også på en vejledning til en "anvendelighedsvurdering", der bruges til at bestemme, hvilke lovmæssige krav der gælder for en specifik organisation.

En selvstændig pointe i forhold til emnet lovgivning, standarder og politikker er, at strategien bør fastsætte, om der vurderes at være behov for ekstern

evaluering af cybersikkerhedsarbejdet, herunder eventuelt audit (se mere i kapitel 5: Roller og ansvar).

Lovgivning, standarder og politikker: Fra krav til virkelighed

Læs mere i kapitel 3

Fokus: Klarhed over compliancekrav, samt hvordan disse overholdes.

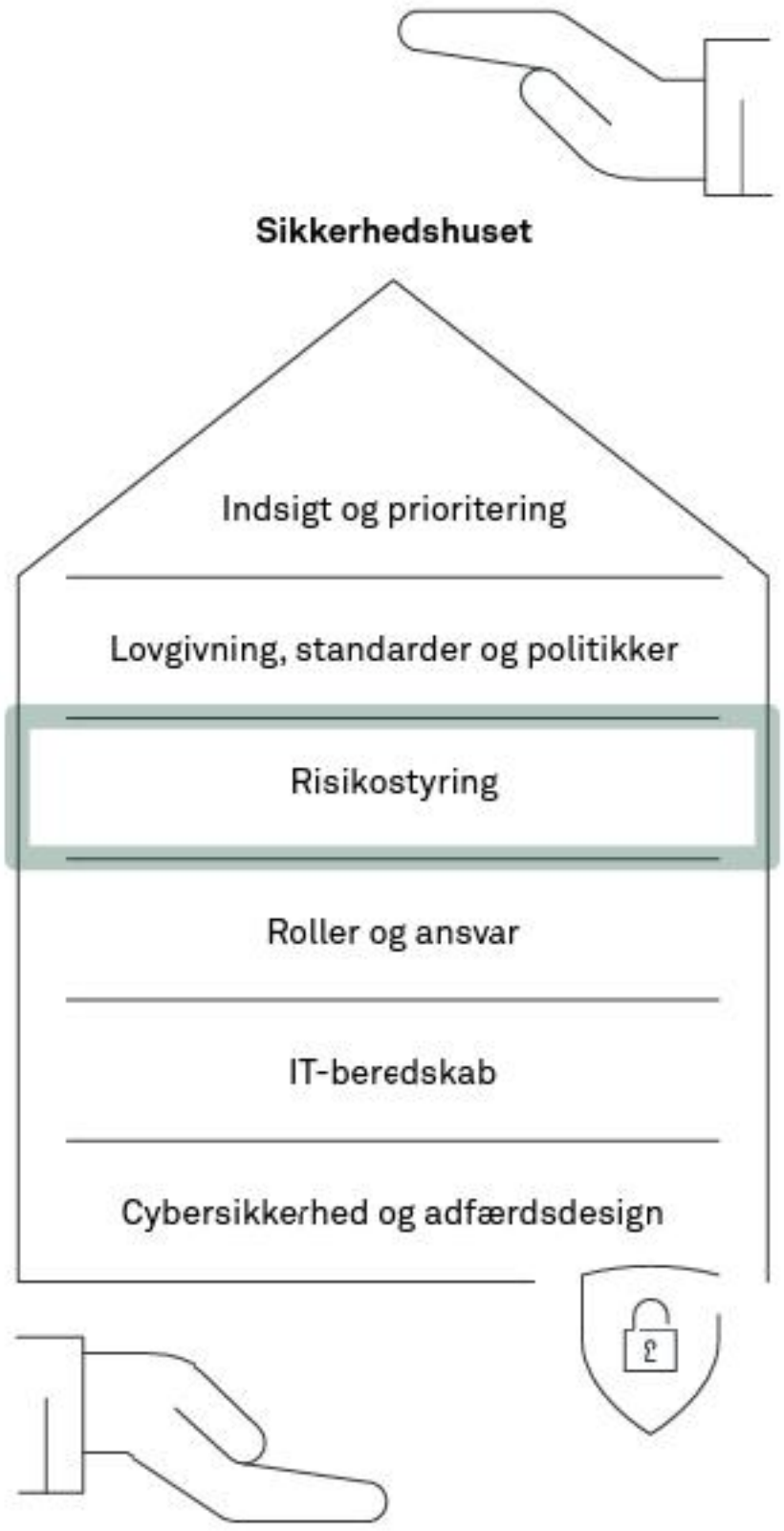
Vigtigste emner:

- Klarhed over, hvilke krav der er til organisationens compliance til lovgivning, politikker og standarder.
- Validering af overholdelse af ovenstående krav, herunder rapportering.
- Vurdering af behov for ekstern evaluering, audit og opfølgning indarbejdet i faste processer.

Tjekliste

- Understøtter ledelsen med sin prioritering af medarbejderressourcer de aktuelle lovkrav, rapporterings- og opfølgningsforpligtelser, som organisationen er omfattet af?
- Har organisationen besluttet, hvordan lovkrav skal efterleves?

Risikostyring: Sæt ind, hvor værdien er størst



Man kan ikke nævne cyber- og informationssikkerhed uden at nævne risikostyring. Risikostyring er kernen i moderne cyber- og informationssikkerhedsarbejde, og det er omdrejningspunktet for alt, hvad vi foretager os på sikkerhedsområdet. Uden en effektiv risikostyring har vi ingen chance for at prioritere indsatsen på sikkerhedsområdet. Alt bliver lige kritisk, og dermed er intet rigtigt kritisk. Det er ikke let at have et effektivt setup til risikostyring, men det er et enormt vigtigt område at prioritere, fordi det skaber fundamentet for, at vi kan sætte ind, hvor det er vigtigst – både i forhold til, hvor vi investerer og fokuserer på sikkerhedsområdet.

Vi har i dette kapitel nævnt, at risikoappetit også er et vigtigt led i at sørge for, at cybersikkerhedsindsatsen går i takt med resten af organisationens digitale udvikling. Risikoappetitten kan dog ikke stå alene, og den skal suppleres af konkrete risikovurderinger af IT- og datasystemer.

Foruden risikoappetitten er det altså væsentligt at udarbejde en risikovurdering for at kunne lave sin cyber- og informationssikkerhedsstrategi på et så oplyst grundlag som muligt. Det er med til at sikre det rette fokus i strategien.

Når man har fået overblik over de kritiske områder i sin organisation og IT-understøttelsen, så kan man se på, hvad der konkret kan medføre, at processen eller systemet bliver kompromitteret. Her bør man lave en trusselsvurdering, hvor man ser nærmere på trusselsaktørerne, deres motiver og evner. Med et klart defineret trusselsbillede kan man overveje, hvad sandsynligheden og konsekvensen ville være, hvis en hændelse- eller endda et angreb- rent faktisk fandt sted, og dermed gennemføre sin risikovurdering.

Risikovurderingen giver altså et fundament for, at ledelsen i virksomheden eller myndigheden kan forstå, hvad der kan ske, hvis aktiver ikke beskyttes tilstrækkeligt. Dermed er det også en forudsætning for, at der kan igangsættes de rette strategiske aktiviteter med de nødvendige investeringer for øje. I strategien kan området indeholde de væsentligste sikkerhedstiltag, der understøtter effektiv beskyttelse af de forretningskritiske aktiviteter og elementer i opgavevaretagelsen.

Risikostyring:
Sæt ind, hvor værdien er størst

Læs mere i kapitel 4

Fokus: At få prioriteret de vigtigste risici først.

Vigtigste emner:

- En opdateret og accepteret risikoappetit, som ledelsen har fastsat.
- En klar og tydelig ansvarsfordeling i organisationens risikostyring.

Tjekliste

- Har ledelsen forståelse for de risici, som organisationen står overfor?
- Har ledelsen godkendt risikotærskel samt mitigerende handlinger?

Roller og ansvar: Hvem gør hvad?

Organisering og samarbejde er noget af det, der er vigtigst at få greb om, når man taler strategisk om cyber- og informationssikkerhed. Uden klarhed om organiseringen er der stor risiko for, at arbejdet falder mellem to stole, altså at der er uklarhed om, hvem der skal gøre hvad, og om, hvordan organisationen forholder sig til ansvar på området.

Vi anbefaler derfor, at der i en strategi for cyber- og informationssikkerhed bliver sat en klar retning fra topledelsen, som siger noget om, hvordan ansvarsfordelingen er på området.

Vi anerkender, at cyber- og informationssikkerhed er en kompleks størrelse. Derfor er det også væsentligt, at alle i organisationen ved, hvad der forventes af dem, for at sikkerheden kan opretholdes. Det er ikke kun i cybersikkerheds-afdelingen, at der er ansvar for, at organisationens aktiver holdes sikre. Det er derimod både topledelsen, ledelsen og medarbejdere på tværs af afdelinger, der skal sikre, at virksomheden eller myndigheden er tilstrækkelig sikker på området for cyber- og informationssikkerhed.

I en cyber- og informationssikkerhedsstrategi er det en god idé at komme ind på, hvordan arbejdet konkret organiseres, og hvem der har ansvar for hvad. Organiseringen af sikkerhedsarbejdet foreslår vi f.eks. kan tage udgangspunkt i de tre forsvarslinjer, som vi gennemgår i kapitel 5 om roller og ansvar. Dernæst kan en strategi for cyber- og informationssikkerhed sige noget om, hvilke beslutninger der er truffet i forhold til bestyrelsens, direktionens og den øvrige organisations ansvar på området for cyber- og informationssikkerhed.

Endelig kan det i en cyber- og informationssikkerhedsstrategi være relevant at beskrive, hvordan man strategisk vil sikre sig, at der er tilstrækkelige kompetencer til rådighed for at løse opgaverne på området. Her kan det både være relevant at overveje, hvordan man kan rekruttere og fastholde medarbejdere, der arbejder med cyber- og informationssikkerhed, og sikre, at denne viden er dokumenteret og fordelt på flere medarbejdere for at minimere sårbarhed, og ligeledes hvordan man kan opkvalificere medarbejdere, så alle har den nødvendige viden til at kunne udføre deres arbejde sikkert.

Roller og ansvar:
Cybersikkerhed som holdsport

Læs mere i kapitel 5

Fokus: Beslutningsrettigheder og -struktur samt samarbejde på tværs af organisationen indenfor informationssikkerhed.

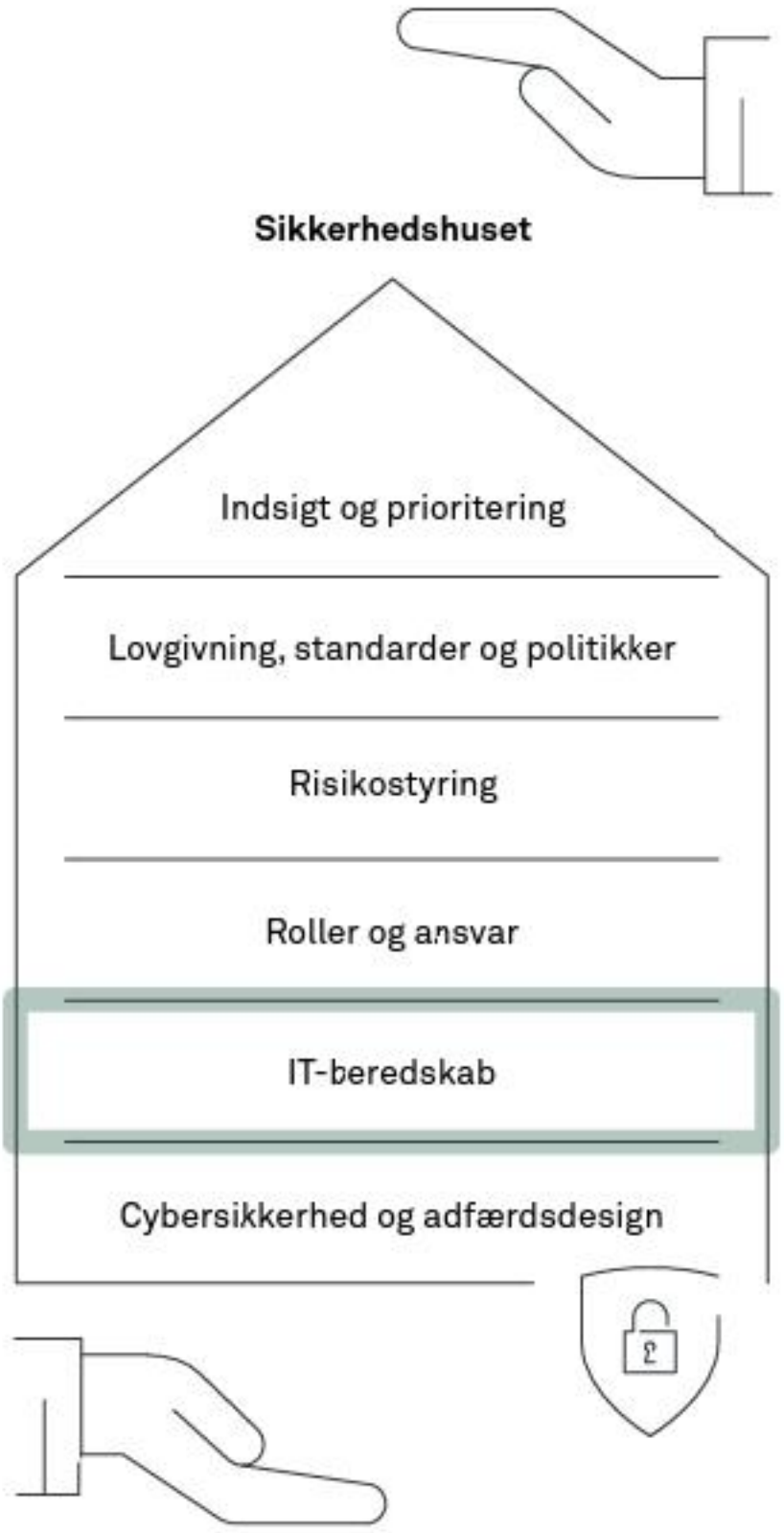
Vigtigste emner:

- Opbygning af klar governance (styringsmodel) for cyber- og informationssikkerheds-arbejdet på tværs af organi-sationen.
- Ledelse, der understøtter cybersikkerhedsarbejdet med ressourcer og kan formulere informations-sikkerhed i organisationens kontekst.
- Transparente og effektive processer på tværs af organi-sationen og eksterne parter.

Tjekliste

- Har organisationen en tydelig governance (styringsmodel) for cyber- og informations-sikkerhed?
- Hvordan sikrer organisationen at have de rette kompetencer blandt medarbejderne til at kunne løfte de prioriterede opgaver?

IT-beredskab og håndtering af krisesituationer: Vær klar, når stormen kommer



Det er væsentligt, at virksomheder og myndigheder har rammerne på plads til at kunne beskytte aktiver samt til at kunne opdage, håndtere og genoprette, når cyberangreb sker. Et effektivt beredskab bygger videre på et grundlæggende kendskab til de vigtigste forretningsprocesser (se mere i kapitel 2) samt en risikovurdering (se mere i kapitel 4). Herfra kan man gå videre med "plan-do-check-act"-metoden, hvor man løbende tester, evaluerer og forbedrer beredskabet, så organisationen er bedst muligt klædt på til at håndtere alvorlige hændelser. I denne bog har vi særligt fokus på forretningskontinuitet, som er

den del af beredskabet der skal sikre, at kerneprocesser i organisationen kan køre videre i en periode, også i tilfælde af manglende IT-understøttelse. Dette er en essentiel del af at sikre organisationens overlevelse.

IT-beredskab og håndtering af krisesituationer

Læs mere i kapitel 6

Fokus: At sikre opretholdelse af organisationens vigtigste forretningsprocesser i tilfælde af en IT-relateret hændelse.

Vigtigste emner:

- Forretningskontinuitet (business continuity) bygger på en solid forståelse for organisationens kerne-processer.
- Udarbejdelse af beredskabet kan følge plan-do-check-act-metoden for at sikre løbende evaluering og opdatering.

Tjekliste

- Ved organisationen, hvem der skal træde til i tilfælde af en krise, og hvad de har mandat til at gøre?
- Hvilke forretningsprocesser skal have fokus først i en krisesituation, og hvordan kan de opretholdes uden den normale IT-understøttelse?
- Har organisationen en tydelig kommunikationsplan, der kan følges i en krisesituation?

Cybersikkerhed og adfærdsdesign: Skab forandring med effekt

Uddannelse, awareness og adfærdsdesign er helt essentielle hjørnesten i at have et cybersikkerheds-setup, der virker – hvis medarbejderne ikke ved, hvad de skal gøre eller *ikke* bør gøre, så efterlader det organisationen i en potentielt meget sårbar situation. Med fokus på denne "etage" i Sikkerhedshuset skal man i strategien således afklare, hvor organisationen ønsker at sætte ind. Igen kommer dette meget an på modenhedsniveauet i organisationen samt den risikovurdering, som organisationen bygger på. I organisationer, der først nu starter deres egentlige arbejde med cybersikkerhed, kan det være et strategisk fokus at få indarbejdet sikkerhedsregler og informationer i for eksempel

onboarding-materiale for nye medarbejdere og medarbejderhåndbog. I mere modne organisationer kan kræfterne fokuseres på andre og måske mere avancerede ændringer.

En cybersikkerhedsstrategi bør fastlægge, hvordan kommunikation, uddannelse, træning og/eller adfærdsdesign prioriteres i organisationen. Er der særlige emner, som bør være i fokus i strategiperioden, skal dette beskrives.

Generelt findes der meget god og grundig litteratur om, hvordan træning, uddannelse og awareness-kampagner kan udføres og tilrettelægges. Vi finder dog ofte, at arbejdet med *adfærdsdesign* og cybersikkerhed er et overset emne, og derfor er det netop det, vi dykker ned i i bogens sidste kapitel.

Cybersikkerhed og adfærdsdesign

Læs mere i kapitel 7

Fokus: At løfte medarbejdernes generelle sikkerhedsniveau i organisationen.

Vigtigste emner:

- At gøre den menneskelige "firewall" (medarbejdere og ledelse!) i stand til at modstå de fleste almindelige angreb samt spotte sårbarheder og forsøg på angreb.
- Medarbejderne skal kende truslerne – og deres ansvar i den forbindelse.
- At arbejde aktivt med motivation, friktion og "trigger" (situation) for, at sikre bedst mulige odds for at sikkerhedstiltag rent faktisk bliver til adfærdsændringer i medarbejdernes dagligdag.

Tjekliste

- Har organisationen blik for, at undervisning eller kommunikationskampagner ofte ikke i sig selv er nok for at sikre reel adfærdsændring?
- Hvordan kan nye sikkerhedsforanstaltninger bedst muligt introduceres – også gerne på en sjov måde?

Cybersikkerhed og målepunkter

Når organisationen har valgt de områder, som skal være i fokus i kommende strategiperiode, anbefaler vi altid at udarbejde målepunkter. Det vil sige en metode, hvormed man kan kommunikere, hvad målet for det udvalgte fokuspunkt er, samt hvornår "godt er godt nok". Et strategisk fokusområde kan f.eks. være en styrket beredskabsplan, og målet kan så være, at den skal være afprøvet og evalueret minimum to gange indenfor kommende strategiperiode. Her er det tydeligt for alle, at test af beredskabsplan er en prioritet, og at det er let for de udførende medarbejdere at vide, hvornår de er "i mål".

> *"Det er godt at have mål at arbejde op imod. Men det, der er vigtigt at forstå, er også, at målene kan flytte sig. Din skydeskive ændrer sig, fordi hackerne også hele tiden udvikler sig. Det er vigtigt at forstå det samlede billede og konteksten i forhold til den konkrete forretningssammenhæng og risiko, og at kunne kommunikere den udvikling, der har været. Og så skal man være bevidst om, at man får det, man måler på, så man skal være grundig med de mål, man vælger".*
> – Kirsten Hede, projektdirektør i Bestyrelsesforeningens Center for Cyberkompetencer

At udarbejde konkrete og brugbare målepunkter er en svær øvelse, og der kan være sandhed i talemåden, at "man får det, man måler". Det vil sige, at man skal være meget opmærksom på, at det, man sætter et målepunkt for, er det, som løber med alt fokus. Det er på sin vis formålet med et målepunkt, netop at det er det område, som fremhæves og skal prioriteres foran alt andet. Men som med så meget andet i cybersikkerhedsverdenen kan det, man ønsker at måle, ændre sig hurtigt, og det vil det også gøre i den fastsatte strategiperiode. Man bør derfor ikke være bange for løbende at evaluere og eventuelt opdatere de målepunkter, der fastsættes. Selvom den efterhånden har et par år på bagen, er der god hjælp og input at hente i Digitaliseringsstyrelsens "Vejledning i evaluering og opfølgning" (2016).

Hvad betyder alt dette for dig, som læser denne bog?

Som nævnt i dette kapitel er det topledelsen/bestyrelsen, der i sidste ende skal godkende den prioritering af cybersikkerhed, der vil være at finde i strategien. Det er også dem, der løbende træffer beslutninger og eventuelle ændringer på baggrund af rapportering af fremdriften i de fastsatte målepunkter. Hvis man *ikke* er i en topledelse eller bestyrelse, kan det strategiske arbejde med cybersikkerhed måske hurtigt blive en fjern eller abstrakt øvelse. Vi ved dog af erfaring, at en lang række medarbejdere er involveret i at udarbejde de analyser, der ligger til grund for det strategiske arbejde, og løbende arbejder med at indhente og behandle det data, der skal til, for at ledelsen eller bestyrelsen kan følge fremdriften (eller mangel på samme!) i de udvalgte målepunkter. Og her kan du derfor bringe dig selv i spil som medarbejder. Vi ved også, at nogle oplever at have en ledelse, som måske ikke er helt bevidst om deres ansvar indenfor cybersikkerhed, eller hvor det opleves, at ledelsen ikke sætter tilstrækkeligt med tid og ressourcer af til emnet. Derfor har vi, i samarbejde med Bestyrelsesforeningen, samlet "5 gode råd til at understøtte bestyrelsens arbejde".

Bestyrelsesforeningen giver her deres 5 gode råd til, hvordan man som medarbejder kan være med til at understøtte det vigtige strategiske arbejde, der skal udføres.

5 gode råd til at understøtte bestyrelsens arbejde

1. Topledelsen har ansvar for cybersikkerhed i organisationen, og du skal som medarbejder understøtte dette arbejde med letforståelig information, der sætter ledelsen i stand til at træffe fornuftige beslutninger. Hvis ledelsen ikke er lydhør, bør du løbende forsøge at gøre dem deres ansvar bevidst og dokumentere dette – også når der ikke er truffet beslutning.
2. Brug eventuelt scenarier, når der skal træffes beslutninger – så det er hurtigt for bestyrelsen at forstå konsekvens af både beslutning, og hvad der sker, hvis der IKKE træffes beslutning.
3. Det kan være nyttigt at gøre brug af benchmarks (sammenligninger) for den industri eller sektor, jeres organisation opererer i, det vil sige, hvordan placerer organisationen sig i forhold til konkurrenterne. Det taler direkte ind i organisationens konkurrenceevne og dermed det sprog, bestyrelsen er vant til at tale.
4. Vær ærlig i kommunikationen til topledelse og bestyrelse. Nogle steder ses en tendens til, at man ønsker at vise lidt mere fremdrift, end der måske har været. Der kan desværre opstå det fænomen, at et strategisk fokusområde, som ikke skrider fremad som ønsket, bliver fremstillet mere "grønt" i projektplanen, end det egentlig er. En bestyrelse skal dog altid have mulighed for at træffe beslutninger på oplyst grundlag, og her er ærlighed vejen frem.
5. Pas på med "information overload", og hold input til strategi og den efterfølgende rapportering så simpel som mulig. Få bestyrelsens evaluering af den præsenterede information, og vær ikke bange for at prøve forskellige formater af.

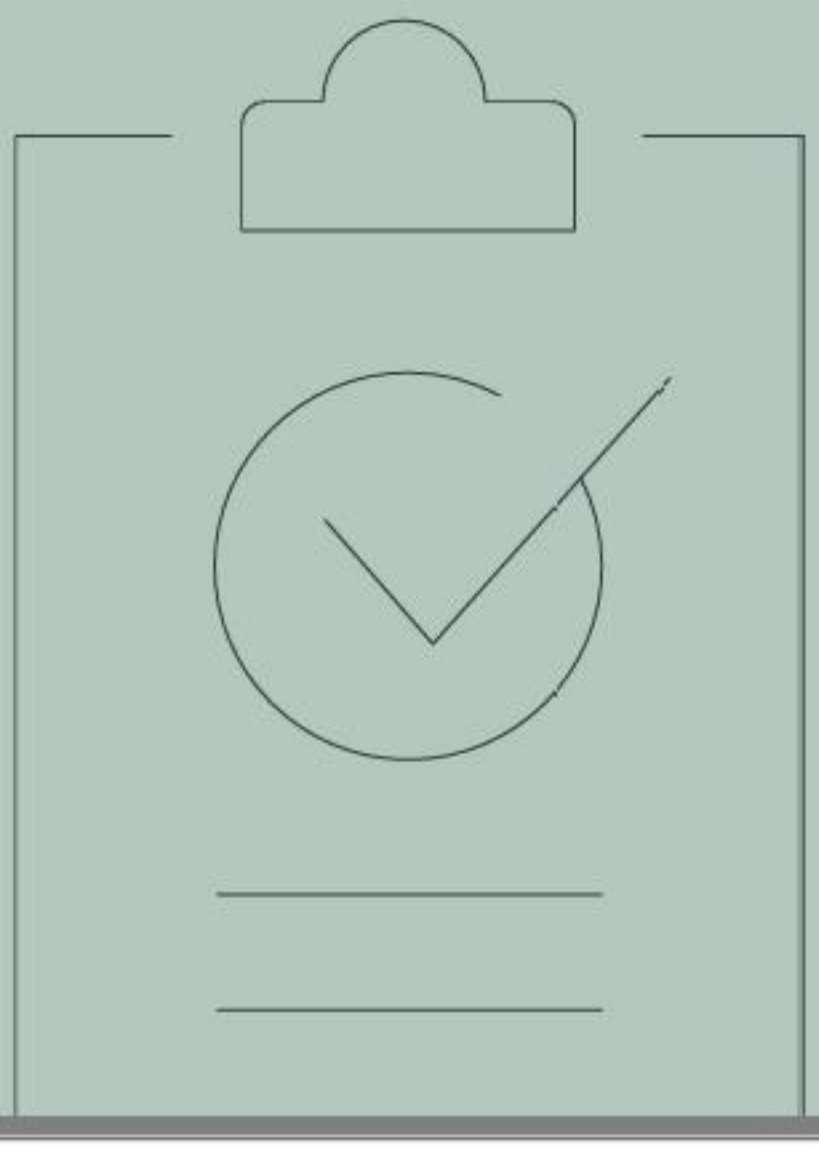
En kort opsummering:

Sikkerhedshuset – Beskyt din organisation fra kælder til kvist

- En organisations cyber- og informationsstrategi skal være i tråd med organisationens risikotolerance og samtidig understøtte forretningens overordnede strategi og digitaliseringsstrategi. Cyber- og informationssikkerhed kan – og bør – ikke stå alene.

- Vores model for cyber- og informationssikkerhedsstrategi, Sikkerhedshuset, opsummerer de seks emner, som en strategi bør indeholde – og som organisationer bør arbejde med. Prioriteringen og vægtningerne af emnerne afhænger af organisationens modenhed.

- Hvert kapitel i denne bog udfolder i yderligere detaljer hver af de seks emner i Sikkerhedshuset.



Case:

Et byggefirma uden cybersikkerhedsstrategi

På dejlige Als ligger byggefirmaet "Als Byg og Renovering", som siden 1893 har hjulpet øens beboere med mindre byggeprojekter og renoveringer. Firmaet har længe været kendt for sine engagerede medarbejdere, som sætter en ære i godt byggeri. Firmaet er fulgt med tiden og har specialiseret sig i klimasikring af alle slags bygninger. Med tiden er efterspørgslen efter deres tjenester vokset, og de har udvidet deres aktiviteter til andre dele af landet. I takt med at firmaet voksede, begyndte de at implementere forskellige IT-systemer for at håndtere deres stigende kundebase og projekter. De anvender derfor nu et projektstyringsværktøj til at organisere deres opgaver, et regnskabssystem til at håndtere økonomiske transaktioner og en kommunikationsplatform til at koordinere med deres team og kunder. Als Byg og Renovering har nu, grundet deres størrelse og voksende kompleksitet, også fået en bestyrelse, der er med til at sikre, at virksomheden opererer på ansvarlig og effektiv vis, samt at den overholder lovgivning og regler.

Als Byg og Renovering har i fem år haft en dygtig IT-chef, som løbende har videreuddannet sig indenfor cybersikkerhed. IT-chefen havde længe været bekymret for virksomhedens manglende fokus på cybersikkerhed og havde derfor stort fokus på de potentielle risici og konsekvenser af et cyberangreb samt et brændende ønske om at implementere bedre sikkerhedsforanstaltninger for at beskytte virksomheden. For at få bestyrelsen i tale har IT-chefen udarbejdet en omfattende plan, der indeholder opdatering af systemer, medarbejderuddannelse og implementering af state-of-the-art sikkerhedsforanstaltninger.

Da hun præsenterede sin plan for bestyrelsen, mødte hun imidlertid stor modstand. Bestyrelsen mente, at omkostningerne ved at implementere sådanne sikkerhedsforanstaltninger var for høje, og de frygtede, at det ville påvirke virksomhedens økonomiske resultater negativt. De var ikke overbeviste om, at cybertrusler var en trussel mod netop deres virksomhed, og de ønskede at fokusere på andre områder, som de forventede ville give hurtigere afkast. IT-chefen forsøgte desperat at overbevise bestyrelsen om vigtigheden af cybersikkerhed, men måtte gå fra præsentationen uden yderligere ressourcer til at arbejde med cyber- og informationssikkerhed.

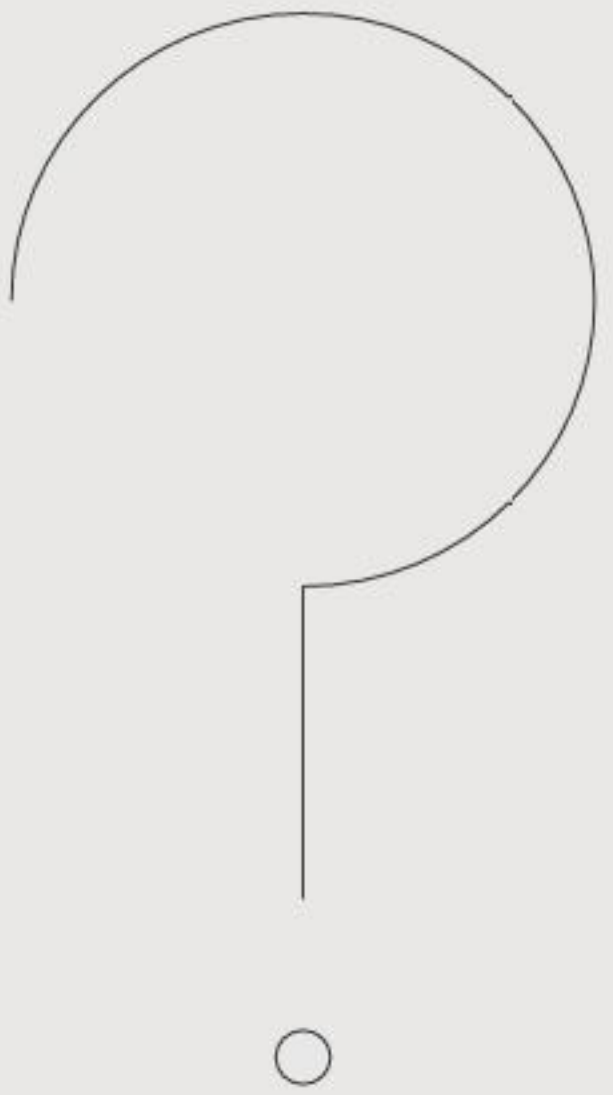
Arbejdsspørgsmål

- Hvilken tilgang havde IT-chefen til at få overbevist bestyrelsen om vigtigheden af cybersikkerhed, og hvordan kunne hun have håndteret situationen anderledes?

- Hvordan har IT-chefen integreret cybersikkerhed i virksomhedens overordnede strategi og forretningsmål?

- Hvilken kommunikationsfremgang havde IT-chefen valgt i sin præsentation, og hvad kunne hun med fordel have gjort anderledes?

- Hvad er konsekvenserne af bestyrelsens beslutning om ikke at prioritere cybersikkerhed, og hvordan kan virksomheden potentielt blive påvirket af dette valg på langt sigt?



Litteraturliste

Digitaliseringsstyrelsen (2016, juni). Vejledning i evaluering og opfølgning 2016.

Finansministeriet (2018). National strategi for cyber- og informationssikkerhed.

Finansministeriet (2021, december). National Strategi for cyber- og informationssikkerhed 2022-2024.

Hepfer, M., & Powell, T. C. (2020). Make cybersecurity a strategic asset. *MIT Sloan Management Review, 62*(1), 40-45.

Huang, K., Wang, X., Wei, W., & Madnick, S. (2023). The devastating business impacts of a cyber breach. *Harvard Business Review.*

International Organization for Standardization (2022). Information Security, cyber security and privacy protection-Information security management systems-Requirements. Reference number ISO/IEC 27001:2022(E).

Lafley, A. G., & Martin, R. (2013). Playing to win: How strategy really works. Harvard Business Press.

Lee, G. (2024, 15. Marts). Cybersecurity Compliance: A definitive Guide. Security Daily Review. Lokaliseret på: www. https://dailysecurityreview.com/blog/a-definitive-guide-to-cybersecurity-compliance/

Lohrke, F. T., & Frownfelter-Lohrke, C. (2023). Cybersecurity research from a management perspective: A systematic literature review and future research agenda. *Journal of General Management.*

National Institute of Standards and Technology (2023). The NIST Cybersecurity Framework (CSF) 2.0. U.S. Department of commerce.

Ozkaya, E. (2022). *Cybersecurity Leadership Demystified: A comprehensive guide to becoming a world-class modern cybersecurity leader and global CISO.* Packt Publishing Ltd.

Porter, M. E. (2008). The five competitive forces that shape strategy. *Harvard business review, 86*(1), 78.

Wikipedia (u.å.) Strategi. Lokaliseret på: https://da.wikipedia.org/wiki/Strategi

Kapitel 2

Kapitel 2

Indsigt og prioritering: Cyber- og informationssikkerheden skal gå i takt med den digitale udvikling

Det er simpelthen license to operate i alle virksomheder i dag at indtænke cybersikkerhed og arbejde struktureret med emnet. I et strategisk perspektiv tænker så godt som alle organisationer og virksomheder digitalisering i større eller mindre grad, og her gør man klogt i at tænke cybersikkerhed samtidig."

Kirsten Hede, projektdirektør for Bestyrelsesforeningens Center for Cyberkompetencer

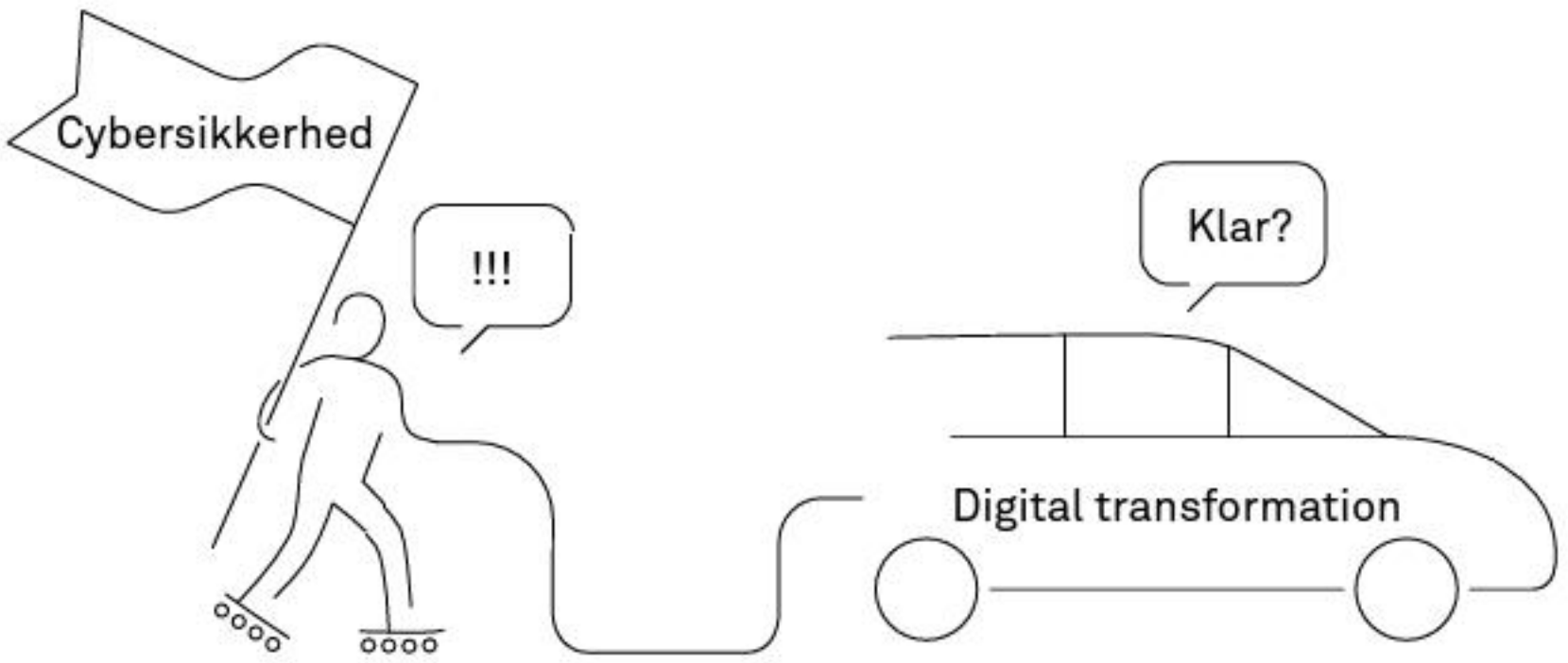
Man skal kende sin organisation, før man kan beskytte den

Udviklingen for både virksomheder og myndigheder går hurtigt. Det er nødvendigt kontinuerligt at have en fleksibel og veldrevet organisation, der kan tilpasse sig efterspørgsel på nye produkter eller services, andre og grønnere måder at producere på eller ny lovgivning at leve op til. Svaret på behovet for den hastige omstilling er ofte en investering i ny teknologi, der gør vores arbejdsprocesser endnu mere digitale (Saeed et al., 2023). Med det følger dog også en dyb afhængighed af den digitale understøttelse af kerneforretningen eller kerneopgaverne i virksomheder og myndigheder (Huang et al., 2023; Finansministeriet, 2021). At få forståelse for forbindelsen mellem vores måde at udføre opgaver på og den digitale afhængighed er en af de allervigtigste pointer i arbejdet med cyber- og informationssikkerhed. Det kræver nemlig en indgående forståelse for, hvordan vi løser vores opgaver i virksomheder eller myndigheder, når vi skal beskytte dem. Denne pointe understøttes også af bl.a. Digitaliseringsstyrelsen: "Overblik og kendskab til processerne er en forudsætning for at vurdere konsekvenserne for organisationen ved potentielle sikkerhedshændelser" (2020).

Hvis ikke vi kobler forståelsen for den digitale understøttelse af vores organisations mulighed for at nå sine mål med indsatsen på cyber- og informationssikkerhedsområder, er der en stor risiko for, at vi rammer skævt, når vi prioriterer vores indsatser på sikkerhedsområdet (Dansk Standard, 2023). Vi bliver blinde for, hvad der egentlig er vigtigt, og vi risikerer, at sikkerhedsindsatsen bliver forkert, for dyr, for bøvlet eller står i vejen for udviklingen af vores

organisation. En rapport fra 2021 peger da også netop på, at ledere anskuer cybersikkerhed som svært og ressourcekrævende (Kulyk et al.).

For at komme det til livs er det nødvendigt, at den digitale forretningsudvikling og cyber- og informationssikkerhedsindsatsen bliver to sider af samme sag. I dette kapitel ser vi nærmere på "taget" i Sikkerhedshuset. Det handler nemlig om, at cyber- og informationssikkerhedsindsatsen skal gå i takt med den digitale udvikling af organisationen. Vi skulle gerne afhjælpe, at vi som sikkerhedsmedarbejdere føler os som den stakkels kvinde på rulleskøjterne på karikaturtegningen herunder. Hun, og altså cybersikkerhedsindsatsen, er her løst tilkoblet den digitale udvikling af organisationen og ender med at være meget lidt værdiskabende – måske endda bare bøvlet at have med på slæb. I stedet for vil vi som cybersikkerhedsmedarbejdere meget hellere have en plads på forsædet. Her kan vi hjælpe chaufføren på førerstedet, som altså billedligt talt sætter retningen for forretningsudviklingen og digitaliseringsindsatsen, med at navigere sikkert gennem de udfordringer, vi måtte møde på vores vej.



Figur 2.1. Cybersikkerhed skal være en støtte for forretningen – og ikke slæbes bagefter.

I dette kapitel vil vi sikre en forståelse for, at en effektiv indsats på cyber- og informationssikkerhedsområdet kræver en dyb indsigt i sin organisation, hvilke mål den har, dens risikoprofil, og hvilke områder af organisationen der er særligt vigtige, for at organisationen kan nå sine mål. Derfor vil de metoder og

værktøjer, der bliver præsenteret i dette kapitel, ikke kun dreje sig om sikkerhed. De skulle gerne hjælpe til at få en klarere fornemmelse for, hvad der er særligt vigtigt i organisationen – også når vi taler om digitale transformationer. De værktøjer, vi præsenterer, lægger sig derfor op ad bedste praksis for arbejdet med digitale transformationer, da det netop er her, at cyber- og informationssikkerhedsindsatsen bør tage sit udspring (Saeed et al., 2023). Vi kommer desuden til at kradse lidt i overfladen på værktøjer til organisationsanalyse, proceskortlægning og IT-arkitekturarbejde. At blive superdygtig til de discipliner kræver mange års uddannelse og erfaring. Vi vil med dette kapitel fremhæve, at tankerne bag de ekspertiseområder er vigtige forudsætninger for et effektivt arbejde med cyber- og informationssikkerhed. Derfor er det ofte også nødvendigt at involvere flere faggrupper med forskellige perspektiver på vores virksomhed eller myndighed, når vi arbejder med sikkerhed.

Kapitlet hænger tæt sammen med kapitel 4 om risikostyring og kapitel 6 om forberedelse og håndtering af en krisesituation, som også skal kaldes for beredskabsstyring. Både risikostyring og beredskabsstyring er først virkelig værdifulde, hvis vi til fulde kender den organisation, vi gerne vil beskytte. Altså skal vi som sikkerhedsmedarbejdere om på forsædet.

Forudsætningerne for det effektive cyber- og informationssikkerhedsarbejde

Som afsæt for både det strategiske, taktiske og operationelle arbejde med cyber- og informationssikkerhed er det relevant at afgrænse indsatsen på cyber- og informationssikkerhedsområdet (Ozkaya, 2022). I tråd med ISO 27001 anbefaler vi, at konteksten for sikkerhedsarbejdet gøres klart. At vi bliver skarpe på konteksten for sikkerhedsarbejdet, kan man også kalde en omverdensanalyse. I etableringen af konteksten skal vi have styr på de grundlæggende knæbøjninger. Vi skal have styr på scope (omfang), afgrænsning, risikotærskelværdi, metode og organisering. Vi oplever, at nogle organisationer kan blive utålmodige over at skulle nå til enighed om netop disse punkter, da de ønsker at komme i gang med "det egentlige arbejde" på sikkerhedsområdet. Vi har dog erfaret gang på gang, at det betaler sig at være *helt* enige om (læs: få det skrevet ned og godkendt af ledelsen!), hvilken kontekst der arbejdes ud fra.

Vi anbefaler, at følgende fem områder for cybersikkerhedsarbejdet afdækkes og beskrives for at sikre, at cyber- og informationssikkerhedsarbejdet udføres, så det stemmer overens med den øvrige strategiske og digitale indsats i organisationen. De fem områder er:

1. **Den overordnede strategiske retning**
   Forstå virksomhedens eller myndighedens overordnede strategiske retning og mål.

2. **Risikoappetit**
   Dernæst skal vi have afstemt, hvilken risikoappetit vi som virksomhed eller myndighed har. Her skal vi etablere en fælles forståelse for de risici og konsekvenser som organisationen ikke kan leve med.

3. **Kerneprocesser, der støtter målopnåelsen**
   Når det er på plads, er det væsentligt at gøre sig klart, *hvordan* virksomheden eller myndigheden når sine mål. Det kan man gøre ved at identificere de forretningsområder eller processer, der er særligt vigtige for opnåelsen af målene. Det kaldes ofte for kerneprocesser eller kerneopgaver.

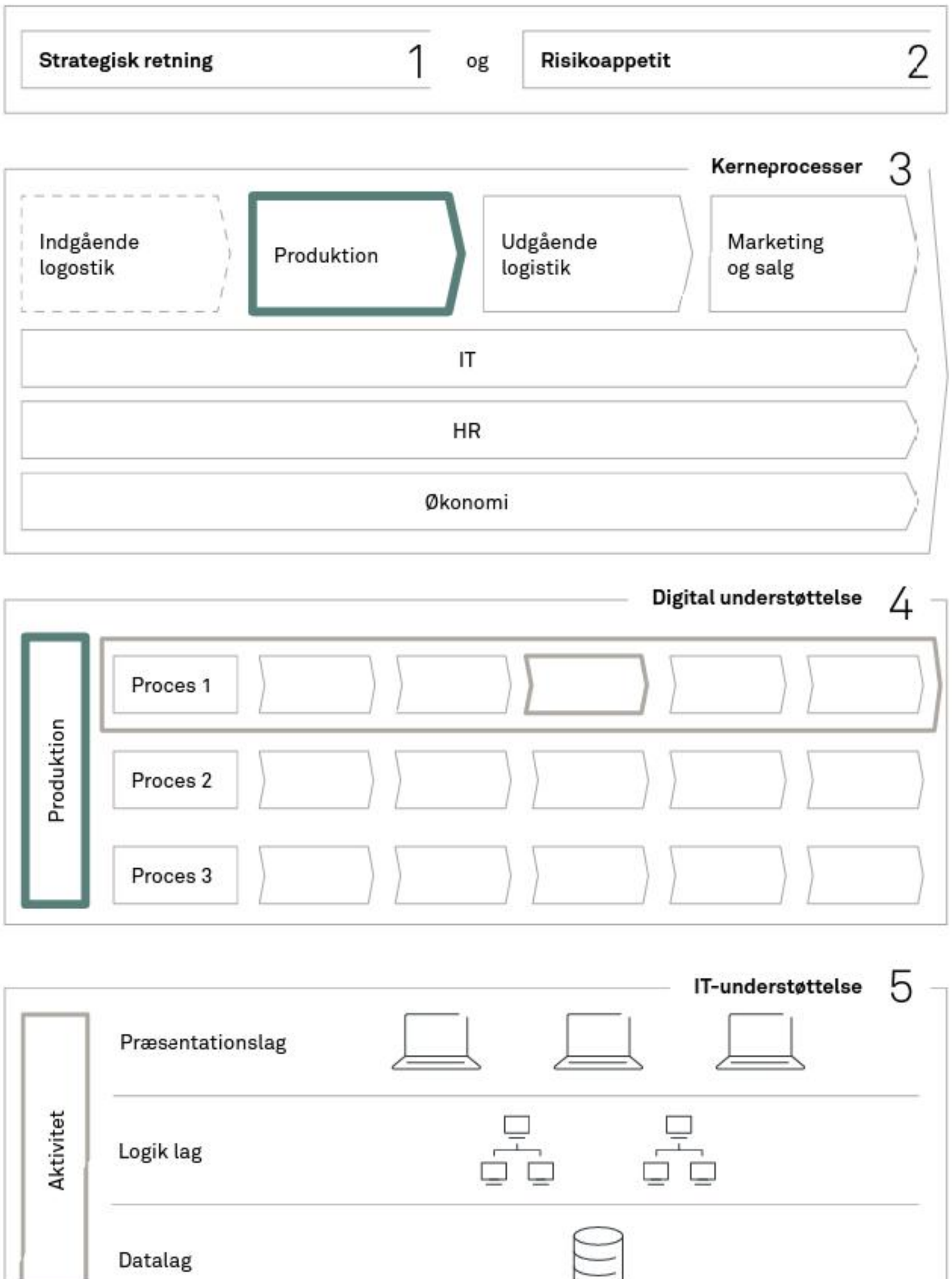
4. **Den digitale understøttelse**
   Når vi har gjort os klart, hvordan virksomheden eller myndigheden når sine mål, så er det vigtigt, at vi får klarhed over den digitale understøttelse af forretningsprocesserne. Dette munder ud i en procesdokumentation.

5. **IT-understøttelse**
   Endelig skal IT-understøttelsen dokumenteres, så det er tydeligt, hvilke systemer, data og infrastrukturkomponenter der støtter opgaveløsningen i forretningsprocesserne. Her er det også vigtigt at se på afhængigheder til øvrige dele af organisationen. Dette munder ud i overblik over IT-arkitekturen.

De fem områder skal afklares, så ledelsen og de relevante medarbejdere har en ensartet forståelse for udgangspunktet for sikkerhedsarbejdet. Ved at have

styr på de fem områder kan arbejdet med cyber- og informationssikkerhed blive koblet tæt på den forretningsmæssige og digitale udvikling af organisationen.

Nedenstående figur visualiserer de fem områder.



Figur 2.2. De fem områder, der skal klarlægges for at kunne sikre et passende niveau af cybersikkerhed: strategisk retning, risikoappetit, kerneprocesser, digital understøttelse og IT-understøttelse.

Grundlæggende handler det om at skabe en forståelse for organisationen som helhed og de forretningsprocesser, der er i organisationen. Det kan kræve mange års erfaring at arbejde med proceskortlægning og dokumentation. Vi vil i denne bog ikke dykke dybt ned i, hvordan man gør det, men blot fremhæve, at det er en vigtig og forudsætningsskabende disciplin for en omkostningseffektiv og fokuseret indsats på cyber- og informationssikkerhedsområdet.

I det følgende ser vi lidt nærmere på, hvordan man konkret kan arbejde med de fem områder. Husk, at det kan være en fordel at trække på erfaringer fra proceskyndige kompetencer, særligt hvis det er store organisationer eller komplekse arbejdsgange, der er i fokus.

Forstå organisationens overordnede strategiske retning og mål

Langt de fleste virksomheder og myndigheder er tydelige omkring, hvor de gerne vil hen strategisk. Der kan være en række forhold i omverdenen, der gør, at organisationer er nødt til at forandre sig, til at ændre måden, man arbejder på, eller ændre kvaliteten af de produkter eller services, man tilbyder. Retningen og den strategiske prioritering vil man kunne finde i overordnede strategier. Det er vigtigt at sætte sig ind i den overordnede strategi og danne sig et realistisk billede af, hvor langt organisationen er i dette arbejde (Ozkaya, 2022). For at komme det nærmere bør vi dobbeltklikke på spørgsmål som:

- Hvad består organisationen af?
- Hvad er organisationen sat i verden for?
- Hvad er organisationens forretningsmæssige mål og prioriteringer?

Disse spørgsmål vil ofte være besvaret, hvis organisationen har en vis modenhed i forhold til sikkerhedsarbejdet generelt og f.eks. har gennemført en strategiproces på cyber- og informationssikkerhedsområdet tidligere. Der kan også være god hjælp at hente i besvarelsen af disse spørgsmål i virksomhedens eller myndighedens informationssikkerhedspolitik, overordnede strategi eller ISMS'et (se mere om ISMS i kapitel 3: Lovgivning, standarder og politikker). Hvis der er tale om en offentlig myndighed, kan man ofte få hjælp i mål- og resultatplanen.

Afdæk organisationens risikoappetit

En vigtig forudsætning for at kunne arbejde effektivt med cyber- og informationssikkerhed er, at vi forstår, hvornår skidt er skidt – det vil sige, hvor meget der skal til, for at organisationen synes, at den bør reagere for at undgå at komme i en sådan situation. En måde at arbejde med det på er at blive skarp på

Risikoappetit, -tolerance eller -tærskel?

Risikoappetit, risikotærskel og risikotolerance er begreber, der ofte bruges indenfor risikostyring. Selvom de kan lyde ens, er der få nuancemæssige forskelle mellem begreberne.

Risikoappetit: Risikoappetit refererer til det niveau af risiko, en organisation er villig til at acceptere for at opnå sine mål (Carmichael, 2022). Appetit er ofte defineret i strategiske termer og bruges som en vejledning til beslutningstagning. For eksempel kan en virksomhed med høj risikoappetit være villig til at investere i højrisikoprojekter for at opnå høje afkast. Bestyrelsesforeningen anbefaler, at bestyrelsen mindst en gang om året fastsætter virksomhedens risikoappetit på cyberområdet (Bestyrelsesforeningens Center for Cyberkompetencer, 2019).

Risikotolerance: Risikotolerance er den specifikke mængde risiko, en organisation er villig til at acceptere. Det er mere præcist og kan variere indenfor forskellige områder af organisationens aktiviteter. For eksempel kan en virksomhed have høj risikotolerance i relation til investeringer i teknologi, men lav risikotolerance i relation til juridiske risici.

Risikotærskel: Risikotærskel angiver det punkt, hvor risiko bliver uacceptabel. Det er en grænse, som organisationen fastsætter, hvor risikoniveauet ikke bør overskrides. Dette er ofte forbundet med specifikke risikoscenarier eller -indikatorer. Hvis risikoen overstiger denne tærskel, skal der træffes beslutninger og igangsættes handlinger for at reducere risikoen til et mere acceptabelt niveau.

Disse koncepter spiller en vigtig rolle i risikostyring, da de hjælper med at definere, hvordan en organisation balancerer muligheder og potentielle ulemper i dens beslutninger og aktiviteter.

I det følgende har vi valgt at bruge ordet risikoappetit, da det er vores erfaring, at det er det, de fleste organisationer bruger.

organisationens risikoappetit. Man kan også støde på termerne risikotærskel eller risikotolerance. Der er nuanceforskelle mellem de forskellige begreber, men grundlæggende siger de noget om, hvor stor en risiko vi som organisation kan leve med at tage på os.

Risikoappetitten er et brugbart redskab til at koble virksomhedens eller myndighedens daglige drift til en strategisk afklaring af, hvad man som organisation har brug for for at kunne udføre sine opgaver. Risikoappetit bør fastsættes ud fra virksomhedens eller myndighedens overordnede målsætninger, risikobillede og investeringsvillighed.

Arbejdet med risikoappetit går ud på at få ledelsens input (og hånd på kogepladen) i forhold til at beslutte, hvornår noget er så stor en risiko, at det er noget, man skal reagere på. Det er en vigtig pointe her at have denne drøftelse, inden man går i gang med at snakke om f.eks. forretningsprocesser osv., fordi ledere for forskellige områder kan have tendens til at synes, at netop deres fagområde er det vigtigste overhovedet, og at ingen risici overhovedet kan tolereres. Ved at snakke risikoappetit er fokusområdet et lidt andet, end hvad ledere på tværs af forretningen hver især har ansvar for.

En vigtig pointe er også, at cyberrisici er ikke de eneste risici, der kan udfordre virksomheden eller myndighedens evne til at nå sine forretningsmæssige mål. F.eks. så vi under COVID-19-pandemien, at mange virksomheder og myndigheder måtte ændre den måde, de opererede på, fordi pandemien medførte en række forandrede måder at drive virksomhed og myndighed på, hvor hjemmearbejde, mangel på råvarer og generel usikkerhed blev dagligdag. Derfor er et godt råd, at arbejdet med risici på cyber- og informationssikkerhedsområdet tænkes ind i et bredere risikostyrings-setup for hele virksomheden eller myndigheden. Det hele handler nemlig om at risikostyre, så organisationen kan nå sine mål.

Det er vores anbefaling, at arbejdet med risikoappetit holdes så konkret som muligt, da det hurtigt kan blive meget abstrakt. Risikoappetitten kan udtrykkes kvalitativt eller kvantitativt. Vi anbefaler, at man går kvantitativt til værks, da det kan give en præcis og målbar grænse for, hvad der er en accepteret risiko i organisationen.

Rent praktisk vil en drøftelse af risikoappetit oftest foregå workshopbaseret, hvorefter beslutninger dokumenteres og sendes til godkendelse i ledelsesgruppen. I disse workshops (det kræver ofte mere end bare en enkelt workshop!) drøftes, hvilke risici en organisation kan acceptere, og hvilke der omvendt skal handles på, således at de forhindres så vidt muligt.

For eksempel vil det for de fleste virksomheder være uacceptabelt med situationer, der kan ende med at koste menneskeliv. Dermed er det de systemer eller processer, der har direkte indflydelse på menneskeliv, der har førsteprioritet. I et hospital vil man f.eks. i en krisesituation drosle ned på f.eks. knæoperationer og fokusere på livsvigtige operationer, der så understøttes af nødgeneratorer eller andet. I en virksomhed, der ikke har liv og død så tæt på som et hospital, er det andre risici, man må drøfte. Hvis virksomheden f.eks. fremstiller plastikemballage til fødevarebranchen, kan det måske godt accepteres, at fakturering ikke sendes ud helt til tiden, hvis det system skulle gå ned. Til gengæld er det uacceptabelt at være mere end f.eks. to dage bagud med produktionen af emballage, da den så ikke kan sendes rettidigt til kunder (f.eks. slagterier), som så ikke kan indpakke deres fødevarer i henhold til lovgivningen. Således er risikoappetitten på fakturerings/betalingssystemer eller internt generelt større end for selve produktionen.

Konkret kan man, når man gennemfører sine risikoappetitworkshops, arbejde med ledelsens risikoappetit ved at tage udgangspunkt i en oversigt over potentielle konsekvenstyper og tale dem igennem med ledelsen for at finde ud af, hvad ledelsesrisikoappetit eller -risikotærskelværdi er. Nedenstående eksempel på en oversigt er udviklet i samarbejde med Digitaliseringsstyrelsen og kan bruges som udgangspunkt for sådanne drøftelser.

Konsekvens-type	Politisk/ strategisk	Økonomisk	Administrativ/ processmæssig	Omdømme
	Medfører ind-skrænkninger i evnen til at handle i en periode	Medfører mer-omkostninger eller tab	Medfører administrative belastninger	Påvirker omdømme i uønsket retning
4. Graverende/ ødelæggende (uaccepta-belt)	Ministeren må gå af. Bliver ude af stand til at gennemføre vigtige aktiviteter, som er planlagt i en periode fremover	Væsentlige økonomiske tab. Bliver sat under administration	Administrative ressourcer må udvides urealistisk	Væsentlig skade på omdømme. Ministeren må gå af
3. Meget alvorlig (kritisk)	Medfører revurdering af vigtige aktiviteter på kort sigt	Store økono-miske tab med risiko for at blive sat under administration	Der må trækkes væsentligt på eksisterende og nye administrative ressourcer	Offentligheden fatter generel negativ interesse mod organisationen
2. Mindre alvorlig	Planlagte aktiviteter kan gennemføres med mindre justeringer	Meromkostnin-ger og tab i begrænset niveau, som kan kræve mindre budget-ændringer	Håndteres inden for rimeligt ekstra administrativt ressourcetræk	Forbigående opmærksom-hed fra enkelte grupper
1. Ubetydelig (uvæsentligt)	Ingen særlig påvirkning	Ingen særlig påvirkning	Håndteres uden særligt ressourcetræk i de administra-tive funktioner	Ingen særlig påvirkning

Figur 2.3. Eksempel på konsekvensbillede.

Forhold til interessenter	Menneskelige	Privacy	Brud på lovgivningen	Ledelsens risikoappetit (årligt)
Påvirker forholdet til interessenter	Medfører konsekvenser for det enkelte individ	Medfører brud på privacy	Medfører brud på lovgivning, f.eks. forvaltningslov eller straffelov	
Væsentligt nedbrud i det generelle samarbejde med interessenter	Menneskeliv sat på spil	Den enkelte udsættes for uacceptable krænkelser af privatlivet. Der træffes bebyrdende afgørelser mod den enkelte på et forkert grundlag. Store mængder følsomme data videregives uretmæssigt	Kritisk lovgivning, f.eks. straffeloven brydes. Ministeren må gå af	0 hændelser
Generelt forringet samarbejde med interessenter	Alvorlig personskade	Den enkelte fratages råderetten over egne data. Enkelte følsomme data videregives uretmæssigt	Lovbrud, der er kritiske og kan stille ministeriet i miskredit	Maks. 1 hændelse
Forringet samarbejde med interessenter i enkelte sager	Den enkelte udsættes for gener, men ikke noget alvorligt	Der er formelle mangler i de oplysninger, der gives den enkelte, men ikke i gravende grad. Ikke-følsomme data videregives uretmæssigt	Manglende overholdelse af administrative procedurer og regler, som ikke er af kritisk karakter	< 10 hændelser
Ingen særlig påvirkning	Ingen særlig påvirkning	Ingen særlig påvirkning	Ingen særlig påvirkning	< 20 hændelser

Man kan også i dialogen med ledelsen hjælpe dem med at overveje følgende spørgsmål:

1. Er der områder, hvor vi ønsker at acceptere en højere risiko, eller områder, hvor vi slet ikke kan acceptere risici?
2. Har vi historisk set haft et passende niveau for risikotærskelværdi, eller skal vi være løsere eller mere restriktive?

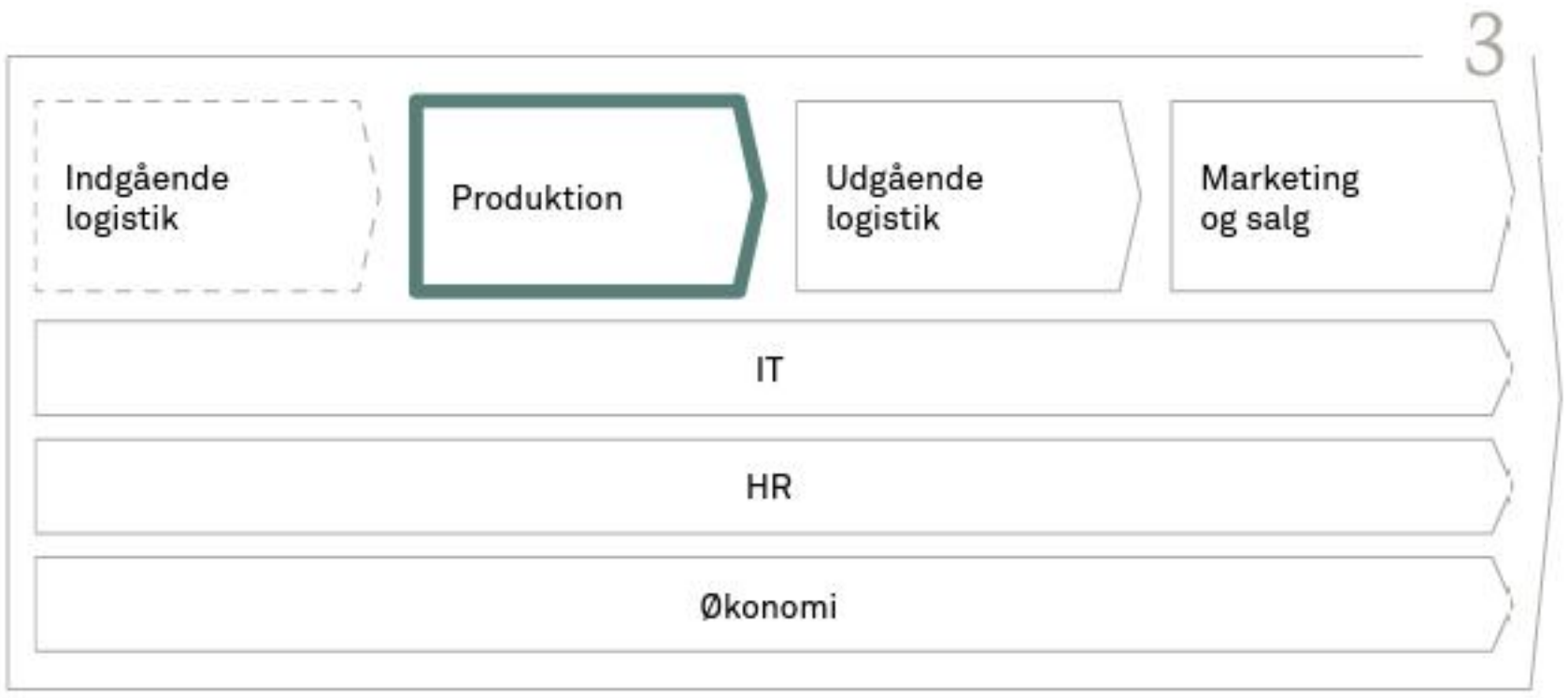
Risikotærskelværdien udtrykker som nævnt det samlede niveau for risici, som virksomheden eller myndigheden er villig til at tage for at realisere sine mål. Risikotærskelværdien bruges også til at fastslå, hvornår en given forretningsproces er kritisk for opnåelsen af vores mål som virksomhed eller myndighed. F.eks. kan det være, at topledelsen har fastsat, at vi kan leve med produktionstab på 10 mio. kr. dagligt. Derfor vil de forretningsprocesser, der bidrager til produktionen med 10 mio. kr. dagligt, være kritiske for os som organisation, mens de forretningsprocesser, der ikke direkte påvirker produktionen, i mindre grad vil være kritiske for vores organisation.

Den pointe er vigtig at holde sig for øje, når vi som det næste skal have en forståelse for kerneprocesserne, der støtter målopnåelsen, som vi gennemgår i næste afsnit.

Kerneprocesser, der støtter målopnåelsen

Det næste helt centrale skridt er at få en forståelse for, *hvordan* organisationen når sine strategiske prioriteringer. Det kan man gøre ved at få en forståelse for, hvordan organisationen ser ud i sin helhed. Her vil der ofte være en række kerneprocesser og en række støtteprocesser.

Ofte vil det være sådan, at der er en række kernefunktioner, som er nødvendige for, at virksomheden eller myndigheden kan udføre sine opgaver. I produktionsvirksomheder er kernen produktionen af varer, mens det i myndigheder kan være det at kunne udføre sagsbehandling, der er særligt vigtigt. Dertil kommer der en række støttefunktioner, som f.eks. finans og HR, som ikke i samme grad er tidskritiske for virksomheden eller myndigheden. Se nedenstående figur for et illustrativt eksempel.



Figur 2.4. Eksempel på kernefunktion med kritisk værdi for organisationen (markeret med grøn).

For at vurdere kritikalitet af et givent forretningsområde eller proces kan man spørge sig selv og sine kollegaer, hvad der ville ske, hvis forretningsområdet eller processen ikke fungerede, som den skulle – hvis nu fortroligheden, integriteten eller tilgængeligheden var kompromitteret. Altså hvor længe vi som organisation vil kunne fungere uden den og stadig kunne løse vores kerneopgave, tjene penge til virksomheden eller lave sagsbehandling for borgere eller virksomheder? Eller hvad nu, hvis vi ikke kunne stole på data, eller data blev gjort tilgængelige for uvedkommende?

Der er mange måder at gå til en kortlægning af kerneprocesser på. Man kan f.eks. se på organisationsdiagrammet for virksomheden eller myndigheden. Her vil der ofte være en leder for hver forretningsproces, f.eks. en innovationschef, en IT- og digitaliseringschef, en økonomichef og en chef for produktionen. I kortlægningen af kerneprocesserne og deres vigtighed for organisationen kan man indhente input fra dem og få deres vurdering af, hvor kritisk netop deres område er for virksomhedens eller myndighedens evne til at kunne operere. Her er det dog vigtigt, at man prøver at forholde sig til så objektive kriterier som muligt, så alle svarer ud fra samme udgangspunkt. Her skal man tænke over, hvilken industri og kontekst organisationen befinder sig i, og også typen af opgaver, organisationen udfører, og kulturen i organisationen. Ifølge ISO 22317, der beskriver, hvordan man kan udføre forretningsmæssige kritikalitetsvurderinger, kan det f.eks. være relevant at se på områdets eller processens betydning i forhold til:

- At nå de forretningsmæssige mål
- Hvilken finansiel påvirkning det vil have for myndigheden eller virksomheden
- Om der er særlige lovgivningsmæssige forpligtelser til at have processen kørende
- Om det vil have en påvirkning af virksomhedens eller myndighedens omdømme
- Om det kan have betydning for medarbejderes liv og helbred.

Man kan altså benytte sig af en række forskellige både kvantitative og kvalitative data til at vurdere kritikalitet af et givent forretningsområde eller forretningsproces. Vi vil generelt foreslå, at man går så objektivt til værks som muligt.

Kvalitativ eller kvantitativ vurdering af forretningsprocessers kritikalitet? Helt grundlæggende kan man anvende en kvalitativ eller kvantitativ tilgang, når man vurderer en given forretningsproces' kritikalitet for en organisation.

Kvantitativ kritikalitetsvurdering

Her anvendes kvantitative data til at vurdere kritikaliteten af en forretningsproces. Det være sig numerisk data og vil ofte være finansielle værdier i kr. og øre i form af potentielt tab ved datas fortrolighed, tilgængelighed eller integritet.

Kvalitativ kritikalitetsvurdering

Man kan også benytte sig af kvalitative data til at foretage sin kritikalitetsvurdering. Det kan f.eks. være i forhold til omdømme, investorers tillid til virksomheden eller tiltrækning af arbejdskraft. Denne type data vil man ofte kategorisere i høj, mellem eller lav.

Målet med overblikket over, hvor kritiske givne forretningsområder eller processer er i forhold til virksomhedens eller myndighedens mulighed for at nå sine mål er, at organisationen så har mulighed for at prioritere indsatser på cyber- og informationssikkerhedsområdet. Dette giver dermed mulighed for at fokusere indsatserne dér, hvor det er vigtigst for organisationens mulighed for at nå sine mål. Med knappe ressourcer er denne tilgang mest værdiskabende.

I kapitel 4 gennemgår vi metoder og redskaber til risikovurdering. Du vil her se, at mange af de grundlæggende spørgsmål og forhold, der skal afklares, går igen. Forskellen på det indledende procesmæssige overblik, som vi har gennemgået her, er, at det sker på overordnet procesniveau. Risikovurderingen, som gennemgås i kapitel 4, sker af de enkelte IT-systemer, der bliver identificeret. Dernæst er forskellen også, at vi her indledningsvis ikke fokuserer så meget på, hvad der kan forårsage, at et givent forretningsområde eller en given proces kompromitteres i forhold til fortrolighed, integritet og/eller tilgængelighed, men mere er interesserede i at forstå, hvilken betydning det har for vores organisations mulighed for at nå sine strategisk fastsatte mål. Det kan nemlig være utrolig dyrt og bøvlet at gennemgå alle processer i forhold til, hvor sandsynligt det er, at en hændelse indtræffer. Vi vil anbefale, at man prioriterer at kigge på sandsynlighed dér, hvor en hændelse på cyber- og informationssikkerhedsområdet forretningsmæssigt har de største konsekvenser.

I kapitel 6 om forberedelse og håndtering af en krisesituation ser vi nærmere på beredskab. Her kommer vi ind på, hvad man kan gøre, hvis man er udsat for et angreb, der gør, at et forretningsområde eller en proces kompromitteres. Her dykker vi mere ned i værktøjer til at kunne lave Business Impact Analysis (BIA), som supplerer det arbejde, vi har gennemgået hidtil i dette kapitel. Ud over at foretage en kritikalitetsvurdering, som præsenteret i dette kapitel, vil vi supplere med at gennemgå yderligere fem trin i en BIA. De tilsammen seks trin i BIA'en gør, at man har gode muligheder for at orkestrere sit beredskabsarbejde hensigtsmæssigt i en krisesituation. De seks trin, der gennemgås i kapitel 6, er:

1. Fastslå kritikalitetsvurdering – det, vi i dette kapitel har berørt ved at forstå kerneprocesserne, der støtter målopfyldelsen
2. Rangering af kritikalitet
3. Beslut maksimal acceptabel nedetid
4. Etabler mål for genopretningen
5. Skab overblik, og prioriter ressourcefordeling
6. Forstå afhængigheder.

Når vi har dannet os et overblik over de kritiske processer, kan vi komme et spadestik dybere. Det gør vi ved at forstå den digitale understøttelse og dokumentere, hvordan arbejdsopgaver udføres, ved at dokumentere processerne.

Forstå den digitale understøttelse af forretningsprocesserne

Når der er dannet et overblik over organisationens kritiske forretningsprocesser, giver det mening at forstå, hvordan de bliver udført. Der kan være tale om både analoge eller digitale forretningsgange. Ofte vil det være et mix af dem begge. I nedenstående eksempel ser vi f.eks., at proces 1 kan håndteres helt manuelt, mens proces 2 og 3 kræver IT-understøttelse.

Figur 2.5. Visualisering af forretningsprocesser, og hvordan de gennemføres. Med inspiration fra Sikkerdigital.dk.

Når man dokumenterer den digitale understøttelse, er der igen mange måder at gribe det an på. Vi vil anbefale, at man tager udgangspunkt i anerkendte værktøjer til procesdokumentation, f.eks. BPMN (Business Process Model and Notation) eller lignende.

> *"Det er kritisk, at man forstår sammenhængen mellem forretningen og IT-understøttelsen, det er ikke alle, der har blik for det. Start med at forstå, hvad forretningen er afhængig af IT-mæssigt, og så lad risikovurderingen udspringe derfra. Vi møder stadig nogle, der siger, at de ikke har kritiske systemer, eller at alt er cloud, og så er det lige meget, synes de. Men der er bare ikke mange, der kan fungere uden den daglige IT-understøttelse. Uden IT kan de intet. Forstå den digitale understøttelse grundigt, så kan man komme videre med risikovurderingen."*
> – Jens Stener, administrerende direktør i Bestyrelsesforeningens Center for Cyberkompetencer

Det er vores anbefaling, at arbejdet hviler på tværfaglige teams, hvor der både er sikkerhedsmæssige og procesfaglige ressourcer til rådighed. Dernæst er det helt afgørende at involvere dem, der kan sige noget om, hvordan arbejdet rent faktisk forløber i arbejdsprocessen, og hvordan den bliver digitalt understøttet, det kan f.eks. være systemejere og procesejere (se mere i kapitel 5: Roller og ansvar).

Skab overblik over IT-understøttelsen med IT asset management

Når man har oversigten over processerne og deres digitale understøttelse på plads, kan man komme endnu et spadestik dybere og se på, hvilke IT-systemer, databaser og infrastrukturkomponenter der er nødvendige, for at processen kan fungere.

Her bevæger vi os ind på et område, der også af mange kendes som IT-arkitektur. I nedenstående figur kan du se et simpelt illustrativt eksempel på, hvordan man kan arbejde med at dokumentere IT-understøttelsen. Det tager udgangspunkt i et lagdelt arkitekturoverblik. Som det beskrives af Larsen (2011): *"IT-arkitektur kan være svær at tage livtag med. Emnet er enormt. Begrebet IT-arkitektur spænder i bredden fra forretning over data til hardware og*

i dybden fra strategi til kode struktur" (Larsen, 2011). Igen har vi altså at gøre med et emne, som er større, end vi kan nå at gå helt i dybden med her i bogen. Vi har derfor udvalgt et enkelt hjørne af IT-arkitekturarbejdet, nemlig IT asset management (forkortes nogle gange til ITAM). For at beskrive, hvad IT asset management går ud på, kan du forestille dig en gennemsnitlig arbejdsplads – du ser sandsynligvis kontorpladser med computere, medarbejdere er udstyret med arbejdstelefoner, dertil kommer så tablets eller andre stykker hardware, der bruges til det daglige arbejde. Alt dette hardware indeholder software og programmer. Og et skridt dybere kommer også servere, databaser og netværksudstyr. Tilsammen udgør disse en virksomheds "IT assets", og det er et stort arbejde at opdatere, reparere og udskifte alt dette. Hvis man ikke har det store overblik over organisationens IT assets, opstår der let en situation, hvor en del af IT-landskabet f.eks. ikke opdateres med seneste sikkerhedsopdateringer og derfor udgør en sårbarhed for organisationen.

I vores arbejde som konsulenter ser vi ofte, at der kan være stor forskel på modenheden i virksomheder og myndigheder i forhold til, hvor godt processer og IT-understøttelsen af dem er dokumenteret. Der er steder, hvor modenheden er høj, hvor man har CMDB-systemer (configuration management database) så som ServiceNow, Remedy m.fl., hvor informationer om hardware- og softwareaktiver opbevares med metainformation tilknyttet, f.eks. hvem der er ejer, hvilken risikovurdering der ligger på det enkelte system, kontrakter osv. Andre steder er modenheden ikke så høj, og her må man starte et sted og så tage ét skridt ad gangen. Det væsentlige er, at vi får en forståelse for, hvor de vigtigste forretningsprocesser er, og hvordan de er understøttet af IT.

Et godt og opdateret IT-overblik kommer ikke af sig selv, men kræver dedikeret og løbende arbejde. Det er dog værd at nævne, at der ikke blot er fordele i forhold til cybersikkerhed, hvis man arbejder med IT asset management, men at der også er penge at spare, fordi man undgår eventuelt dobbeltindkøb og ideelt set også har bedre styr på f.eks. garantier og kontrakter. Man udnytter simpelthen det, man har, på bedste vis.

Hvis du vil dykke nærmere ned i asset management, finder man i ISO 27001 5.9-5.11 særskilt fokus på bl.a. at udvikle og vedligeholde overblik over alle assets. Derudover er der hjælp at hente i f.eks. rammeværket NIST CSF 2.0 (se mere i kapitel 3: Lovgivning, standarder og politikker). Her fremhæves asset

management som et centralt emne (under funktionen "Identify"), og i rammeværket kan man finde hjælp til de emner, der skal afdækkes, når man ønsker at få (bedre) styr på organisationens asset management.

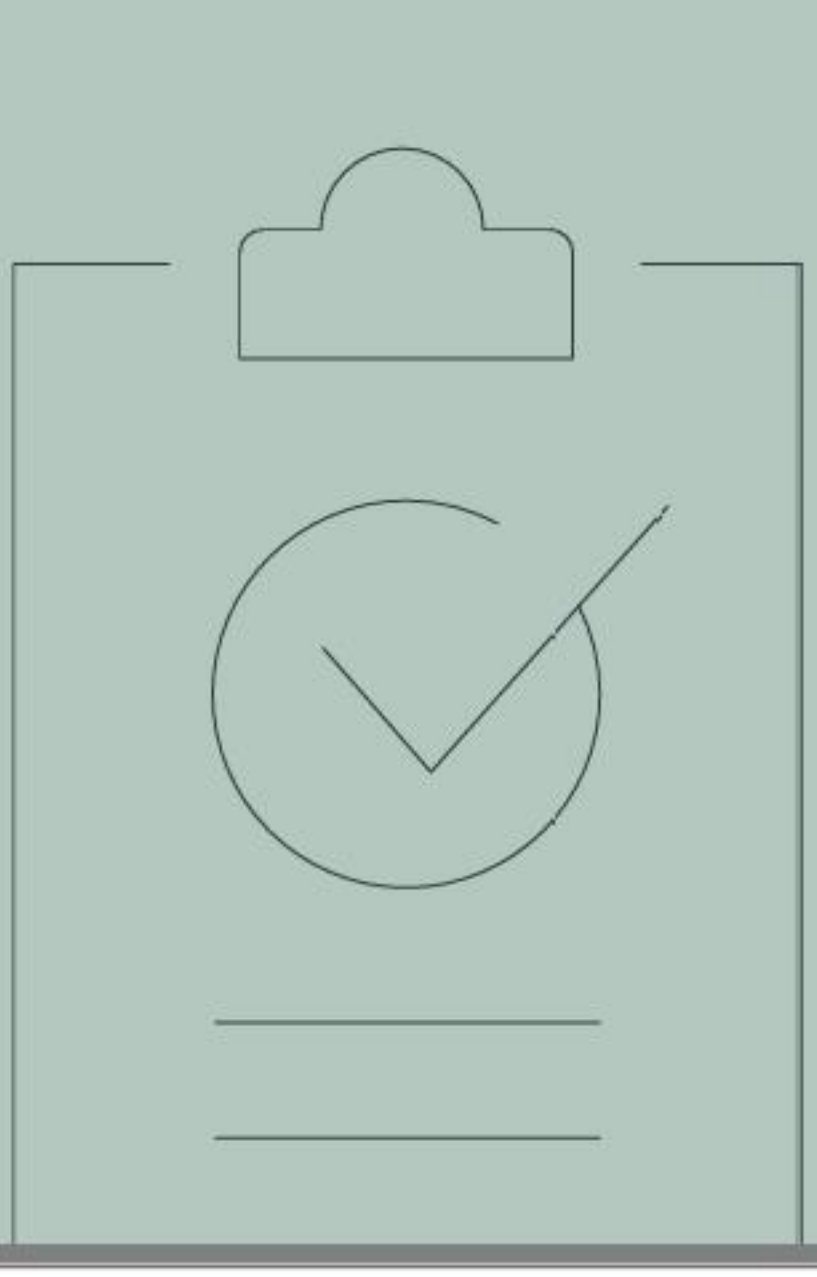
Med fundamentet på plads dykker vi i de kommende kapitler ned i, hvordan man kan koble sin forståelse for organisationen med sikkerhedsarbejdet, så vi rammer et sikkerhedsniveau, der er passende for organisationen. Dette både i forhold til prioritering, investering og eksekvering.

En kort opsummering:

Indsigt og prioritering; Cybersikkerhed og digital udvikling skal gå i takt

- Cybersikkerhed bør aldrig være målet i sig selv – det er tvingende nødvencigt, at den digitale forretningsudvikling og cyber- og informationssikkerhedsindsatsen bliver to sider af samme sag; risikostyring.

- For at skabe gode forudsætninger for cyber- og informationssikkerhedsarbejdet skal der være klarhed over fem områder: den overordnede strategiske retning, risikoappetit, kerneprocesser og den digitale understøttelse og IT-understøttelsen.



Case:

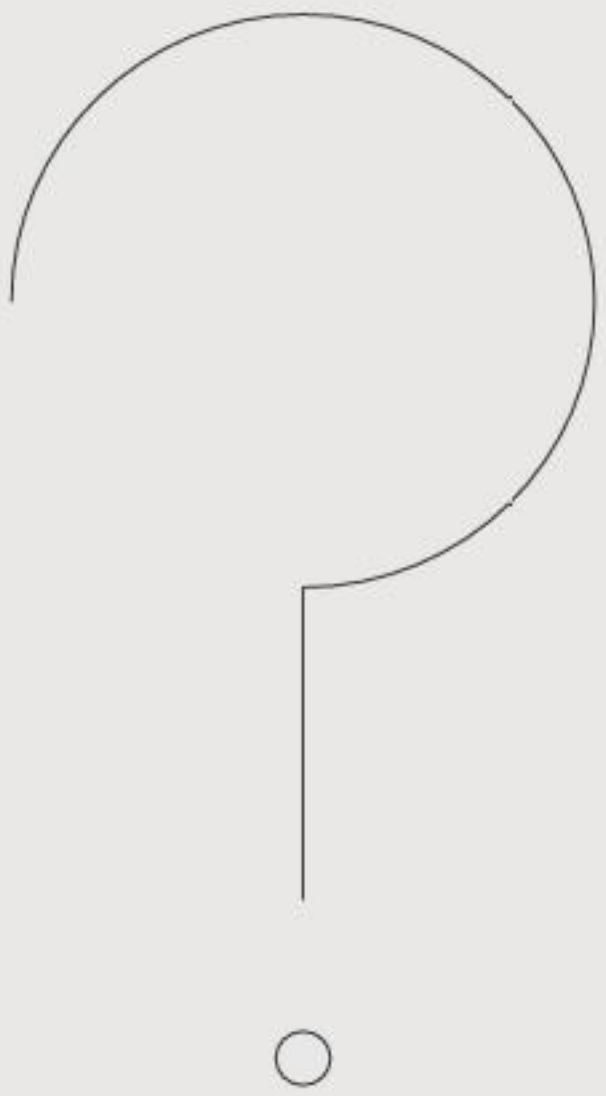
Legetøj skal løftes ind i fremtiden

FutureToys Inc. er en dansk legetøjsvirksomhed, der producerer legetøjsfigurer, der vækker glæde og begejstring hos børn over hele verden. Virksomheden har nu set potentialet i at udnytte den danske ekspertise indenfor robotteknologi og innovation til at "løfte deres legetøj ind i fremtiden", som det hedder så flot i den overordnede strategi. FutureToys Inc. har derfor valgt at udvide med produktion af robotlegetøj på en stor fabrik i udkanten af København. Fabrikken skal udstyres med avancerede produktionslinjer og robotteknologi for at sikre høj kvalitet og effektivitet i produktionen. Virksomheden ansætter også de bedste danske ingeniører og designere for at sikre, at legetøjsrobotterne er innovative og opfylder de højeste sikkerhedsstandarder.

FutureToys Inc. har indtil nu kun fremstillet mere traditionelle legetøjsfigurer, altså uden teknologi "indeni". Bestyrelsen er begejstret for dette nye forretningseventyr og helt klar over, at cyber- og informationssikkerhed naturligvis skal gå hånd i hånd med de nye forretningsmål. De beder deres CISO om at samle et par gode medarbejdere, der skal udarbejde et forslag til en cyber- og informationssikkerhedsstrategi. Teamet får adgang til alle ressourcer, de har brug for, og skal være tydelige og transparente omkring deres arbejdsmetoder og løbende fremdrift. Du er nyansat medarbejder i dette team, og du glæder dig til at komme i gang!

Arbejdsspørgsmål

- Hvilke forudsætninger skal være på plads, for at FutureToys Inc. kan udarbejde en effektiv cyber- og informationssikkerhedsstrategi?
- Hvordan ville du indhente informationer om hver af de fire forudsætninger for arbejdet, og hvem ville du involvere i arbejdet?
- Hvilke metoder og værktøjer kan virksomheden anvende til at vurdere deres risikoappetit på cyber- og informationssikkerhedsområdet, og hvorfor er det vigtigt at etablere en klar risikoappetit?
- Hvad er betydningen af at identificere og forstå kerneprocesser, der støtter målopnåelsen for en organisation, og hvordan kan dette bidrage til en mere effektiv indsats på cyber- og informationssikkerhedsområdet?
- Hvordan kan brugerens (barnets) privatliv beskyttes gennem design og data-minimering?



Litteraturliste

Bestyrelsesforeningens Center for Cyberkompetencer (2019). Cybersikkerhed for bestyrelser. Anbefalinger til Styrkelse af Cyberkompetencer.

Carmichael (2022, 24. oktober). Risk appetite vs. Risk tolerance: What is the difference? ISACA. Lokaliseret på: www.isaca.org/resources/news-and-trends/isaca-now-blog/2022/risk-appetite-vs-risk-tolerance-what-is-the-difference

Dansk Standard (2023). Guide til risikostyring. Risikostyring i forhold til cyber- og informationssikkerhed for smv'er. Dansk Standard.

Digitaliseringsstyrelsen (2015, februar). Vejledning i it-risikostyring og -vurdering.

Digitaliseringsstyrelsen (u.å.). Styrk virksomhedens digitale sikkerhed. Sikkerdigital.dk. Lokaliseret på: www.sikkerdigital.dk/virksomhed

Finansministeriet (2021, december). National Strategi for cyber- og informationssikkerhed 2022-2024.

Huang, K., Wang, X., Wei, W., & Madnick, S. (2023). The devastating business impacts of a cyber breach. *Harvard Business Review*.

International Organization for Standardization (2022). Information Security, cyber security and privacy protection-Information security management systems-Requirements. Reference number ISO/IEC 27001:2022(E).

International Organization for Standardization (2022). Information Security, cyber security and privacy protection-Information security management systems-Requirements. Reference number ISO/IEC 27001:2022(E).

Kulyk et al. (2021, 15. december). Assessment on the Status of Cybersecurity in Denmark. Lokaliseret på: www.ascd.dk/results/

Larsen, Philip E. (2011). It-arkitektur – en praktisk guide for it-chefer. Artikel trykt i It-håndbogen. Børsen Forum A/S.

National Institute of Standards and Technology (2024, Februar). The NIST Cybersecurity Framework (CSF) 2.0. Lokaliseret på: https://doi.org/10.6028/NIST.CSWP.29

Ozkaya, E. (2022). Cybersecurity Leadership Demystified: A comprehensive guide to becoming a world-class modern cybersecurity leader and global CISO. Packt Publishing Ltd.

Saeed, S., Altamimi, S. A., Alkayyal, N. A., Alshehri, E., & Alabbad, D. A. (2023). Digital transformation and cybersecurity challenges for businesses resilience: Issues and recommendations. *Sensors*, *23*(15).

Kapitel 3

Kapitel 3

Lovgivning, standarder og politikker

> Vores undersøgelser og dem, vi taler med, viser, at der er konkurrencemæssige fordele ved at arbejde med cybersikkerhed."

Malene Stidsen,
programchef for Industriens Fonds Cybersikkerhedsprogram

Cybersikkerhed som en konkurrencefordel

For nogle brancher gælder det, at de længe har været underlagt krav og lovgivning om at efterleve f.eks. NIS-direktivet fra EU. For andre brancher oplever man først nu at være underlagt egentlige lovkrav, eller at ens kunder er underlagt lovgivning, så de begynder at stille større krav til deres leverandører. Tendensen er dog tydelig – på tværs af EU arbejdes henimod en mere samlet og ensartet måde at tilgå cybersikkerhedsdomænet på. Så hvad enten man er tilhænger af disse lovgivningsmæssige forpligtelser eller ej, er det nødvendigt at sætte sig ind i arbejdet og forholde sig til de krav, det bringer til netop den virksomhed, man arbejder for (Lee, 2024). At der er love og regler at leve op til, betyder også, at arbejdet med cyber- og informationssikkerhed nogle gange risikerer at blive en lidt tung øvelse, hvor fokus er at leve op til reglerne for reglernes skyld.

Vi vil dog gerne være med til at slå et slag for at arbejde med cybersikkerhed, også fordi det – hvis det er ordentligt struktureret og tages alvorligt – kan udløse en række konkurrencemæssige fordele. I kapitel 1 udfoldede vi konkurrencefordele i forhold til det strategiske arbejde med cybersikkerhed. I dette kapitel går vi fra det strategiske arbejde videre til at se på lovgivning, standarder og politikker. Også her kan der høstes konkurrencemæssige fordele:

> *"Vi ser tre 'klumper' af fordele. Først, effektivitet. Når du alligevel skal analysere alle processer for at sikre dem, jamen så dukker der ofte noget op, som kunne gøres anderledes og bedre. Det stimulerer nytænkning. For det andet tillid. Vi kan se, at styrker man sin cybersikkerhedsindsats, så*

vækker det tillid hos både bestyrelse, kunder, og eventuelt investorer. Investorer i dag kigger ikke kun på vækstrater, men også på, om du passer på din virksomhed. Til sidst bundlinje. Du kan differentiere dig og endda nogle gange sætte prisen op, fordi du differentierer dig i markedet ved at have styrket fokus på cybersikkerhed".

– Malene Stidsen, programchef for Industriens Fonds Cybersikkerhedsprogram

Vi ved det godt: Lovgivning og regulering kan være rigtig tungt arbejde. Nogle organisationer forsøger derfor at komme hurtigt i mål ved enten bare at lave lappeløsninger på det, de allerede har, eller ved at vælge en standard eller et rammeværktøj hurtigt for derefter hovedløst at kaste sig ud i at få "flueben" i hver tjekboks. Dette er en sikker vej til en dødssejler af et projekt, som ikke opnår reel effekt. Det er nødvendigt at gøre sit benarbejde ordentligt, forstå det lovgivningsmæssige setup og få arbejdet brudt ned i overskuelige og prioriterede dele. Hvis dette er på plads, og man forstår, *hvorfor* man har valgt (eller er blevet pålagt) en given standard eller rammeværk, kan dette også lettere kommunikeres både internt og eksternt. Det er her, vi så kan håbe at opnå nogle af de konkurrencemæssige fordele, som nævnes i citatet ovenfor.

I dette kapitel dykker vi derfor ned i nogle af de lovgivningsmæssige forpligtelser, der er mest udbredt for danske myndigheder og virksomheder. Det være sig det såkaldte NIS2-direktiv, GDPR (persondataforordningen) eller DORA-forordningen. Derefter viser vi, hvordan man konkret kan finde vej i junglen af regulativer og finde ud af, hvilke lovgivningsmæssige rammer man som organisation skal leve op til. Det gør vi via værktøjet "anvendelighedsvurdering".

Når man har et overblik over, hvilke lovgivningsmæssige forpligtelser ens organisation skal leve op til, så skal man finde ud af, hvordan man så gør det i praksis. Lovgivningen vil ofte pege på, at virksomheden eller myndighedens cybersikkerhedsarbejde skal være funderet på en risikobaseret metode, og dernæst sætte mere eller mindre konkrete krav til sikkerhedsarbejdet. Der vil dog ofte være metodefrihed for den enkelte organisation i forhold til, hvordan man konkret vil leve op til gældende lovgivning.

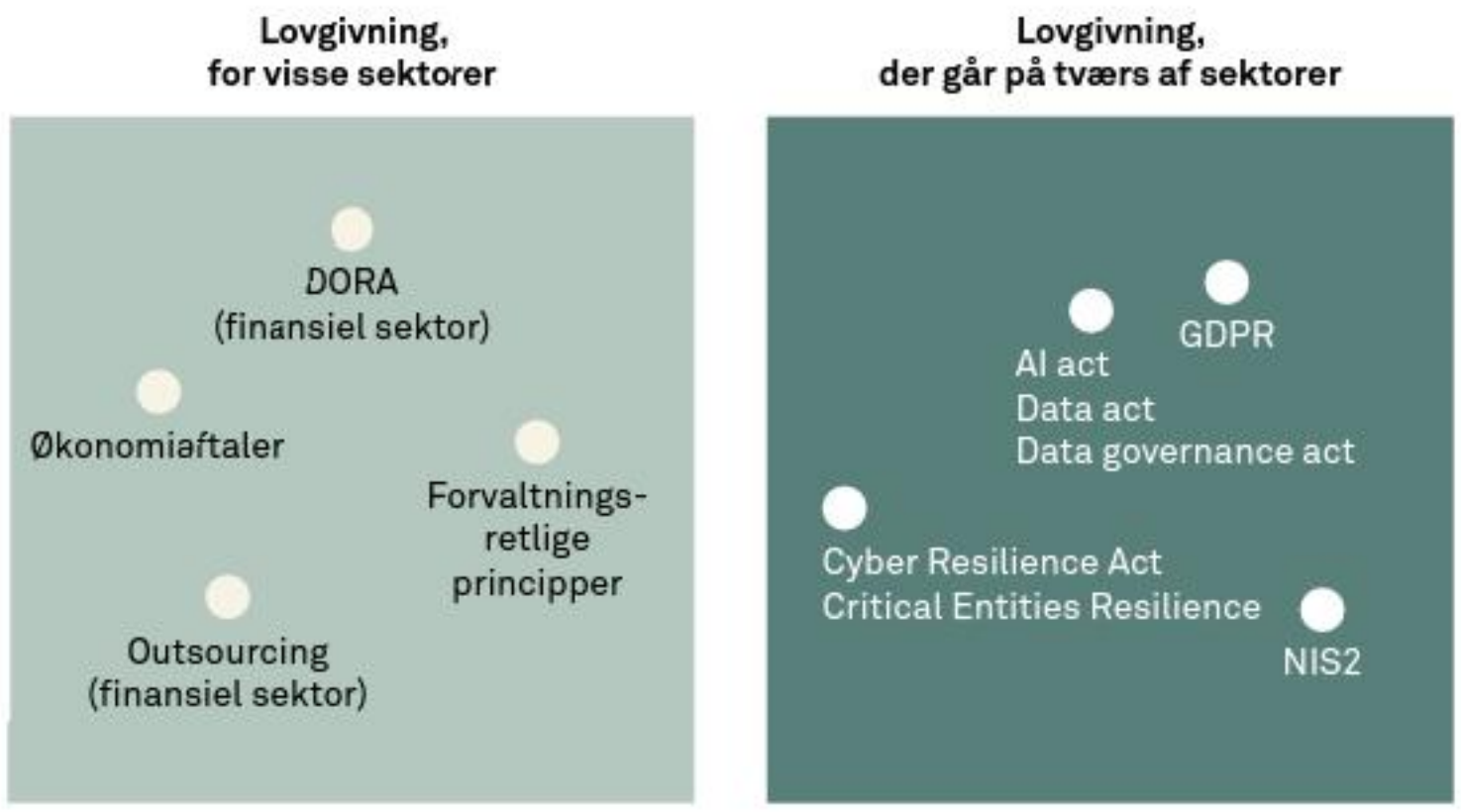
Her er det vores anbefaling, at man tager udgangspunkt i en internationalt anerkendt standard som f.eks. ISO 27001 eller rammeværket NIST. Dette råd

gælder sådan set for både store og små organisationer da det simp,elthen giver mening ikke at skulle opfinde den dybe tallerken selv. Begge tilgange bliver uddybet i dette kapitel. Hvilken standard eller rammeværk der passer bedst til den enkelte organisation, vil bl.a. afhænge af, hvor man opererer geografisk, og hvilke kompetencer man har adgang til i sin medarbejdergruppe.

Endelig bør politikker for cyber- og informationssikkerhed være med til at give rammerne for, hvordan man i virksomheden eller myndigheden skal arbejde med cyber- og informationssikkerhed i dagligdagen. I afslutningen af dette kapitel giver vi derfor konkrete råd, tips og tricks til, hvordan man kan udarbejde sin(e) politik(ker).

Lovgivning på cyber- og informationssikkerhedsområdet

Det er ikke let at få et samlet overblik over regulering på området for cyber- og informationssikkerhed, fordi der er lovgivning, der går på tværs af sektorer, noget, der er teknologispecifikt, og noget, der udelukkende gælder indenfor én sektor, f.eks. finanssektoren eller for offentlige myndigheder. Nedenstående figur giver en grov oversigt over essentielle stykker lovgivning, hvorvidt de er sektorspecifikke eller tværgående, samt hvor bredt et omfang de kan siges at have.



Figur 3.1. Visualisering af sektorspecifik og tværgående lovgivning samt deres anvendelse.

I denne bog har vi været nødsaget til at udvælge blot et par lovgivningsmæssige nedslagspunkter, da det ellers ville blive alt for langt og tungt at komme igennem det hele. For nye medarbejdere eller studerende på området vil vi dog vove at sige, at hvis man har en grundlæggende forståelse for NIS2, DORA og GDPR, så er man godt dækket ind i forhold til at hjælpe langt de fleste organisationer på vej i deres cybersikkerhedsarbejde. Disse er listet i figuren nedenfor og præsenteres kort i de følgende afsnit.

	Forkortelsen	... står for:	Bonus-info
Regulering	NIS2	Network and Information Systems 2	Forsvarsministeriet er ansvarlig for implementering af NIS2-direktivet i Danmark
	DORA	Digital Operational Resilience Act	Har særligt fokus på finansielle virksomheder og på at gøre samfundet mindre sårbart overfor cybertrusler
	GDPR	General Data Protection Regulation, på dansk "databeskyttelsesforordningen"	Når vi arbejder med cybersikkerhed, beskytter vi samtidig de oplysninger, som er vigtige i GDPR. Det er en fordel at gennemtænke og bruge de overlap, der her findes
	AI Act	Artificial Intelligence Act	Den første regulering af AI området. AI systemer der vurderes at udgøre en trussel mod mennesker vil blive forbudt.

Figur 3.2. NIS2, DORA, GDPR, og AI Act.

NIS2
– EU-direktiv med fokus på at øge minimumsniveau for cybersikkerhed på tværs af EU

Lovgivning beskyldes ofte for at have svært ved at følge med den teknologiske udvikling. De seneste år har EU-samarbejdet dog formået at udvikle en række

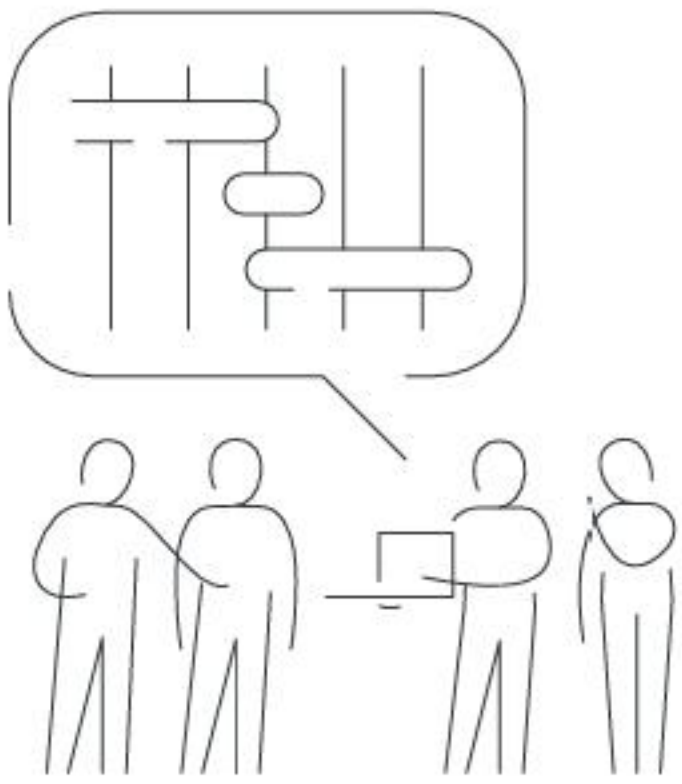
relevante reguleringer og direktiver, som forsøger at gøre op med dette. Det er NIS- og NIS2-direktivet gode eksempler på. NIS2 (som erstatter NIS) er en risikobaseret tilgang til cybersikkerhed for kritisk infrastruktur og indebærer nye juridiske krav til et minimumsniveau for cybersikkerhed og kritisk infrastruktur i EU. Ganske kort kan man opsummere NIS2-opdateringen ved at sige, at den gør sig gældende for langt flere virksomheder og myndigheder, og at der også gælder flere krav. Dernæst indføres der også et strengere tilsyn, der skal håndhæves af de nationale myndigheder. Hertil kommer sektorielle tilsyn, da hver sektor vil have en dedikeret tilsynsmyndighed. Hensigten er samtidig at gøre rapporteringskrav og bødesystemer (mere) ensartede på tværs af EU. NIS2 er et "direktiv", fordi det først gælder i Danmark, når Folketinget har implementeret det i dansk lovgivning. I skrivende stund (forår 2024) er implementeringen forsinket, og *"et lovforslag er planlagt fremsat i oktober 2024"* (Center for Cybersikkerhed, 2024). I skrivende stund forventes loven at træde i kraft pr. 1. marts 2025. Rigtig mange virksomheder er allerede nu ved selv at vurdere, om de vil kunne være omfattet af direktivet, og hvad det vil kræve af dem. En analyse fra DI Digital og Industriens Fond peger på, at 1079 danske virksomheder vil være berørt (DI Digital, 2024). Under alle omstændigheder er det vores klare anbefaling, at man griber tyren ved hornene og starter arbejdet nu for ikke at være bagud fra start. Nedenstående oversigt viser eksempler på krav fra NIS2.

NIS2: Direktiv om netværks- og informationssikkerhed 2

Hvad?	• NIS2 er en lovgivning indenfor EU • NIS2 lægger op til en risikobaseret tilgang til cybersikkerhed, men fremsætter også en række minimumskrav • I NIS2-direktivet skelnes mellem "væsentlige" og "vigtige enheder". En analyse fra Industriens Fond og DI peger på, at op imod 1100 danske virksomheder indenfor 12 sektorer vil blive direkte berørt af NIS2-direktivet.
Hvem?	Flere sektorer end tidligere er omfattet af NIS2 end NIS. Oprindeligt var følgende sektorer omfattet: energi, transport, vandforsyning, sundhed, digital infrastruktur, digital serviceudbydere, banking og finansmarked. Med NIS2 udvides omfanget til også at gælde for: fødevarer, offentlig administration, post- og pakkeservice, vandspilds- og affaldsservices, rummet (f.eks. udvikling, produktion og drift af satellitter), udbydere af offentlige elektroniske kommunikationsnet, elektroniske kommunikationstjenester som sociale medier og datacenter-services, fremstilling af nogle "kritiske produkter" (som medicin, medicinsk udstyr og kemikalier).
Hvorfor?	Formålet med NIS2 er at sikre en høj og mere ensartet standard for cybersikkerhed i hele EU for i langt højere grad at kunne sikre samfundet mod cybertrusler.

5 vigtige pointer				
Væsentlige/ vigtige enheder Væsentlige og vigtige enheder skal leve op til de samme krav, men der er forskel på tilsyn og bøde-størrelser	**Signifikante bøder** NIS2 lægger op til signikant større bøder end hidtil set	**Hændelses-håndtering** Første rapportering indenfor 24 timer og indledende analyse indenfor 72 timer	**Ledelses-ansvar** Cybersikker-hed er ledel-sens ansvar, og denne er ansvarlig for eventuelt manglende overholdelse	**Træning** Træning og løbende uddannelser af ledelses-laget er obligatorisk

Figur 3.3. Om NIS2.



DORA – krav til den finansielle sektor

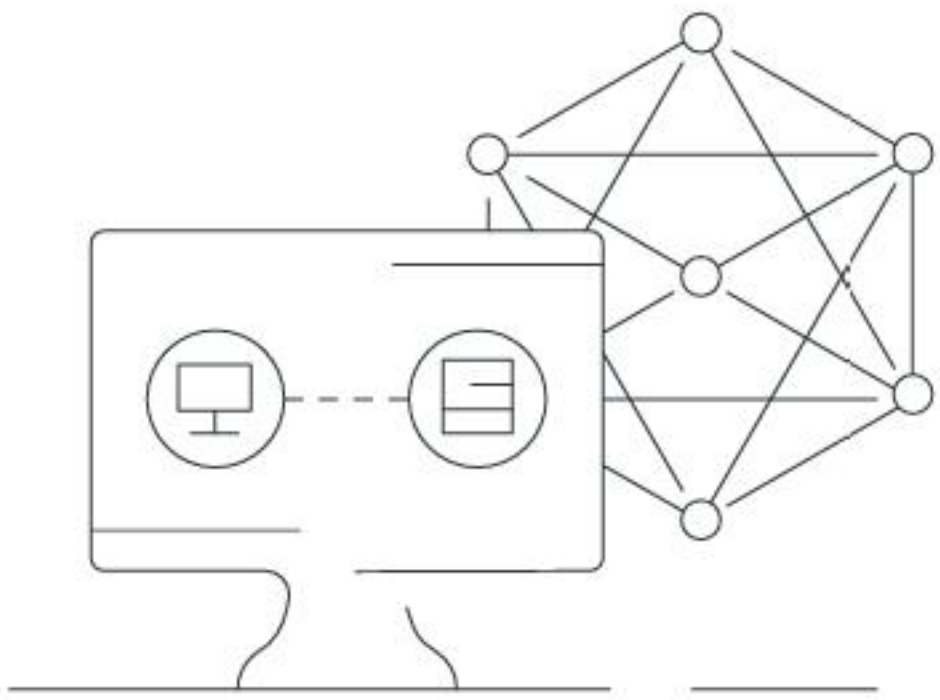
Den Europæiske Kommission har introduceret DORA, som står for Digital Operational Resilience Act (loven om digital operationel modstandsdygtighed), i Europas finansielle sektor (European Council, 2022). DORA sørger for, at virksomheder indenfor den finansielle sektor er godt forberedt til at håndtere enhver situation, der kan sætte den digitale sikkerhed på spil. Målet er at sikre vores samfund bedre ved at gøre den finansielle sektor mere modstandsdygtig overfor cybertrusler. DORA har også til formål at sikre, at de samme regler for digital sikkerhed gælder i hele EU, så der ikke er forskellige regler i de forskellige lande.

DORA stiller krav til IT-tjenesteudbydere i den finansielle sektor om at følge fastsatte cybersikkerhedsregler. Først og fremmest understreger reguleringen vigtigheden af governance, hvilket indebærer, at virksomheder skal etablere robuste ledelsesstrukturer for effektiv håndtering og overvågning af deres IT-sikkerhed. Dernæst kræver DORA, at virksomheder implementerer stærke hændelseshåndterings-processer (incident management), der sikrer hurtig identifikation, reaktion og afhjælpning af sikkerhedshændelser. For at støtte denne proces skal virksomheder også bruge realistiske trusselscenarier til at teste sikkerhedsforanstaltninger (også kendt som TLPT (Threat Led Penetration Testing). Dertil kommer, at DORA omfatter bestemmelser for risikostyring af tredjeparter (også kendt som Third-Party Risk Management), som sikrer, at leverandører og partnere opfylder de samme strenge sikkerhedskrav. Til sidst opfordres virksomheder til at dele information om cybertrusler og IT-fejl med hinanden for at sikre, at alle hurtigt kan reagere på eventuelle sikkerhedsbrud (Finanstilsynet, 2022; Implement Consulting Group, u.å.).

DORA – Digital Operational Resilience Act

Hvad?	DORA fastsætter ensartede krav til sikring af finansielle aktiviteter på tværs af alle EU-medlemslande.				
Hvem?	En lang række finansielle institutioner er omfattet af DORA; herunder (men ikke udelukkende) kredit- og betalingsinstitutter, forsikringsselskaber, arbejdsmarkedspensionsselskaber, værdipapircentraler, virksomheder indenfor kryptoaktiver, kreditvurderingsbureauer.				
Hvorfor?	DORA er opstået på baggrund af en erkendelse af behovet for at styrke den finansielle sektors modstandsdygtighed overfor cyberangreb. Formålet er i højere grad at kunne sikre finansiel stabilitet og forbrugerbeskyttelse.				
5 vigtige pointer	**Vidensdeling** DORA lægger op til en højere grad af udveksling af information vedrørende cyber-realaterede trusler	**Leverandør-fokus** Leverandører af IKT (informations- og kommunikationsteknologi) til den finansielle sektor er også i fokus	**Afprøvning** Generelt øget fokus på test af cyber-sikkerhed	**Indberetning** DORA fastsætter krav til inberetning af større IT-relaterede hændelser til myndighederne	**Ledelses ansvar** Med DORA, ligesom i NIS2, er ledelsen (bestyrelse og direktion) øverst ansvarlig for cyber-sikkerhed

Figur 3.4. Om DORA.



GDPR – EU-lovgivning med fokus på de mest følsomme data

I 2018 tog Den Europæiske Union et stort skridt fremad i beskyttelsen af personlige oplysninger med indførelsen af GDPR, som står for General Data Protection Regulation, eller på dansk Databeskyttelsesforordningen (Europa-Kommissionen, u.å.; Datatilsynet u.å.). Formålet med denne lovgivning er at beskytte EU-borgeres personlige oplysninger og give kontrol over egne data. Personlige oplysninger dækker over alt, der kan identificere et individ, lige fra navn og adresse til e-mail, telefonnummer, billeder og selv detaljer om online-aktiviteter.

GDPR styrker EU-borgeres privatlivsrettigheder og kontrol over deres egne data. Forordningen sikrer, at personoplysninger behandles fortroligt og udelukkende til formål, som borgeren har samtykket til (Datatilsynet, u.å.). Borgere har ret til at se, hvilke data virksomheder opbevarer om dem, og de kan anmode om at få disse data rettet eller slettet, kendt som "retten til at blive glemt". Organisationer skal beskytte data mod uautoriseret adgang eller tab og være transparente om deres databehandling. Overtrædelser kan medføre store bøder. En nøglekomponent i GDPR er, ifølge artikel 30, kravet om en fortegnelse over behandlingsaktiviteter. Fortegnelsen skal liste alle virksomhedens aktiviteter med personoplysninger og følge udvalgte kriterier. Denne fortegnelse skal opdatere og vedligeholdes løbende for at dokumentere overholdelse af databeskyttelseskravene.

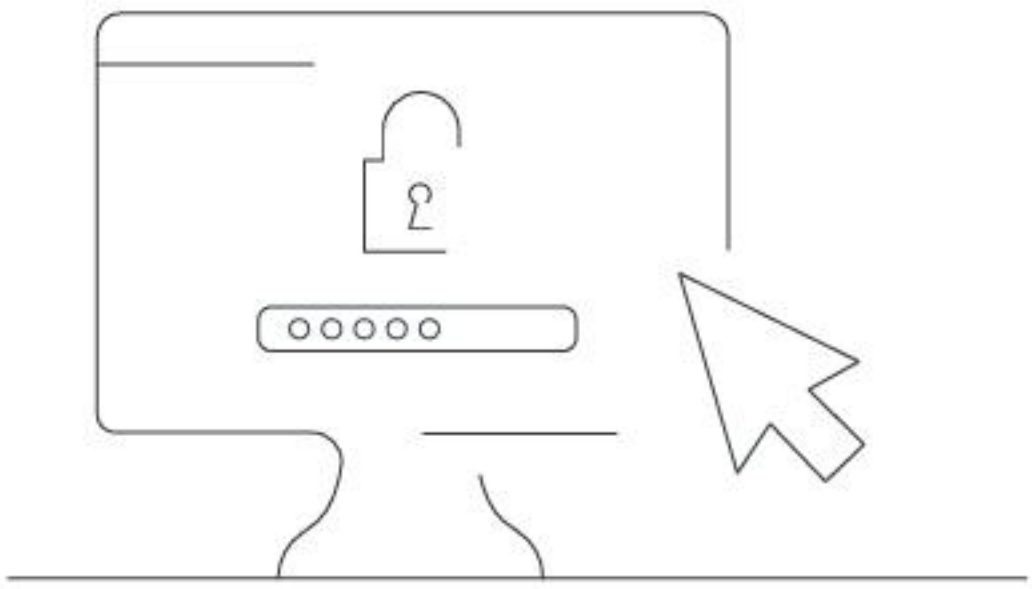
GDPR har medført betydelige arbejdsbyrder for mange virksomheder, der har måttet udvikle nye arbejdsgange for at sikre, at registrerede personer modtager korrekt information og kan få slettet deres data efter behov. Mange virksomheder har endnu ikke fuldt implementeret disse processer, men de fortsatte bestræbelser på at opdatere arbejdsgange i takt med udviklingen af nye digitale tjenester skaber muligheder for stærkere databeskyttelse og øget tillid fra forbrugere, hvilket kan føre til en forbedret kundeoplevelse og konkurrencefordele.

GDPR – General Data Protection Regulation

Hvad?	GDPR står for General Data Protection Regulation, og det er en lov, som regulerer beskyttelsen af personlige data for enkeltpersoner i EU. Den blev vedtaget i 2016 og trådte i kraft i maj 2018.
Hvem?	GDPR gælder for enhver virksomhed eller organisation, der behandler personlige data for enkeltpersoner i EU, uanset hvor i verden virksomheden er placeret. Dette omfatter virksomheder, offentlige myndigheder, non-profit-organisationer og andre enheder, der behandler personlige data som en del af deres aktiviteter.
Hvorfor?	Formålet med GDPR er at give enkeltpersoner mere kontrol over deres personlige data og at sikre, at virksomheder og organisationer behandler sådanne data på en ansvarlig måde.

5 vigtige pointer				
Kontrol GDPR giver enkeltpersoner rettigheder til at kontrollere deres personlige data, herunder retten til at få adgang til deres data, retten til at få rettet unøjagtige oplysninger og retten til at blive glemt	**Retligt grundlag** Man skal have lov til at behandle personoplysninger inden man går i gang. Det kan man f.eks. få hvis man skal opfylde en kontrakt, hvis det fremgår af lovgivningen eller hvis man beder om lov (samtykke)	**Krav til beskyttelse af data** Indfører strengere krav til beskyttelse af personlige data for at forhindre krænkelser af individer	**Bøder** Overtrædelser kan føre til bøder på op til 4 % af den årlige omsætning eller 20 millioner euro, alt efter hvad der er højst	**En ny rolle** Offentlige myndigheder skal udpege en DPO (data protection officer, på dansk databeskyttelsesrådgiver). Dette gælder også for private virksomheder, som lever op til en række betingelser.

Figur 3.5. Om GDPR.



AI Act – EU's lovgivning om kunstig intelligens

AI act er i skrivende stund (sommer 2024) på alles læber. AI act er det første, bindende juridiske rammeværk, som har fokus på at udvikle etiske og sikre AI systemer på det europæiske marked. Som nævnt er det tidlige dage for AI act, så vi kan endnu ikke vide så meget om implikationerne for organisationer rundt om i EU endnu, men vi kan se de spilleregler, som EU-parlamentet har sat op. Her kan vi nævne fire hjørnesten. For det første har AI act indflydelse på hele værdikæden, det vil sige at reguleringen omfatter alt fra udvikler til brugeren af systemet, og sætter forskellige specifikke krav for forskellige aktører afhængig af deres rolle. For det andet er AI act i sit udgangspunkt "human-centric", som det lyder på engelsk. Det vil sige, at der er fokus på at beskytte fundamentale rettigheder for individet såsom demokrati, sundhed, fysisk sikkerhed og miljøbeskyttelse. Derudover er AI act risikobaseret, så det er en vurdering af det enkelte systems risici, der ligger til grund for hvilket niveau af sikkerhedsforanstaltninger, dokumentation, osv., det skal leve op til. Slutteligt er en hjørnesten i AI act, at alle personer eller medarbejdere, der påvirkes eller omfattes af AI løsninger, skal informeres tilstrækkeligt om, hvad et AI-system indebærer. Der indføres altså et undervisningskrav, så de involverede personer skal kunne forstå, evaluere og kritisk forholde sig til AI systemerne, der omgiver os.

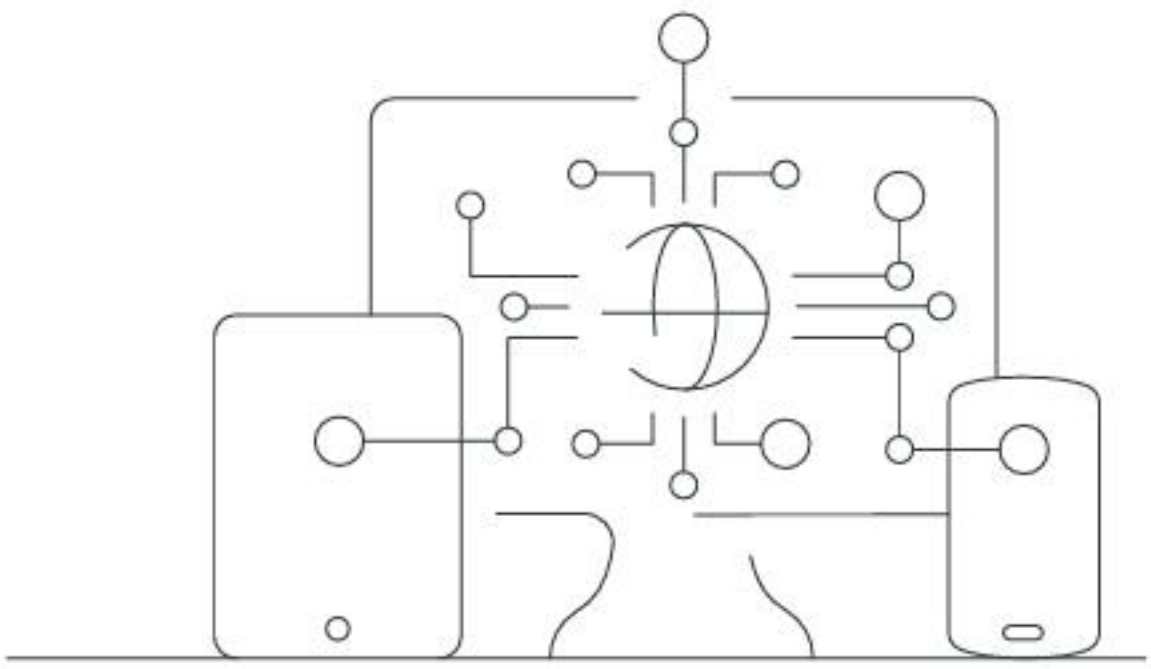
AI Act sætter en klassificering af AI systemer op med fire risikoniveauer. Nederst finder vi systemer, som vurderes at have minimal eller ingen risiko for skade på mennesker og miljø. Her finder vi f.eks. spam-filtre. Næste niveau af systemer er dem, der vurderes at have begrænsede risici, og her vil der være krav til et højt niveau af information og gennemsigtighed, herunder f.eks. chatbots. Dog skal formålet stadig vurderes, idet systemer som f.eks. anvender store sprogmodeller både kan være underlagt transparenskravene under begrænsede risikokategorier og samtidig placere sig i højrisikoen. I højrisikokategorien finder vi systemer som f.eks. AI i legetøj, fly eller medicinsk udstyr samt AI, der anvendes inden for blandt velfærdsydelser og kritisk infrastruktur. Her er der endnu et niveau af foranstaltninger og rapportering, som systemerne skal leve op til. Skulle man finde systemer med "uacceptable risici", som er det sidste niveau, vil disse systemer skulle tages ud af brug, da de er ulovlige efter AI acten.

AI Act

Hvad?	AI act er lovgivning med fokus på såkaldte "artificial intelligence" systemer, på dansk kaldet kunstig intelligens. Det vil sige systemer der fungerer med varierende grad af autonomi og som muligvis udvikler og ændrer sig efter de er taget i brug, på baggrund af det data som systemet får adgang til.
Hvem?	AI act har især fokus på både udbyder og bruger af AI systemer og sætter specifikke krav til de respektive aktører. De specifikke krav og forholdsregler, der skal følges, afhænger af individuelle risikovurderinger, som placerer AI systemer i en af fire risiko kategorier i AI act.
Hvorfor?	AI systemer har potentialet til at øge produktivitet og automatisere en række arbejdsopgaver på tværs af en række sektorer. Samtidig er man på tværs af EU opmærksom på, at der med brugen af AI systemer følger en række risici i forhold til borgernes demokratiske rettigheder, sundhed og sikkerhed, etik, miljøhensyn og beskyttelse af ophavsrettigheder.

5 vigtige pointer	**Omfattende** AI Act er den mest omfattende lovgivning om kunstig intelligens i verden og er designet til at regulere brugen af AI på tværs af private og offentlig sektor	**Risiko-baseret** Kravene til et AI systemerne afhænger af den etablerede risikoprofil. Dvs. formål og databrug er essensielt	**Husk øvrig lovgivning** AI act inter-agerer med den øvrige regulering, så husk også vurdering af om systemet er omfattet af GDPR, NIS2, osv.	**Nogle syste-mer forbydes** AI systemer, der vurderes at have uacceptable risici skal være udfaset senest 6 måneder efter AI Act trådte i kraft	**Helheds-orienteret** Lovgivningen indeholder bestem-melser om, hvordan AI-teknologi skal udvikles, testes og implemen-teres for at sikre, at den er sikker, pålidelig og gennem-sigtig

Figur 3.6 Om AI Act.



Er vores organisation omfattet?

Det kan kræve dyb juridisk viden og mange års erfaring med området at sætte to streger under, hvilke lovgivningsmæssige krav en virksomhed eller myndighed skal leve op til. Det har været, og er til stadighed, et stort forretningsområde for både konsulent- og advokathuse at hjælpe både myndigheder og virksomheder med at få overblik over, hvilke lovgivningsmæssige forpligtelser de har på området for cyber- og informationssikkerhed.

I denne bog vil vi dog give en kort introduktion til, hvordan man kan komme i gang med at se på, hvilke lovgivningsmæssige forpligtelser ens virksomhed eller myndighed er omfattet af. Værktøjet, vi anvender, kaldes "anvendelighedsvurdering" og kan bruges til at indkredse, om man som virksomhed eller myndighed er omfattet af en given lovgivning. Det er dog væsentligt at holde tungen lige i munden, og det er ofte en god idé at søge juridisk bistand i tvivlstilfælde.

Anvendelighedsvurdering – en metode til at vurdere, om virksomheden eller myndigheden er omfattet af en specifik lovgivning

En anvendelighedsvurdering er en systematisk proces, der bruges af organisationer til at bestemme, hvilke lovmæssige krav der gælder for dem. Det er selvsagt kritisk for organisationer at få overblik over, hvilke krav der gælder for dem, før de kan overholde dem. Her er fire generelle trin, man kan gå igennem for at vurdere, om ens organisation er omfattet af en given lovgivning eller ej:

1. Identificer omfang og kontekst

Bestem scopet for vurderingen ved at identificere de forretningsenheder, processer, produkter og tjenester, der skal dækkes.

2. Indsaml oplysninger

Indsaml relevante oplysninger om det juridiske og lovgivningsmæssige landskab, der kan påvirke organisationen. Det gælder både internationale og nationale regler, industristandarder og frivillige adfærdskodekser.

3. Forstå virksomheden

Skab overblik over organisationens forretningsmodel, drift og de specifikke aktiviteter, der kan være underlagt regulering (indenfor det scope, som er fastlagt i trin 1). Dette omfatter forståelse af data, anvendte teknologier, geografiske driftssteder og arten af interaktioner med kunder og leverandører.

4. Vurder anvendelighed

For hvert regelområde (som identificeret i trin 2) skal man vurdere, om lovgivningen gælder for organisationen. Dette indebærer at fortolke reglens omfang og krav og dernæst analysere, hvordan den vedrører organisationens aktiviteter. Dette trin kræver som oftest juridisk ekspertise for at sikre nøjagtig fortolkning.

Husk, at det også er en god idé at få dokumenteret, hvis det vurderes, at et bestemt stykke lovgivning ikke findes relevant for organisationen. Et veldokumenteret fravalg kan spare en for rigtig meget tid, hvis der på senere tidspunkt igen opstår spørgsmål i forretningen om, hvorvidt man er omfattet eller ej. I stedet for, at viden om fravalg går tabt blandt de medarbejdere, der var med til at udarbejde analysen, bør man få fravalget dokumenteret.

Det er afgørende at bemærke, at overholdelse af lovgivningen er en løbende proces, ikke en engangsforestilling. Regler kan ændre sig, og det samme kan organisationens aktiviteter. Øjne og ører skal holdes åbne, og det kræver kontinuerlig opmærksomhed at sikre, at virksomheden eller myndigheden har blik for, hvilke regler den skal overholde på området for cyber- og informationssikkerhed. Derfor kan det være relevant at indsætte aktiviteter omkring løbende opdatering af de lovgivningsmæssige forpligtelser i sit årshjul, der angiver vigtige aktiviteter i arbejdet med cyber- og informationssikkerhed. Processen kan være kompleks og teknisk, og det er ofte fordelagtigt at involvere eksperter eller juridiske rådgivere.

Med et overblik over, hvilke regler virksomheden eller myndigheden er underlagt, er det tid til at se på, hvordan man så rent faktisk kan leve op til kravene i lovgivning. Her anbefaler vi, som også tidligere nævnt, at man tager udgangspunkt i internationalt anerkendte standarder som f.eks. ISO 27001 og NIST, da de kan sætte retningen for et passede og dækkende niveau af cybersikkerhed. Dette dykker vi mere ned i i det kommende afsnit.

Hvordan hænger lovgivning og standarder sammen?

Lovgivning, som f.eks. NIS2, har til formål at øge cybersikkerhed på tværs af medlemslandene. NIS2 sætter krav og rammer for, hvad medlemslandene skal omsætte til national lovgivning. En standard som f.eks. ISO 27001 giver værktøjer og processer til at leve op til de fastsatte krav. Men selvom man bruger ISO 27001, betyder det ikke nødvendigvis, at alle krav fra NIS 2-direktivet er opfyldt. Det er vigtigt at tjekke grundigt, om man opfylder alle NIS 2-krav. Andre standarder, eller i princippet en helt egen-udviklet tilgang, kan også sikre, at organisationen lever op til de fastsatte krav. Opfordringen fra Industriens Fond er dog klar:

> *"Lad være med at opfinde noget, andre allerede har opfundet. Hvis andre har en god løsning, så brug da den! Større åbenhed om de gode løsninger, der bruges, er virkelig nødvendigt. Vi har for travlt, og truslen er for stor til, at vi gør det hele selv hver især."*
> Malene Stidsen, programchef for Industriens Fonds Cybersikkerhedsprogram

Internationale standarder og effektiv styring af cyber- og informationssikkerhedsarbejdet

For at arbejde effektivt med cyber- og informationssikkerhed er det vores anbefaling at gå systematisk til værks. En måde at gøre det på er ved at organisere styringen af arbejdet med udgangspunkt i et såkaldt ISMS (ledelsessystem) for cyber- og informationssikkerhed (se tekstboks nedenfor) eller rammeværk.

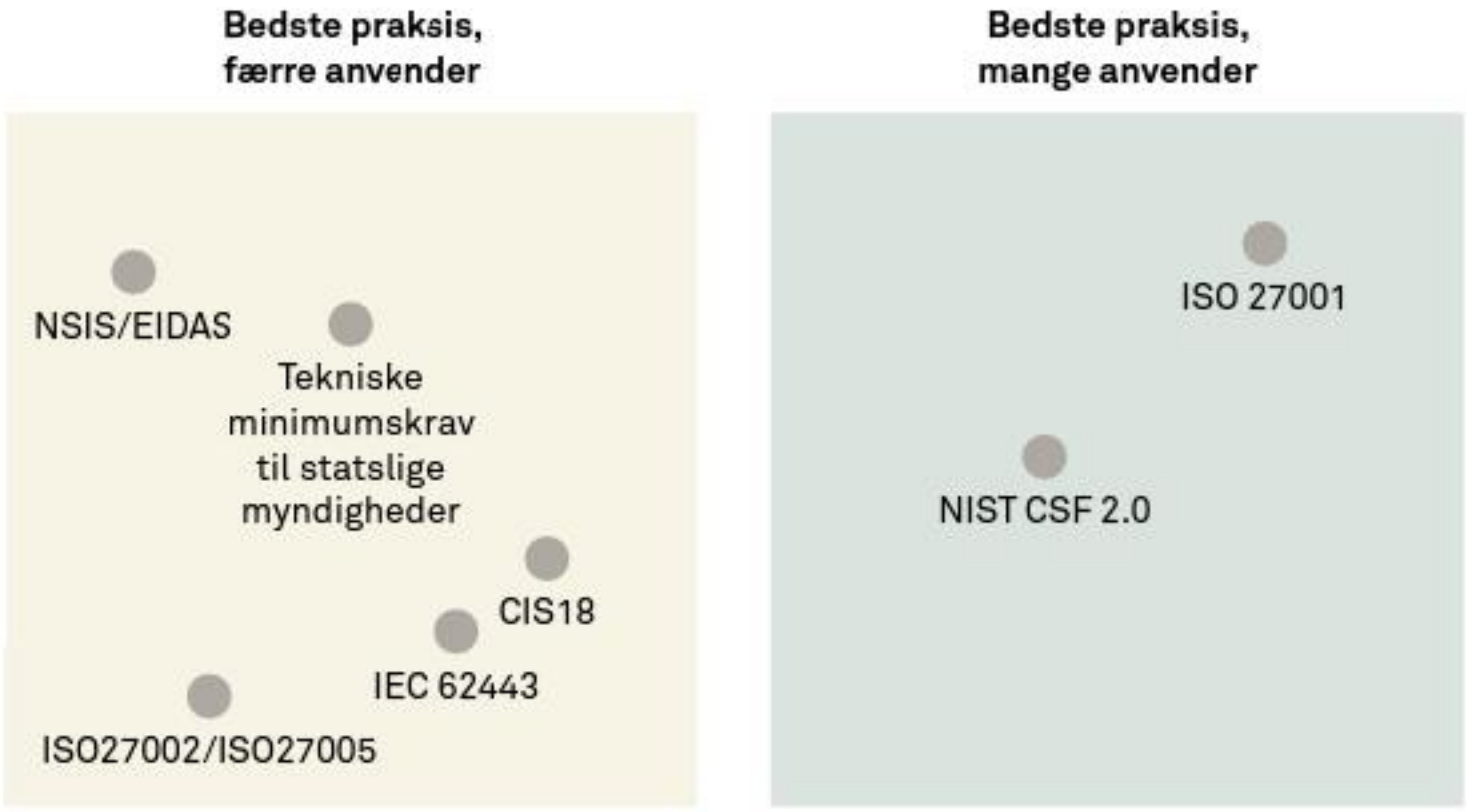
ISMS

ISMS står for "Information Security Management System", på dansk også kaldet "ledelsessystem for informationssikkerhed". Det refererer til en systematisk og struktureret tilgang til at styre virksomhedens informationssikkerhed, herunder politikker, processer, dokumentation og teknologier til at beskytte organisationens vigtigste oplysninger (Digitaliseringsstyrelsen, u.å.).

Det er en fordel at tage udgangspunkt i allerede anerkendte metoder, såsom som fx ISO 27001 eller NIST CSF 2.0, og bruge denne som en slags tjekliste eller vejviser. Grundlæggende er der en række fordele ved at anvende internationalt anerkendte standarder og rammeværk. Det giver f.eks. en systematik i arbejdet, og ved at anvende bedste praksis kan man også forvente et tilstrækkeligt og højt sikkerhedsniveau, der passer til organisationen.

Der findes en række forskellige standarder eller bedste praksis-værktøjer, som man som virksomhed eller myndighed kan tage udgangspunkt i. Vi har indsat en række eksempler i figuren nedenfor.

"Det er en kæmpe fordel at arbejde med standarder: Man sikrer at man kommer hele vejen rundt om et emne, man står på skuldrene af internationalt akkumuleret viden og erfaring, der findes rigtig mange færdige værktøjer man kan tage op af skuffen i stedet for at skulle bygge dem selv, man kan bechmarke sig op imod andre, man får et fælles sprog på tværs af teknikere og jurister, og man kan let dokumentere sine tiltag overfor omverdenen", udtaler Henning Mortensen, der er CISO og formand for Rådet for Digital Sikkerhed.



Figur 3.7. Bedste praksis og anerkendte standarder i Danmark

NSIS (forkortelse for "National Standard for Identiteters Sikringsniveauer") har fokus på digitale identiteter og identitetstjenester (tænk f.eks. "MitID", her er det vigtigt, at man har tillid til, at den digitale identitet er knyttet til den rigtige person) (Digitaliseringsstyrelsen, u.å.). Med CIS18 bevæger vi os over i den engelsksprogede verden, da CIS står for "Center for Internet Security". Hele titlen for CIS18 er "The 18 CIS Critical Security Controls". Det er med andre ord 18 udvalgte sikkerhedsforanstaltninger, som udgør en liste af cybersikkerhedsrelaterede aktivteter, som alle virksomheder, ifølge dette værktøj, *bør* indføre. Her skipper man så at sige henover en risikovurdering og siger, at der simpelthen er nogle emner, som er så essentielle, at de skal udføres lige meget hvad (herunder f.eks. styring af konti (account management), adgangsstyring (access control management) og træning (security awareness and skills training) (Center for Internet Security, u.å.).

Den samme tankegang ligger bag de "Tekniske minimumskrav for statslige myndigheder 2024". Igen er ideen her, at man ikke behøver en risikovurdering for at konstatere, at det er en ualmindeligt god idé at implementere firewall på alle klienter, at der ikke må anvendes tidligere lækkede passwords, og operativsystemer og apps på alle mobile enheder skal holdes sikkerhedsopdateret (for blot at nævne et par stykker) (Digitaliseringsstyrelsen, 2024). Endelig har IEC 62443-standarden særskilt fokus på industrien, f.eks. forsyningsanlæg, maskinanlæg, procesindustrien osv. (IEC, 2021).

Bevæger du dig i cybersikkerhedskredse, vil du formentlig støde på de ovenstående termer og forkortelser (NSIS, CIS18, tekniske minimumskrav og IEC 62443). Vi har dog valgt at dykke ned i de to standarder ISO 27001 og NIST CSF 2.0, som vi oplever har bredest anvendelse i virksomheder og myndigheder i Danmark. Bagefter giver vi forslag til ting, man kan overveje, når man skal finde ud af, hvilken standard man skal lægge sig op ad i sin virksomhed eller myndighed.

ISO 27001
– En struktureret og risikobaseret tilgang til cybersikkerhed

ISO ("International Organization for Standardization") er en organisation, der udvikler standarder, der finder global anvendelse, således også indenfor cyber- og informationssikkerhed. Hvis man har øje for detaljer (og det har folk,

der arbejder grundigt med disse standarder ofte), så vil man se, at den korrekte henvisning er "ISO/IEC 27001: 2022", fordi organisationen IEC (International Electrotechnical Commission) også indgår i arbejdet. Det er også værd at have "2022", fordi det er her, den senest blev opdateret. Det er dog ikke ofte, den opdateres – den udkom første gang i 2005 og blev sidst opdateret i 2013. Dansk Standard er vores nationale pendant til ISO og oversætter de udgivne standarder til dansk, da de i udgangspunktet er på engelsk.

ISO 27001 understøtter en risikobaseret metode til forbedring af cyber- og informationssikkerhed, hvilket udforskes nærmere i kapitel 3. Standarden præsenterer ikke blot en simpel tjekliste, men opfordrer virksomheder og offentlige myndigheder til aktivt at identificere og evaluere potentielle risici og sårbarheder, de måtte stå overfor. Ud fra denne vurdering skal de fastslå og implementere *passende* sikkerhedsforanstaltninger. En sikkerhedsforanstaltning (i tidligere ISO 27001:2013 kendt som en "kontrol"), er *"tiltag der bevarer og/eller ændrer en risiko. En foranstaltning kan være forebyggende, opdagende, korrigerende, eller en kombination af disse"* (Datatilsynet, 2023). I ISO 27001 finder man det såkaldte "Anneks A", som er en liste over sikkerhedsforanstaltninger, som alle (med udgangspunkt i organisationens generelle risikovurdering) skal analyseres. Organisationen skal således begrunde, om sikkerhedsforanstaltningen finder anvendelse eller ej. Denne analyse og vurdering samler man i et "SoA-dokument" (Statement of Applicability). Man kan finde en SoA-skabelon flere steder, f.eks. på SikkerDigital.dk (Digitaliseringsstyrelsen, u.å.).

ISO 27001 er en del af et bredere "ISO-landskab" med en række af standarder, der indbyrdes understøtter og komplementerer hinanden. F.eks. er ISO 27002 en slags vejledning eller "hjælpedokument" til en del af ISO 27001 og forklarer, hvordan sikkerhedsforanstaltningerne fra ISO 27001 kan implementeres. Der er god og konkret hjælp at hente i vejledninger til etablering af et ledelsessystem, fx på sikkerdigital.dk, hvor der er en vejledning i etablering og drift af et ledelsessystem for informationssikkerhed (ISMS) med udgangspunkt i ISO 27001 (Digitaliseringsstyrelsen, 2021).

Visse virksomheder er underlagt krav om at kunne fremvise certificeringer på deres cybersikkerhedsniveau. Dette gøres hos mange virksomheder ved at blive certificeret efter ISO 27001-standarden. Virksomheder, der formår at få

opbygget et stærkt ISMS, f.eks. ved at benytte ISO 27001-standarden, står et rigtig godt sted i forhold til at sikre, at deres sikkerhedsforanstaltninger er effektive og løbende opdateres, og de kan dermed nemmere opnå certificering, hvis det bliver aktuelt.

Der findes også en række private virksomheder, der udbyder undervisning og certificering i ISO 27001-standarden, så man som medarbejder kan blive klædt på til at arbejde med standarden. Træningsudbydere tager sig ofte ganske godt betalt for dette, så økonomi er bestemt også en faktor, man bør overveje.

ISO 27001

Figur 3.8. 5 hurtige om ISO 27001.

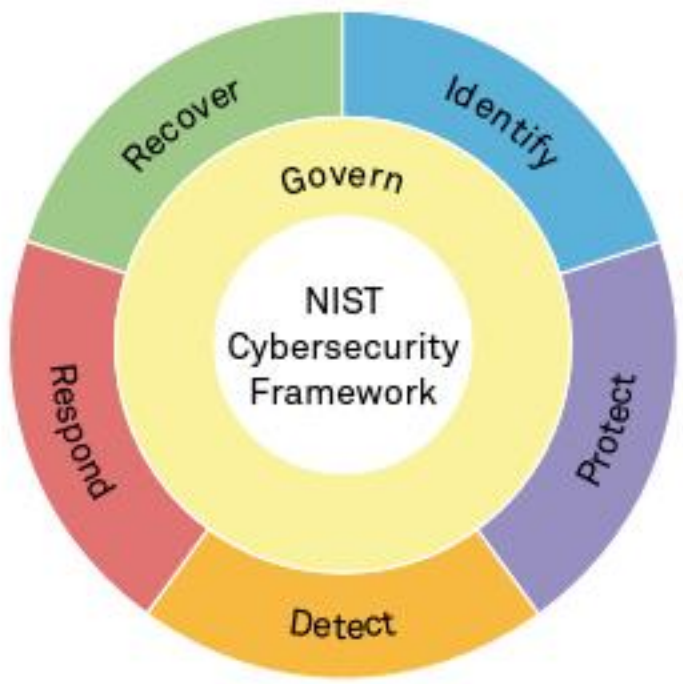
NIST Cybersecurity Framework (CSF) 2.0 – En amerikansk baseret og bredt anvendt tilgang til cybersikkerhed

Det amerikanske National Institute of Standards and Technology har udviklet rammeværktøjet NIST CSF 2.0, som anses for at være en bedste praksis (en metode), organisationer kan følge, når de ønsker at styre og nedbringe cyber-relaterede risici. Bemærk, at dette altså ikke er en "standard", man kan lade sin organisation certificere sig under. Derfor kaldes det i stedet et rammeværk, eller ofte med det engelske ord "framework".

NIST CSF 2.0 er meget anvendt i USA, men er også velanset og anvendt udenfor USA's grænser. NIST CSF var oprindelig udviklet til kritisk infrastruktur, men har fundet anvendelse også udenfor det felt. I dag, og særligt med opdateringen til NIST CSF 2.0, anvendes rammeværket i en række organisationer af meget varierende størrelse og med meget forskelligt modenhedsniveau indenfor cybersikkerhed. Heri ligger også en af styrkerne, nemlig at rammeværket kan tilpasses til organisationens behov. Dog ser vi i vores eget arbejde en tendens til, at det særligt er mellemstore og store organisationer, der benytter NIST CSF 2.0, da det trods ønsket om at være fleksibelt kan være ganske omfattende at anvende.

NIST CSF 2.0 anvender også en risikobaseret tilgang til cybersikkerhed, ligesom ISO 27001. Det vil sige, at vi endnu en gang her har et rammeværk, som ikke er en endelig tjekliste, men en tilgang, som organisationer kan læne sig op ad for at afdække relevante aspekter i deres arbejde.

NIST CSF beskriver det mål, der bør arbejdes henimod, men er ikke normativ i forhold til, hvordan en organisation kan nå derhen. For at finde specifik vejledning kan man så dykke ned i det univers af onlinevejledning, ressourcer og værktøjer, som der findes. NIST udgiver løbende publikationer, både quick guides og whitepapers, der – ligesom selve rammeværket – er ganske gratis.



Styring	Etabler og monitorer organisationens risikostyring Denne funktion sætter retningen for, hvordan de øvrige fem funktioner skal udføres
Identificér	Fastlæg de nuværende risici på cybersikkerhedsområdet
Beskyt	Understøt organisationens arbejde med at indføre og anvende sikkerhedsforanstaltninger, der forebygger eller nedbringer risici
Opdag	Find og analysér potentielle angreb og hændelser
Håndter	Reagér, når der er konstateret en hændelse
Genopret	Genopbyg aktiver og forretningsprocesser, når disse har været påvirket af hændelse eller angreb

Figur 3.9. De seks kernefunktioner i NIST CSF 2.0 (bemærk, vores oversættelse).

Ligesom der løbende udgives en mængde af støttedokumenter, opdateres rammeværket også jævnligt, og i hvert fald langt oftere end f.eks. ISO 27001. NIST CSF 2.0 indeholder derfor nu seks funktioner (her vores oversættelse til dansk): Identificér, Beskyt, Opdag, Respondér og Gendan (Computer Security Research Center, u.å.). Alle disse funktioner styres af styringsfunktionen "Styring" (på engelsk "govern"). Funktionerne kan ses som de "emner", en organisation skal omkring i sit cybersikkerhedsarbejde, og hver af disse brydes så ned i kategorier og derefter subkategorier. Hver subkategori præsenterer så et specifikt aspekt, som organisationen kan arbejde med.

Vi arbejder i Implement med organisationer, som bruger hele NIST CSF 2.0-rammeværket, men også med organisationer, som særligt bruger rammeværket til at vurdere modenheden af en organisation. Hvis en koncern har flere enheder rundtom i verden, kan NIST CSF 2.0 bruges til at vurdere, hvor godt hver enhed performer på tværs af de subkategorier, som hver funktion deles op i.

NIST CFS 2.0

Er et robust og internationalt anerkendt rammeværktøj. Og det hele er i øvrigt gratis.

Der findes rigtig gode vejledninger udarbejdet til forskellige typer af virksomheder, og derudover til henvisninger og vejledning til andre industrispecifikke sikkerhedskrav.

NIST CSF 2.0 kan også bruges til modenhedsvurderinger, som kan give et godt øjebliksbillede af organisationens situation.

Rammeværket er fleksibelt, men kræver et vist niveau af IT-kyndighed og kan være omfattende, særligt for små virksomheder.

Figur 3.10. 4 hurtige om NIST CSF 2.0.

Hvilken standard eller rammeværk skal man tage udgangspunkt i?

Når man skal afgøre, hvilken standard eller rammeværk man som virksomhed eller myndighed skal tage udgangspunkt i, er der en række faktorer, man skal overveje. Det er f.eks. organisationens specifikke kontekst, lovkrav, forretningsmål og kundeforventninger. Her er nogle overvejelser, der kan hjælpe dig med at beslutte, hvilken standard der er den rigtige for jeres organisation:

1. Lovgivningsmæssige og kontraktlige forpligtelser

- Er der reguleringsmæssige forpligtelser eller regler, der kræver overholdelse af den ene eller den anden standard? F.eks. er statslige myndigheder forpligtet til at følge principperne i ISO 27001.
- Er der kontrakter med kunder eller leverandører, der kræver brug af den ene eller anden standard?

2. Geografisk område som organisationen opererer i

- Hvor opererer din organisation geografisk? ISO 27001 har bred udbredelse i Europa, mens NIST CSF 2.0 almindeligvis bruges i USA og kan være en fordel, hvis man er på det amerikanske marked.

3. Branchens og kundernes forventninger

- Er der en bestemt standard, som historisk er anvendt i den branche eller sektor, din organisation er i?
- Har jeres kunder eller leverandører nogle forventninger til, hvilken standard I anvender?

4. Certificeringsmål

- Er der behov for at opnå en certificering, eller er det tilstrækkeligt med en selvvurdering eller erklæring fra tredjeparter?

5. Tilpasning til eksisterende praksis

- Er der en struktur, der passer bedre end andre til de nuværende informationssikkerhedspraksisser og -procedurer? Her kan man overveje, hvilke ressourcer og indsatser det vil kræve at implementere den ene standard i forhold til den anden baseret på din eksisterende sikkerhedstilstand.

6. Integration med andre ledelsessystemer

- Overholder din organisation allerede andre standarder (f.eks. ISO 9001 for kvalitetsstyring)? I så fald kan implementering af ISO 27001 give en mere problemfri integration med de eksisterende ledelsessystemer i forhold til andre standarder.

7. Ressourcetilgængelighed og ekspertise

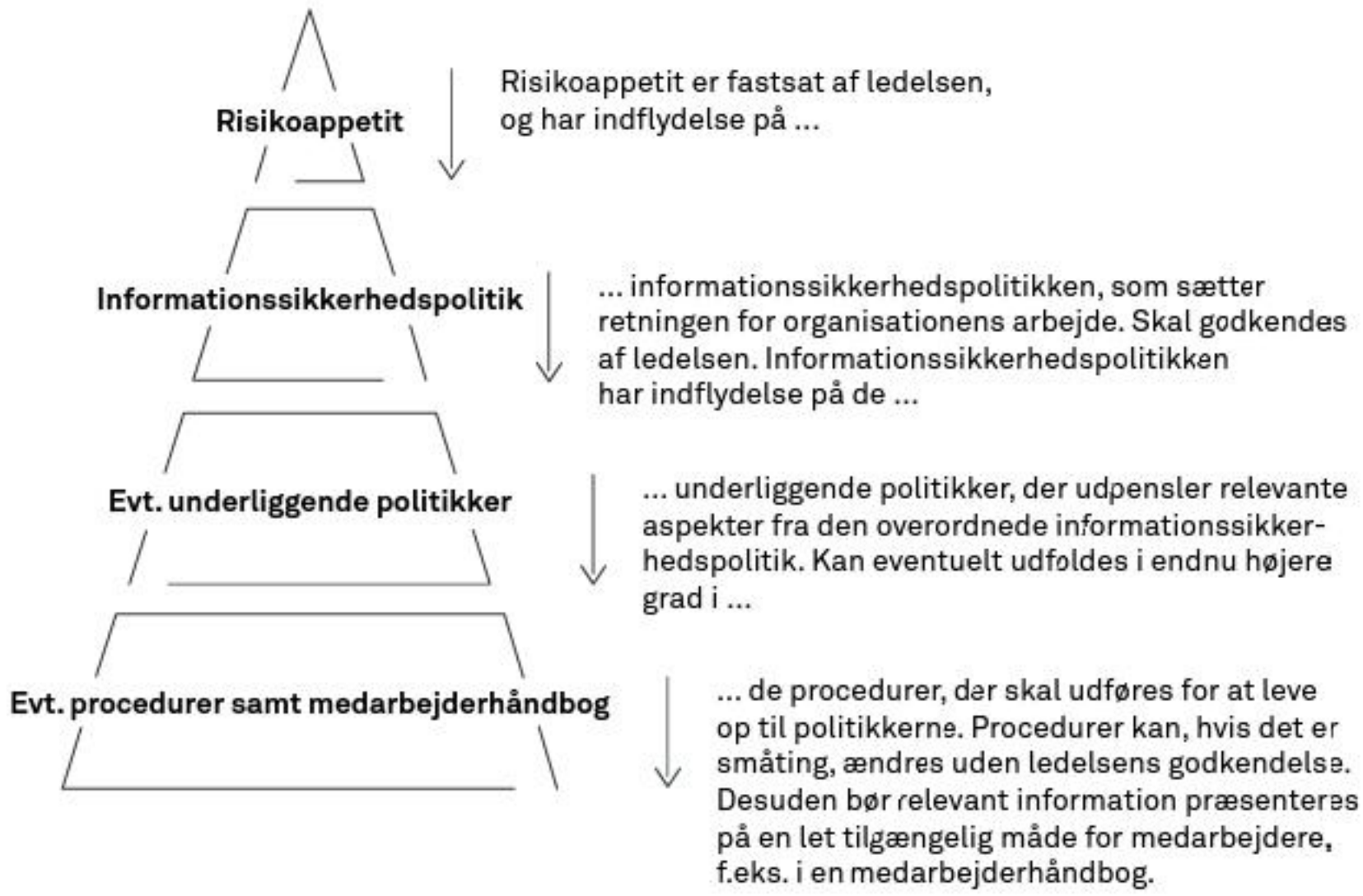
- Er der ressourcer eller ansatte i organisationen, der er bekendt eller har erfaring med den ene eller anden standard? Her kan man overveje de omkostninger og den indsats, der kræves for at uddanne medarbejdere, implementere standarden og opretholde overholdelse.

I vores erfaring kan virksomheder opleve, at man bliver fortabt i detaljer, og dermed bliver implementeringen af ISO 27001-standarden eller NIST CFS 2.0-vejledningen også for kompleks og ressourcekrævende. Her gælder dog den gyldne regel, at *"det perfekte må ikke blive det godes fjende"*. Husk, at begge tilgange lægger op til, at man simpelthen starter et sted og lægger en plan for det næste, der skal ske, og så tager det et skridt ad gangen. Rom blev ikke bygget på én dag.

Politikker for cyber- og informationssikkerhed

Effektiv styring af cybersikkerhed kræver helt enormt konkret og tydelig kommunikation, således at det er ligetil for alle at forstå, hvordan den retning, der er udstukket af ledelsen, så rent faktisk udføres i praksis. Dette kan opnås, hvis man har (og løbende arbejder med) effektive politikker. Følgende er skrevet med udgangspunkt i vores erfaringer med ISO 27001, men de gode råd og retningslinjer finder formentlig anvendelighed bredt set.

Et hierarki for de mest typiske styringsdokumenter kan visualiseres som vist i figuren på næste side.



Figur 3.11. Hierarki for politikker, procedurer og medarbejderhåndbog.

Et meget centralt element i ledelsen af cyber- og informationssikkerhedsindsatsen er *informationssikkerhedspolitikken*. Denne politik skal gerne være direkte i tråd med ledelsens risikoappetit. Det skal forstås på den måde, at hvis ledelsen helst ser en utrolig stram styring af cybersikkerhedsområdet, så nytter det ikke, at informationssikkerhedspolitikken siger, at organisationen arbejder med cybersikkerhed sådan lidt "ad hoc".

Informationssikkerhedspolitikken udstikker således retningen for cybersikkerhedsarbejdet i organisationen. Man kan næsten se det som en slags "kontrakt", som organisationen lover sine interessenter at overholde (Bayuk, 2024). Det er vigtigt her at huske, at en informationssikkerhedspolitik ikke indeholder referencer til eller beskrivelser af tekniske tiltag eller indstillinger. Det kommer første i senere, mere specifikke dokumenter, såsom underliggende politikker, eller måske endda først i proceduren.

Afhængigt af organisationens størrelse, modenhed, kompleksitet, og prioriteringer kan det være relevant at arbejde med flere underliggende politikker på området for cyber- og informationssikkerhed. De underliggende politikker vil typisk være mere uddybende og retningsanvisende end den overordnede

informationssikkerhedspolitik. I ISO 27002 er der listet en række eksempler på, hvilke underliggende politikker der kan være relevante at udarbejde. Det er f.eks. emnespecifikke politikker, hvor man sammensætter krav på tværs af emner relevante for din organisation (politik for leverandørforhold, politik for adgangsstyring m.m.).

Igen, det afhænger af organisationens størrelse og modenhed.

Har man behov for at gøre en arbejdsgang endnu mere tydelig, kan man udvikle en procedure, som hører til en specifik politik. Man kan med fordel gøre det visuelt, så det er tydeligt, hvordan politikkernes indbyrdes afhængighed er (f.eks. som i figuren ovenfor).

Fordelen ved at holde informationssikkerhedspolitik, underliggende politikker og dernæst procedurer separate er, at man ellers ville drukne i information, hver gang man skal slå noget op, og versionsstyring bliver et mareridt. Den overordnede informationssikkerhedspolitik sætter retning, og både den og de underliggende politikker skal igennem et større reviewarbejde og endelig godkendelse hos ledelsen, når der sker ændringer. En procedure er langt mere ligetil, helt ned til, hvilken knap man skal trykke på for at oprette en bruger eller opdatere et program. Det kan nå at ændre sig mange gange – og behøver ikke at komme til ledelsen for godkendelse.

I nogle, særligt større organisationer gør man også brug af "standarder" som et lag imellem politikkerne og procedurerne. Der er også holdninger til, at f.eks. processer og procedurer kan være forskellige. Der er på dette område, som med meget andet på cyber- og informationssikkerhed, smagsforskelle i, hvad folk foretrækker at kalde de forskellige dokumenter, og hvor meget det er nødvendigt at dele arbejdet op. I mange tilfælde vil opdelingen som vist i figuren ovenfor dog være alt rigelig, og det vigtigste er som altid, at man i sin egen organisation er skarp på, hvilke definitioner man bruger og hvornår.

Tjekliste til den effektive politik

Vi har (mere tekniske) kollegaer, der tørt har udtalt, at hackere er ret ligeglade med fine politikker. Og det har de jo ret i – politikker, der ligger for sig selv og ikke bliver anvendt, har ingen værdi. Vi kan dog tydeligt se, at i de organisationer, hvor man lykkes med at udarbejde og vedligeholde tydelige politikker (og dertilhørende tydelige procedurer), der er de et godt kommunikationsredskab,

der kan anvendes som opslagsværk af hele organisationen. Den overordnede informationssikkerhedspolitik kan også være en del af aftalegrundlaget med eksterne samarbejdspartnere (DIGST, 2021: 4). Endelig er det også et krav, hvis man følger ISO 27001-standarden, at ledelsen fastlægger en informationssikkerhedspolitik (med endnu mere vejledning at finde i ISO 27002 5.1 Politikker for informationssikkerhed).

Hvad enten man er underlagt krav eller ej, så resulterer tydelige politikker, i vores erfaring, i, at en organisation "går i samme retning", når det handler om cybersikkerhed, og hvor det er tydeligt, hvem der gør hvad.

ISO 27001 (5.2 Politik) lister en række punkter, der bør indgå i informationssikkerhedspolitikken, bl.a. at politikken skal "være passende til organisationens størrelse", at den skal omfatte "målsætning for informationssikkerhed", "kommunikeres internt" og "være tilgængelig for interessenter, hvis hensigtsmæssigt". Disse kan virke logiske og endda indlysende (bl.a. skal en politik være "dokumenteret", hvilket vil sige, at det ikke er nok at sige, at man "havde et møde om det"). Men hvordan man får det lige gjort – og så det står skarpt? Det kræver lidt øvelse, og man gør sig selv en stor tjeneste ved at stille sig selv følgende spørgsmål:

1. *Har topledelsen helt endeligt godkendt politikken og forpligtet sig til at sikre, at den føres ud i livet?*
   Det er som oftest CISO, der udvikler politikkerne (med god hjælp fra relevante medarbejdere), og det skal være CEO/topledelse, der endeligt godkender en politik. Vi har dog desværre set en del spildt arbejde på politikker, der aldrig nåede helt op på beslutningsniveau. Politikker er intet værd, før de er helt endeligt forstået, støttet og godkendt af ledelsen.

2. *Er det tydeligt, hvem der skal sørge for versionsstyring og løbende opdatering af alle dokumenter?*
   Det er ikke én person, der skal sidde med alt arbejdet her, men hvis det ikke uddelegeres, så sander politikkerne til i de delte mapper og foldere. Der skal være tydeligt ejerskab. I store organisationer kan der være helt utroligt mange dokumenter, så det kræver en del arbejde at opdatere og versionsstyre det hele.

3. *Hvordan kommunikeres de ændringer i arbejdsgange, som politikken måske resulterer i, og følger der ressourcer med til at udføre det arbejde, som politikken skitserer?*
   Hvis en politik resulterer i ændringer, der har indflydelse på specifikke jobfunktioner, er det da sikret, at dette kommunikeres videre til de jobfunktioner, og er der sat tid af i cybersikkerhedsteamet til at hjælpe dem på vej?

4. *Er der udarbejdet underliggende politikker, eller procedurer, således at politikken let(tere) kan implementeres?*
   Hvis disse ikke er udarbejdet, skal det udpeges, hvem der skal gøre dette. En politik for adgangsstyring kan f.eks. angive, at der i organisationen skal være sat en "passende adgangsstyring" og en gennemgang af tildelte rettigheder hver 3. måned. En procedure er så en "brugervejledning", der viser de relevante medarbejdere, hvordan de, i netop det program, de arbejder i, kan tjekke adgangstildeling.

5. *Er politikken skrevet i et tydeligt sprog?*
   En politik skal være tydeligt formuleret. "Bør" og "kunne" lyder som valgmuligheder, hvorimod "skal" forpligter.

Sikkerhedsforanstaltninger og kontroller

De sikkerhedsforanstaltninger som fastlægges af organisationen er vigtige et følge op på. Hvis man ikke kontrollerer sit setup kan man ikke vide om en foranstaltning virker og giver værdi for organisationen.

Regler kan udtrykkes som tekniske (TF) og organisatoriske (OF) foranstaltninger. En regel kan f.eks. være: Der skal foretages backup (TF). Backup'en skal være air-gapped (TF). Det skal testes at back-up'en virker (OF). Hver gang man har en regel, skal der være en kontrol, som gennemføres af en funktionelt (intern eller ekstern) uafhængig auditor. På baggrund af kontrollerne kan man rapportere status og fremdrift til ledelsen.

Hver gang man har en sikkerhedsforanstaltning, skal der være en kontrol, som gennemføres af en funktionelt (intern eller ekstern) uafhængig auditor. Kontrollerne skal derfor være: Kan organisationen demonstrere at der er taget

backup? Er backup'en genindlæst og kontrolleret, og er det dokumenteret at den virker? På baggrund af kontrollerne kan man rapportere status og fremdrift til ledelsen.

> *"Når man har en regel, skal man have en kontrol. Uden en kontrol kan man ikke dokumentere sin sikkerhed. Man kan heller ikke dokumentere sin compliance. Hvis det ikke er kontrolleret, er det ikke gjort"*, udtaler Henning Mortensen, CISO og formand for Rådet for Digital Sikkerhed.

En kort opsummering:

Lovgivning, politikker og standarder – Fra krav til virkelighed

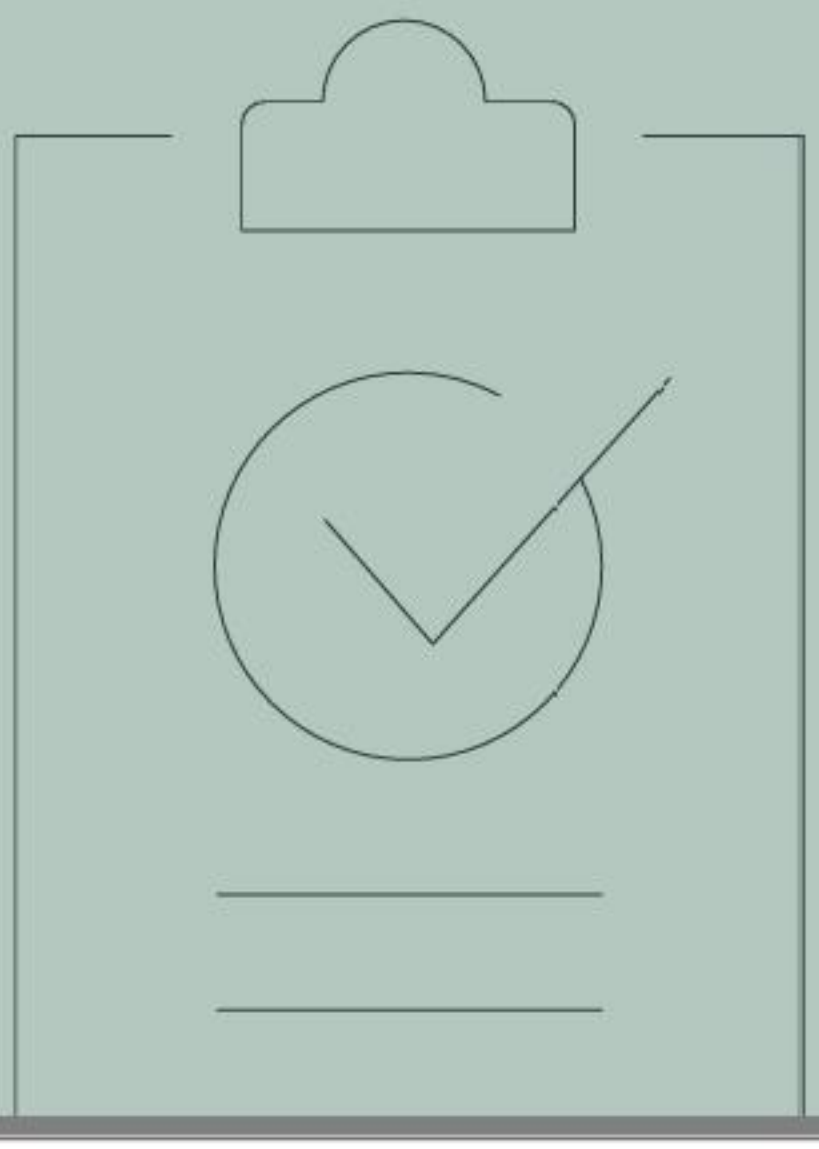
- Lovgivning gør det i stigende grad tvingende nødvendigt for flere organisationer at arbejde struktureret med cybersikkerhed – men der er faktisk konkurrencemæssige fordele ved arbejdet, hvis man tænker sig om.

- Lovgivning udvikler sig hele tiden, så det er nødvendigt løbende at genbesøge og vurdere, hvad man er underlagt af.

- I de fleste danske virksomheder og organisationer vil det, som medarbejcer indenfor cybersikkerhed, være en stor fordel at kende til NIS2 og GDPR og (hvis det er den finansielle sektor) DORA.

- Lovgivning siger, hvilke krav nogle omfattede organisationer skal leve op til, men ikke hvordan. Der er således mange veje, man kan vælge at gå, men det er en fordel at tage udgangspunkt i allerede anerkendte metoder, såsom f.eks. ISO 27001 eller NIST CSF 2.0, og bruge dem som en slags tjekliste eller vejviser.

- Effektive styringsdokumenter (politikker) sikrer, at alle i organisationen ved, hvor de skal lede efter svar på, hvad organisationens retning er indenfor cybersikkerhedsrelaterede spørgsmål. De kan desuden bruges aktivt til at sikre en ensartet kommunikation både internt og eksternt.



Case:

Craft & Styles Ltd. taber ordrer til konkurrenter

Craft & Styles Ltd. er en stolt dansk virksomhed, der siden 2007 har specialiseret sig i at udvikle og implementere IT-løsninger indenfor klimastyring af tøjproduktion. Craft & Styles Ltd.'s mission er at bidrage til overgangen til en mere bæredygtig og miljøvenlig styring af tøjproduktion ved at levere innovative og pålidelige IT-løsninger, der reducerer CO2-udledningen og fremmer brugen af vedvarende energi. Craft & Styles Ltd. har vokset sig store, og det næste kapitel i forretningseventyret hedder USA.

Virksomheden har siden sin grundlæggelse haft et stærkt ønske om at være first mover på teknologi og har fra start haft fokus på cybersikkerhed. Deres chef for IT har fungeret som chef for både IT-sikkerhed og cybersikkerhed og har over årene udarbejdet en række styringsdokumenter. Disse dokumenter findes i Word-format i IT-afdelingens arbejdsdokumenter og bliver kun sjældent opdateret. Ledelsen har meget stor tillid til chefens arbejde og godkender løbende udgifter til sikkerhedsforanstaltninger uden større diskussion i ledelsesgruppen. Ledelsesgruppen har set de politikker, chefen anvender, men de er ikke endeligt godkendt og har ikke været genbesøgt ved ændringer.

Craft & Styles Ltd. oplever nu oftere og oftere, at deres kunder henvender sig med spørgsmål til virksomhedens håndtering af cybersikkerhed. IT-chefen bliver i stigende grad frustreret, da der "jo altid har været godt styr på vores forretning!". Chefen når flere gange ikke at svare tilfredsstillende på forespørgslerne fra kunderne. Dette skaber store problemer for samarbejdet internt i virksomheden, og virksomheden taber flere gange store opgaver til konkurrenter.

Arbejdsspørgsmål

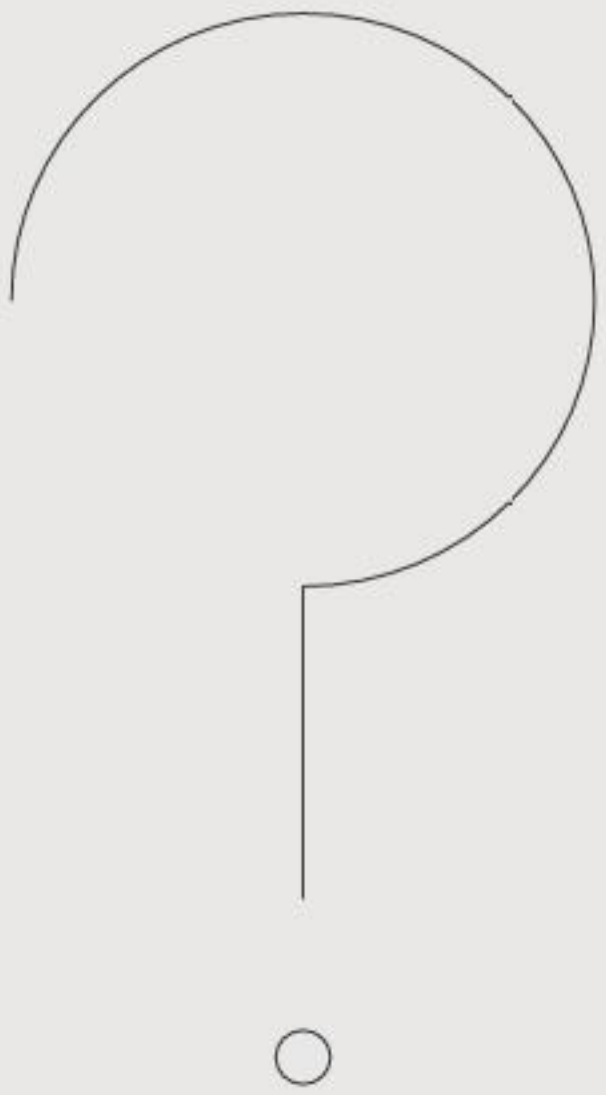
- Hvordan kan Craft & Styles Ltd. forbedre deres håndtering af cybersikkerhed – især med henblik på at udvide deres forretning til USA?

- Hvordan kan Craft & Styles Ltd. starte arbejdet med at vurdere, hvilken lovgivning de eventuelt er underlagt?

- Hvad er konsekvenserne af at have informationssikkerhedspolitikker og procedurer i Word-format, der sjældent opdateres? Hvad kunne virksomheden med fordel gøre anderledes?

- Hvordan kan virksomheden kommunikere deres engagement i cybersikkerhed til deres kunder og interessenter for at genoprette tilliden og forhindre tab af opgaver til konkurrenter?

- Hvilke konkurrencemæssige fordele kunne der opnås ved at arbejde mere struktureret med cybersikkerhed, og hvad ville det kræve for at opnå disse fordele?



Litteraturliste

Bayuk, J. L. (2024). Stepping Through Cybersecurity Risk Management. John Wiley & Sons.

Center for Cybersikkerhed (2024, 8. februar). Status på NIS2. Lokaliseret på: https://www.cfcs.dk/da/om-os/nis2/

Center for Internet Security (u.å.). The 18 CIS Critical Security Controls. Lokaliseret på: https://www.cisecurity.org/controls/cis-controls-list

Computer Security Research Center (CSRC) (u.å.). Cybersecurity Framwork CSF. Lokaliseret på: https://csrc.nist.gov/Projects/cybersecurity-framework/Filters#/csf/filters

DI Digital (2024, 23. februar). Ny analyse: 1079 virksomheder på tværs af 12 sektorer ser ud til at blive direkte omfattet af NIS2 direktivet.

European Council (2022, 28. november). Digital finance: Council adopts Digital Operational Resilience Act.

Datatilsynet (u.å.), Hvornår må du behandle personoplysninger? Lokaliseret på: https://www.datatilsynet.dk/hvad-siger-reglerne/grundlaeggende-begreber/hvornaar-maa-du-behandle-personoplysninger

Datatilsynet (u.å.). Lovgivning. Databeskyttelsesforordningen. Lokaliseret på: https://www.datatilsynet.dk/hvad-siger-reglerne/lovgivning

Digitaliseringsstyrelsen (2021, august): Vejledning i etablering og drift af et ledelsessystem for Informationssikkerhed (ISMS) med udgangspunkt i ISO 27001.

Digitaliseringsstyrelsen (2021): Vejledning i politikker for informationssikkerhed. SikkerDigital.dk.

Digitaliseringsstyrelsen (2024). De tekniske minimumskrav til statslige myndigheder 2024.

Digitaliseringsstyrelsen (u.å.). National Standard for Identiteters Sikringsniveauer (NSIS). Lokaliseret på: https://digst.dk/it-loesninger/standarder/nsis/ofte-stillede-spoergsmaal-om-nsis/

Digitaliseringsstyrelsen (u.å.). SoA-dokumentet. Lokaliseret på: https://www.sikkerdigital.dk/myndighed/iso-27001-implementering/forstaa-arbejdet-med-informationssikkerhed/soa-dokumentet

Digitaliseringsstyrelsen (u.å.). Ledelsessystem for informationssikkerhed (ISMS). Lokaliseret på: https://www.sikkerdigital.dk/myndighed/iso-

27001-implementering/forstaa-arbejdet-med-informationssikkerhed/ledelsessystem/

Europa-Kommissionen (u.å.). Data protection in the EU. Lokaliseret på: https://commission.europa.eu/law/law-topic/data-protection/data-protection-eu_en

Finanstilsynet (2023, 26. januar). Nye regler om cybersikkerhed i finanssektoren.

Implement Consulting Group (u.å.). DORA – The EU's Digital Operational Resilience Act. Lokaliseret på: https://implementconsultinggroup.com/topic/dora

International Electrotechnical Commission (IEC). Industrial communication networks – Network and system security. IEC 62443.

International Organization for Standardization (2022). Information Security, cyber security and privacy protection-Information security management systems-Requirements. Reference number ISO/IEC 27001:2022(E).

Lee, G. (2024, 15. marts). Cybersecurity Compliance: A definitive Guide. Security Daily Review. Lokaliseret på: www. https://dailysecurityreview.com/blog/a-definitive-guide-to-cybersecurity-compliance/

National Institute of Standards and Technology (2024, februar). The NIST Cybersecurity Framework (CSF) 2.0. Lokaliseret på: https://doi.org/10.6028/NIST.CSWP.29

Kapitel 4

Kapitel 4

Risikostyring:
Sæt ind, hvor det er vigtigst

> Alle organisationer er omgivet af risici, og i en foranderlig verden er risikobilledet under konstant udvikling. Risikostyring handler derfor ikke om at undgå risici, men at kende til sine risici og proaktivt at styre de ude- og indefrakommende risici, som organisationen står overfor. Når risikostyringen er effektiv, kan den blandt andet danne et bedre grundlag for strategisk prioritering, effektiv udnyttelse af ressourcer og opdagelse af fejl og svig."
>
> **Økonomistyrelsen, 2024**

Risikostyring i en kompleks og omskiftelig verden

Alle virksomheder og myndigheder står overfor en lang række store risici – også på området for cyber- og informationssikkerhed. Der er risiko for massive økonomiske tab grundet hacking eller menneskelige fejl, der f.eks. fører til datalækage. Derudover ændrer verden sig konstant. Risikostyring i en kompleks og omskiftelig verden kan derfor være en svær opgave. For hvad gør vi, når vi har svært ved at forudsige morgendagen og de trusler, der følger med? Det var nok de færreste, der i efteråret 2019 havde forudset, at vi seks måneder senere ville opleve nedlukning af Danmark som følge af en global coronapandemi. På samme måde kom det som et chok for de fleste, at der i 2022 udbrød krig i Europa, da Rusland angreb Ukraine.

Nogle hændelser – og dermed håndtering af deres konsekvenser – er svære at forudsige, mens andre hændelser i højere grad kan foregribes og kontrolleres af os. Risikostyring handler dog ikke om at eliminere risici fuldstændigt. Det handler i stedet for om, at vi som medarbejdere på sikkerhedsområdet er med til at sikre, at vores organisation tager stilling til, hvordan vi *håndterer* de risici, vi unægtelig står overfor (Ozkaya, 2022).

Risikostyring kræver klare processer, samarbejde på tværs af organisationen og involvering af de rette ressourcer. De fleste organisationer har begrænsede ressourcer, og der skal derfor prioriteres benhårdt, så der sættes ind, hvor det giver mest værdi. Alt dette kan en systematisk risikostyringsproces hjælpe med at understøtte.

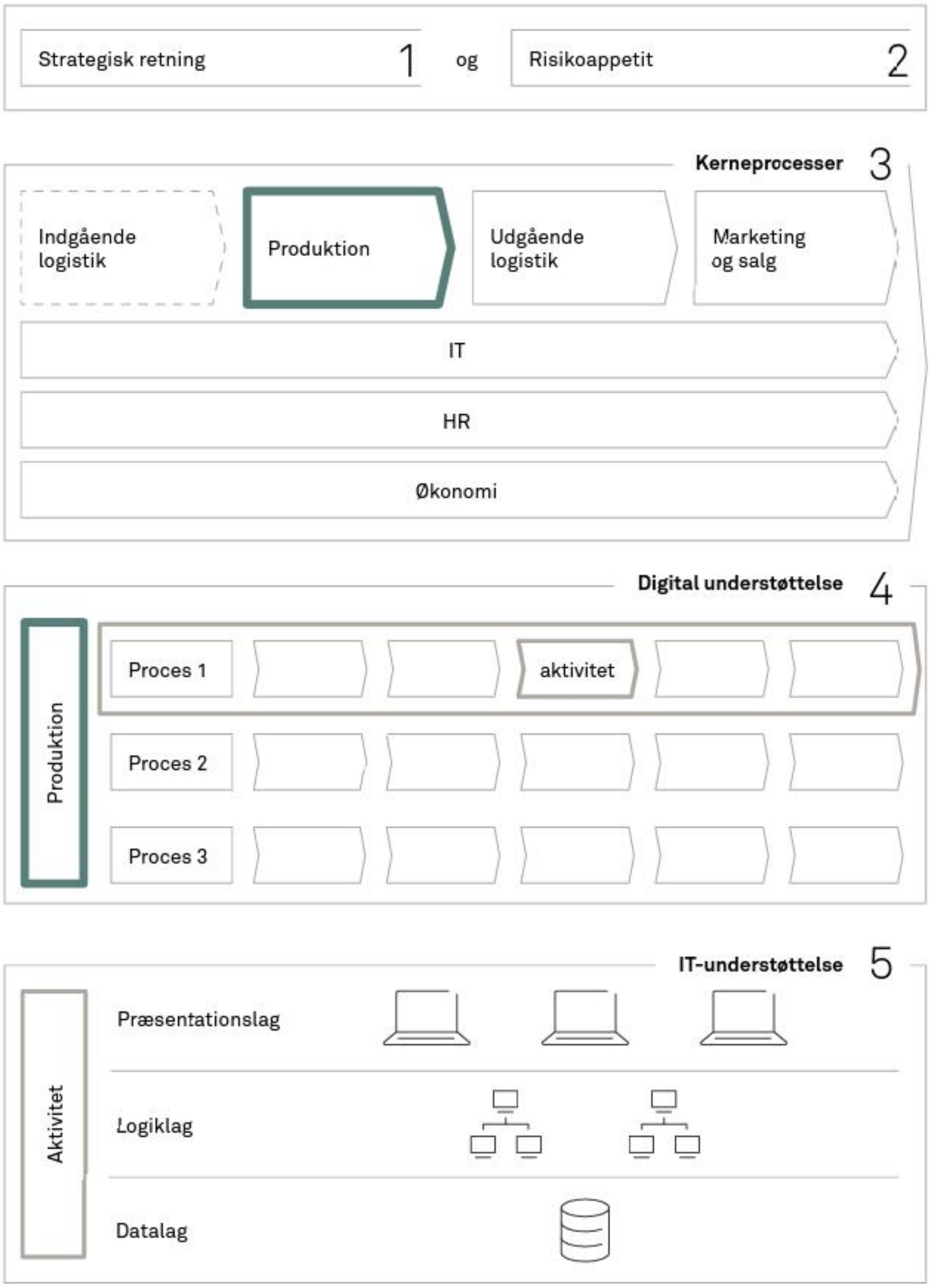
Risici på cyber- og informationssikkerhedsområdet er kun en delmængde af de samlede risici

Det er vigtigt at understrege, at risici på cyber- og informationssikkerhedsområdet kun udgør en delmængde af de samlede risici, som man som virksomhed eller myndighed står overfor og bør forholde sig til. Andre risici kan være f.eks. økonomiske eller miljømæssige. En effektiv håndtering af de samlede risici, som virksomheden eller myndigheden har, bør indgå i det, der kaldes Enterprise Risk Management (beskrevet i dybden i ISO 31000). Det kan både styres via standard Governance, Risk and Compliance-systemer, også kaldet GRC-systemer (Nicho et al., 2017) udviklet til formålet, eller i mere håndholdte Excel-ark. Uagtet valg af understøttelse er det centrale i håndteringen, at ledelsen får et overblik over, hvilke risici der er, og hvordan de kan håndteres på en overskuelig og fyldestgørende måde.

Kun med et klart og tydeligt overblik over de samlede risici kan organisationens ledelse træffe gode og velovervejede beslutninger på området for risikostyring.

I dette kapitel dykker vi nærmere ned i konkrete værktøjer til risikostyring. Kapitlet bygger videre på de emner og værktøjer, der blev præsenteret i kapitel 2, hvor vi gjorde det klart, at indsatser på cyber- og informationssikkerhed skal følge virksomhedens eller myndighedens overordnede mål og de digitale indsatsområder. I kapitel 2 understregede vi også, at der er visse dele af organisationen, der er vigtigere, for at en given organisation kan nå sine mål, end andre. Det er væsentligt at holde sig for øje, når man læser dette kapitel. I dette kapitel om risikostyring fokuseres på risikovurdering af IT-understøttelsen og i mindre grad på forretningsområder og processer.

I nedenstående tegning er det altså primært det nederste niveau i modellen, som vi fokuserer på i dette kapitel. Det er niveau 5 i nedenstående figur.



Figur 4.1. De fem lag i arbejdet med cyber- og informationssikkerhed – fra strategisk retning til IT-understøttelse.

I dette kapitel begynder vi med at forklare, hvad risici, trusler, sårbarheder og aktiver egentlig er. De fire begreber er vigtige at forstå for at arbejde med risikostyring på cyber- og informationssikkerhedsområdet. Derefter introducerer vi kort, hvordan rammeværker kan give stor værdi i forhold til at sætte retning i risikostyringsarbejdet. Dernæst dykker vi ned i risikostyringsprocessen og kommer med gode råd til, hvordan man kan arbejde med risikostyring i praksis. Med de rette værktøjer og metoder behøver det ikke at være så kompliceret. Risikostyringsarbejdet er dog ikke en "one-size-fits-all", men bør skaleres efter den enkelte organisations risikoprofil. Endelig ser vi nærmere på, hvordan man kan følge op på risikostyringsarbejdet, sikre sig de rette roller og ansvar i arbejdet, og endelig lister vi konkrete råd til, hvordan man kommunikerer omkring risikostyring.

I kapitel 6 ser vi nærmere på beredskabshåndtering, og hvordan man kan forberede sig til en krisesituation. Kapitel 6 skal altså også læses i tæt sammenhæng med dette kapitel.

Begrebsafklaring: Risici, trusler, sårbarheder og aktiver

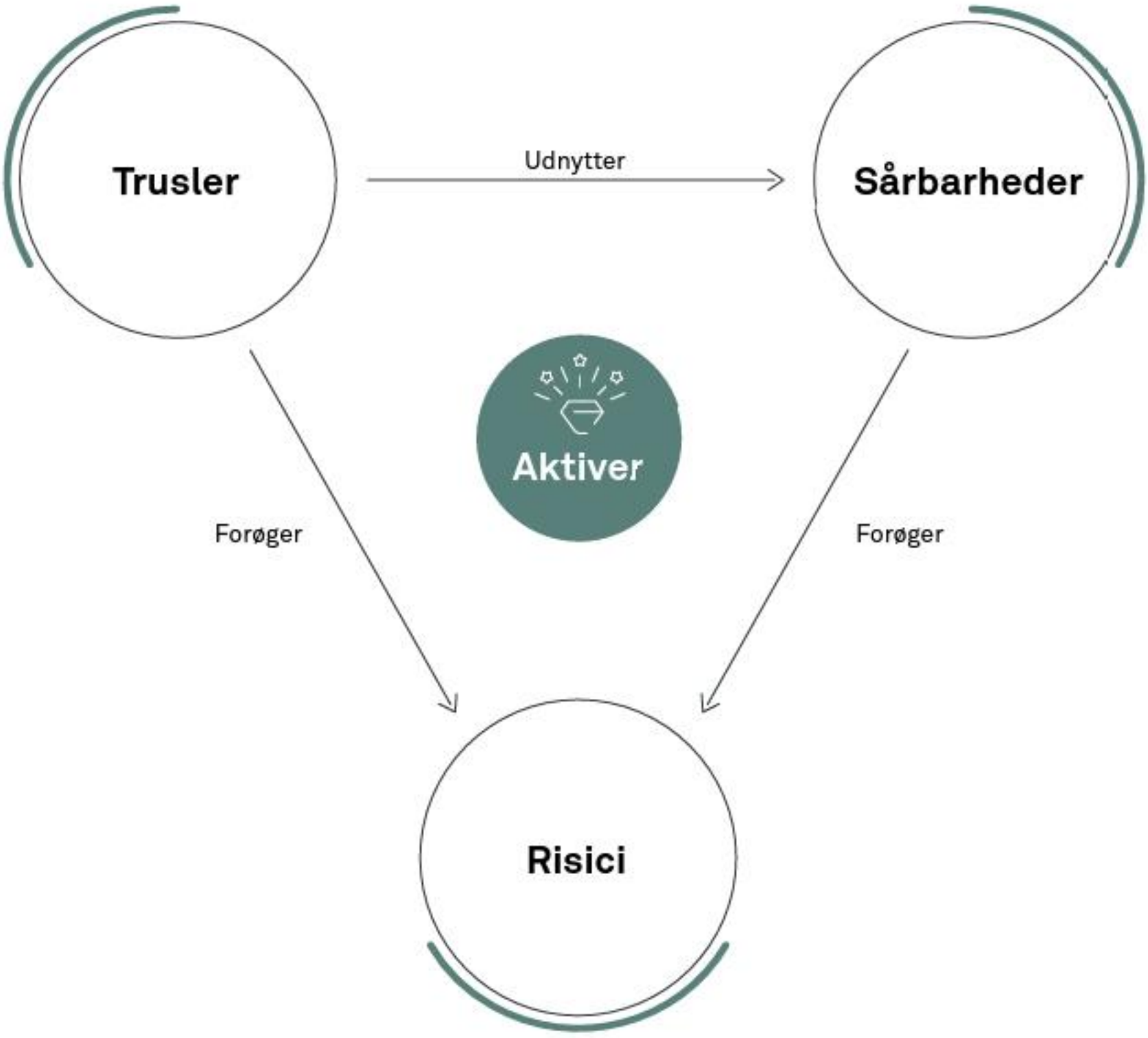
Før vi dykker nærmere ned i risikostyringsprocessen, og hvordan vi i praksis kan arbejde med risikostyring, er der en række ord og begreber, vi skal have på plads. For nogle kan det måske virke som en akademisk øvelse at skulle sortere i, hvorvidt en bestemt hændelse eller emne kan siges at være en trussel, en sårbarhed eller en risiko. Her er vores anbefaling dog, at det kan betale sig at være helt enig og konsekvent omkring det sprog, man bruger på tværs af organisationen, for hurtigere at nå til enighed og handling.

Som privatpersoner har vi f.eks. vidt forskellige holdninger til, i hvor god tid man skal være i lufthavnen inden afgang. "*Hvis vi misser flyet, så når vi ikke frem til vores hotel i aften, og så mister vi vores booking!*" siger den ene måske. "*Jamen, vi skal kun et stop med metroen – vi kan nærmest gå hen til lufthavnen*", siger den anden. Her er grobund for debat, blot i dette lille eksempel.

I en organisation er risici ofte mere komplekse end i lufthavnseksemplet, og de kan være svære at gennemskue. Men der er meget at hente ved et præcist sprogbrug, for taler vi faktisk om *helt* det samme her – eller er du i virkeligheden i gang med at vurdere konsekvensen af det missede fly, imens jeg er ved

at gå ned i, hvilke sårbarheder i transporten til lufthavnen vi står overfor? Et præcist sprogbrug kan gøre det lettere at mødes og nå til enighed, og derefter handling.

Nedenstående figurer viser de fire centrale begreber i risikostyring: aktiver, trusler, sårbarheder og risici.



Figur 4.2. Kernebegreberne i risikostyring: Trusler, sårbarheder og risici, der alle knytter sig til de aktiver, der er vigtige for organisationen.

Aktiv: En ressource, proces, produkt eller system, som skaber værdi for en organisation. Aktiver kan være materielle, såsom computere og hardware, eller immaterielle som f.eks. image. Ligeledes kan aktivernes værdi være materiel, f.eks. indkøbsprisen på en computer, eller immateriel, fordi den skaber komparative fordele for organisationen.

Trusler: En hændelse, der kan have en negativ eller uønsket effekt på et aktiv i en organisation. Hændelsen kan være menneskeskabt eller forårsaget af naturen.

Sårbarhed: En fejl eller uhensigtsmæssighed f.eks. i et IT-system, som medfører, at trusler skaber større negative eller uønskede effekter, eller at de har større sandsynlighed for at forekomme.

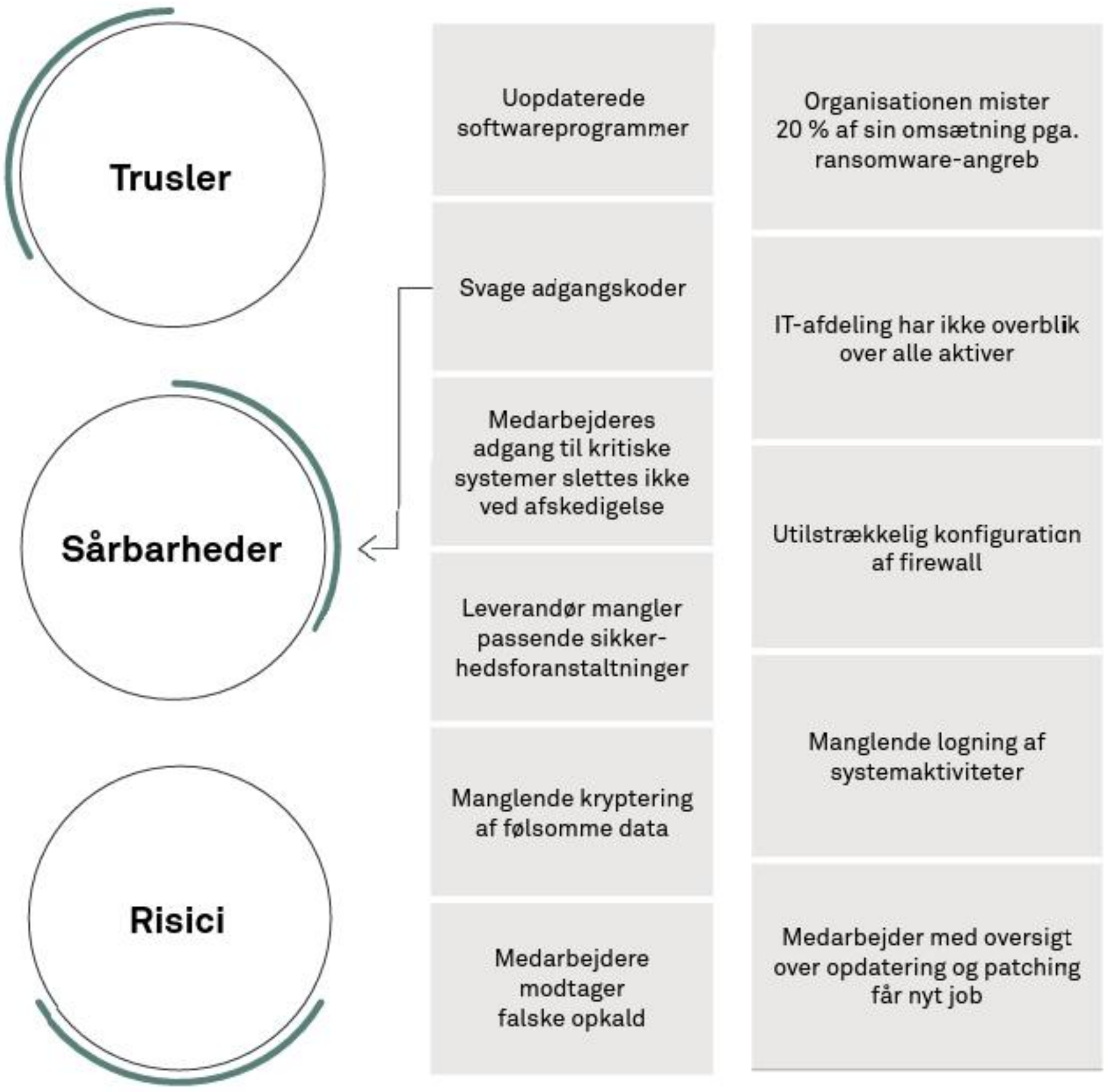
Risici: I ISO 27001 betegnes risiko som "effect of uncertainty on objectives" eller på dansk som effekten af usikkerhed på målsætninger. Selvom ISO definerer risiko som noget neutralt, vil vi ofte på dansk se det som en negativ eller uhensigtsmæssig påvirkning på målsætninger. Risiko måles ved at bedømme, hvor stor sandsynligheden er for, at en trussel vil kunne påvirke en sårbarhed, og hvor store konsekvenser det kan have (ISO 27001, Ozkaya 2022).

Lad os give et kort eksempel på hvert af disse begreber. Sårbarheder findes hos alle organisationer, men bliver først rigtig relevante, hvis der samtidig er en aktiv trussel. F.eks. kan det jo ske, at medarbejdere skriver et password til en computer ned og gemmer det under tastaturet. Det er særligt problematisk i det øjeblik, at en anden person med onde hensigter finder kodeordet og bruger det til at få uretmæssig adgang til vigtigste systemer på denne vis. I en anden situation kunne man have samme sårbarhed (kodeord skrevet ned), men hvis computeren f.eks. kun bruges til at kunne håndtere gæstebilletter til kantinen og ikke er koblet til noget som helst andet, er der formentlig ikke så mange IT-kriminelle, der vil gå efter den computer (ingen aktive trusler).

Det er også let at få øje på trusler, f.eks. phishing-e-mails, hvor IT-kriminelle forsøger at lokke informationer eller penge ud af medarbejderne (CFCS, u.å.). Men hvis medarbejderne er trænet til at spotte disse mails, og der samtidig er et stærkt spamfilter sat i værk, vurderes den samlede risiko formentlig lav (konsekvensen er selvfølgelig høj, hvis det lykkes de IT-kriminelle, men sandsynligheden i dette tilfælde er lav).

En "risiko" er således ikke bare en "risiko", men kræver en analyse af både, hvilken sårbarhed (eller sårbarheder) der ligger til grund, og om der findes aktive trusler. Dette skal sammen med en vurdering af konsekvens og sandsynlighed give et billede af den risiko, man står overfor.

Nedenfor finder du et par eksempler på trusler, sårbarheder og risici, der tager sit udgangspunkt indenfor cyber- og informationssikkerhedsområdet. Brug gerne 5 minutter på at læse disse igennem, og se, om du kan placere dem i de tre kategorier ovre til venstre. Det er ikke let – og det er pointen! Tænk over, hvilken information du ville skulle bruge for at kunne prioritere i opgaverne, og hvilke diskussioner det giver anledning til, når man skal dele dem ind i enten trusler, sårbarheder eller risici.



Figur 4.3. Test dig selv: Kan du identificere, om eksempler er trusler, sårbarheder eller risici? Hvilke informationer ville du skulle have adgang til for en detaljeret vurdering?

Rammeværker og standarder til risikostyring

Som på mange andre områder indenfor cyber- og informationssikkerhed er der indenfor risikostyring ingen grund til at opfinde den dybe tallerken. Der findes en række rammeværker og standarder, der indeholder glimrende redskaber, man kan tage udgangspunkt i, når man skal arbejde med at identificere risici og håndtere dem. Nogle af de mest anvendte er nedenstående:

- ISO 27005
- NIST SP800-37
- COBIT 5 fra ISACA
- ISO 31000.

I dette kapitel tager vi udgangspunkt i risikostyringsprocessen, der er i ISO 27005.

Risikostyringsrammeværkerne vil ofte pege på, at der er en række trin, det er anbefalelsesværdigt at tage, når man arbejder med at identificere og styre sine risici i en organisation. De typiske trin er:

1. Udarbejd strategier og politikker for risikostyring
2. Etabler en risikotolerance
3. Kategoriser systemer, data og infrastruktur
4. Foretag risikoidentifikation og vurdering
5. Håndter risici ved at implementere sikkerhedsforanstaltninger
6. Vurder sikkerhedskontrollerne i forhold til deres effekt
7. Monitorer sikkerhedskontrollerne.

Punkt 1-3 har vi gennemgået, hvordan man kan arbejde med, i kapitel 2. Vi ser nærmere på punkt 4-7 i dette kapitel. Først har vi dog brug for at se lidt nærmere på risikostyringsarbejdet helt overordnet.

Risikostyring på det rette niveau

Vi har som konsulenter set talrige eksempler på, at risikostyringsarbejde er blevet en tung papirtiger, der ikke skaber det rette overblik og beslutningsgrundlag for ledelser at handle på. Vi har mange gange set, at velmenende sikkerhedsmedarbejdere har slået op i databasen over IT-systemer og er begyndt at risi-

kovurdere it-systemer, der begynder med A, så B og så C osv., osv. Intensionen om at risikovurdere alle it-systemer er god. I praksis viser det sig dog hurtigt, at man kan miste pusten og overblikket over systemer, hvis vi tager udgangspunkt i en liste baseret på alfabetisk orden frem for, hvilke it-systemer der er vigtigst for vores organisations mulighed for at nå sine mål. Mange organisationer har flere 100 it-systemer, der kan risikovurderes. Det kan være enormt dyrt og tage alt for lang tid, og i sidste ende alligevel ikke give beslutningstagerne et operationelt og håndgribeligt overblik over de væsentligste risici.

Derfor peger flere rammeværker og standarder også på, at det giver mening at anskue risikovurderingen på en anden måde. De fleste rammeværker og standarder argumenterer for, at man laver risikostyring på flere forskellige niveauer. Ifølge ISO 27005 er der overordnet to forskellige niveauer, som man bør forholde sig til. Den ene er en overordnet risikovurdering, også kaldet "*high level information security risk assesment*". Den anden er en mere detaljeret risikovurdering, derfor ofte kaldet "*detailed information security risk assesment*". Forskellen på de to niveauer er, hvor meget man går i dybden med at beskrive risiciene. I risikovurderingen på overordnet niveau undersøger man *konsekvenserne* ved brud på datas fortrolighed, integritet og tilgængelighed, mens man i den detaljerede risikovurdering også går i dybden med at undersøge *sandsynligheden* for, at risikoen indtræffer, og også hvordan risikoen skal håndteres.

Den overordnede konsekvensvurdering svarer til den, vi har anbefalet og gennemgået i kapitel 2. Det handler om at finde de forretningsområder og processer og deres underliggende IT-understøttelse, hvor konsekvenserne ved kompromittering af datas fortrolighed, integritet og tilgængelighed er størst i forhold til organisationens mulighed for at nå sine mål. Ved at foretage den overordnede konsekvensvurdering, før man går i dybden med at se på sandsynligheden for, at noget kan gå galt, kan risikostyringsarbejdet fokuseres der, hvor det giver størst værdi.

Erfaringsmæssigt viser det sig ofte, at det ca. er 10-20 pct. af virksomhedens aktiver, der, hvis de bliver kompromitteret, har konsekvenser, der ligger over ledelsens risikotærskelværdi, og derfor er særligt vigtige for os at beskytte. Det er altså de 10-20 pct. af aktiverne, som er virkelig vigtige for at beskytte. Derfor er det også her, vi bør fokusere på at undersøge sandsynligheden for, at noget går galt, og hvordan det kan gå galt.

Figur 4.4 nedenfor viser et illustrativt overblik over en organisations aktiver på x-aksen. Y-aksen angiver de forretningsmæssige konsekvenser, hvis aktivet bliver kompromitteret i forhold til fortrolighed, integritet eller tilgængelighed. Vi anbefaler, at de forretningsmæssige konsekvenser opgøres kvantitativt og gerne i direkte og afledte omkostninger, da det er langt lettere at forstå og sammenligne konsekvenser på tværs af en organisations forretningsområder.

For at hjælpe forståelsen på vej har vi i tekstboksen herunder givet et eksempel på, hvordan man kan arbejde med at værdifastsætte konsekvensen, hvis et aktiv bliver kompromitteret.

Værdiansættelse af aktiver og konsekvenser ved kompromittering

Som nævnt kan aktiver både have en materiel og immateriel værdi. At arbejde med værdifastsættelse af aktiver og konsekvenserne ved evt. kompromittering gør risikostyringsarbejdet langt lettere for beslutningstagere at forholde sig til.

En måde at se på værdiansættelse af aktiver og deres konsekvenser ved kompromittering er ved at spørge finansafdelingen, hvad vi fx har indkøbt et givet aktiv for. Det kan være en maskine til produktion, en applikation, der understøtter en kerneopgave, eller en computer osv. Svaret fra finansafdelingen vil dog ofte ikke give os hele sandheden i forhold til, hvad aktivet er værd for os som organisation.

Hvis en ældre server f.eks. er involveret i en hændelse og må udskiftes, så er det ikke sikkert, at vi kan nøjes med at se på anskaffelsesprisen, som i dette eksempel kunne være 10.000 kr.

Det kan meget vel være, at det at udskifte serveren har langt højere omkostninger for os som organisation. Det kan være, at serverens nedetid gør, at vi ikke kan udføre vores kerneopgaver i produktionen, og at det derfor koster organisationen 5 mio. kroner på bundlinjen dagligt.

Det vil sige, at selve aktivet nok har en værdi på omkring 10.000 kr., men konsekvenserne ved et nedbrud, der medfører kompromittering af tilgængelighed, vil svare til en værdi for organisationen på 5 mio. kr. dagligt.

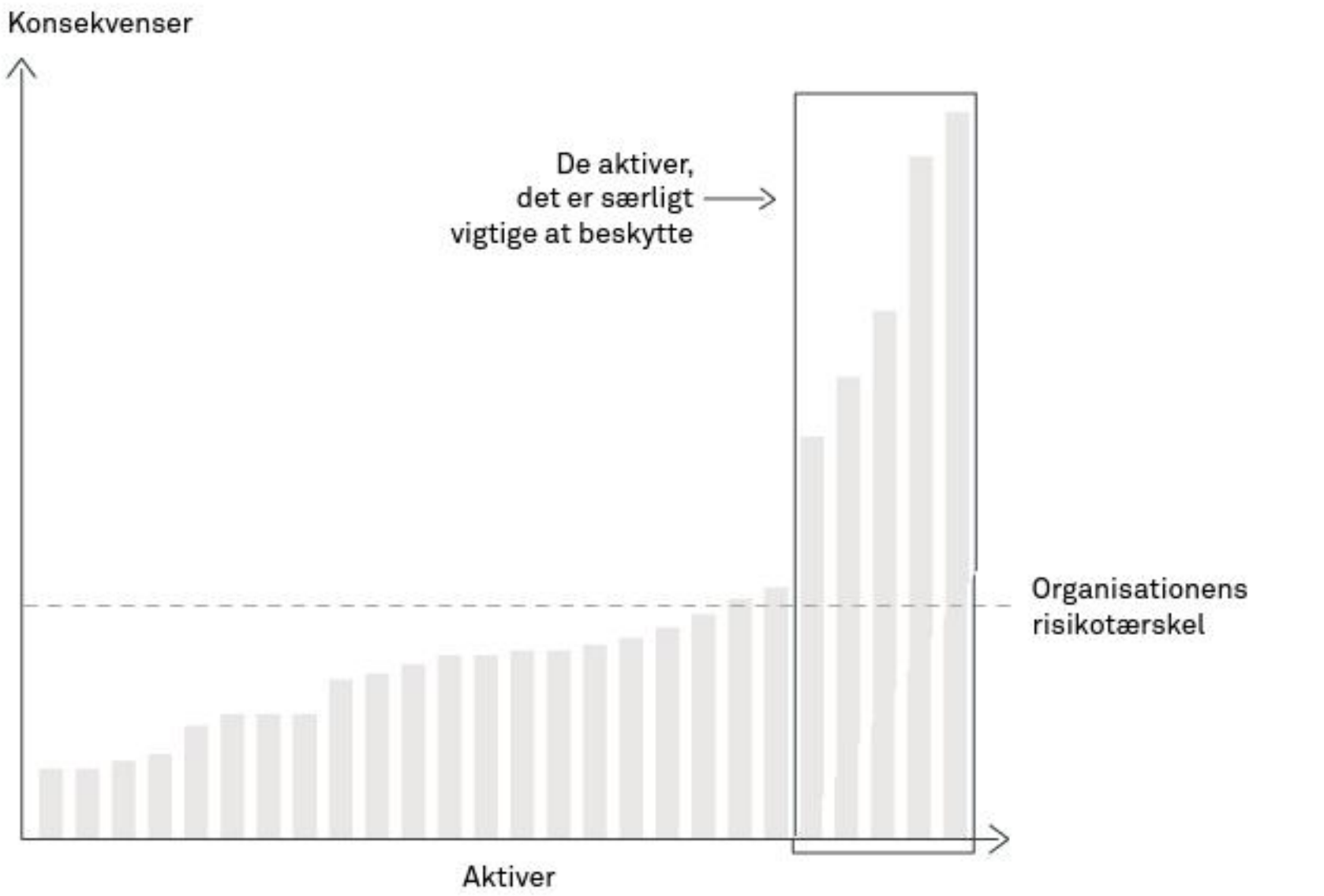
Det vil sige, at selve aktivet nok har en værdi på omkring 10.000 kr., men konsekvenserne ved et nedbrud, der medfører kompromittering af tilgængelighed, vil svare til en værdi for organisationen på 5 mio. kr. dagligt.

Har ledelsen fastsat en risikotærskelværdi, der siger, at organisationen kan leve med tab på 1 mio. kr. dagligt, ja så betyder det, at netop denne server vil høre med i aktiver, der er kritiske for organisationen.

Ved at arbejde systematisk med værdifastsættelse af konsekvenser ved aktivers kompromittering får organisation følgende fordele:

- Understøtter en cost-benefit-baseret tilgang til risikostyring, hvor vi har mulighed for at se på en business case, før vi sætter investeringer i gang
- Kan være med til at understøtte en beslutning om evt. investering i forsikringer på cyber- og informationssikkerhedsområdet
- Hjælper med at skabe mindre personafhængighed i sikkerhedsarbejdet, fordi vi arbejder hen mod mere objektive vurderinger
- Bidrag til kvantitativ og kvalitativ risikovurdering, Business Impact Analysis (se kapitel 6) og IT-sikkerhedsrevision.

De aktiver, som hvis de bliver kompromitteret, har konsekvenser, der ligger over organisationens risikotærskelværdi, er de aktiver, som vi skal være særligt opmærksomme på. Fordi aktiver kan være processer, produkter eller systemer, er det vigtigt at gøre sig klart, hvilket niveau man arbejder på. For IT-systemers vedkommende vil mange organisationer kalde de systemer, der ligger indenfor den blå boks, for organisationens kronjuveler. Kronjuveler skal man jo som bekendt passe rigtig godt på. Vær opmærksom på, at IT-kronjuveler ofte beskyttes på linje med andre IT-systemer, og derfor kan deres risikoeksponering være tæt forbundet med mindre værdifulde aktiver.



Figur 4.4. Visualisering af organisationens aktiver, konsekvenser ved kompromittering og den organisatoriske risikotærskel.

Risikostyringsprocessen – fire faser til effektiv risikostyring

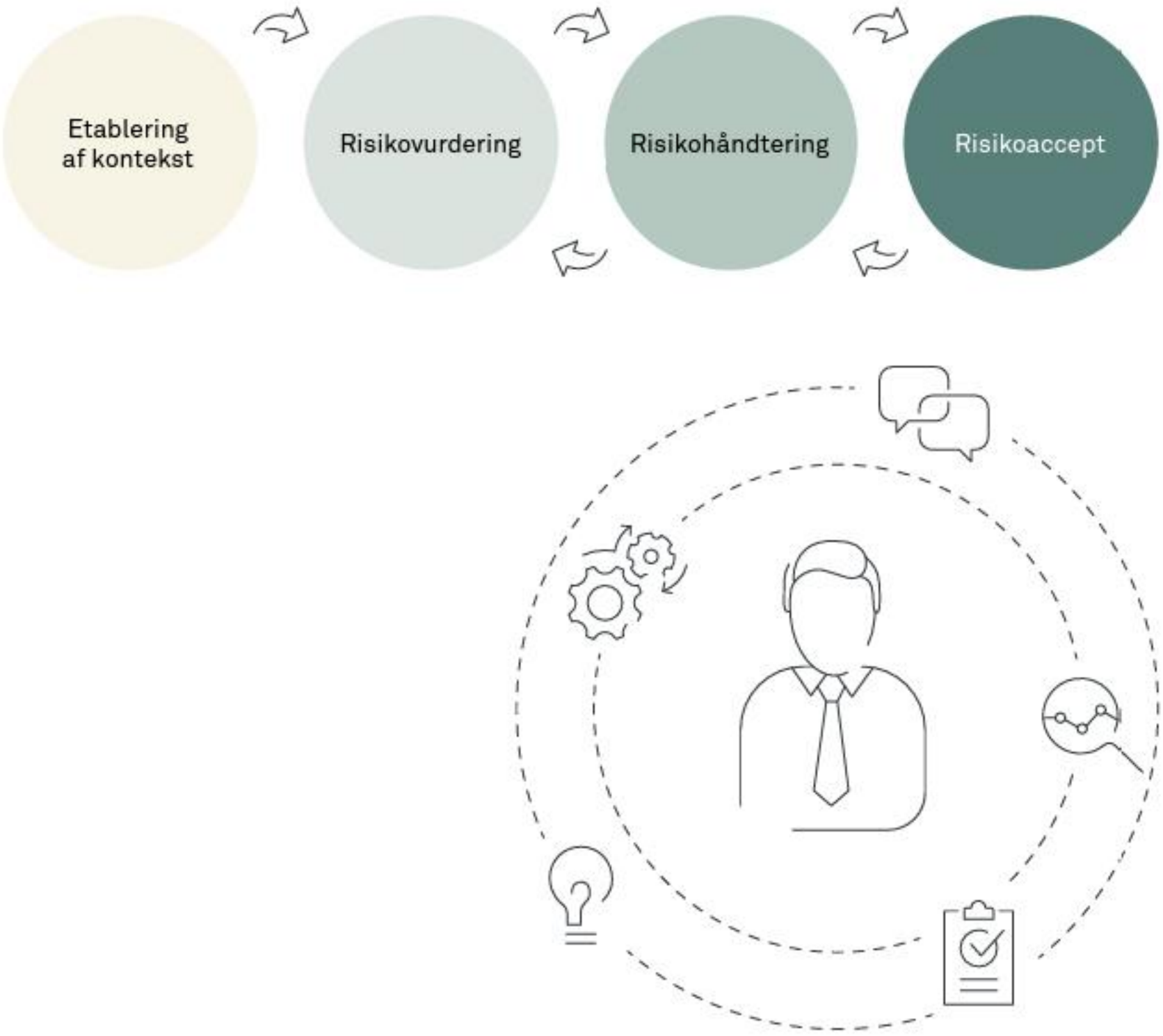
Med begreberne introduceret er vi klar til at dykke ned i risikostyringsprocessen, der sætter ledelsen i stand til at prioritere ressourcerne i forhold til, hvor de gør mest gavn. Risici hverken kan eller skal fjernes helt, men med en systematisk tilgang er det muligt at forholde sig til, hvor meget organisationen vil investere for at reducere en given risiko til et acceptabelt niveau. Som med så mange andre ting er risikostyring måske svært i starten, men med tid og øvelse bliver det lettere, og man finder i sin organisation forhåbentlig en fælles forståelse for sproget og fremgangsmåden.

Der er flere måder at gå til arbejdet med risikostyring på. Som konsulenter ser vi dog ofte, at organisationer gerne vil gøre brug af internationalt anerkendte standarder på området. Det er der flere grunde til. For det første giver det mulighed for at få et fælles sprog, og for det andet kan det give en konkurrencemæssig fordel at benytte sig af f.eks. ISO 27000-serien eller NIST CSF, og

endelig kan det være lettere at vedligeholde arbejdet, når nye medarbejdere kommer til.

I vores gennemgang af risikostyringsprocessen tager vi udgangspunkt i ISO 27005, som uddyber risikostyringsprocessen (Bogush, 2022). Standarden bygger på en mere generel og generisk tilgang til risikoarbejde i organisationer, som findes i en anden ISO-standard, nemlig ISO 31000. Risikostyringsprocessen fra ISO 27005 går hånd i hånd med kravene fra ISO 27001 (se mere om ISO 27001 i kapitel 3: Lovgivning, standarder og politikker).

Der findes et væld af illustrationer af risikostyringsprocessen, også når man tager udgangspunkt i ISO 27005-standarden. Nogle er så detaljerede, at de kan være svære at finde rundt i. Vi kan godt lide at holde det simpelt og sige, at der overordnet set er fire hovedfaser:



Figur 4.5. Fire faser i risikostyringsprocessen.

Pilene i figuren skal vise, at det sjældent er en helt lineær øvelse at gå igennem disse faser, men at man netop ofte har brug for at genbesøge materiale fra tidligere eller justere, i takt med at man bliver klogere. Vi argumenterer dog også for, at det kan være en god idé også at insistere på at "afslutte" en fase (i hvert fald for en stund) for at komme videre til prioriteringer og beslutninger.

I de kommende afsnit dykker vi dybere ned i indholdet i hver af de fire faser.

Fase 1: Etablering af kontekst

Den første fase i risikostyringsprocessen er at få styr på konteksten, jf. den gule markering i figuren herunder.

Før man går i gang med at implementere den store og forkromede risikostyringsproces, bør man have en forståelse for den kontekst, som risikostyringen skal fungere i. Dette gøres for at sikre, at sikkerhedsindsatsen går hånd i hånd med både organisationens overordnede mål og de indsatser, der er sat i søen på teknologi- og digitaliseringsområdet.

I de foregående kapitler har vi været inde på, hvad der ligger i at etablere en god forståelse for konteksten. Opsummeret handler det om at få en fælles forståelse for:

- Hvilke mål har organisationen?
- Hvilke forretningsområder eller kerneopgaver er særligt vigtige for, at organisationen kan nå de fastsatte mål, og hvordan understøttes disse af teknologi?
- Hvad opfattes som alvorlige konsekvenser for organisationen – har organisationen en afstemt risikoappetit?
- Hvordan ser det generelle trusselsbillede ud for organisationen?

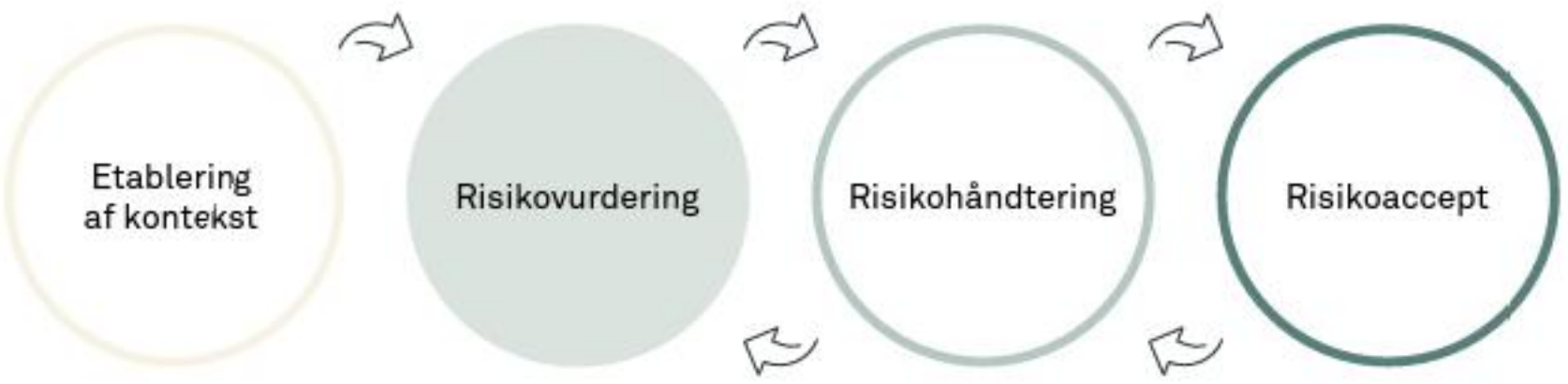
Når man har taget stilling til, hvem vi er som organisation, og dermed scopet for risikovurderingen, skal vi også i fasen "Etablering af kontekst" definere afgrænsningen af risikovurderingen. Det kan både være den organisatoriske, fysiske og tekniske afgrænsning. Risikovurderingen bør i udgangspunktet omfatte hele virksomheden eller myndigheden, og en afvigelse af dette bør have en god grund. At risikovurderingen bør omfatte hele organisationen, er ikke modstridende med, at vi fokuserer på de områder, der er særligt vigtige for os som organisation. De områder har vi jo identificeret ud fra en risikobaseret tanke og tilgang.

Husk også, at det er vigtigt at få etableret en metode til risikovurderingen samt roller og ansvar for risikostyringsprocessen. Se eventuelt mere om roller og ansvar i kapitel 4.

Man kan med fordel samle output fra "Fase 1: Etablering af kontekst" i et samlet produkt, som kan kommunikeres bredt i virksomheden. I den bør der være informationer om organisationens holdning til risici, herunder hvilke risici der styres og hvordan, hvilken målsætning vi har med risikostyringsarbejdet, hvordan vi organiserer arbejdet, måler, monitorerer og rapporterer på risici. Den kan også med fordel indeholde et årshjul, der viser, om opfølgning og rapporteringen sker kvartalsvis, halv- eller helårligt. Se mere om årshjul sidst i dette kapitel.

Fase 2: Risikovurdering

Risikovurderingen er fase 2 i risikostyringsprocessen, jf. den gule markering på figuren herunder.



Dette er rygraden i risikostyringsarbejdet. Når vi laver risikovurderinger, så ser vi på, hvad konsekvensen ved en hændelse vil være, og også hvor stor sandsynligheden er for, at hændelsen indtræffer. Risikovurderingsfasen består af tre på hinanden følgende aktiviteter ifølge ISO 27005. De tre aktiviteter er:

1. **Identifikation af risici:** Det første skridt i risikovurderingen er at identificere de forskellige sikkerhedsrisici, der kan påvirke organisationens informationssystemer. Dette omfatter identifikation af værdifulde aktiver, trusler, sårbarheder og eksisterende kontrolforanstaltninger.

2. **Risikoanalyse:** Efter at have identificeret risiciene skal de analyseres for at forstå sandsynligheden for, at en given trussel udnytter en sårbarhed, og hvilken indvirkning det ville have på organisationen. Dette kan gøres gennem kvalitativ eller kvantitativ risikoanalyse, som beskrevet tidligere.

3. **Risikoevaluering:** I denne fase vurderes risiciene for at bestemme deres relative prioritet. Dette indebærer typisk at rangere risiciene baseret på deres sandsynlighed og konsekvens, hvilket resulterer i en risikovurdering, der hjælper med at guide beslutningstagningen om, hvilke risici der skal behandles og hvordan.

I det følgende dykker vi nærmere ned i, hvordan man kan komme igennem de tre aktiviteter i risikovurderingen. Vi begynder med risikoidentifikation.

Identifikation af risici

Formålet med risikoidentifikationen er at få overblik over potentielle tab – dette både i forhold til hvor, hvordan og hvorfor der kan ske tab. Identifikationen af risici bør omfatte hele organisationen. ISO 27005 anbefaler, at man følger fire skridt for at komme hele vejen rundt om risikoidentifikationen. De fire skridt består af identifikation af:

1. Aktiver
2. Trusler
3. Sårbarheder
4. Konsekvenser.

I figuren nedenfor uddyber vi de fire begreber, og hvad man skal være opmærksom på.

Aktiver

Et aktiv er alt, der har værdi for en organisation, og som derfor skal beskyttes. Det kan være en lidt svær størrelse at arbejde med, og derfor anbefaler vi, at man går til identifikationen af aktiver ved at se på forretningsprocesser.

Ved at se på, hvad organisationen "laver" (producerer, behandler, udvikler, etc.), kan vi få en forståelse for, hvad der vil ske, hvis en hændelse indtræffer, og forskellige forretningsprocesser ikke kan gennemføres.

Når forretningsprocesserne er kortlagt, skal det undersøges, hvilke forudsætninger der er til stede, for at disse processer kan fungere ved normal drift. Der er f.eks. ofte brug for IT-systemer, der indeholder data, og som beror på infrastrukturkomponenter såsom servere, databaser etc.

Trusler

For at få et fyldestgørende overblik over organisationens risici skal der også dannes overblik over de trusler, der potentielt kan skade relevante aktiver.

Man kan systematisk gå til arbejdet med at identificere trusler ved at benytte sig af trusselskataloger. De er at finde f.eks. fra efterretningstjenester. Ved at gennemgå trusselskataloger kan man pejle sig ind på, hvilke trusler der er relevante for de udvalgte aktiver.

Sårbarheder

For at en trussel kan manifestere sig i en hændelse i organisationen, kræver det, at der er en sårbarhed, der kan udnyttes.

En sårbarhed kan findes i mange forskellige henseender, f.eks. i processer, fysiske lokationer, IT-systemer eller hos eksterne leverandører.

For at identificere sårbarheder kan man se på de kontroller, organisationen allerede har etableret, og vurdere deres effekt.

En anden måde at identificere sårbarheder på er ved at tage udgangspunkt i sårbarhedskataloger. Det kan man f.eks. finde i ISO 2005.

Konsekvenser

Sidste skridt i risikoidentifikationen er konsekvensvurderingen.

I konsekvensvurderingen skal det vurderes, hvad der vil ske, hvis en sårbarhed udnyttes. Vi vil anbefale, at man ser nærmere på, hvad der er mest vigtigt for en given proces i forhold til fortrolighed, integritet og tilgængelighed.

Når man har det på plads, kan man spørge ind til, hvad det vil koste organisation, hvis der sker en hændelse. Man kan i den forbindelse blive klogere ved at undersøge, om en hændelse vil påvirke:

1. Liv og førlighed
2. Tabt arbejdstid
3. Tabt indtjening
4. Bod til leverandører eller bøder.

Figur 4.6. Identifikation af risici.

I en omskiftelig verden kan det være svært at forudsige risici, blandt andet fordi trusselsbilledet er under konstant forandring. Det kan derfor være en hjælp at tage udgangspunkt i trusselskataloger, der oplister de mest udbredte og frekvente trusler lige nu. Dernæst er det helt afgørende, at der har været dialog med systemejere og forretningsansvarlige. Med de to ting kombineret er der større chance for, at vi som sikkerhedsmedarbejdere rammer rigtigt, når vi præsenterer ledelsen for top 10-risici, som myndigheden eller virksomheden står overfor.

At arbejde med trusselsanalyse kræver ekspertise på området, og vi vil anbefale, at man tager en rådgiver eller erfaren kollega med på råds. Der er mange måder at gå til arbejdet med trusselsanalyse på, og det vil ofte kræve teknisk indsigt. Derfor dykker vi i denne bog ikke dybere ned i det område, men vil blot nævne, at arbejdet ofte består af at:

1. Definere truslen
2. Identificere de mulige konsekvenser for organisationen, hvis truslen indtræffer
3. Fastsætte en mulig sandsynlighed for, at truslen indtræffer.

Nedenstående er et eksempel på en trussel fra et trusselsregister, der er udarbejdet af Trafikstyrelsen.

Cyberspionage mod forretningskritiske data *Cyberespionage on business-critical data*	IT
Risikoidentificering *Risk identification*	
Trussel *Threat*	Ondsindede aktører (private eller statsstøttede aktører) infiltrerer jeres netværk/systemer med software som i al hemmelighed "trækker" fortrolige og/eller forretningskritiske data fra virksomhedens systemer. Forretningskritisk data i denne sammenhæng kan f.eks. være sikkerhedsplaner, persondata, beredskabsplaner og/eller konfigurationsdata til forretningskritiske systemer.
Årsag *Cause*	Mulige årsager kan være, at kritiske data/systemer ikke er tilstrækkeligt beskyttede, fx pga. mangelfuld kryptering, fejlkonfiguration, at netværkstrafikken på IT-systemerne ikke er tilstrækkeligt overvåget eller at en medarbejder utilsigtet trykker på et inficeret link. Angrebet kan også være foregået hos en leverandør.
Mulige konsekvenser *Potential consequences*	Et spionageangreb resulterer i uvedkommendes adgang til data, som er forretningskritiske og/eller fortrolige. Adgangen leder til at fortroligheden og integriteten i information og/eller data kompromitteres med indvirkning på virksomhedens drift og sikkerhed. En ondsindet aktør får f.eks. adgang til kunders persondata eller virksomhedens kontrakter med leverandører. **Overvej farens mulige konsekvenser for:** 1. Sikkerhed (egen og kunder), 2. Drift (egen og kunder), 3. Økonomi, 4. Omdømme, 5. Privacy
Overvej bl.a. nedenstående foranstaltninger *Consider the following measures*	
Organisatoriske foranstaltninger/organizational measures • Har virksomheden et overblik over kritiske forretningsdata og systemer, herunder digital opbevaring, procedurer for opdatering samt hvilke medarbejdere, der har adgang hertil? • Har virksomheden taget stilling til hvorvidt de kritiske forretningsdata skal være tilgængelige på maskiner med opkobling til internet? • Har virksomheden overblik over leverandører, også af hardware og software? • Har virksomheden risikovurderet brugen af ovenstående leverandører, herunder om kontrollen af leverandør er tilstrækkelig? • Har virksomheden etableret (aktiv) overvågning af netværkstrafik på IT-systemerne, både for den administrative og den operationelle del? • Har virksomheden overvejet indvirkningen på samarbejdspartnere ved et spionageangreb? **Tekniske foranstaltninger/technical measures** • Vurdér om virksomheden deler og modtager viden om trusler ift. spionage mod kritiske data. • Har virksomheden etableret andre foranstaltninger/tiltag for at mitigere konsekvenserne og eller sandsynligheden af et spionageangreb, antivirus mv.? • Bliver der logget eller på andre måder dokumenteret aktivitet og adgange til kritisk data mhp. efterforskning? • Er der back-up's på kritiske data samt procedurer for at opdatere disse? • Hvor lang tid tager genetablering? Er evt. forsinkelser medregnede i genetableringsplaner? **Adfærdsmæssige foranstaltninger/behavioral measures** • Vurdér om virksomheden i tilstrækkeligt omfang gennemfører awareness-kampagner?	

Figur 4.7. Eksempel på trusselskatalog fra Trafikstyrelsen (Trafikstyrelsen, u.å.).

Ud over mangel på sporbarhed og fuldstændighed er en faldgrube i risikoidentifikationsarbejdet ofte, at vi kommer til at basere vores analyser på historisk data. Dvs. at der fokuseres på, hvad der allerede er gået galt, og ikke så meget, hvad der kan gå galt i fremtiden. Hvis vi bliver bedre til at forudsige, hvad der kan gå galt i fremtiden, kan vi forbedre vores risikostyringsarbejde. Det er ikke let. Men man kan tænke på, hvordan kunder/borgere, markeder eller leverandører forventes at udvikle sig, når vi kigger i krystalkuglen. Hvis vi bliver bedre til at kigge fremad, vil vi stå stærkere i forhold til at ruste os mod nye trusler, der udnytter sårbarheder, og som derigennem kan påvirke myndighedens eller virksomhedens mulighed for at nå sine mål og få succes i fremtiden.

Risikoanalyse

I risikoanalysen vurderes en sårbarhed ud fra dens risikoniveau – altså hvor sandsynligt det er, at det vil ske, og hvad konsekvensen vil være. Når vi taler om sandsynlighed, så er det værd at nævne, at begrebet kan være svært at arbejde med, og at det ofte bliver for subjektivt tolket. Når man tænker på sandsynlighedsbegrebet, kan det hjælpe at tænke i retning af, at sandsynligheden (som er produktet af aktuel sårbarhed og frekvens) er et udtryk for, hvor realistisk det er, at hændelsen realiseres med den skitserede konsekvens i den aktuelle organisations kontekst.

En måde at illustrere risikoanalysen på er ved at udarbejde en risikomatrix, som kunne se ud som nedenstående.

Konsekvens					
Graverende/ ødelæggende (uacceptablet)	Under middel score: 4	Middel score: 8	Over middel score: 12	Høj score: 16	
Meget alvorlig (kritisk)	Lav score: 3	Under middel score: 6	Middel score: 9	Over middel score: 12	
Mindre alvorlig (generende)	Lave score: 2	Under middel score: 4	Under middel score: 6	Middel score: 8	
Betydelig (uvæsentlig)	Lave score: 1	Lav score: 2	Lav score 3	Under middel score: 4	
	Usandsynligt	Mindre sandsynligt	Sandsynligt	Forventet	**Sandsynlig-hed**
	Lav- middel: Bør ikke give anledning til yderligere behandling				
	Middel: Bør give anledning til løbende overvågning				
	Over middel: Bør give anledning til håndtering				
	Høj: Bør håndteres med det samme				

Figur 4.8. Risikomatrix til vurdering af risici (Digitaliseringsstyrelsen, 2020).

Kvantitativ og kvalitativ risikoanalyse

Kvalitativ risikoanalyse

Kvalitativ risikoanalyse fokuserer på at bedømme og prioritere risici baseret på subjektive skøn af sandsynligheden for og konsekvensen af forskellige sikkerhedstrusler. Denne metode anvender ofte beskrivende kategorier som "høj", "medium" og "lav" til at klassificere både sandsynligheden for, at en trussel materialiserer sig, og den potentielle skade, hvis den gør.

Fordele

- Hurtig og omkostningseffektiv
- Kræver ikke dybdegående statistiske data
- Nyttig til at opnå en bred forståelse af sikkerhedslandskabet.

Ulemper

- Subjektiv og ikke konsekvent
- Afhænger af ekspertise og erfaring af de involverede personer
- Kan mangle præcision i vurderingerne.

Kvantitativ risikoanalyse

Kvantitativ risikoanalyse søger at kvantificere risici ved at anvende numeriske værdier til sandsynligheden og konsekvensen af sikkerhedstrusler. Denne tilgang bruger ofte statistiske metoder og dataanalyse til at estimere potentielle tab i monetære termer og beregne sandsynligheden for forskellige sikkerhedshændelser.

Fordele

- Giver detaljerede numeriske estimater, der kan understøtte økonomisk beslutningstagning
- Kan hjælpe med at prioritere sikkerhedsinitiativer baseret på potentielle økonomiske konsekvenser
- Mere objektiv sammenlignet med kvalitativ analyse.

Ulemper

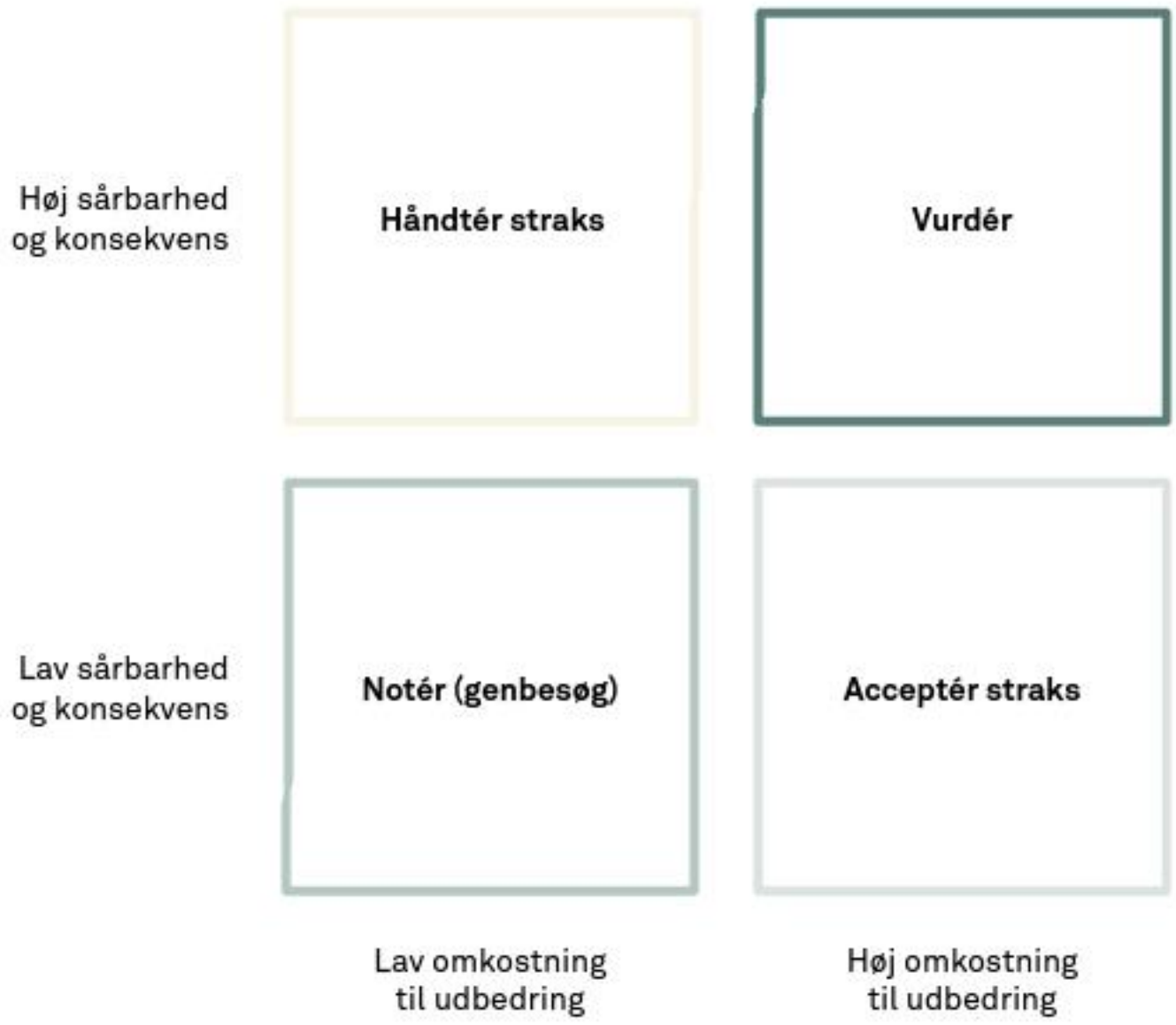
- Kræver detaljerede og præcise data, som kan være vanskelige at skaffe
- Tidskrævende og ofte dyrere end kvalitativ analyse
- Kan være følsom over for fejl i data eller modeller.

I praksis anvender mange organisationer en kombination af begge metoder for at få en mere robust forståelse af deres sikkerhedsrisici og for bedre at kunne planlægge deres sikkerhedsstrategier.

Risikoanalysen kan grundlæggende gennemføres via to forskellige metoder – enten kvalitativt eller kvantitativt. Ofte vil organisationer gennemføre risikoanalyse via en kombination af de to metoder, hvilket kaldes for hybrid risikoanalyse. I tekstboksen herunder folder vi de to metoder ud.

Risikoevaluering

Risikovurderingen færdiggøres ved at evaluere de fundne risici *i* forhold til de kriterier, der er fastsat af ledelsen. Det væsentlige er, at vi skal stå med et risikobillede, der er til at forstå – både for ledelsen og for de medarbejdere, der skal arbejde med det i praksis. Nedenstående figur kan bruges til rapportering af risici, hvor vi placerer dem i de forskellige felter, alt efter hvilken håndtering der skal ske. Nogle risici skal f.eks. håndteres straks, mens andre skal vurderes yderligere eller genbesøges.



Figur 4.9. Forslag til visualisering af fundne risici.

Fase 3: Risikohåndtering

Den tredje fase i risikostyringsprocessen er risikohåndtering, jf. den gule markering i figuren herunder.

I denne fase skal vi beslutte, hvad vi skal gøre med de risici, vi har identificeret. Vi kan overordnet beslutte os for, at vi vil håndtere risikoen ved at indføre:

1. Risikoreduktion: implementere risikomitigerende tiltag
2. Risikoundgåelse: ændre forretningsproces eller fjerne aktiv
3. Risikooverførsel: sker typisk via outsourcing og forsikring
4. Risikoaccept: på baggrund af defineret risikoappetit.

Det mest almindelige er, at man som beslutningstager og sikkerhedsteam ser på, hvordan man kan reducere risikoen, så den kommer ned til et acceptabelt niveau. Det kan man gøre ved at implementere en eller flere risikomitigerende tiltag. Når man har valgt, hvilke risikomitigerende tiltag man vil sætte i værk, skal de naturligvis implementeres i organisationen. Der kan være tale om både procesmæssig, teknisk og/eller organisatorisk implementering. Eksempler på risikomitigerende tiltag er listet i nedenstående tekstboks.

Eksempler på risikomitigerende tiltag

- Ændringer til politikker, standarder, processer og procedurer
- Ændringer i teknologi
- Organisatoriske ændringer.

Der er en række overvejelser, man som sikkerhedsteam eller ejer af et aktiv skal gøre sig, før man iværksætter risikomitigerende tiltag. Det kan f.eks. være:

- Om det økonomisk giver mening ud fra en cost-benefit-tankegang.
- Om der er juridiske krav til at indføre risikomitigerende tiltag. Det kan f.eks. som følge af GDPR eller andre lovgivningsområder, hvor man lovgivningsmæssigt er forpligtet til at iværksætte visse tiltag til at minimere risici.
- Om det driftsmæssigt giver mening, eller om påvirkningen på driften er for risikabel. Man ser nogle gange, at den potentielle indvirkning på driften er for risikabel, så vi som organisation må leve med risici, der egentlig overstiger risikotærskelværdien.

Den mest almindelige måde at beslutte, om der skal iværksættes risikomitigerende tiltag på, er ved at lave en cost-benefit-analyse, hvor man ser på den forventede omkostning ved et nedbrud, og hvad det vil koste at ruste organisationen til at forebygge nedbruddet og nå indenfor risikotærskelværdien, der er fastsat af ledelsen. Det er selvfølgelig vigtigt, at man tager alle omkostninger forbundet med det risikomitigerende tiltag med i sine overvejelser, så både indkøb, udvikling og licensomkostninger medtages. Dernæst skal man også se på test og implementering, og om det gør noget ved organisationens samlede IT-arkitektur.

Beslutningen om, hvordan risikoen skal håndteres, dokumenteres i en risikohåndteringsplan. Når man har lavet en risikohåndteringsplan, kan den bruges som et godt dialogredskab med ledelsen i forhold til at prioritere ressourcer til at få håndteringen effektueret.

Selve den grafiske fremstilling af risikohåndteringsplanen kan frembringe store diskussioner blandt fagfolk – for hvilket format skal den have, og hvordan skal den vedligeholdes? Det er værd at tage alle disse snakke tidligt i processen, således at alle er enige om indhold og format. Det giver den største chance for, at planen faktisk følges og holdes ved lige. Forsøg dog også gerne samtidig at holde det så simpelt som muligt, så der ikke er for mange felter, der skal udfyldes.

Fase 4: Risikoaccept

Det sidste skridt i risikostyringsprocessen er risikoaccept, jf. den gule markering i figuren herunder.

Risikohåndteringsplanen beskriver, hvordan de identificerede risici bliver håndteret, så de møder vores risikotærskelværdi. Det er selvfølgelig vigtigt, at de ansvarlige ledere er opmærksomme på, hvad der skal iværksættes på deres respektive område, for at de risici, der befinder sig hos dem, også bliver håndteret.

Nogle gange sker det dog, at organisationer må acceptere en risiko, selvom den ligger over den godkendte risikotærskelværdi. Det kan f.eks. være, det er for dyrt eller for svært at gøre noget ved risikoen. Hvis man som ejer af et aktiv må acceptere en risiko, der ligger over risikotærskelværdien, så vil det ofte kræve, at der er enighed om at acceptere risikoen. I sådan et tilfælde vil det være op til f.eks. informationssikkerhedsudvalget at beslutte, om organisationen vil acceptere risikoen.

Roller, ansvar og effektiv kommunikation

Et effektivt, troværdigt og opdateret risikostyringsarbejde kræver input fra mange forskellige interessenter i virksomheden eller myndigheden. Hvis arbejdet skal udføres godt og effektivt, kræver det tværfaglighed og samarbejde mellem forskellige afdelinger. F.eks. kan procesafdelingen hjælpe med at skabe overblik over forretningsfunktioner og processer, mens sikkerhedsafdelingen kan hjælpe med værktøjer, metoder og sparring, når der skal udføres risikovurderinger. Endelig kan procesejere og systemejere hjælpe med indsigter i

forhold til, hvad der vil ske, hvis der sker brud på fortrolighed, integritet eller tilgængelighed for en funktion, en proces, et IT-system eller en infrastrukturkomponent.

Roller og ansvar varierer naturligvis med størrelsen af virksomheden, men nedenstående figur viser et overordnet billede og forslag til fordeling. Se kapitel 4 for mere om roller og ansvar i cybersikkerhed generelt.

Rolle	Ansvar
Ledelse	Skal have overblik over risici og løbende træffe nødvendige beslutninger om tiltag, der resulterer i, at risici er på acceptabelt niveau.
Informationssikkerhedsudvalg eller risikokomite	Løbende indsamling til rapportering og drøftelse i ledelsesgruppen.
Systemejer	Fokus på og ansvar for sikkerhed og risici knyttet til "deres" systemer.
Dataejer	Fokus på og ansvar for sikkerhed og risici knyttet til specifikt udvalgte data.
Ejere af fysiske aktiver	Fokus på og ansvar for sikkerhed og risici knyttet til fysiske aktiver, såsom bygninger, produktionsenheder, etc.

Figur 4.10.Roller og ansvar i forbindelse med risikovurdering og risikostyring.

Monitorering og rapportering

Selv de bedst gennemarbejdede risikovurderinger og mest velovervejede sikkerhedstiltag bliver kastet til hjørne, hvis ledelsen ikke får dem præsenteret på effektiv og konkret vis. Konkret og præcis rapportering til ledelsen kan ikke undervurderes og skal give ledelsen et klart og opdateret billede af organisationens risikoprofil og løbende fremdrift. Kun på et godt beslutningsgrundlag kan ledelsen træffe informerede beslutninger om alt fra risikoappetit til kon-

krete risici og risikostyringsstrategier. En effektiv ledelsesrapportering kan hjælpe med at sikre, at virksomheden er proaktiv i forhold til risikostyring og kan reagere effektivt på potentielle trusler. Vi finder ikke mange medarbejdere og ledere, der ikke vil være enige i vigtigheden af ledelsesrapporteringen. Men som med mange andre ting i livet er det lettere sagt end gjort, og vi oplever desværre ofte, at arbejdet med risikovurdering stjæler 95 % af tiden, og så bliver der i sidste øjeblik sat nogle forvirrende og meget teksttunge Power-Point-slides i nakken på ledelsen.

Dernæst ser vi også ofte, at vi støder på vandmelonudfordringen i rapporteringen af risici. Der er ofte mange interessenter, der er med i vurderingen af risici. Og jo tættere vi kommer på topledelsen, jo flere har været inde over risikovurderingen. Det kan være, at man som systemejer har identificeret nogle udfordringer, men som risikovurderingen kommer højere op i systemet, er der flere, der peger på, at: "Vi har jo nogle planer til at håndtere risikoen, eller så slemt er det jo heller ikke". Det medfører, at risikoen bliver farvet grøn, selvom den nok er rød. Dermed står vi med en vandmelon. En risiko, der udenpå, når vi får den præsenteret, er grøn og dermed problemfri, men i virkeligheden er rød og udfordringstung indeni.

Her følger vores bedste råd til effektiv og konkret ledelsesrapportering:

- Få så tidligt som muligt afstemt med ledelsesgruppen, hvilken type information de vil have og i hvilket format. Det er frustrerende at udarbejde en lang Word-afrapportering for at få at vide, at den maksimalt må fylde en slide og 5 minutter på kommende møde.
- Få afklaret, hvad ønsket er med den konkrete rapportering på det givne tidspunkt. Er målet udelukkende til information, skal ledelsen godkende planer og tildele ressourcer eller noget helt tredje?
- Tag udgangspunkt i anerkendte kommunikationsmodeller som f.eks. SCQA (situation, complication, question, answer) (Omolu, 2017). Kan ledelsen finde svar på, hvad situationen, de står overfor, handler om, hvilke udfordringer der kan udpeges, hvad hovedbeslutningspunktet er, samt forslag til beslutning? Vi har alle en tendens til at fokusere ensidigt på bare et eller to hovedspørgsmål. Sørg for, at de alle er dækket af.
- Hold en løbende dialog med nøglepersoner fra ledelsen, og afstem retningen for rapporteringen. Hvis man er enige om retningen allerede,

inden man mødes, er det lettere at få diskussionen i retning af beslutninger i stedet for en diskussion om resultaterne i rapporteringen.

- Tildel ejere på nye opgaver, og tag referat! Sørg for, at alle beslutninger noteres og hurtigt deles med ledergruppen til endelig godkendelse. Sørg for, at nye opgaver tildeles en ansvarlig ejer, som accepterer denne opgave. Det er slidsomt at nå hen til næste rapportering blot for at konstatere, at ingen kan huske, hvad der blev drøftet sidste gang, og at ingen har taget ansvar for opgaverne.
- Evaluér med de kollegaer, der var med til rapporteringen. Skabte rapporteringen den ønskede diskussion? Nåede vi frem til konkrete beslutninger? Hvis ikke, hvad skal vi gøre anderledes næste gang?

Vi kan ikke sige det nok: Ledelsesrapportering må ikke undervurderes!

Det hemmelige våben: Et levende årshjul

Som det formentlig er gået op for læseren på dette tidspunkt, er risikostyring en omfattende og tidskrævende øvelse med mange involverede. Det kan give både bulder og brag i en organisation at skulle trække mange ressourcer til, og blot det at samle ledelsesgruppen til løbende orientering kan være hård kalendergymnastik. I disse tilfælde anbefaler vi altid at få udarbejdet et årshjul, så det er visuelt og overskueligt for alle, hvilke aktiviteter der skal foretages hvornår. At udarbejde et årshjul og holde det i live er ikke en simpel øvelse, men kan give netop den struktur og ro i arbejdet, som mange medarbejdere ønsker. En god kilde til mere viden om årshjul og planlægning findes på Sikker-Digital.dk (Digitaliseringsstyrelsen, 2024). Gennemtænk på forhånd, hvordan årshjulet skal visualiseres, og hvordan det skal kunne tilgås og redigeres af de rette medarbejdere. Ellers sander årshjulet til i en mappe på skrivebordet hos den velmenende medarbejder, der udarbejder det. Sørg samtidig for, at de datoer, der fastsættes i årshjulet, med det samme reserveres i kalenderen hos de rette ledere. Hermed øges både opmærksomheden omkring arbejdet, og sandsynligheden for, at man får de rette personer rundt om bordet, forøges markant.

En kort opsummering:

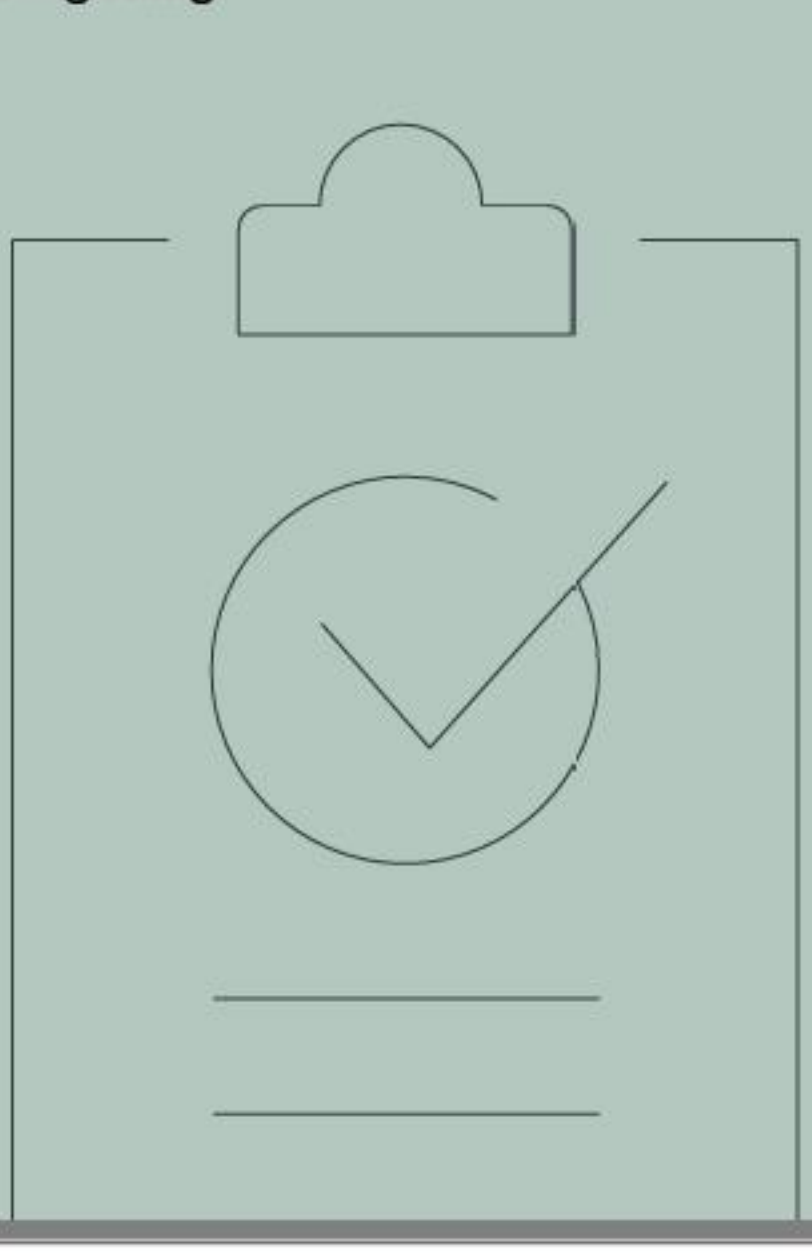
Risikostyring – Sæt ind, hvor værdien er størst

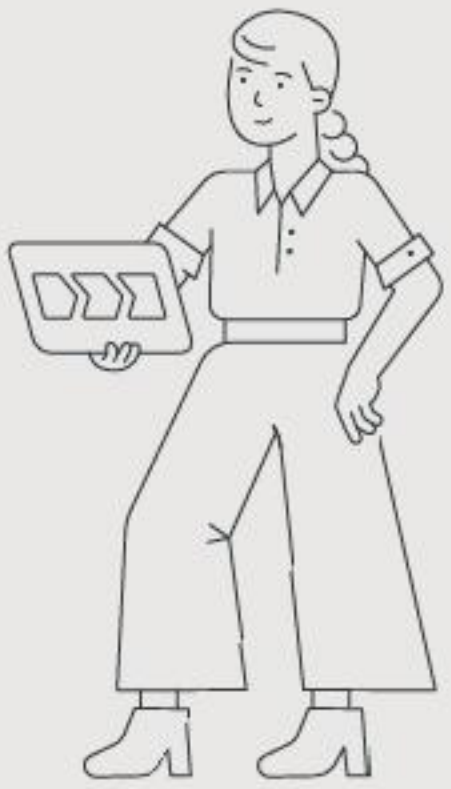
- **Vær skarp på begreber og metode**
  Vær enige om både definitionerne og fremgangsmåden, organisationen vil følge. Det er også en stor fordel at samtænke risikostyringsarbejdet på cyber- og informationssikkerhedsområdet med den øvrige risikostyring i organisationen.

- **Ledelsen skal med på banen, og de skal fastsætte en risikotærskelværdi**
  Det er afgørende for effektivt risikostyringsarbejde, at ledelsen kommer på banen og tager stilling til, hvornår skidt er skidt. Eller sagt på en anden måde, hvor høje risici kan organisationen acceptere? Det gælder f.eks. både i forhold til tabt indtjening, hvis vi ikke overholder loven, eller hvis vores omdømme bliver påvirket af en hændelse på cyber- og informationssikkerhedsområdet. Ledelsen vil også skulle allokere ressourcer til risikostyringsprocessen og sikre opbakning til, at det bliver gjort.

- **Risikostyring er en dynamisk størrelse**
  Man bliver egentlig aldrig færdig med sin risikostyring, da trusler og sårbarheder hele tiden udvikler sig. Det samme gør organisationen forhåbentlig vis. Det betyder dog også, at risikostyringsprocessen er en iterativ proces, som skal gentages med et aftalt interval. Når vi går iterativt til værks, kan vi også sikre en god balance mellem dybde og detalje i vores risikovurderingsarbejde og den tid, vi bruger på det, hvor vi til stadighed fokuserer på de områder af vores organisation, der har høj risiko for at forstyrre vores muligheder for at nå vores mål, hvis noget går galt. Kort sagt skal der løbende være risikoovervågning og review.

- **Der skal løbende være risikokommunikation og -rådgivning:**
  Uden planlægning, kommunikation og koordination kommer vi ikke langt i risikostyringsprocessen. Det gælder, både før, under og efter aktiviteterne er gennemført. Det er derfor også vigtigt, at de ansvarlige for cyber- og informationssikkerhedsarbejdet løbende kommunikerer og rådgiver om risikostyringsarbejdet. Som vi også gennemgår i kapitel 5, ligger ansvaret for risiciene ude hos de ansvarlige afdelinger i organisationen og ikke hos sikkerhedsafdelingen, men det kræver et stærkt samarbejde og løbende kommunikation på tværs at få dette op at køre.





Case:

GastroGenetix Foods vil have fokus på risikostyring

GastroGenetix er en hurtigt voksende dansk biotech-virksomhed, der har specialiseret sig i at levere sunde måltidskasser sammensat på baggrund af analyser af kundens DNA. De er således en teknologielskende fødevarevirksomhed, som også fokuserer på økologi og bæredygtighed.

Virksomheden består af to arbejdsomme grundlæggere med fokus på vækst, et dedikeret team af forskere indenfor koblingen mellem fødevarer og sygdomme, en produktionsenhed og sekretariatet. Virksomheden har for nylig opkøbt flere produktionshaller i Spanien, så de kan skalere produktionen, og derfor har de også overtaget salgs- og markedsføringsteamet i Spanien.

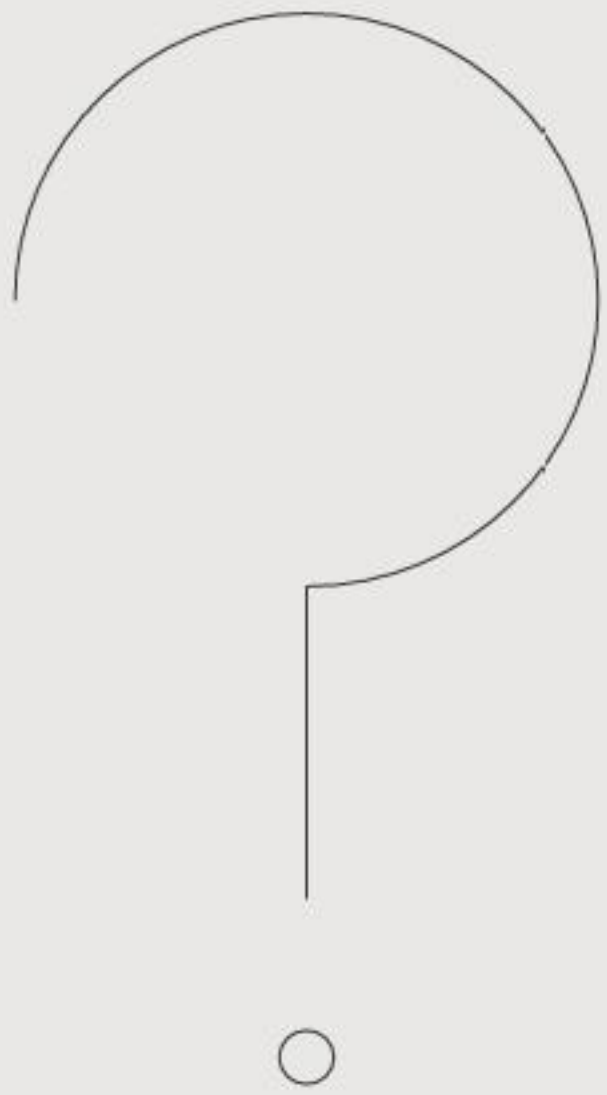
GastroGenetix håndterer følsomme data om deres kunders sundhedstilstand og har forretningshemmeligheder i forhold til deres produktionsprocesser. Da virksomheden er involveret i internationale samarbejder og partnerskaber indenfor bioteknologibranchen, er der snak om, hvorvidt de har behov for at overholde forskellige internationale standarder og regulativer indenfor bioteknologi og cybersikkerhed. Der findes ikke et egentligt overblik over virksomhedens risici, og ledelsen har ikke fastlagt en risikotærskel. Virksomheden har ansat en nyuddannet medarbejder til at håndtere cybersikkerhedsrelaterede risici.

En solrig forårsmorgen opdager den ene grundlægger, at virksomhedens forskningsdata og opskrifter til deres innovative fødevareprodukter er blevet kompromitteret ved et cyberangreb. Angrebet har, så vidt vides, resulteret i læk af fortrolige oplysninger og er en alvorlig trussel mod virksomhedens konkurrenceevne og omdømme.

Arbejdsspørgsmål

Du er den nyansatte cybersikkerhedsmedarbejder i GastroGenetix. Du foreslår ledelsen at gennemgå de fire faser i risikostyringsprocessen, og ledelsen giver dig fuld opbakning. Ledelsen vil gerne allerede nu have svar på følgende:

- Hvilke risici, trusler og sårbarheder kan have været med til, at GastroGenetix blev målet for cyberangrebet? (Nævn og begrund f.eks. 5-7 styk)
- Når krisen er afværget, og der skal arbejdes videre med risikostyring, hvad er så det første, der skal etableres? (Hint: Se "Fase 1: Etablering af kontekst")
- Hvem vil du inddrage i risikovurderingen?
- Hvad er det vigtigste output fra "Fase 3: Risikohåndtering"?
- Hvilke budskaber er vigtigst at kommunikere til ledelsen, hvornår vil du fremlægge disse, og hvordan vil du gå til opgaven?



Litteraturliste

Bogush, P. (2022, 14. februar). ISO 27005 in 6 steps: A quick overview of ISO 27005 for Business Users. Business Tech Weekly.

Center for Cybersikkerhed (u.å.). Ordforklaringer. Lokaliseret på: https://www.cfcs.dk/da/cybertruslen/ordforklaringer/

Computer Security Resource Center (CRCS). Risk management framework for information systems and organizations: A System Life Cycle Approach for Security and Privacy. NIST SP 800-37 Rev.2.

Digitaliseringsstyrelsen (2020, december). Vejledning til risikostyring indenfor informationssikkerhed.

Digitaliseringsstyrelsen (2024). SikkerDigital.dk: Årshjul og planlægning. Lokaliseret på: https://www.sikkerdigital.dk/myndighed/iso-27001-implementering

International Organization for Standardization (2018). Risk management. ISO/IEC 3100:2022(E).

International Organization for Standardization (2022). Information Security, cyber security and privacy protection-Information security management systems-Requirements. Reference number ISO/IEC 27001:2022(E).

International Organization for Standardization (2022). Information security, cybersecurity and privacy protection — Guidance on managing information security risks. ISO/IEC 27005:2022(E).

ISACA (u.å.). COBIT 5. ISACA.

Nicho, M., Khan, S., & Rahman, M. S. M. K. (2017, september). Managing information security risk using integrated governance risk and compliance. In 2017 International Conference on Computer and Applications (ICCA) (pp. 56-66). IEEE.

National Institute of Standards and Technology (2024, februar). The NIST Cybersecurity Framework (CSF) 2.0. Lokaliseret på: https://doi.org/10.6028/NIST.CSWP.29

Omolu, S. (2017, 12. oktober). Learning to Pitch with the SCQA Technique. Medium.com. Lokaliseret på: https://medium.com/@stephanie.omolu/learning-to-pitch-with-the-scqa-technique-94b0182d9148

Ozkaya, E. (2022). Cybersecurity Leadership Demystified: A comprehensive guide to becoming a world-class modern cybersecurity leader and global CISO. Packt Publishing Ltd.

Trafikstyrelsen (u.å.). Trusselskatalog. Lokaliseret på: https://admin.trafikstyrelsen.dk/Media/638435838523320229/Trusselskatalog.docx

Økonomistyrelsen (2024). Risikostyring. Lokaliseret på: https://oes.dk/it-og-oekonomistyring/risikostyring/

Kapitel 5

Kapitel 5

Roller og ansvar: Cybersikkerhed som holdsport

> En god analyse og løbende drøftelse af roller og ansvar gør det tydeligt for alle, hvis der ligger for mange opgaver på enkelte personer, og man kan bedre indgå i dialog med ledelsen om, hvordan der skal prioriteres. Denne dialog er helt nødvendig for at sikre, at alle prioriterede opgaver følges helt til dørs, så man ikke konstant overvældes af nye opgaver, som også skal prioriteres. Det ser vi desværre ofte på cyber- og informationssikkerheds-området."

Carsten Jørgensen,
Senior cybersecurity consultant og ekstern lektor ved Københavns Universitet

Enighed om roller og ansvar er med til at skabe fremdrift

På cyber- og informationssikkerhedsområdet vrimler det med titler og forkortelser, hvilket kan være lidt af en jungle at navigere rundt i. Til tider kan det endda føles, som om der er flere "aktører" på dette felt, end der er karakterer i samtlige afsnit af Game of Thrones. Både på internationalt og nationalt plan eksisterer en række aktører, som sætter rammen for lovgivning og tilsyn. Internt sætter organisationer ofte deres eget præg på, hvilke opgaver eller ansvarsområder en bestemt stillingsbetegnelse skal varetage. Det følger derfor næsten naturligt, at der kan opstå uenigheder om, hvem (rolle) der skal varetage hvilke opgaver (ansvar) i forbindelse med cybersikkerhedsarbejdet i en organisation. Ofte opstår uenighederne, fordi forskellige medarbejdere i organisationen ikke har samme forståelse af, hvilke opgaver der skal løses, og hvordan der skal prioriteres. Det behøver dog ikke at være sådan, og det er vores erfaring, at hvis man bruger tid på at få drøftet roller og ansvar med hele organisationen – herunder også støttefunktioner som f.eks. HR og jura – så kommer det fremtidige samarbejde til at gå langt bedre. Derudover er præcisering af roller og ansvar internt i organisationen et krav ifølge bl.a. ISO 27001-standarden og NIST (se mere om ISO 27001 og NIST CSF i kapitel 3).

Roller og ansvar i cyber- og informationssikkerhedsarbejdet er således ikke til at komme udenom. I mange organisationer åbner det for svære diskussioner og dilemmaer, og ofte er det en proces, der er under stadig udvikling, i takt med at medarbejdere rekrutteres, og systemer enten tilkøbes eller afvikles. Roller og ansvar i arbejdet med cyber- og informationssikkerhed er ikke et one-size-fits-all, og tilpasning til organisationens størrelse, modenhed og kompleksitet

er afgørende for et velfungerende sikkerhedsarbejde. At have overblik over, hvem der gør hvad på cyber- og informationssikkerhedsområdet, er derfor helt essentielt.

Dette kapitel beskriver først internationale aktører, derefter nationale myndigheder og interessenter og til sidst de roller og ansvarsområder, man typisk støder på i en organisation. Kapitlet præsenterer to centrale modeller, som kan understøtte en struktureret tilgang til rolle- og ansvarsfordelingen:

- Three layers of defense-modellen (3LD)
  Er baseret på en risikobaseret tilgang og med sin tydelige funktionsadskillelse skaber den tydeligt ejerskab og fremdrift.
- RACI-modellen
  Er i udgangspunktet ikke tiltænkt cyber- og informationssikkerhedsfeltet, men vi bruger den ofte, da den er god til at fremhæve, hvilket ansvar forskellige involverede roller har også på både overordnet, specifikt opgave- eller projektniveau.

Kapitlet skitserer dernæst et format for det gode leverandørsamarbejde, da leverandører i de fleste organisationer er en vigtig aktør og spiller en vigtig rolle med stor indflydelse på den samlede sikkerhed.

Internationale aktører

På den helt store klinge ser vi en række vigtige aktører, som blandt andet sætter dagsordenen for lovgivning og tilsyn. Disse aktører er man som menig medarbejder i en organisation sjældent i berøring med, men det kan være godt at kende til deres eksistens, så der opnås en forståelse for det samlede "økosystem" af aktører.

På et internationalt plan svinger EU taktstokken i forhold til rammelovning, der gennem direktiver sætter retningen for medlemslandenes arbejde med cyber- og informationssikkerhed. Medlemslandene har ansvar for at fortolke og implementere EU-lovgivningen i national lovgivning. Der har været og bliver til stadighed udviklet nye direktiver på EU-plan, som påvirker, hvilke minimumskrav både myndigheder og virksomheder skal leve op til på områder for cyber- og informationssikkerhed.

EU samarbejder på en række områder for at have en samlet og styrket tilgang til håndtering af cybertrusler. På Det Europæiske Råds hjemmeside kan man således læse, at *"EU arbejder på forskellige områder for at fremme cyberrobusthed, bekæmpe cyberkriminalitet og styrke cyberdiplomati og -forsvar"* (Det Europæiske Råd, 2024). Under Europol er der således oprettet et Europæisk Center for Bekæmpelse af Cyberkriminalitet, også kaldet EC3 (European Cybercrime Centre). Alt dette med øje for, at cyberkriminalitet sjældent respekterer de nationale grænser, og at et styrket samarbejde derfor er nødvendigt.

Grundliggende er der en række direktiver, der rammer bredt på tværs af brancher, størrelse og arbejdsområde, såsom GDPR (Europa-Kommissionen, u.å.), mens andre direktiver er branchespecifikke eller kun rammer virksomheder eller myndigheder, der er særligt kritiske for samfundet. Det gælder f.eks. DORA for finanssektoren eller NIS-direktiverne for virksomheder og myndigheder, der leverer kritiske tjenester. Helt overordnet kan man sige, at jo mere kritisk ens virksomhed eller myndighed er for, at samfundet fungerer, jo flere krav stiller EU til beskyttelse af organisationens aktiver.

I de kommende år forventes særligt EU's arbejde vedrørende NIS-direktivet at sætte rammerne for informationssikkerhedsarbejdet bredt i danske myndigheder og virksomheder. Læs mere om GDPR, DORA og NIS2 i kapitel 3.

Nationale aktører

I Danmark spiller en række offentlige myndigheder sammen om cyber- og informationssikkerhedsindsatsen på nationalt plan. Disse myndigheder udarbejder lovgivning, yder tilsyn, giver råd og vejledning eller hjælper til håndtering af IT-kriminalitet. Nedenstående illustration viser overordnet, hvilke myndigheder der håndterer opgaver på cyber- og informationssikkerhedsområdet nationalt i Danmark.

For de fleste læsere af denne bog vil det nok være CFCS's rådgivning og vejledninger, som vil være mest relevante at kende til og kunne drage nytte af. Det er også CFCS, der udarbejder og analyserer trusselsvurderingen mod Danmark i sin helhed (Center for cybersikkerhed, 2024). Den nationale strategi

for cyber- og informationssikkerhed er bestemt også en gennemlæsning værd (Finansministeriet, 2021).

Arbejder du i den offentlige sektor, er du formentlig også stødt på vejledninger eller analyser fra Digitaliseringsstyrelsen. Styrelsen koordinerer og gennemfører sikkerhedsaktiviteter, analyser og vejledningsmaterialer primært til den offentlige sektor. Digitaliseringsstyrelsen, også ofte kaldet "Digst", står bag hjemmesiden SikkerDigital.dk. For dig som medarbejder, men også som almindelig borger, kan netop SikkerDigital være en rigtig god kilde til rigtig mange værktøjer og vejledninger (Digitaliseringsstyrelsen, u.å.).

Ud over de offentlige myndigheder har en række erhvervsorganisationer og private aktører såsom konsulent- og revisionshuse specialiseret sig i at yde rådgivning på området for cyber- og informationssikkerhed mod betaling.

Cyber- og informationssikkerhed på organisationsniveau

I vores samarbejde med forskellige myndigheder og organisationer har vi set mange måder at organisere sig på og forskellige måder, man fordeler ansvarsområder på. Der kan f.eks. være forskel på, hvilke titler der bliver anvendt, hvor opgaverne med cyber- og informationssikkerhed er placeret, hvem den sikkerhedsansvarlige referer til, samt hvilke ansvarsområder der er omfattet. Det gælder dog for alle, at organisering og ledelse (også ofte omtalt med det engelske ord governance) på området for cyber- og informationssikkerhed skal passe til organisationens størrelse og modenhed samt leve op til evt. sektorspecifikke regler på området.

Det er vores erfaring, at så længe alle i organisationen er enige om, hvilket ansvar og hvilke opgaver der hører under hvilke personer, behøver det ikke at give anledning til problemer. Det er først, når der opstår forskellige forventninger til arbejdet, at opgaver falder imellem to stole. Her har vi oplevet, at det kan tage længere tid at drøfte, *hvem* der skal løfte en opgave, end det ville gøre egentlig at få opgaven udført. Hvis du oplever, at drøftelsen af, hvem der har hvilket ansvar i din organisation, trækker tænder ud, skal du vide, at dette ikke er enestående! Samtidig vil vi dog opfordre til, at du skubber på for at få formaliseret ansvar og rollefordelingen, altså få ansvarsfordelingen skrevet ned og sikre topledelsens godkendelse. Herefter er det vigtigt, at også roller

og ansvarsfordeling løbende genbesøges og bekræftes, i takt med at organisationens risikovurdering udvikler sig, og medarbejdere enten kommer til eller forlader organisationen.

Ligegyldigt hvordan en organisation i sidste ende vælger at sammensætte roller og ansvar, er der et par kernespørgsmål, som skal afklares, herunder:

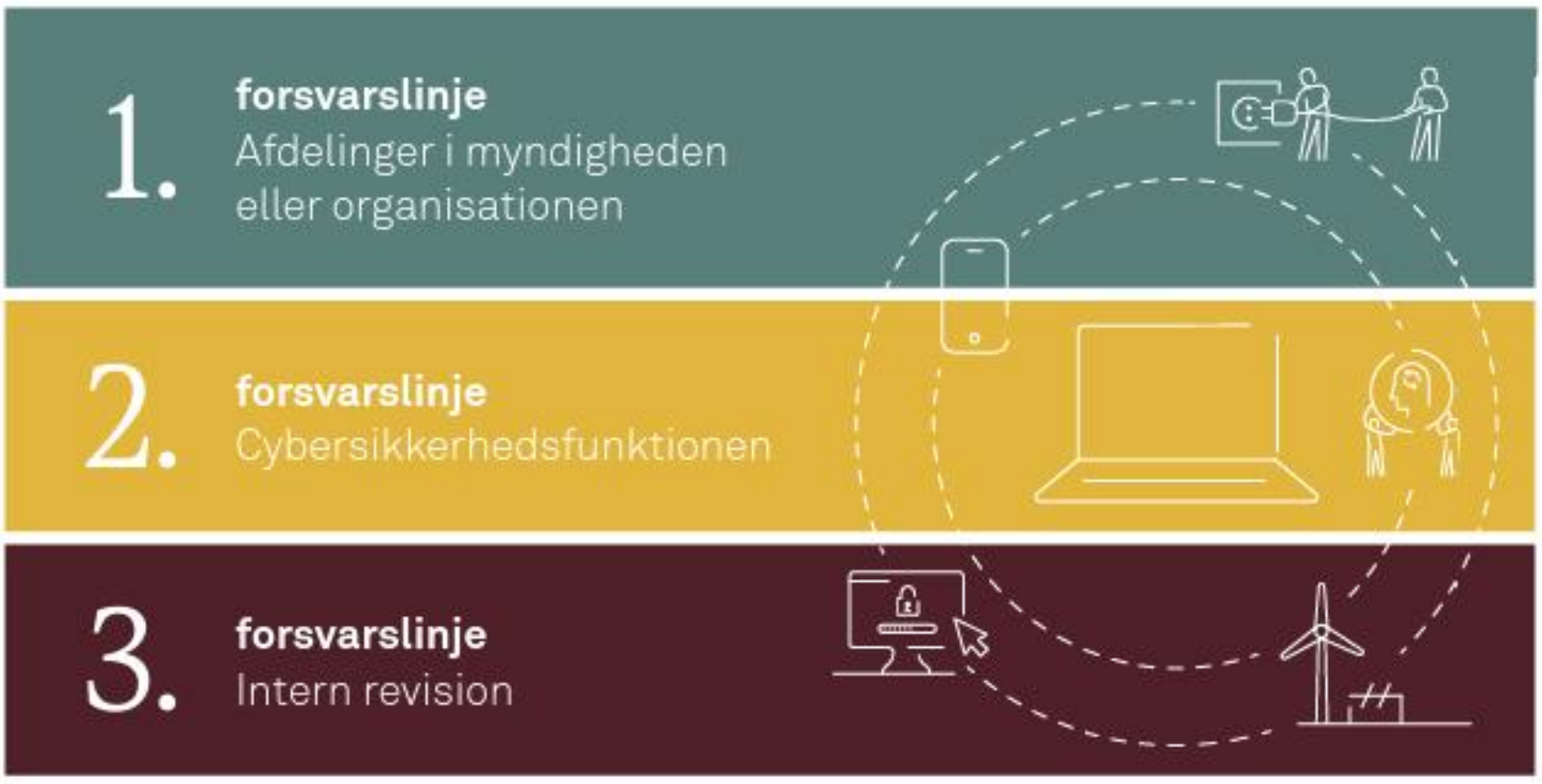
1. Er der klarhed over, hvilke opgaver der skal løftes på cyber- og informationssikkerhedsområdet, og hvem der gør det?
2. Hvor i organisationen ligger ansvaret for cyber- og informationssikkerhed placeret, og hvem rapporterer cybersikkerhedsfunktionen til?
3. Er der klarhed over samspillet mellem cybersikkerhedsfunktionen og øvrige forretningsområder?

For at besvare disse spørgsmål kan man med fordel gøre brug af "3LD-modellen" (Three layers of defence), eller "De tre forsvarslinjer", som anvendes på tværs af mange forskellige industrier (Ruud, 2019).

De tre forsvarslinjer – en måde at organisere risikostyringsarbejdet på

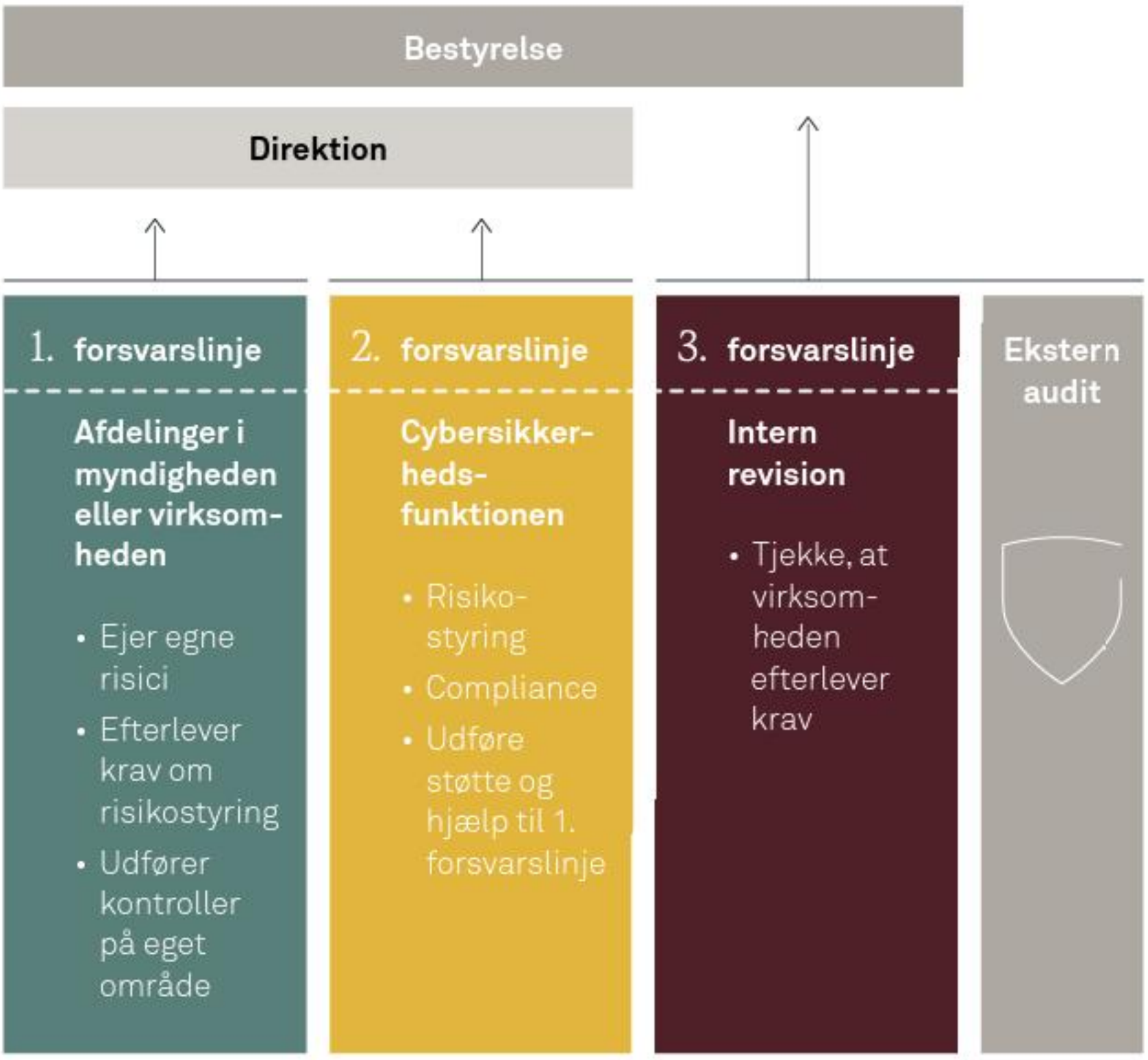
Hvordan styring af cyberrisici skal forankres i virksomheden eller myndigheden, og hvilke roller de enkelte afdelinger skal varetage, er væsentlige elementer i beslutningen om organiseringen af cybersikkerhedsarbejdet. 3LD-modellen er en meget brugt model, som stammer fra Institute of Internal Auditors (IIA). Modellen giver værdifulde input til, hvordan man kan sikre sig et organisatorisk setup, der giver en klar adskillelse af funktioner, roller og ansvar i arbejdet med håndteringen af risici på cyber- og informationssikkerhedsområdet (IIA, 2020).

Modellen giver et bud på, hvordan arbejdet med sikkerhed kan orkestreres, så ledelsen og direktionen (og for private virksomheders vedkommende bestyrelsen) har det overordnede ansvar for virksomhedens eller myndighedens risikoappetit (se mere i kapitel 2 og 4) og cybersikkerhed, mens det daglige arbejde med cyber- og informationssikkerhed forankres i tre forsvarslinjer (Ruud, 2019):



Figur 5.1. De tre forsvarslinjer, og hvem de omfatter.

Ovenstående figur illustrerer de tre forsvarslinjer og deres interne afhængigheder og ansvarsområder. Når risikostyringsarbejdet fordeles på denne måde, vil resultatet være, at der ikke er overlap imellem arbejdsopgaver, og at risici og kontrol af disse har en "højere sandsynlighed for at blive effektivt styret" (vores oversættelse af citat fra Ruud, 2019). Se visualisering af 3LD-modellen nedenfor.



Figur 5.2. En detaljeret præsentation af 3LD-modellen (De tre forsvarslinjer). Baseret på ECIAA/FERMA & Ruud, 2019.

Et centralt omdrejningspunkt for 3LD-modellen er en afklaring af, hvem cybersikkerhedsfunktionen refererer til. Historisk set er cyber- og informationssikkerhed ofte udsprunget fra IT-afdelingen, hvorfor cyber- og informationssikkerhedschefen eller CISO'en ofte refererer til chefen for IT. Det kan dog give store problemer at skulle være "vagthund" eller råbe op om risici, som IT-chefen muligvis ikke har på sin dagsorden. Vigtig viden kan således gå tabt i kommunikationen "op til" ledelsen. Følger man 3LD-modellen, skal man derfor organisere sig således, at cybersikkerhedsfunktionen refererer direkte til direktionen (CEO).

Modellen er også udarbejdet som en konsekvens af, at det er umuligt for cybersikkerhedsfunktionen at "eje" alle risici, udføre alle informationssikkerheds-

relaterede opgaver samt have budgetansvaret for at håndtere evt. risici, der overstiger virksomhedens eller myndighedens risikotolerance. Det er afdelinger og medarbejdere i selve forretningen, der skal forstå, hvilke risici der er forbundet med brugen af for eksempel deres centrale IT-programmer, hvilke krav der er sat til brugen af dette, skal holde sig ajour med opdateringer i IT-sikkerhedspolitikken, og som løbende selv skal udføre kontroller. Ellers risikerer man, som vi desværre også ofte har set, at der sættes krav af IT-sikkerhedsafdelingen, som nok lyder godt "på papiret", men som aldrig kommer ud og leve i virkeligheden.

I det kommende afsnit dykker vi dybere ned i roller og ansvar, hvis man følger 3LD-modellen. Det er vores erfaring, at der er forskel på offentlige myndigheder og private virksomheder i anvendelsen af titler og organisering af arbejdet. Derfor lister nedenstående tabel de oftest anvendte titler i henholdsvis private og offentlige myndigheder.

	Private virksomheder	**Offentlige myndigheder**
Ledelsen	Bestyrelsen	Topledelse i departement
	Direktion	Direktion
	Evt. informationssikkerhedsudvalg	Informationssikkerhedsudvalget
Første forsvarslinje	Procesejere	Procesejere
	Systemejere	Systemejere
	Systemansvarlige	Systemansvarlige
Anden forsvarslinje	CISO/Head of security	CISO/Head of security
	BISO	BISO
	DPO	DPO
Tredje forsvarslinje	Intern revision	Intern revision
	Ekstern revision	Ekstern revision

Figur 5.3. Oversigt over de mest gængse roller og titler i cyber- og informationssikkerhed. For mere information om hver rolle se de kommende tekstbokse.

I følgende afsnit går vi et spadestik dybere for hver rolle og beskriver, hvilket ansvar rollen indebærer, hvis man følger 3LD-modellen, samt hvad der skal til for at være en succes i den rolle. Hvis du som medarbejder bliver bedt om at træde ind i denne rolle, kan du med fordel bruge oversigterne som udgangspunkt for samtaler med din leder. Det kan du både gøre i forhold til de formelle ansvarsområder, men også de mere uformelle kompetencer, der kan være med til at gøre dig til en succes i rollen.

Ledelsen

Ledelser i både myndigheder og virksomheder står hver dag overfor beslutninger, der involverer styring og afvejning af risici (Jacobsgaard og Lavesen, 2024). Det gælder også på området for cyber- og informationssikkerhed, hvor cyberangreb er blandt de største forretningsrisici for danske virksomheder og myndigheder (Center for Cybersikkerhed, 2023). Derfor er det helt afgørende, at ledelsen er sit ansvar bevidst i forhold til at fastsætte virksomhedens risikoprofil og investeringsvilje.

I NIS2-direktivet, der er omtalt i kapitel 3, er der markante krav om ledelsesforankring af cyber- og informationssikkerhedsarbejdet, hvilket bl.a. indebærer, at ledelsen skal være bekendte med kravene i direktivet og risikostyringsindsatsen. Den får et direkte ansvar for, at cyberrisici bliver identificeret og håndteret, samt at kravene overholdes (se mere i kapitel 3).

Bestyrelse/topledelse i departementet

Bestyrelsen i private virksomheder og topledelser i departementerne for offentlige myndigheder har ansvaret for at beslutte virksomhedens eller myndighedens risikoprofil, risikotolerancetærskel og føre effektiv kontrol med virksomhedens eller myndighedens risici.

Formelt ansvar

- Beslutte virksomhedens eller myndighedens risikoprofil og investeringsvilje
- Beskytte virksomhedens eller myndighedens aktiver, forretningsprocesser og kunder
- Føre effektiv kontrol med virksomhedens eller myndighedens risici

Hvad skal der til for at være en succes i rollen

- Viden og kompetencer til at kunne adressere virksomhedens eller myndighedens risici på cyberområdet

Direktion

Direktionen har ansvaret for at sætte rammerne for virksomhedens eller myndighedens arbejde med cyber- og informationssikkerhed, herunder at sikre, at der er en fast strategi, god sikkerhedskultur og tilstrækkelige ressourcer til at løfte sikkerhedsarbejdet.

Formelt ansvar

- Fastlægge og rammesætte virksomhedens eller myndighedens cybersikkerhedsstrategi
- Fastlægge indhold, kvalitet og frekvens af rapportering og risikovurdering til ledelsen
- Fastlægge anvendelsen af anerkendte standarder som ISO 27001, NIST og CIS-kontroller
- Sikre tilstrækkelige ressourcer til at løfte sikkerhedsarbejdet i myndigheden eller virksomheden

Hvad skal der til for at være en succes i rollen

- Viden og kompetencer til at kunne sætte retningen for virksomhedens cyber- og informationssikkerhedsarbejde
- Ressourcer til at sikre, at sikkerhedsarbejdet bliver løftet i hele myndigheden eller virksomheden

Første forsvarslinje

Første forsvarslinje udgøres af organisationens eller myndighedens afdelinger, f.eks. ansatte i salgs-, finans- eller produktionsafdelinger. Kendetegnet for dem er, at de ejer alle de risici, de påtager sig på eget område. De er ansvarlige for at leve op til de overordnede rammer for cyber- og informationssikkerheden, der er sat af ledelsen. Det er ligeledes dem, der er ansvarlige for, at der er budget til, at risici udenfor risikotærskelværdien håndteres, medmindre det besluttes at acceptere risikoen. Det vil ofte være sikkerhedsudvalget eller risikoforum, der beslutter at acceptere risici, der ligger udenfor tærskelværdien.

Procesejere

Især større organisationer har formaliserede processer for udvalgte arbejdsgange (f.eks. indkøb, ansættelse, etc.). En procesejer arbejder på tværs af organisationen og sikrer, at alle forretningsenheder taler sammen, og at nye tiltag (som f.eks. cybersikkerhedstiltag) implementeres.

Formelt ansvar

- Udvikling af udvalgte processer og løbende implementering og evaluering af nye tiltag til processen

Hvad skal der til for at være en succes i rollen

- Forståelse for den/de pågældende processer og evne til at navigere i forretningsenhedernes (ofte) forskelligrettede behov

Systemejere

Særligt i større organisationer har alle IT-systemer en ejer, som er udpeget af ledelsen.

Formelt ansvar

- En systemejer har ansvar for, at systemet lever op til forretningens fastsatte krav til fortrolighed, integritet og tilgængelighed. De løbende opgaver kan uddelegeres til systemansvarlig(e), men ansvaret er altid formelt hos systemejer

Hvad skal der til for at være en succes i rollen

- At systemejer har forståelse for hele forretningens brug af systemet
- At systemejer har ressourcer til at igangsætte, implementere og løbende evaluere sikkerhedsforanstaltninger

Systemansvarlige

Den systemansvarlige understøtter det arbejde, som systemejer sætter i gang. Den systemansvarlige har ofte det daglige ansvar for systemmet, f.eks. i forbindelse med oprettelse/nedlukning af brugere, overvåge systemet og opdatere software.

Formelt ansvar

- Implementering og løbende evaluering af de sikkerhedstiltag, der er aftalt i samarbejde med systemejer

Hvad skal der til for at være en succes i rollen

- Direkte og løbende dialog med systemejer
- Ressourcer til at løse de informationssikkerhedsrettede opgaver i forbindelse med systemet, og ikke bare en "superbruger", som kollegaerne kan ringe til for at få hjælp

Anden forsvarslinje

Er ansatte eller afdelinger, der er specialiserede indenfor risikostyring, kontrol og compliance – og i dette tilfælde indenfor cybersikkerhed. Det er sikkerhedsfunktionens ansvar at sætte klare krav til forretningen på sikkerhedsområdet, herunder udarbejde forretningsgange for overholdelse af bestyrelsens risikoappetit, sikre overholdelse af reglerne samt at overvåge, at de rigtige kontroller er implementeret og udført. Kort sagt: at designe, koordinere, styre og støtte op om en konsekvent ramme og politik for organisationens arbejde med cyberrisici.

Helt officielt, det vil sige ifølge et rammeværk som f.eks. ISO 27001, er der ikke krav om, at en DPO fast er med i f.eks. et informationssikkerhedsudvalg. Nogle roller som DPO, HR eller Legal kan enten være faste medlemmer eller have en ad hoc-rolle, afhængigt af hvad der giver mening for organisationen. Her aftaler man ofte, at f.eks. DPO'en kun bringes i spil, når der er drøftelser, der drejer sig om personoplysninger af den ene eller den anden art.

CISO (Chief Information Security Officer)

Ansvarsområderne kan variere fra organisation til organisation, men typisk har en CISO fokus på at opbygge og løbende forstærke et ledelsessystem for informationssikkerhed.

Formelt ansvar

- Opbygge og lede strategi for cybersikkerhed, f.eks. ved at udarbejde og implementere informationsikkerhedspolitikker og procedurer
- Løbende evaluere og styre cybersikkerhedsrelaterede risici
- Rapportering til topledelsen (herunder CEO og bestyrelse)

Hvad skal der til for at være en succes i rollen

- Erfaring i at oversætte tekniske løsninger til ledelse og øvrige interessenter, således at der er forståelse for risici og eventuelle konsekvenser
- En CISO bør have direkte linje til CEO og bestyrelse

BISO (Business Information Security Officer)/ informationssikkerhedskoordinator

Dette ansvarsområde varetages måske af flere personer, men har til hovedformål at understøtte CISO'en i at implementere cybersikkerhedsstrategien og kan især for større virksomheder være en vigtig ressource i forhold til at sikre fremdrift. I nogle organisationer er det mere almindeligt, at en informationssikkerhedskoordinator udelukkende fokuserer på sekretariatsbetjening af bestyrelsen og indsamling af data og rapportering.

Formelt ansvar

- Understøtte implementering af cybersikkerhedsstrategien, bl.a. ved at understøtte udarbejdelse og implementering af informationssikkerhedspolitikker
- Være bindeled mellem forretning og ledelse

Hvad skal der til for at være en succes i rollen

- Grundig forståelse for forretningens arbejdsgange og behov, samt have løbende og god dialog med CISO for at sikre godt samarbejde på tværs

DPO (Data Protection Officer)

Offentlige myndigheder og organisationer er pålagt at udpege en DPO, og der kan være tilfælde, hvor private organisationer også er forpligtet til at udpege en DPO. En DPO (Data Protection Officer) har fokus på personoplysninger, og meget af cyber- og informationssikkerhedsarbejdet generelt kan ligge langt udenfor DPO'ens område og viden.

Formelt ansvar

- En DPO's hovedansvar er at rådgive om, hvordan organisationen lever op til krav sat i GDPR-lovgivningen (se kapitel 3 for mere om GDPR).
- Ifølge f.eks. ISO 27001 skal en DPO ikke nødvendigvis inddrages i cyber- og informationssikkerhedsarbejdet generelt set. I praksis aftaler man ofte, at DPO'en kun bringes i spil, når der er drøftelser, der drejer sig om personoplysninger.

Hvad skal der til for at være en succes i rollen

- DPO'en skal inddrages rettidigt og ved relevante drøftelser om persondata
- Skal have ressourcer til at følge tildelte opgaver til dørs, således at DPO-rollen ikke blot er en opgave ved siden af mange andre

Tredje forsvarslinje

Den tredje forsvarslinje udgøres af den enhed, som udfører audit. Audit er det engelske ord for revision (også ofte kaldet tilsyn), og det er forskelligt, hvilket ord der bruges i forskellige organisationer. Uanset navnet, så sikrer denne funktion en uafhængig kontrol, der fungerer som direktionens eller bestyrelsens garant for, at virksomhedens risikostyringssystem er tilstrækkeligt, samt at virksomheden efterlever de udstukne rammer for cybersikkerhed.

I nogle organisationer er intern audit nok. I større og mere komplekse organisationer, og hvis man er certificeret efter f.eks. ISO 27001, er der krav om ekstern audit. Før en organisation kan blive certificeret, og løbende derefter, skal organisationen bevise, at den fortsat opretholder et passende informationssikkerhedsniveau og løbende forbedrer sig. I Danmark er der en håndfuld organisationer, der kan certificere, herunder Dansk Standard, DSV og Veritas. I nogle organisationer vælger man at bruge udenlandske certificerende virksomheder. Det vigtige her er blot, at den certificerende virksomhed faktisk også selv skal være certificeret til opgaven! For mange organisationer er det mest almindeligt at blive "udsat" for tilsyn og revision og ikke nødvendigvis egentlig certificering efter f.eks. ISO 27001-standarden.

Intern revision/ audit/ tilsyn

Den interne audit er organisationens egenkontrol og kvalitetssikringsfunktion, der fokuserer på at dokumentere og verificere, at virksomheden lever op til de krav, der er fastsat af ledelsessystemet for informationssikkerhed (se kapitel 3).

Formelt ansvar

- Bestyrelsens/topledelsens sikring af, at organisationen vurderer og håndterer relevante risici på forsvarlig og effektiv vis

Hvad skal der til for at være en succes i rollen

- Skal have adgang til alle relevante materialer og aktiver, samt mandat og ressourcer nok til at udføre relevante kontroller og opfølgning

Ekstern revision/audit

Ekstern revision og audit foretages af en virksomhed, som gennemgår og kontrollerer organisationens informationssikkerhedskrav, samt den praktiske implementering heraf. Kan foregå både ved fastsatte intervaller, samt i nogle tilfælde ved uanmeldte besøg.

Formelt ansvar

- Hvis organisationen skal certificeres (f.eks. ISO 27001), spiller ekstern audit en central rolle. Også i virksomheder, der ikke er certificeret, sikrer den eksterne auditor en vigtig kilde til viden og løbende evaluering

Hvad skal der til for at være en succes i rollen

- Skal have adgang til alle relevante materialer og aktiver, samt mandat og resourcer nok til at udføre relevante kontroller og opfølgning

I denne bog, og i dette kapitel, har vi udvalgt de roller og titler, som man vil støde på hos langt de fleste virksomheder, der arbejder seriøst med cybersikkerhed. Vi må selvfølgelig lige påpege, at der er langt flere roller og titler end dem, vi kan nå omkring her. F.eks. har større og ofte mere modne virksomheder et bredt udvalg af roller og jobtitler relateret til cybersikkerhed – såsom f.eks. Cyber Incident Responder, Cybersecurity educator, cybersecurity implementer, Cyber legal, policy & compliance officer m.m. Hvis du er nysgerrig på at dykke ned i, hvad hver af disse – og en række andre – titler egentlig dækker over, så kan vi anbefale at se nærmere på "European Cybersecurity Skills Framework" fra ENISA (European Union Agency for Cybersecurity, 2023).

En tydelig fordeling af roller og ansvar er en essentiel del af et stærkt cyber- og informationssikkerheds-setup. Som Carsten Jørgensen uddyber nedenfor, så starter det hele med ledelsens rammer.

"Det allervigtigste er at vide, hvor ledelsen står. Ledelsen skal være helt tydelige omkring de rammer og den risikoappetit, som de kan acceptere. Hvis det ikke er på plads, er det her, man skal starte. Min anbefaling vil

også være at afklare, hvor der er fælles interesser, og arbejde på at etablere et godt samarbejde bredt i organisationen. F.eks. vil man ofte kunne hente hjælp til at afklare f.eks. kontrakter og til at forstå konsekvenserne af ny lovgivning med den juridiske afdeling. Husk også facility management – altså den fysiske sikkerhed. Jeg ser desværre ofte, at organisationer kan blive ivrige efter at styrke IT-sikkerheden, men nedprioriterer fysisk sikkerhed. Det nytter ikke at have stærke sikkerhedsforanstaltninger i et IT-perspektiv, men at det så samtidig er muligt for uvedkommende at komme ind i bygningerne, og at man ikke har overblik over sine fysiske bygninger og aktiver."

– Carsten Jørgensen, senior cybersecurity consultant og ekstern lektor ved Københavns Universitet

RACI – et kringlet, men godt værktøj til at skabe overblik

Når man arbejder ud fra en 3LD-model (De tre forsvarslinjer), er man godt på vej med at fastlægge, hvilke ansvarsområder der tilhører hvilke roller. Vores erfaringer har dog vist, at netop med rollefordeling er det ikke nok at være "godt på vej", det skal være fuldstændig skåret ud i pap (og godkendt af ledelsen) for at sikre, at der ikke opstår unødvendige gnidninger og lange diskussioner. Til dette har vi ofte haft glæde af at bruge den såkaldte RACI-model (Costello, 2012).

RACI er oprindeligt et projektledelsesværktøj og er en forkortelse af ordene Responsible, Accountable, Consulted og Informed (Costello, 2021). Vi har i vores arbejde ofte oplevet mange, der tænker, at *"det da er helt tydeligt i min organisation, hvem der har ansvar for det her".* Sagen er bare den, at som projektet skrider fremad, er det måske alligevel ikke helt tydeligt for alle, hvem der *egentlig* har ansvaret for f.eks. at godkende det endelige produkt, eller hvem der *egentlig* skulle have været med til at give kommentarer og input. Her kan RACI'en være et rigtig godt værktøj at have med sig. Oversættelsen til dansk kan volde lidt problemer, da "responsible" og "accountable" begge ofte oversættes til "ansvarlig" på dansk. Af den grund synes mange, at RACI-modellen kan være en anelse "kringlet". Men vi har oplevet, at når man først har forstået termerne, kan man se nødvendigheden i at holde fast i begge. Se oversættelse med et eksempel på en awareness-kampagne nedenfor.

Engelsk	Dansk	Kommentar
Responsible	Ansvarlig for, at opgaven udføres. Refererer "opad" til den person, der er "accountable".	Et eksempel kan være, at en organisation vælger, at der skal gennemføres en awareness-kampagne med fokus på at undgå phishing-e-mails. Selve kampagnen udarbejdes af en medarbejder i IT-sikkerhedsafdelingen i samarbejde med en medarbejder fra kommunikationsafdelingen.
Accountable	Den øverst ansvarlige for opgaven. Kan uddelegere opgaven, men ikke ansvaret.	I tilfældet med kampagnen kunne den øverst ansvarlige for at godkende kampagnen og sikre ressourcer til opgaven være CISO.
Consulted	Konsulteret Den eller de personer, der skal give input eller konsulteres undervejs.	For en awareness-kampagne kunne det f.eks. være, at en leder for kommunikationsafdelingen skal konsulteres og give input, f.eks. kan det være relevant at drøfte timing, så der ikke samtidig er andre kommunikationsopgaver i spil, der kæmper om medarbejdernes opmærksomhed.
Informed	Informeret Den eller de personer, som skal informeres om projektet/indsatsen, men som ikke har indflydelse på opgaven.	En kampagne som denne vil ofte give anledning til spørgsmål, som en kommunikationsafdeling eller andre skal sidde klar til at besvare. Disse kunne derfor være et eksempel på en brugergruppe, der skal informeres, inden kampagnen lanceres.

Figur 5.4. RACI-model med eksempler.

RACI-modellen er som sådan ikke udviklet til cyber- og informationssikkerhedsområdet, men kan være et stærkt værktøj at have med, når opgaver skal uddelegeres og aftales endeligt. Selv bruger vi det i opstarten af en indsats for at have forventningsafstemt grundigt, inden arbejdet sættes i gang. Vi har desværre ofte oplevet, at når det kommer til endelig godkendelse af en sikkerhedsforanstaltning, kan dette trække i langdrag. Dette kan være, fordi personer, som man som projektmedarbejder troede blot skulle informeres ("informed"), mener, de skal konsulteres ("consulted"), og at de derfor har mange indvendinger og kommentarer. Det kan også være uklart, hvem der for eksempel har ansvar for at tildele flere resourcer eller den endelige godkendelse ("accountable").

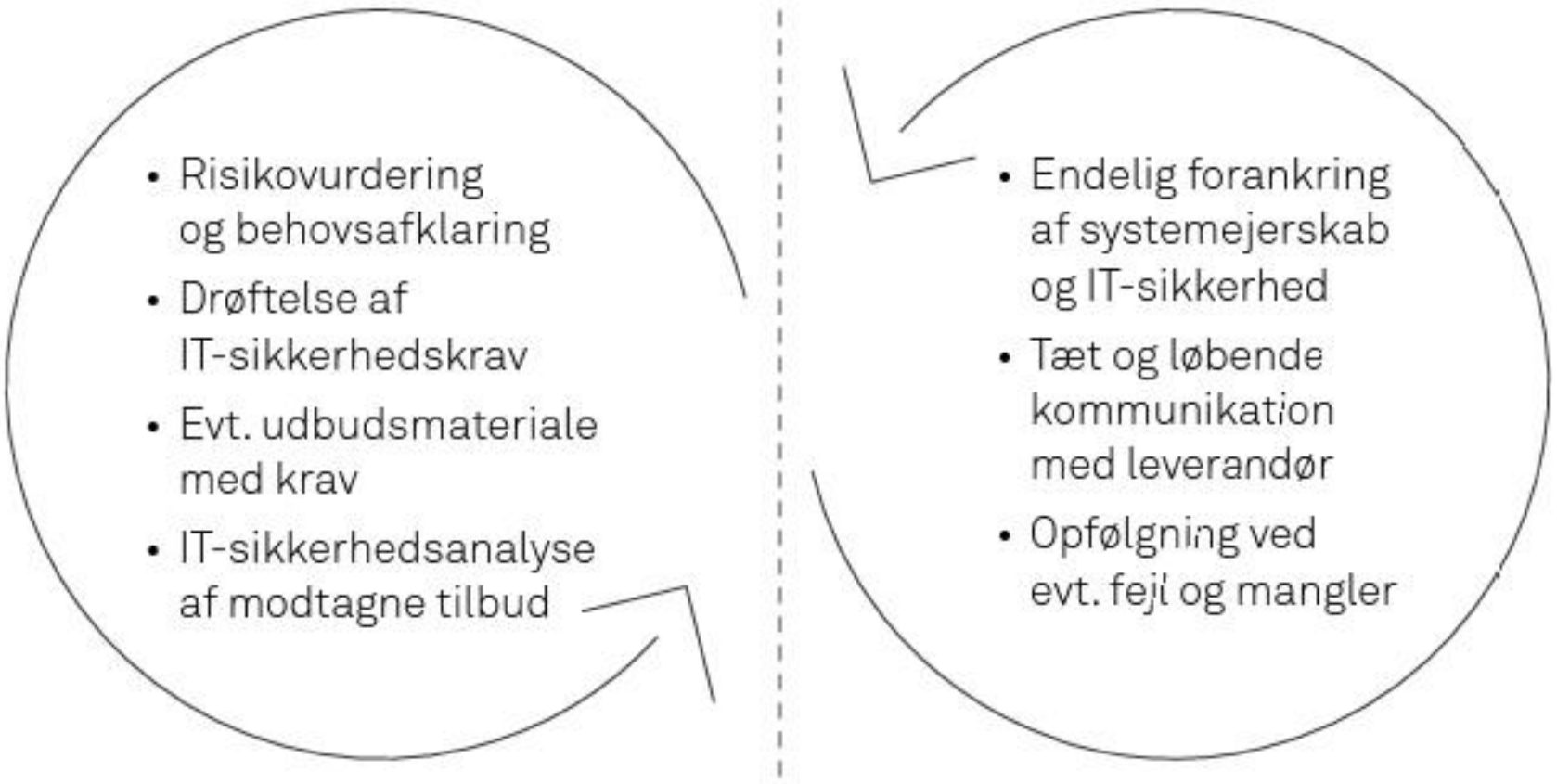
RACI i samarbejdet med andre afdelinger i en organisation

En gennemgang af RACI-modellen kan bruges, som i eksemplet i tabellen ovenfor, på opgaveniveau. Derudover kan det også med fordel bruges i "helikopterperspektiv" for alle roller i informationssikkerhedsarbejdet og i samarbejdet med andre afdelinger. Her skal "andre afdelinger" forstås som f.eks. HR, økonomiafdelingen og IT-afdelingen. Disse afdelinger, eller fagkontorer, er en nødvendig del af at sikre en organisation med et passende informationssikkerhedsniveau. Her er det vigtigt at få et godt samarbejde op at køre, således at f.eks. medarbejdere fra HR inddrages og forstår, hvorfor de skal medvirke til f.eks. en risikovurdering af et HR-system, men samtidig ikke drukne dem i det IT-tekniske og faglige sprog, der ofte kan være. Endnu en fordel ved RACI-modellen er, når kollegaer ved, at de f.eks. vil blive "consulted" undervejs, så opgaven ikke kommer som en overraskelse. Dermed ved man, at der skal sættes tid af, og hvilken rolle man spiller – og dermed er der større sandsynlighed for, at opgaven udføres (og til tiden!).

Format for et godt leverandørsamarbejde

Når man taler om roller og ansvar i cyber- og informationssikkerhed, er det helt nødvendigt også at nævne leverandører (Digitaliseringsstyrelsen, u.å.). Der findes trods alt ingen virksomheder i dag, som ikke på den ene eller den anden måde har nogle leverandører af IT-systemer, der understøtter organisationens arbejde. Helt fra de store leverandører som f.eks. Microsoft og ned til meget små, specialiserede leverandører, der udvikler netop det stykke software, der f.eks. styrer produktionen af den dims, som virksomheden lever af at producere. Leverandørstyring er så stort et område, at det nemt kunne være et kapitel for sig, og ofte har vi et særligt modul om leverandørstyring, når vi er ude og undervise. Det er dog også vores erfaring, at mange medarbejdere ikke har direkte berøring med leverandørstyring, men derimod blot har behov for at forstå de overordnede linjer i, hvad leverandørstyring er, og hvad man som medarbejder skal være opmærksomhed på i forbindelse med dette.

Leverandørstyring er en betegnelse for det samarbejde, der er imellem en organisation (kunde) og en leverandør. Leverandørstyring kan med fordel anskues som en proces med et tydeligt "før" og "efter" indgåelse af kontrakt.



Figur 5.5. Leverandørstyring kan opdeles i faserne "før" og "efter" kontraktindgåelse.

Før kontraktindgåelse

Tiden før valg af leverandør og indgåelse af kontrakt kan være både lang og kort, afhængigt af hvad det er, organisationen skal indkøbe, hvor kritisk det er for forretningen, og om det er underlagt f.eks. udbudsregler. Typisk vil der dog være opstået et behov for enten at indkøbe et nyt IT-system eller at sætte et IT-system i udbud. Det kan også dreje sig om noget fysisk materiel, som også indeholder "noget teknologi", der skal vurderes, f.eks. overvågningskameraer, printere, telefoner osv. Forretningen skal klarlægge de funktionelle behov, hvilket i sig selv kan være en omfangsrig opgave. Vi har derfor oplevet, at organisationer kan være tilbageholdende med at tage endnu flere perspektiver med ind i drøftelserne eller simpelthen glemmer, at cyber- og informationssikkerhed er et nødvendigt perspektiv. Vi anbefaler dog altid, at kyndige folk med et IT-sikkerhedsperspektiv kommer ind i overvejelserne så tidligt som muligt. Det sikrer, at forretningen får sat de rette krav og i god tid – dermed mindskes sandsynligheden for, at indkøb af et nyt system eller teknologi stoppes i sidste øjeblik, fordi nogen alt for sent opdagede, at det f.eks. ikke må anvendes til håndtering af den type personoplysninger, som organisationen håndterer. Alt dette baserer sig på risikovurderingen, som kan gøre det tydeligt, hvilke sik-

kerhedskrav der skal stilles til leverandøren, herunder hvor detaljerede krav der skal stilles, og hvilken dokumentation eller audit der vil være behov for.

Med cyber- og informationssikkerhedsbrillerne på bør man hurtigt få afklaret, hvilke data forretningen forestiller sig, systemet skal behandle. Derudover skal det grundigt afklares, hvilke behov forretningen stiller til håndtering og opbevaring af data i systemet, så det ikke – som det desværre ofte sker – blot er leverandøren og dennes indstillinger, der ender med at sætte rammerne. Husk at se nærmere på ISO 27001 5.19-5.22, som netop beskæftiger sig med dette område.

Efter kontraktindgåelse

Når først kontrakten er indgået, er det nødvendigt også løbende at holde kontakten med leverandøren og sikre, at de løbende lever op til de krav, der er sat. Vi ved af erfaring, at det for nogle kan være svært at skulle "kigge leverandøren efter i kortene", og vi har oplevet, at det kan synes svært, fordi det virker, som om man så ikke stoler på samarbejdet.

I nogle organisationer og myndigheder har man måske i årevis samarbejdet med den samme leverandør om et kernesystem, og samarbejdet giver ikke umiddelbart anledning til problemer. Udfordringen her er dog, at kravene til leverandørstyring ændrer sig i takt med den digitale udvikling. Og det med at "stole på", at leverandøren lever op til de krav, der er fastsat i kontrakten, er simpelthen ikke godt nok i en verden, hvor IT-kriminelle står på spring for at udnytte hver en lille sprække, de kan finde. Leverandører har også tit en del at se til, så selvom det ikke nødvendigvis er af ond vilje, bliver der ikke altid fulgt op på alt det, man har aftalt. Det må man altså som kunde selv være helt sikker på. Man gør sig selv en stor tjeneste ved, at man i organisationen tydeligt aftaler, hvem der har ansvaret for leverandørsamarbejdet, og sørger for, at der bliver rettet op, hvis man finder fejl.

I nogle tilfælde skal et IT-system sendes i udbud, og dette bør man betragte, som om processen starter forfra, så man igen er i "før kontrakt"-fasen. Der vil næsten altid være sket så meget med forretningens behov og ikke mindst med sikkerhedskravene, at det er nødvendigt at få vurderet sikkerhedsbehovet på ny. Ved udbud er det derfor naturligt, at sikkerhedskravene gennemgås, men husk ellers, at det er risikovurderingen, der skal vise, hvordan der skal priori-

teres. Det er så let at lade alt fokus gå til de nye og spændende systemer, der skal indkøbes, og langt mindre sexet at være den, der insisterer på, at et gammelt system også skal leve op til de nyeste sikkerhedskrav. Det kan være en sej omgang at genforhandle en gammel kontrakt på et system, som de fleste i organisationen bare helst vil glemme alt om, men du kan jo selv gætte på, hvor det formentlig er lettest for en hacker at få adgang.

En kort opsummering:

Roller og ansvar – cybersikkerhed som holdsport

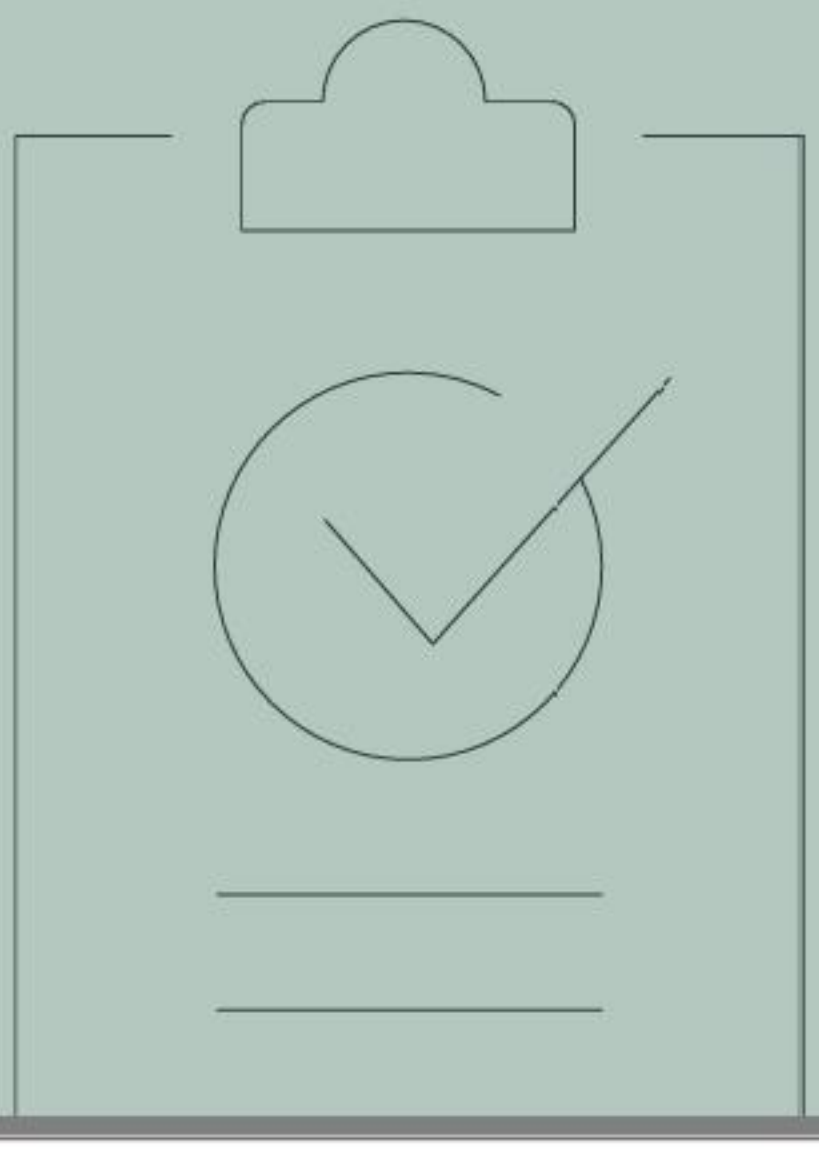
- Der er mange aktører på cyber- og informationssikkerhedsområdet, men som medarbejder er det allervigtigste at kende til de rammer og den risikoappetit, der er udstukket af ledelsen. Alt andet arbejde udspringer fra dette.

- I en enhver organisation, der skal styrke sit cybersikkerhedsforsvar, skal roller og ansvar for informationssikkerhedsarbejdet være tydeligt uddelegeret og formaliseret (skrevet ned). Dette er også et ufravigeligt krav, hvis organisationen f.eks. skal ISO 27001-certificeres.

- 3LD-modellen (De tre forsvarslinjer) er en anerkendt måde at organisere sig på i forhold til informations- og cybersikkerhed. Ledelsen står altid øverst, men 1. forsvarslinje er den afdeling eller rolle i organisationen, som ejer de udpegede risici, og som har til ansvar at efterleve de fastsatte krav. Cybersikkerhedsfunktionen udgør 2. forsvarslinje og er overordnet ansvarlig for risikostyringsprocessen og understøtter ved behov 1. forsvarslinje. 3. forsvarslinje er intern revision, der løbende udfører kontrol og er ledelsens garant for, at de udpegede risici rent faktisk håndteres som aftalt.

- RACI-modellen kan bruges på både afdelingsniveau og på opgaveniveau til at klarlægge, hvem der har ansvar, således at der skabes grundlag for godt samarbejde og fremdrift.

- Leverandørsamarbejdet kan anskues som en "før" og "efter" kontraktindgåelse. Det er vigtigt, at det informationssikkerhedsmæssige perspektiv kommer med i overvejelserne "før" valg af leverandør. "Efter" kontraktindgåelse skal man sikre det gode samarbejde med fastsatte møder, agendaer og hurtig opfølgning, hvis leverandøren ikke lever op til aftalerne.



Case:

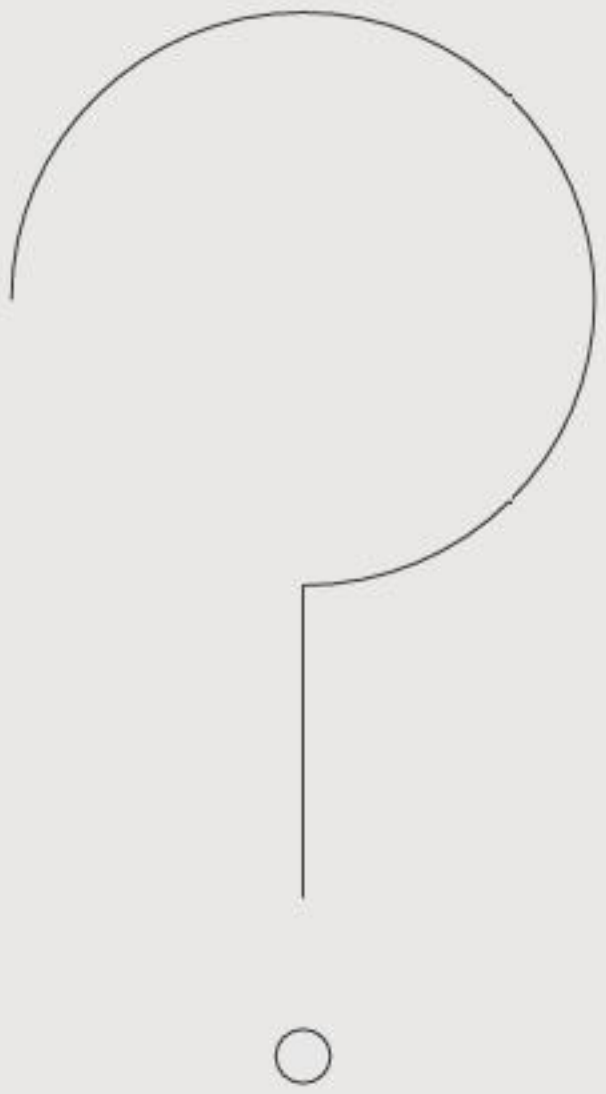
En awareness-kampagne trækker i langdrag

Som eksempel på, hvorfor det kan være en god idé at have en drøftelse af RACI-modellen med i cyber- og informationssikkerhedsarbejdet, handler denne case om en awareness-kampagne, som bygger videre på de roller og det ansvar, der er beskrevet i tabellen ovenfor.

I en flot gammel bygning i indre København har den danske handelsvirksomhed ExportaDan A/S til huse. Ved den seneste drøftelse i informationssikkerheds-udvalget er alle blevet begejstrede for ideen om en knivskarp kampagne, der skal oplyse medarbejdere om, hvordan de skal spotte og rapportere phishing-e-mails. Kampagnen skal både være informativ og sjov, men selvfølgelig også have en faglig dybde og være på linje med organisationens øvrige kommunikationsmaterialer. Der nedsættes en arbejdsgruppe på to medarbejdere fra henholdsvis informationssikkerhedsafdelingen og kommunikationsafdelingen, som får til opgave at udarbejde kampagnen. CISO'en tror, at det er kommunikationschefen, der skal endeligt godkende materialet, og kommunikationschefen er sikker på, at det er CISO'en, der skal afsætte tid til godkendelsesprocessen, da det "faglige" indhold ikke er på hendes bord. Allerede ved de første oplæg af materialet er det derfor ikke tydeligt for de to medarbejdere, hvem de skal indkalde til møder, og kampagnen bliver allerede her forsinket. Det fastlægges herefter, at det er CISO, der har ansvar for den endelige godkendelse af materialet. Da kampagnen er ved at være klar, sendes materialet til info til kommunikationsafdelingen for yderligere input. Disse medarbejdere har dog travlt og er ikke klar over, at der skal afsættes tid til at gennemgå kampagnen. Det varer derfor to uger yderligere, før kommunikationsmedarbejderne har tid til at give input og sikre, at kampagnen er i tråd med virksomhedens øvrige kommunikationsguidelines. I mellemtiden har DPO'en meldt sig på banen med en række kommentarer og er meget ivrig og vedholdende omkring at give input. Han mener, at plakaterne mangler en række vigtige pointer, som absolut skal med. DPO'en begynder derfor nu at sende hidsige mails til arbejdsgruppen, med kommunikationschefen CC. Kampagnen udskydes yderligere to uger for at være sikker på, at alle kommentarer vurderes.

Arbejdsspørgsmål

- Hvem i den ovenstående case mener du er henholdsvis Responsible, Accountable, Consulted og Informed? Hvorfor?
- Hvilket ansvar mener personerne i casen selv, at de har – og stemmer det overens med det, du har vurderet?
- Hvorfor opstår uenigheden om den endelige godkendelse?
- Hvad kunne man have gjort for at undgå, at DPO'en så sent i processen kommer med kommentarer?



Litteraturliste

Center for Cybersikkerhed (2024, 8. februar). Status på NIS2. Lokaliseret på: https://www.cfcs.dk/da/om-os/nis2/

Center for Cybersikkerhed (2024, 4. juli). Trusselsvurdering. Lokaliseret på: https://www.cfcs.dk/da/cybertruslen/trusselsvurderinger/

Costello, T. (2012). RACI—Getting Projects" Unstuck". IT Professional, 14(2), 64-63.

Digitaliseringsstyrelsen (u.å.). SikkerDigital. Lokaliseret på: www.sikkerdigital.dk

Europa-Kommissionen (u.å.). Data protection in the EU. Lokaliseret på: https://commission.europa.eu/law/law-topic/data-protection/data-protection-eu_en

Det Europæiske Råd (2024). Cybersikkerhed: EU's håndtering af cybertrusler. Lokaliseret på: https://www.consilium.europa.eu/da/policies/cybersecurity/

European Cybercrime Centre-EC3 (u.å.). Combating crime in a digital age. Lokaliseret på: https://www.europol.europa.eu/about-europol/european-cybercrime-centre-ec3

European Union Agency for Cybersecurity (2023, september). European Cybersecurity Skills Framework.

Finansministeriet (2021, december). National Strategi for cyber- og informationssikkerhed 2022-2024.

Implement Consulting Group (u.å.). DORA-The EU's Digital Operational Resilience Act. Lokaliseret på: https://implementconsultinggroup.com/topic/dora

Institute of Internal Auditors (IIA) (2020). THE IIA'S three lines model. An update of the Three Lines of Defense. Lokaliseret på: https://www.theiia.org/globalassets/documents/resources/the-iias-three-lines-model-an-update-of-the-three-lines-of-defense-july-2020/three-lines-model-updated-english.pdf

International Organization for Standardization (2022). Information Security, cyber security and privacy protection-Information security management systems-Requirements. Reference number ISO/IEC 27001:2022(E).

Jacobsgaard, T. og Lavesen, A. (2024, 18. marts). Cybersikkerhed er afgørende for væksten-og bliver nu bestyrelsens ansvar". Børsen.

National Institute of Standards and Technology (2023). The NIST Cybersecurity Framework (CSF) 2.0. U.S. Department of commerce.

Nicho, M., Khan, S., & Rahman, M. S. M. K. (2017, september). Managing information security risk using integrated governance risk and compliance. In 2017 *International Conference on Computer and Applications (ICCA)* (pp. 56-66). IEEE.

Ruud, F. (2019). Reflections on the Three Lines of Defense. Internal Audit Service, European commission.

Kapitel 6

Kapitel 6

IT-beredskab:
Vær klar, når stormen kommer

> Hvis organisationer synes, at gode beredskabsplaner er dyre, så bliver de slemt overrasket, når de prøver de dårlige."

Dion Rønne-Rasmussen,
cybersikkerhedskonsulent, Implement Consulting Group

Når tid er penge

Forestil dig dette scenarie: Det er en fredag sen eftermiddag, og de fleste medarbejdere er allerede draget ud i eftermiddagstrafikken og er på vej hjem til deres familier. Pludselig får topchefen det opkald, som de fleste topchefer nok frygter allermest. En panisk IT-medarbejder fortæller med rystende stemme, at de har tydelige indikationer på, at virksomheden er ramt af ransomware-angreb. Hackerne påstår at være i besiddelse af de allermest sensitive informationer, organisationen har. IT-chefen sidder i et fly på vej til skihytten i Norge, og ingen aner, hvad de skal stille op. IT-medarbejderen er i fuld panik og allerede på grådens rand. "Men hvad skal vi gøre, chef?"

Ovenstående er måske et lidt karikeret eksempel, men ikke desto mindre et, der alt for ofte finder sted i både danske og internationale virksomheder. Hackere er udspekulerede og sender gerne angreb afsted på utroligt ubelejlige tidspunkter, såsom f.eks. i weekender eller ferier, eller når nøglemedarbejdere er utilgængelige. Lad os forestille os, at man i en organisation *ikke* har et beredskab klar, eller at beredskabsplanerne ikke er opdaterede eller tilgængelige. Her vil de første meget vigtige timer af et angreb eller en hændelse gå med blot at få lokaliseret medarbejderne, få dem informeret om situationen og få aftalt helt lavpraktiske detaljer såsom, hvordan man får fat i hinanden (hvis f.eks. mails og almindelige chatkanaler er lagt ned), og hvor man evt. fysisk kan mødes henne (hvis kontoret f.eks. er utilgængeligt). Først herefter kan det egentlige arbejde med at få overblik, få udbedret skaden og få genetableret driften begynde. Det er timer, der koster rigtig, rigtig mange penge. For samfundskritiske funktioner, såsom f.eks. fjernvarme, vand og elektricitet, kan

større udfald i sidste ende have fatale konsekvenser. I dette tilfælde er talemåden "Tid er penge" virkelig helt sand, og endda i nogle tilfælde gælder det, at tid også kan koste menneskeliv.

"Et godt beredskab er ligesom at have et køleskab. Du påskønner det ikke i hverdagen, men når det bryder sammen, så finder du ud af, hvor vigtigt det var. Det handler om, at ting, som vi i hverdagen ser som selvfølgeligheder, bare ikke altid er selvfølgeligheder. På samfundsniveau sikrer beredskabet og vores resiliens, at vi har en hverdag med en høj levestandard, også når der sker overraskelser. For organisationer kan et længerevarende nedbrud betyde konkurs", fortæller Christian Ehlers Mikkelsen, cyber- og informationssikkerhedsekspert hos Implement. Som om disse dystre udsigter ikke var begrundelse nok for aktivt at beskæftige sig med beredskab og disaster recovery, så er det værd at nævne, at det naturligvis også er en del af kravene, f.eks. ifølge ISO-standarden 27001 i anneks A, foranstaltning 5.30.

Beredskabsstyring og resiliensbegrebet eksisterer, fordi organisationer, store som små, kan blive udsat for og bliver udsat for uforudsete hændelser, der påvirker driften negativt. Det kan være f.eks. globale pandemier, krige, uforudsete markedsbevægelser osv. Det kan også være på cyber- og informationssikkerhedsområdet, hvor IT-systemers fortrolighed, integritet eller tilgængelighed bliver kompromitteret, så vores data kommer i de forkertes hænder, vi ikke kan stole på vores data eller ikke har adgang til vores IT-systemer. Alt sammen noget, der har betydning for vores evne til at tilpasse os en ny virkelighed, genoprette og opretholde normal drift og leverancesikkerhed i vores daglige arbejde. Sagt med andre ord så påvirker hændelserne vores forretnings- og informationssikkerhedskontinuitet.

Som med de øvrige områder i denne bog kræver det, også med IT-beredskabsstyring, mange års erfaring at sikre høj kvalitet i arbejdet. Det er derfor en god idé at alliere sig med en erfaren kollega eller ekstern ekspert til at gennemføre eller validere arbejdet. Derudover findes der mange gode onlineressourcer samt relevante netværk, hvor man kan dele viden og erfaring. Vi vil dog i denne bog præsentere nogle af nøglebegreberne, metoder og værktøjer til at komme i gang med eller bidrage til beredskabsarbejdet, selvom man ikke – endnu – er 100-metermester indenfor feltet. Cyber- og informationssikkerhed har som fagfelt generelt en forkærlighed for forkortelser, og dette er

også særligt udtalt på beredskabsområdet. Men hold fast, og vi skal i dette kapitel forsøge at få foldet de allermest centrale begreber ud og få dem sat i sammenhæng med hinanden, så det er tydeligt, hvilke opgaver der ligger i hver, samt hvilket formål de tjener.

Eksempler på forretningskontinuitet (business continuity)

Uden at være klar over det har du formentlig flere gange oplevet "business continuity" i din hverdag. I supermarkedet sker det nu og da, at man ikke kan betale med kort, her er nødproceduren ofte, at der kan betales med kontanter i stedet. Koncerter og forlystelsesparker skal holde øje med, hvor mange besøgende de har, for at kunne overholde f.eks. brandlovgivning, men hvis registreringen er nede, står de og tæller med en "klikker" i hånden. Hvis der er problemer på togsporene, indsættes der togbusser. Alle disse er eksempler på beredskaber, så man er klar, hvis "kerneprocesen" er brudt ned (business continuity).

Hvor skal man starte?

Fundamentet for et effektivt arbejde med beredskab bygger, ligesom effektivt cyber- og informationssikkerhedsarbejde i sin helhed, på, at man kender sin organisation. Det er en forudsætning for beredskabsstyringen, at man har styr på sine kritiske forretningsprocesser og sin risikovurdering. Derfor bygger dette kapitel ovenpå de pointer, der er præsenteret i hhv. kapitel 2 om, at cyber- og informationssikkerheden skal gå i takt med digitaliseringen, og kapitel 4 om risikovurdering. Nedenstående oversigt viser, hvordan dette kapitel bygger videre på kapitel 2 og 4.

Figur 6.1. Et effektivt beredskab bygger videre på et grundlæggende kendskab til de vigtigste forretningsprocesser (se mere i kapitel 2) og risikovurdering (se mere i kapitel 4).

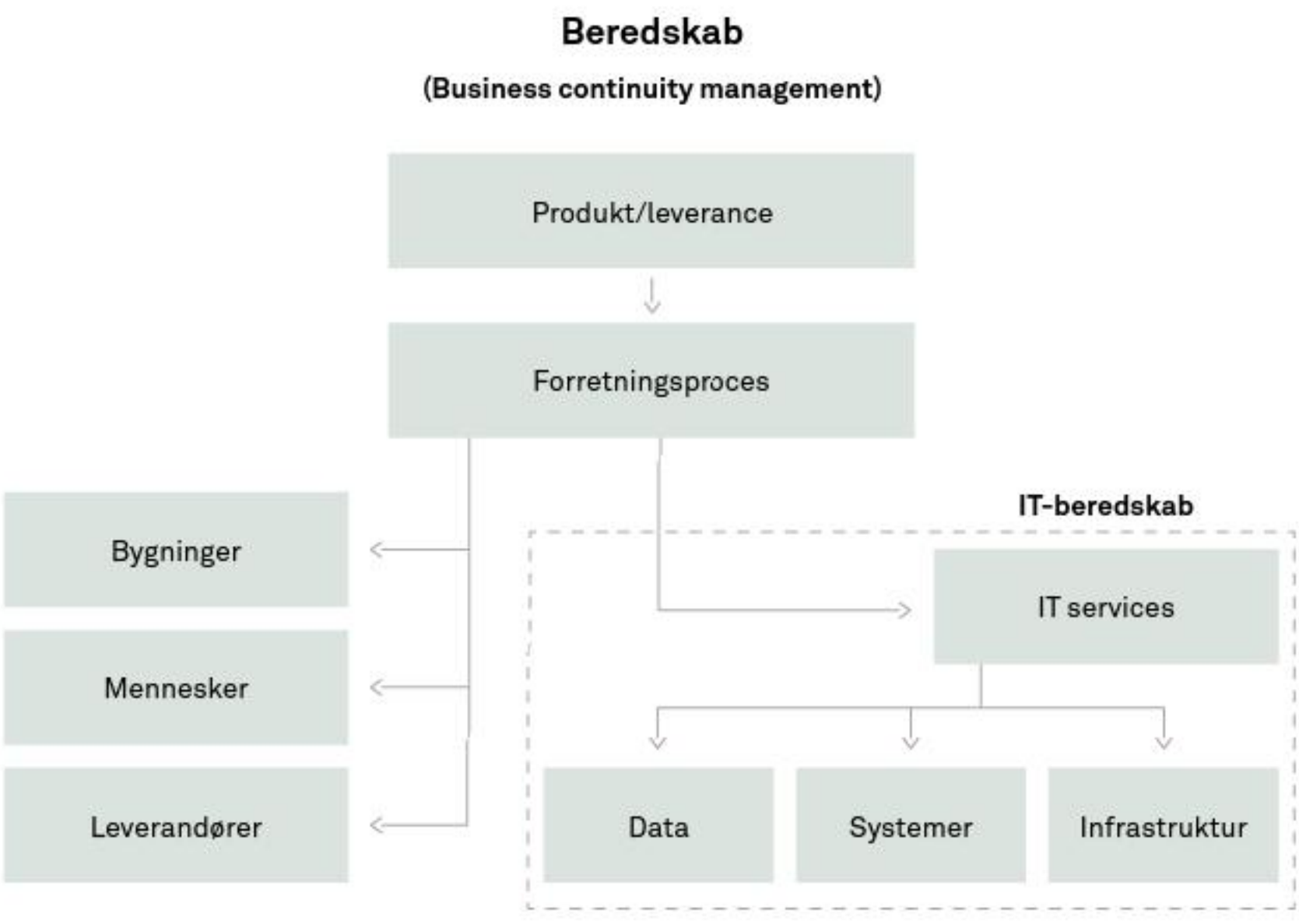
En meget anvendt fremgangsmåde i branchen er at gøre brug af "plan-do-check-act-tilgangen", som vi derfor præsenterer i dette kapitel. Her ser vi på, hvordan man kan planlægge beredskabsarbejdet, men også implementere og teste det i praksis, så alle er klar over, hvordan de skal reagere i tilfælde af en krisesituation. Endelig ser vi også på, hvordan man evaluerer indsatsen, så arbejdet løbende forstærkes og udbedres.

IT-beredskab som en del af det generelle beredskab

Før vi dykker ned i kapitlets egentlige emne, tager vi lige et par indledende knæbøjninger i form af definitionsarbejde. IT-beredskab er generelt filtret ind i en del begrebsforvirring, og forskellige eksperter vil foretrække at bruge en række forskellige termer. Vi har forsøgt i dette kapitel at holde os til ISO-standarden 22301:2019. Den mere overordnede standard ISO 27001 indeholder også et par nedslag i beredskab, men for organisationer, der ønsker endnu mere vejledning, kan man med fordel dykke ned i 22301.

Beredskab har overordnet set det formål, at organisationen skal være bedst muligt rustet til at håndtere uforudsete hændelser af enhver art. I dette kapitel beskæftiger vi os særligt med IT og IT-understøttede forretningsprocesser og derfor den "gren" af beredskab, som kan kaldes IT-beredskab. Vi ser desværre

indimellem, at IT-beredskab bliver udarbejdet i sin egen silo, og at det ikke er tydeligt for organisationen, hvad IT-beredskabet dækker over, eller hvordan det skal sættes i værk i tilfælde af en alvorlig hændelse. I dette kapitel beskæftiger vi os ikke med det "klassiske" beredskab, men udelukkende den del, der i figuren nedenfor er afgrænset til IT-beredskab. Det er dog væsentligt, at en virksomhed eller myndighed sikrer sig, at IT-beredskabet er i overensstemmelse med øvrige beredskabsindsatser, så der samarbejdes på tværs (Cordero, 2019).



Figur 6.2. IT-beredskab som en del af det overordnede beredskab.

Følgende figur visualiserer en del af de dokumenter og planer, der knytter sig til arbejdet på beredskabsområdet. Vi har over årene set en del forskellige måder, hvorpå organisationer både udvikler, navngiver og opdeler deres dokumenter. Nedenstående figur kan bruges som et udgangspunkt og skal naturligvis tilrettes og udvikles i overensstemmelse med organisationens modenhed.

BIA = Business Impact Analysis

På dansk: Konsekvensvurdering

Er en forudsætning for prioriteringen i beredskabet

→

Beredskabsplan

Forretnings-kontinuitetsplan

På engelsk: Business continuity plan (BCP)

→

IT-beredskabs-politik

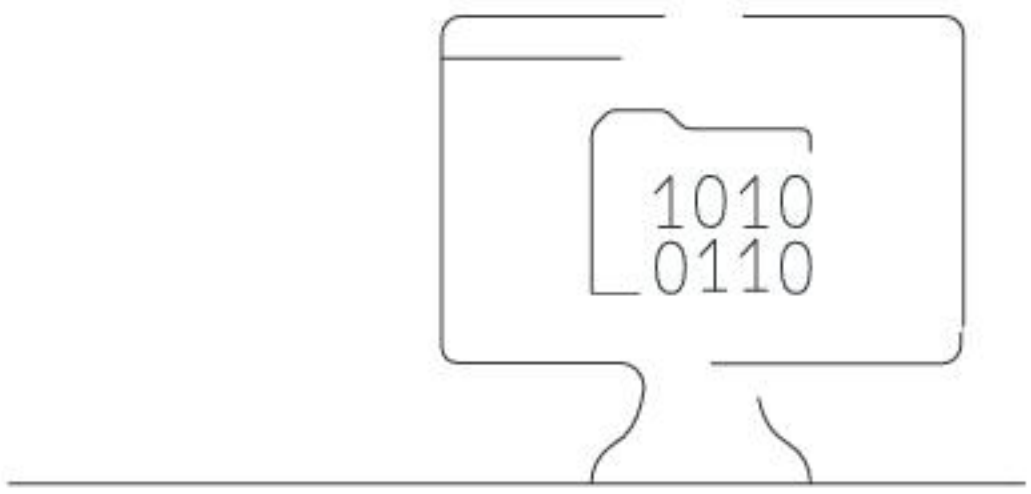
Overordnede rammer for organisationens arbejde med og implementering af IT-beredskabet.

↓

IT-beredskabsplan

På engelsk: IT-BCP = IT Business continuity plan

Den mere detaljerede udmøntning af IT-beredskabspolitikken.



↓

DRP = Disaster Recovery Plan

På dansk: Genetableringsplan

Én DR-plan per forretningsområde/funktionsniveau, med fokus på gentablering af dette område/niveau

↓

TRP = Technical Recovery Plan

På dansk: Teknisk genetableringsplan

Én TR-plan per system, med fokus på genetablering af det pågældende system

Figur 6.3. Sammenhæng mellem typer af dokumenter i IT-beredskabet.

Som figur 6.3 viser, er hovedfokus for dette kapitel IT-beredskabspolitikken og IT-beredskabsplanen. Denne plan ser vi nogle gange opstår eller udarbejdes fra IT-afdelingens side, men dette kan give store problemer, da det arbejde ender med ikke at stemme overens med resten af organisationens behov. De helt overordnede rammer og målsætning for beredskabet findes i en beredskabspolitik (Digitaliseringsstyrelsen, u.å.).

> *"Det er ikke planerne, der er det vigtige. Men det er alle mellemregningerne i vejen til at skrive planerne – altså planlægningen. For det er i dette forløb, virksomheden lærer en masse og vil være i stand til at ændre på tilstande, der ikke findes acceptable. Derfor er det at udarbejde planerne ikke bare at skrive ned, som man mener, verden hænger sammen. Men at der indsamles oplysninger til planen, som skal hænge sammen. Og bare det at få det til at hænge sammen på papir afstedkommer opdagelser og huller, der skal lukkes som en del af planlægningen. Det vil sige, at det er en yderst vigtig fase at udarbejde planerne. Når de så ER lavet, så kan man teste/afprøve, om de så holder. Og gør de ikke, så retter man alt efter det, man har fundet, og tester igen."*
> Dion Rønne-Rasmussen, cybersecurity consultant og Disaster Recovery-specialist, Implement Consulting Group

IT-beredskab ved brug af plan-do-check-act

I det følgende benytter vi os af plan-do-check-act-tilgangen, der gør, at forberedelsen af en IT-relateret krisesituation bliver så god som muligt, samt at man løbende evaluerer og opdaterer sit beredskab. Vi læner os dermed op ad ISO 27001 om beredskabsstyring, der anviser en række foranstaltninger, der har til hensigt at sikre, at organisationen har et tilstrækkeligt beredskab. Standardens anneks A, foranstaltning 5.30, pointerer f.eks., at forretningskontinuiteten skal:

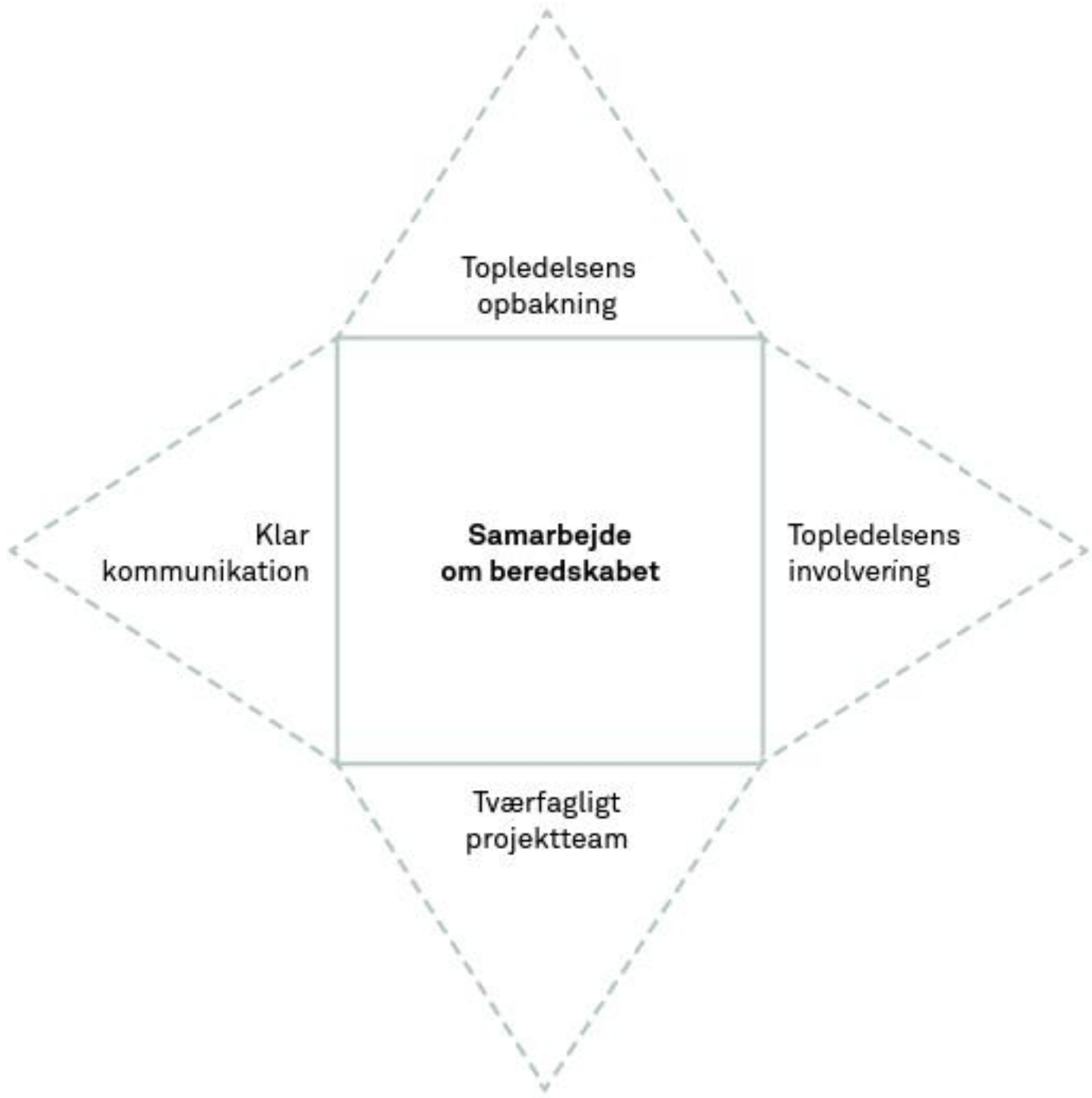
- Planlægges (plan)
- Implementeres (do)
- Verificeres og gennemgås (check)
- Evalueres (act).

Plan (forberedelse)

Det første og afgørende skridt i et effektivt krise- og beredskabsstyrings-setup er planlægningsfasen. Det er her, retningen og blikket sættes for, hvordan det videre arbejde skal udføres. Det er i planlægningsfasen, at man som organisation bør overveje og tage stilling til rammerne for forretningskontinuiteten. Vigtige spørgsmål at få svar på er f.eks.:

- Hvilke områder i vores organisation er særligt vigtige for, at vi kan opretholde en acceptabel drift?
- Hvilke ønsker har vi til nøddrift af forretningsprocesser? Herunder hvilke processer og dermed IT-systemer skal være omfattet af nøddriften?
- Hvordan skal beredskabet struktureres (roller og ansvar)?
- Hvordan prioriterer vi vores ressourcer i en krisesituation?
- Hvordan, til hvem og hvornår kommunikerer vi, når vi står i en krisesituation?

Det er klart, at det hviler på ledelsen at træffe beslutning om prioriteterne i beredskabet. Hvis ikke ledelsen er godt klædt på til at forstå, hvilke konsekvenser der vil være i en krisesituation, så er det vanskeligt for dem at træffe de rigtige beslutninger. Det er derfor vores erfaring, at samarbejde er nøgleordet for et effektivt beredskabsstyringsarbejde. Nedenstående figur viser nogle af de væsentligste forudsætninger for et godt samarbejde om beredskab.



Figur 6.4. Forudsætninger for samarbejde i beredskabssammenhæng.

Foruden et effektivt samarbejde på beredskabsarbejdet er der en række elementer, der er vigtige at fokusere på i planlægningsarbejdet for at besvare ovenstående spørgsmål. Det være sig helt overordnet, at vi skal kende vores organisation – dens mål, forretningsgange, digitale og IT-mæssige understøttelse, jf. pointerne i kapitel 2, og dens risikovurdering, jf. kapitel 3, og dernæst at vi skal fastsætte rammerne og målsætningerne i beredskabsarbejdet.

Konkret kan man komme et skridt videre end pointerne opridset i kapitel 2 ved at supplere sin omverdensanalyse, altså alt det, der påvirker konteksten for vores organisation, og risikovurdering med en såkaldt *business impact analysis*.

Business impact analysis

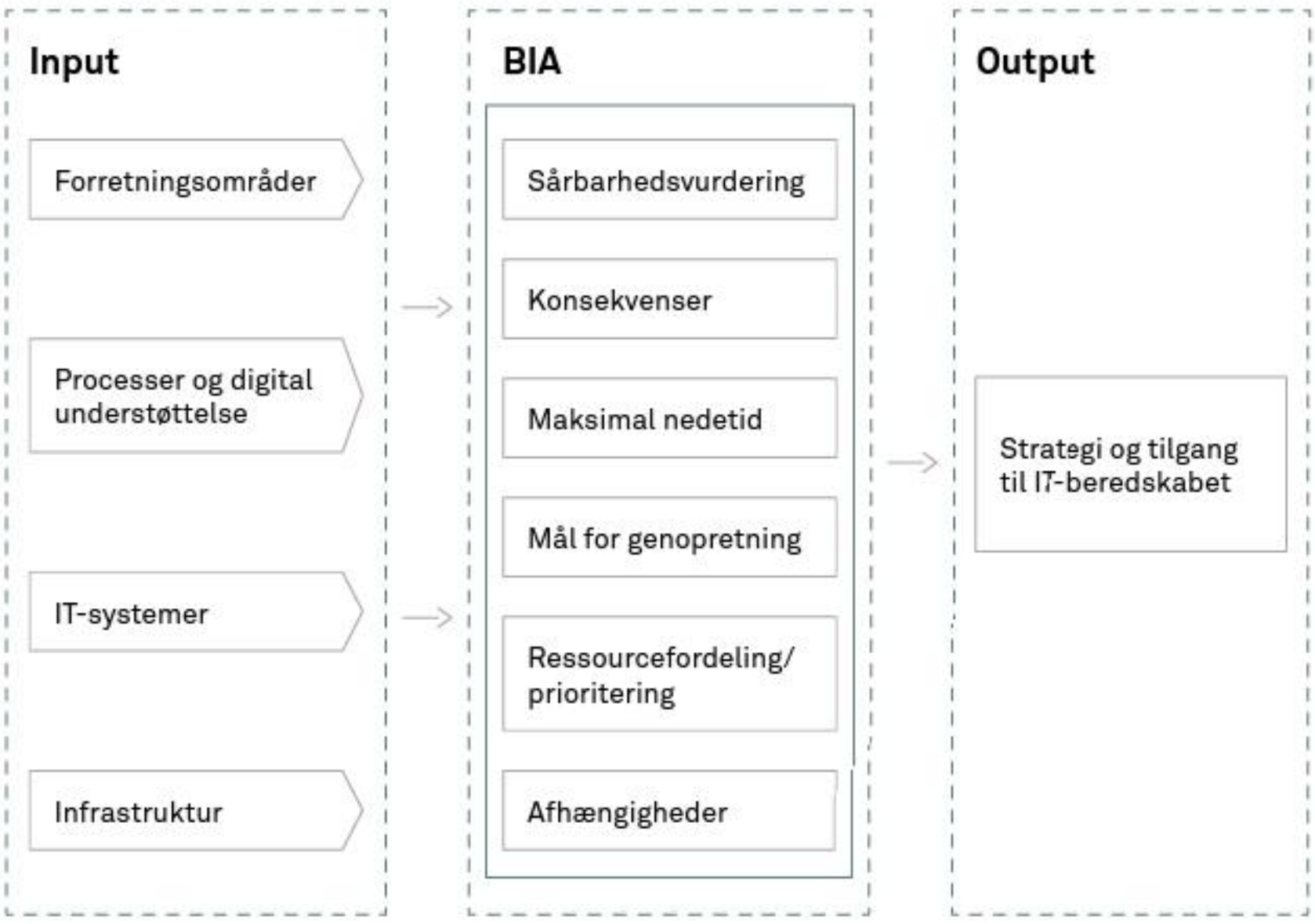
"Business impact analysis" er endnu en engelsk term, som vi ikke har fundet den gode danske oversættelse for. I nogle offentlige organisationer har vi set

termen ROS (Risiko- og sårbarhedsanalyse) i brug. Men uanset navnet er en business impact analysis (også ofte af fagfolk blot kaldet en "BIA") en forudsætning for arbejdet med beredskab, der bidrager til at skabe et overblik over de forretningsmæssige konsekvenser, vores organisation kan opleve i en krisesituation. Med et godt overblik er der grobund for en prioritering af indsatsen, hvilket er alfa og omega, når man står i en krisesituation.

For nogle organisationer er det fristende at slå autopiloten til og gennemgå *alle* deres forretningsprocesser og udarbejde et detaljeret beredskab for *hele* forretningen. Dette kan vise sig at være et ganske uoverskueligt arbejde, og når et nedbrud sker, er det ikke til stor hjælp. Vi anbefaler derfor alle organisationer, der arbejder seriøst med beredskab, aktivt og kritisk at indgå i arbejdet om at gennemføre en BIA.

Når man udfører en BIA, er der nogle input, der er centrale at få på plads. Dernæst gennemføres BIA'en i en række trin – vi foreslår, at man kigger på seks trin. Målet er, at vi har tilstrækkeligt materiale til at udarbejde en klar IT-beredskabsstrategi og tilgang, der understøtter, at vi som organisation kan prioritere genopretningsindsatsen i en krisesituation.

Nedenstående figur opsummerer input til BIA, indhold i BIA'en og det ønskede output. De enkelte dele gennemgås i det følgende.



Figur 6.5. Eksempel på indhold i business impact analysis.

Input til BIA

Figuren ovenfor viser i venstre side de input, der er nødvendige at indsamle, før man kan gennemføre en BIA. Her handler det om først at have overblik over risikoappetit, og hvordan kritikalitet vurderes i organisationen. Det er vigtigt at indsamle input fra organisationen og *både* få input fra fagområder, have overblik over forretningsprocesser og IT-systemer samt infrastruktur og "assets" (hardware såsom computere, telefoner osv.). Nogle organisationer begår desværre den fejl, at de kun spørger IT-kyndige kollegaer om, hvilke systemer der er essentielle. Dette kan lede til, at fokus lægges det helt forkerte sted, og at vi fokuserer på at opretholde vores økonomi- eller HR-system, selvom disse ikke nødvendigvis er særlig kritiske for vores produktion. Hvis man, omvendt, kun indhenter input fra fagområder eller ser på processer, kan der være fare for, at essentiel understøttende og tværgående infrastruktur tages for givet. Som eksempel vil de fleste afdelinger i en organisation hurtigt udpege deres kernesystemer, og hvilke opgaver de ville have svært ved at udføre uden IT-understøttelse af disse. Formentlig ville de ikke forholde sig til tværgående in-

frastruktur som f.eks. adgang til AD'et eller adgang til bygninger, som også kan være essentielle.

De værktøjer, der blev præsenteret i kapitel 2, skulle gerne medføre, at vi har et tilstrækkeligt overblik over:

- Forretningsområder
- Forretningsprocesser og den digitale understøttelse heraf
- Overblik over IT-systemer
- Overblik over infrastruktur.

Ved at indsamle input på tværs føder alt dette ind i en BIA. En BIA skal også vise, hvordan processer i en organisation kan håndteres uden IT-understøttelse (forretningskontinuitetsplan) (Alexander, 2016). I pensionsselskaber kan man for eksempel tænke, at det at kunne udbetale pension til rette tid er et essentielt område. Det kan dog være, at *beregning* af korrekt ydelse (pension) og *udbetaling* viser sig at være to forskellige arbejdsgange. Udbetalingens forretningsnødplan kan være at udbetale det beløb, som kunderne fik udbetalt i sidste måned. Det er selvfølgelig ikke optimalt, men vil sikre, at der ikke er kunder, der står uden livsvigtig indkomst, og dette kan korrigeres senere. Hermed kan der prioriteres, så det er de vigtigste processer, der får fokus på genetablering først.

BIA'en

I selve BIA'en dykker vi ned i, uddyber og dokumenterer forretningsprocessernes kritikalitet. BIA'en beskriver den forretningsmæssige konsekvens som følge af en krisesituation. Der kan være tale om både kvalitative og kvantitative konsekvenser, som gennemgangen også kort viste i kapitel 2. Man skal overordnet forholde sig til, hvor sårbar en organisation er, hvis en given forretningsproces bliver kompromitteret. Målet er at kunne rangere forretningsprocesserne ud fra deres kritikalitet. Dernæst bør man få sig en idé om, hvor lang tid organisationen kan leve med, at processen er ude af drift – eller hvor længe (tid) man vil være i alternativ eller nøddrift – og hvad det kan koste i penge og andre ressourcer (f.eks. mandskab eller samarbejdspartnere/underleverandører). Man skal desuden også forholde sig til målet for genopretningen, skabe et overblik over prioriteringen af ressourcefordelingen i en krisesituation og forstå afhængigheder. Alle disse skridt er kort uddybet nedenfor.

1. **Fastslå en kritikalitetsvurdering**
   Kritikalitetsvurdering i en BIA er på forretningsmæssigt niveau og ikke på systemniveau, som tilfældet var for risikovurderingen på systemniveau i kapitel 4. I den forretningsmæssige kritikalitetsvurdering er målet at finde ud af, hvor sårbar organisationen er, hvis netop denne forretningsproces bliver kompromitteret i forhold til fortrolighed, integritet eller tilgængelighed (for mere information om FIT-triaden (på engelsk: CIA) se kapitel 0: Introduktion). Her kan man altså spørge sig selv, hvad der kan ske, hvis nogen uretmæssigt får adgang til vores data, hvordan vil nogen kunne ændre på data, eller hvordan vores systemer kan blive gjort utilgængelige for os. Svaret på spørgsmålet kan både opgøres kvantitativt eller kvalitativt. Det kan f.eks. være, at det vil koste xx kr. for organisationen, eller at det vil påvirke organisationens omdømme. I kapitel 2 under afsnittet "Kerneprocesser, der støtter målopnåelsen" gennemgik vi redskaber til den forretningsmæssige kritikalitetsvurdering, så der er konkrete værktøjer at hente i gennemgangen der.

2. **Rangering af kritikalitet**
   Når vi har forstået, hvor kritiske forretningsprocesserne er for vores organisations mulighed for at nå sine mål, så kan vi rangere forretningsprocesserne ud fra deres kritikalitet. Nogle forretningsprocesser vil være mere kritiske end andre og skal derfor behandles derefter – særligt i en krisesituation. Her kan vi se på, hvilke processer der, hvis de bliver kompromitterede, vil ligge over den risikotærskelværdi, der er fastsat af ledelsen. Det kan f.eks. være i forhold til, hvor mange penge vi som organisation kan risikere at miste, ved at forretningsprocessen er utilgængelig, data kommer i de forkerte hænder, eller vi ikke kan stole på data.

3. **Beslut maksimal acceptabel nedetid**
   En uddybning af kritikalitetsvurderingen er at beslutte, hvor lang tid vi som organisation kan leve med nedetid. Her er den engelske term MTD ofte i spil hos fagfolk. MTD står for Maximum Tolerable Downtime[1]. MTD

1 MTD: Maximum Tolerable Downtime kaldes også MTO: Maximum Tolerable Outage, og andre gange igen kaldes den MTPD: Maximum Tolerable Period of Disruption (ISO 22301:2019).

handler om at finde ud af, hvor lang tid der går, før organisationen lider permanent skade eller ligefrem risikerer ikke at overleve, ved at en forretningsproces er ude af drift. For at konkretisere det kan man f.eks. tænke på en onlineboghandel. Kunderne vil nok undre sig lidt, hvis hjemmesiden er utilgængelig i en time eller et par dage. De vil måske komme tilbage igen efter et par dage for at købe deres bog. Det vil de dog næppe, hvis der går uger, før hjemmesiden er oppe at køre igen. Kunderne vil nok her gå til en konkurrerende hjemmeside for at købe deres bøger. I dette eksempel kunne MTD f.eks. være 72 timer.

At forholde sig til MTD er altså meget vigtigt for, at organisationen kan prioritere, hvor der skal sættes ind i en krisesituation, hvis IT-systemer kompromitteres i forhold til fortrolighed, tilgængelighed eller integritet.

Hvor galt skal det egentlig gå?

Det er ikke nogen let opgave at bestemme MTD. For hvornår er forretningsområder og processer så vigtige, at de er afgørende for organisationens overlevelse? Det kan være svært at afgøre. Ligeledes vil visse organisationer, f.eks. visse offentlige myndigheder eller institutioner, selv ikke i tilfælde af et langvarigt nedbrud forsvinde.

Man skal derfor se på sin organisation og tænke over, hvad der særligt ville skade den. Det kan f.eks. være:

1. Betydningen for den offentlige orden
2. Tab af markedsandele
3. Tab af menneskeliv
4. Tab af aktieværdi.

Der bør være en tæt sammenhæng til organisationens risikotolerance i arbejdet med MTD.

4. **Etabler mål for genopretningen**

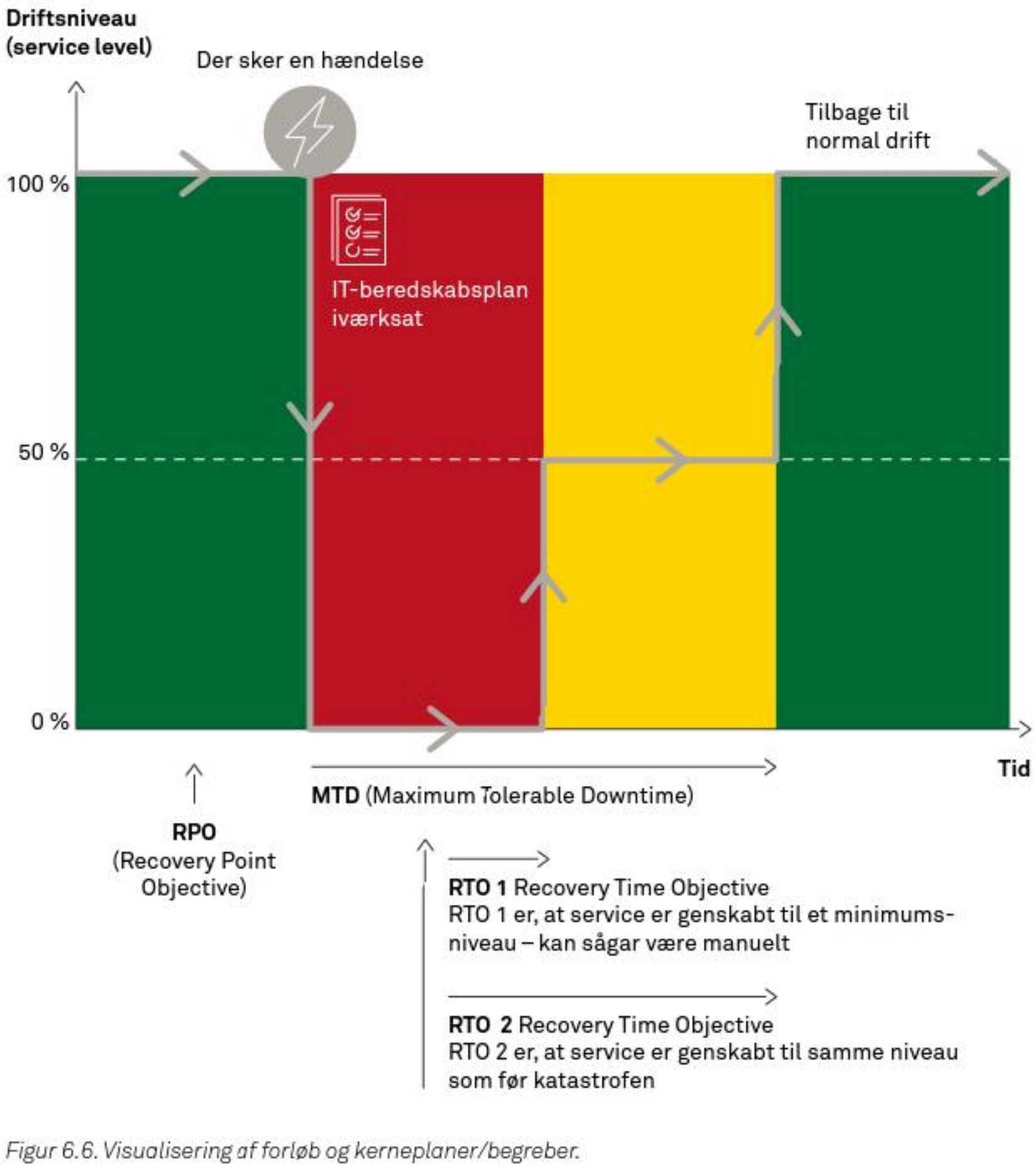
   Når vi har skabt os et overblik over, hvilke dele af vores organisation der er særligt vigtige, og den maksimale tid, vi kan leve med, at et forretningsområde eller proces er ude af drift (MTD), så kan vi gå i gang med at sætte mål op for genopretningen. Her handler det særligt om at tænke på, hvor lang tid der skal gå, før vi er "oppe at køre igen". At være "oppe at køre igen" kan gradbøjes i den forstand, at der ofte vil være visse dele af processerne, som kan genetableres hurtigere end andre, og som gør, at vi kan komme i gang med vores arbejdsopgaver igen. Nedenstående case er et eksempel herpå.

   Når man beslutter sig for målene for genoprettelse, er der ofte to koncepter, der bliver bragt i spil. Det er igen engelske termer, der bruges. Det første er RTO, der står for "recovery time objective", og det andet er RPO, som er en forkortelse for "recovery point objective".

   RTO er den maksimale nedetid for et forretningsområde eller en proces, der må være i tilfælde af en krisesituation. Krisesituationen kan opstå som følge af en lang række forskellige ting, f.eks. naturkatastrofer eller pandemier. Det kan dog også følge af cyberrelaterede hændelser. Uagtet hvad der forårsager krisesituationen, skal RTO være besluttet, for at vi som organisation kan iværksætte de rette foranstaltninger for at genoprette processen indenfor den tid, der er besluttet af organisationen.

   RPO er helt enkelt sagt den mængde data, som en virksomhed kan tåle at miste i tilfælde af en uforudset hændelse, uden at det skader virksomheden alt for meget. Her skal man vide, hvor ofte der bliver foretaget backup af data i en forretningsproces. Hvis det f.eks. sker en gang om ugen, kan man risikere at miste en hel uges data, hvis en hændelse finder sted, lige inden backuppen køres. Hvis det er for meget data, der mistes i forhold til organisationens beslutninger og prioriteter, må man sørge for, at backup sker f.eks. hvert døgn.

Visuelt kan man illustrere ovenstående via nedstående figur.



Figur 6.6. Visualisering af forløb og kerneplaner/begreber.

Figur 6.6 skal læses som en tidslinje, der beskriver, hvornår de forskellige begreber bringes i spil. I den første "grønne del" til venstre i figuren er en organisation i almindelig drift – alt går godt (fagpersoner vil omtale dette som, at service level er på 100 %). Når der sker en hændelse, er det den seneste brugbare backup fra den grønne fase, som man skal finde tilbage til (RPO = Recovery Point Objective). Mange organisationer bliver ubehageligt overraskede over at finde ud af, at deres RPO ligger meget

langt tilbage, og de mister derfor unødigt meget data ved en sikkerhedshændelse.

"Det røde felt" viser, at driften falder drastisk ved en kritisk hændelse, der forstyrrer IT-driften – måske endda så meget, at hele organisationen er totalt lammet. Nu skal IT-beredskabsplanen bringes i spil. Det er vigtigt her at huske, at der vil være hændelser, der tilsyneladende ser kritiske ud, men som viser sig ikke at være det, eller hvor situationen kan håndteres uden at iværksætte hele beredskabet. IT-beredskabet vil, hvis det fungerer efter hensigten, kunne genoprette organisationens drift til det "gule" niveau, altså hvor organisationen oppebærer kritiske funktioner i et givent tidsrum, mens der arbejdes på at komme helt tilbage til normal drift (grøn igen). Husk, at det skal være tydeligt i IT-beredskabsplanerne, hvornår de skal iværksættes (Industriens Fond, 2024).

"Processen omkring, hvornår en plan skal tages i brug, er vigtig at forstå. Organisationen bør have en generel begivenheds- og hændelsesproces (event management / incident management). Det skal være helt tydeligt for alle de relevante medarbejdere, hvordan hændelser indberettes, og hvordan de risikovurderes – og hvornår de er kritiske nok til at trigge, at IT-beredskabsplanen iværksættes. Har man dette på plads, er man godt på vej."
Dion Rønne-Rasmussen, cybersecurity consultant og Disaster Recovery-specialist, Implement Consulting Group

5. **Skab overblik, og prioriter ressourcefordeling**

   Det er de færreste organisationer, der har uanede mængder af ressourcer. Særligt i krisesituationer. Når krisen rammer, så bliver det hurtigt alles kamp mod alle for at få de bedste ressourcer til at hjælpe sig med at genoprette processer, så opgaverne kan genoptages. Det er dog ikke en hensigtsmæssig tilgang, at de, der råber højest eller har flest stjerner på skulderne, får hjælp først.

   Det er derimod en langt bedre tilgang at være velovervejet omkring, hvor knappe ressourcer prioriteres først. Det gøres bedst, når der ikke

allerede er ild i serverrummet, eller hackerne allerede har låst for adgangen til nøgle-IT-systemer.

Vi kan bruge BIA'en som rettesnor til at aftale, hvilke forretningsområder eller processer der prioriteres først i tilfælde af en krisesituation. Ressourcer kan omfatte:

a. IT-systemer og applikationer
b. Leverandører og andre samarbejdspartnere
c. Nøglepersonel – både dem med forretningsmæssig og teknisk forståelse
d. Udstyr, f.eks. maskiner, telefoner osv.

6. **Forstå afhængigheder**

   Det sidste skridt er at blive bevidst om eventuelle afhængigheder. Her er det vigtigt at få skabt klarhed over, hvordan de vigtigste forretningsområder eller processer er afhængige af evt. andre input fra andre forretningsprocesser. Det kan også være i forhold til IT-understøttelsen, hvor de prioriterede forretningsprocesser kun fungerer, hvis der er data fra andre IT-systemer eller applikationer, der egentlig hører under et andet forretningsområde. Noget, man ofte også kommer til at overse, er, hvordan infrastrukturkomponenter såsom AD er nødvendige, for at en proces kan fungere efter hensigten. Afhængigheder indebærer også en analyse af roller og ansvar, ressourcer, kompetencer, ferie- og fraværsplaner, alternativ drift samt alternative bygninger, i fald de fysiske lokationer er ramt.

   De afhængigheder, man identificerer, skal dokumenteres, og det vurderes, om der skal sikres relevant backup (f.eks. fysiske lokaler), så organisationen er bedst muligt rustet til at overleve en krisesituation.

Med en risikoappetit i ryggen og en enighed om, hvilke processer der er kritiske for forretningen, er organisationen godt på vej til at kunne udarbejde et prioriteret og stærkt beredskab. Samlet giver dette et overblik over de forretningsprocesser, som er kritiske for organisationen. Det er netop disse forretningsprocesser, der ved et nedbrud derfor bør have særligt fokus i form af

IT-beredskabsplan. Den pointe uddyber vi nedenfor, hvor vi ser nærmere på IT-beredskabsstrategien.

Resultatet af en BIA (output)

Når man har gennemført sin BIA, vælger mange organisationer at samle dette i en IT-beredskabsstrategi. Denne type af strategi beskriver på mere overordnet niveau elementer såsom mål for beredskabet, beredskabsprocedurer, kommunikationsplaner og test og revision af beredskabsplanen. Strategien bør også omfatte ressourceallokering, træning af personale og en klar rollefordeling i tilfælde af en nødsituation. Husk, at også denne strategi skal godkendes af ledelsen. Disse overordnede beskrivelser i IT-beredskabsstrategien skal udfoldes yderligere i en mere detaljeret IT-beredskabsplan, som vi dykker ned i i det følgende afsnit.

Do (implementering)

Efter den grundige "Plan"-fase har man et overblik over, hvilke processer der er helt kritiske for forretningen, og som først skal have opmærksomhed i en krisesituation, og en godkendt IT-beredskabsstrategi. Først nu er man i stand til at udarbejde en IT-beredskabsplan, der faktisk giver værdi.

> *"Du starter med at finde det, der er allermest kritisk for organisationen, de kritiske forretningsprocesser – hvad er det, der gør, at organisationen overlever? Hvad er vi allermest bekymrede for? Det skal der være en plan for. Og så har du genetableringen med fokus på IT og hændelseshåndtering."*
>
> – Tine Tuxen Løvstrand, selvstændig informationssikkerhedsrådgiver

Dette afsnit præsenterer tre konkrete værktøjer, som hvis de er ordentligt på plads, vil kunne hjælpe organisationen godt igennem en krisesituation, således at de kritiske forretningsprocesser opretholdes.

1. IT-beredskabsplan

IT-beredskabsplanen er en mere præcis og operationel plan, der beskriver de specifikke procedurer, handlingsplaner og kommunikationsplaner, der skal bruges i konkrete nødsituationer. Der er en del detaljer, der skal med her, f.eks. er det vigtigt også at huske tydeligt at få beskrevet, hvordan/hvornår en krise vurderes til at være af et sådant omfang, at planen skal iværksættes, hvem der indgår i beredskabsteamet, og hvordan der føres log over handlinger og aktiviteter, samt hvem der gør det.

Udviklingen af en skarp IT-beredskabsplan er en disciplin i sig selv, som det kan være godt at søge yderligere information om. Vi vil dog her gerne fremhæve et par pointer, som kan være gode at have med sig, hvad enten man er ansat i en organisation, der netop nu skal til og i gang med beredskabsplanlægning, eller en virksomhed, som er mere moden på dette område.

- **Brug skabeloner**
  Online findes der en række gode ressourcer, som kan give et godt udgangspunkt for udarbejdelsen af en IT-beredskabsplan. Se bl.a. Sikker-Digital.dk og Dansk Brand- og Sikringsinstitut.

- **Husk at have planen printet ud/lettilgængelig**
  Tænk over, hvordan I vil tilgå en beredskabsplan i en krisesituation. At have den i et Word-format gemt i en Sharepoint-løsning, hvis man ikke har adgang til computere, er virkelig ærgerligt.
- **Tydelig kommunikation**
  En krisesituation kræver utroligt tydelig og løbende information til både medarbejdere, der er involveret i krisehåndteringen, samt dem, som ikke her. Og så selvfølgelig tydelig kommunikation til presse eller øvrige interessenter, hvis det er en situation på den helt store klinge.

"Den største udfordring er faktisk ofte kommunikation. Hvordan overleverer vi informationer mellem afdelinger, mellem samarbejdspartnere, og måske endda offentligheden? Det skal være på plads!" uddyber Tine Tuxen Løvstrand, selvstændig informationssikkerhedsrådgiver.

- **Mini-beredskabsplan**
  Vi anbefaler altid dem, vi arbejder sammen med, at få udarbejdet en "mini-beredskabsplan". Denne plan er den ultrakorte pixi-udgave af beredskabsplanen, printet ud på holdbart papir og i en størrelse, så det kan passe ned i lommen eller siden af tasken. Mini-beredskabsplanen beskriver kort, hvordan IT-beredskabsteamet aktiveres (kriterier herfor), hvem der er i kriseledelsen, hvor man kan mødes fysisk, og hvordan man kan få fat i de vigtigste personer (også hvis arbejdstelefonerne er lagt ned!). Med denne mini-plan i hånden spares der helt utroligt værdifuld tid i de første indledende timer af en hændelse, hvor mange organisationer ellers har oplevet, at medarbejdere løber forvirret rundt for bare at kunne finde ud af, hvem det nu var, der var i beredskabsteamet, og hvordan man får fat på hinanden. Et eksempel på en mini-beredskabsplan kan f.eks. hentes på SikkerDigital.dk og kan så tilpasses den enkelte organisation (Digitaliseringsstyrelsen, u.å.).

Vi har også indsat et eksempel på en mini-beredskabsplan nedenfor.

- **Mini-beredskabsplan**
  Vi anbefaler altid dem, vi arbejder sammen med, at få udarbejdet en "mini-beredskabsplan". Denne plan er den ultrakorte pixi-udgave af beredskabsplanen, printet ud på holdbart papir og i en størrelse, så det kan passe ned i lommen eller siden af tasken. Mini-beredskabsplanen beskriver kort, hvordan IT-beredskabsteamet aktiveres (kriterier herfor), hvem der er i kriseledelsen, hvor man kan mødes fysisk, og hvordan man kan få fat i de vigtigste personer (også hvis arbejdstelefonerne er lagt ned!). Med denne mini-plan i hånden spares der helt utroligt værdifuld tid i de første indledende timer af en hændelse, hvor mange organisationer ellers har oplevet, at medarbejdere løber forvirret rundt for bare at kunne finde ud af, hvem det nu var, der var i beredskabsteamet, og hvordan man får fat på hinanden. Et eksempel på en mini-beredskabsplan kan f.eks. hentes på SikkerDigital.dk og kan så tilpasses den enkelte organisation (Digitaliseringsstyrelsen, u.å.).

Vi har også indsat et eksempel på en mini-beredskabsplan nedenfor.

Start et sted – og byg systematisk videre derfra

"Jeg ser beredskab som en organisatorisk ting mere end en IT-ting. Det må ikke være kompliceret og skal være tilpasset den enkelte organisation. Hold det helt simpelt, og start eventuelt med et par sider, som så får mere input og udvikles undervejs.

Husk, at en beredskabsplan er operationel. Alt mulig metatekst og baggrund og så videre skal i andre bilag eller være andetsteds. Brug præcise vendinger i planen, og hav fokus på træning. Jeg anbefaler ofte at bruge mikrotræning, f.eks. bare i en frokostpause, hvor vi træner, hvordan vi får fat på hinanden, hvis telefonerne er nede. Eller hvor vi tjekker, vi ved, hvor planen er, hvis IT-systemerne er utilgængelige."

– Tine Tuxen Løvstrand, selvstændig informationssikkerhedsrådgiver

Check (test og træning)

Alle, der har arbejdet med beredskab, vil fremhæve, at særligt *træning* eller *test* af beredskabsplaner er det, der for alvor giver arbejdet værdi. Der kan være nok så mange gode tanker og arbejde lagt i en IT-beredskabsplan, som på papiret ser ud til at fungere rigtig godt. Men når en krisesituation banker på døren, hjælper planen ikke spor, hvis de relevante medarbejdere ikke ved, hvor den er, hvad de skal gøre, eller hvis teksten viser sig ikke at være helt så selvforklarende for brugeren, som man egentlig troede (Somers, 2018). Det er heller ikke nok blot at se på beredskabsplanen en enkelt gang, da der i langt de fleste organisationer er udskiftning på medarbejdere, og vigtig viden derfor kan gå i glemmebogen. Træning kan (og bør) tilrettelægges, så den passer til organisationens størrelse og modenhed. Vi råder også altid til, at "lidt er bedre end ingenting", så man i hvert fald er klar over, at beredskabsplanen eksisterer, og hvem der er involveret i tilfælde af en krisesituation. Hvis man vil hive sig lidt op i niveauerne, kommer her tre bud på, hvordan man kan sørge for, at IT-beredskabsplanen kommer mere "ind under huden" på organisationen.

1. **Den korte og lette**
   Den helt lette øvelse, som derfor næsten burde være obligatorisk for alle, kalder vi for "skrivebordsøvelsen". Her samler man de medarbejdere, der også ville være involveret i en krisesituation, i et mødelokale, hvor man

har beredskabsplanen printet og klar. En mødefacilitator giver først en kort indflyvning til programmet og formålet samt eventuelt lidt afsat tid til at læse planen, hvis dette ikke har været gjort inden. Herefter gennemgår man en udvalgt situation og taler sig igennem de forskellige punkter i planen. Allerede her har man sikret sig, at værdifuld viden er delt i medarbejdergruppen, da alle har læst planen og haft mulighed for at stille spørgsmål. Dette kan gøres på 2 timer.

2. **Den sjove**

   Vi ser en stigende tendens til, at flere organisationer ønsker at træne deres medarbejdere endnu mere i at kunne reagere hensigtsmæssigt i en lang række situationer, og at der opnås større forståelse for de forskellige rollers ansvarsområder og opgaver. Til dette formål bruger vi ofte forskellige "beredskabsspil", hvor der er udvalgt relevante scenarier, som spilles igennem. En facilitator sørger for, at der indimellem sker uventede hændelser, som gruppen så sammen skal tage stilling til med udgangspunkt i IT-beredskabsplanen. Er der mange deltagere, kan man med fordel dele op i flere grupper og så holde opsamling undervejs for at drøfte, hvordan de forskellige grupper løser de udfordringer, spillet har givet. Man kan sørge for at få udfordret forståelsen for forskellige rollers ansvar ved at tildele forskellige medarbejdere andre roller end dem, de ellers har i hverdagen. Det vigtige her er at få skabt en lidt mere "legende" stemning, så medarbejderne tør at læne sig ind i spillet og få udfordret deres viden og handlinger. Denne type af test kræver en del mere forberedelse, da de udvalgte scenarier og roller skal være relevante og brugbare. Der skal desuden være en facilitator, der kan holde grupperne på sporet samt sørge for en relevant opsamling.

3. **Den omfattende**

   I den helt store udgave af træningen af IT-beredskabsplanen aftaler man et tidspunkt, hvor man afprøver, hvad man ville gøre, hvis en af de udvalgte "kronjuveler" var utilgængelig. Man afprøver de udviklede manuelle arbejdsprocesser og øver det hele igennem. Lidt ligesom når man hører brandalarmen i en bygning og sørger for at øve, hvordan man går

ud af bygningen. Det er vigtigt at sige her, at dette kræver virkelig grundig forberedelse, således at man selvfølgelig ikke forstyrrer forretningen unødigt, og at alle ved, at der rent faktisk er tale om en øvelse. Denne type af øvelse kan være særligt givende for de udvalgte nøgleprocesser, men er også ganske omfangsrig og krævende.

Der findes en del inspiration online til, hvordan man kan træne sit IT-beredskab, og f.eks. på SikkerDigital.dk findes en række cases, som er lige til at gå til (Digitaliseringsstyrelsen, 2024).

Act (evaluering og forbedring)

Efter øvelse og træning af beredskabet er det helt essentielt at få afsat tid til evaluering og opsamling. Helt basalt skal man sørge for, at der er afsat ressourcer til, at de læringer, der opstår ved øvelserne, samles ind (noteres) og indarbejdes i nye versioner af beredskabsplanen. Vi har endnu ikke været med til en træning af en IT-beredskabsplan, der ikke viste, hvor der var plads til forbedring, men vi har desværre ofte oplevet, at der kan gå lang tid, fra øvelsen er afholdt, til de nye læringer er ordentligt indarbejdet.

Pointen om at evaluere gælder selvfølgelig også i tilfælde af, at organisationen er udsat for en "rigtig" hændelse, og IT-beredskabsplanen bliver bragt i spil. Sørg for, at alle involverede – når de har fået deres søvn igen, og der er ro igen efter hændelsen – bliver samlet og får debriefet på situationen. Her er det relevant også at tale evaluering af planen og få lavet de nødvendige justeringer, så organisationen er endnu bedre rustet næste gang.

Efter "act" starter man forfra i sin "plan-do-check-act"-cyklus, således at beredskabet til enhver tid passer til den situation, organisationen befinder sig i.

Et mineselskab på Madagaskar var udsat for et alvorligt cyberangreb

Som konsulenter indenfor cyber- og informationssikkerhed oplever vi lidt af hvert. Således sender vi på et tidspunkt et hold af konsulenter til Madagaskar for at hjælpe med en IT-beredskabsopgave i et mineselskab, der havde været udsat for et alvorligt cyberangreb.

Angrebet gjorde, at de ikke kunne udføre deres kerneopgave, som er at producere råstoffer. Tabet af produktionen kostede hver dag mange millioner amerikanske dollars. Noget måtte gøres.

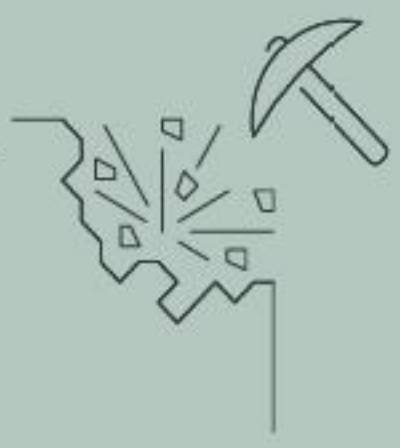
Vores team af genopretnings- eller disaster recovery-specialister gik i gang med at sørge for at afbøde skadens omfang ved at slukke for adgangen til internettet. Dernæst fik de i løbet af de første dage genoprettet centrale systemer, så minen igen kunne genoptage sin produktion af råstoffer. Dernæst fik de i løbet af de første dage overblik over, hvilke systemer der var centrale, og den rækkefølge, hvormed de skulle genoprettes, så minen igen kunne genoptage sin produktion af råstoffer.

For at give den nødvendige ro til at genetablere de påvirkede IT-systemer blev adgangentil internettet ved med at være afbrudt. Det resulterede i, at støtteprocesser som finans, HR, salg osv. ikke kunne genoptages med det samme.

Til gengæld kunne minearbejderne ude i produktionen heller ikke tilgå internettet. Der var ting, de ikke kunne registrere, som de plejede, så i en periode overgik de til manuelle registreringsprocesser (forretningskontinuitet).

Eksemplet illustrerer, at selvom ikke alle IT-systemer er tilbage i fuld drift, så kan man med den rette prioritering godt reetablere dele af de kritiske forretningsprocesser, så organisationen kan genoptage sine kerneopgaver – også i en krisesituation.

Som en krølle på halen viste det sig senere, at afkoblingen fra internettet medførte, at produktionen i perioden endte med at blive 10 % mere effektiv. Direktøren for minen havde en formodning om, at det var, fordi adgangen til sociale medier og YouTube blev afskærmet i arbejdstiden. Om det er sandt eller falsk, kan vi dog hverken be- eller afkræfte.



En kort opsummering:

IT-beredskab - Vær klar, når stormen kommer

- En business impact analysis (BIA) identificerer potentielle konsekvenser af nedetid, datatab, tab af forretningskritiske processer osv. og hjælper med at prioritere, hvilke systemer og processer der er mest kritiske for forretnings-kontinuiteten.

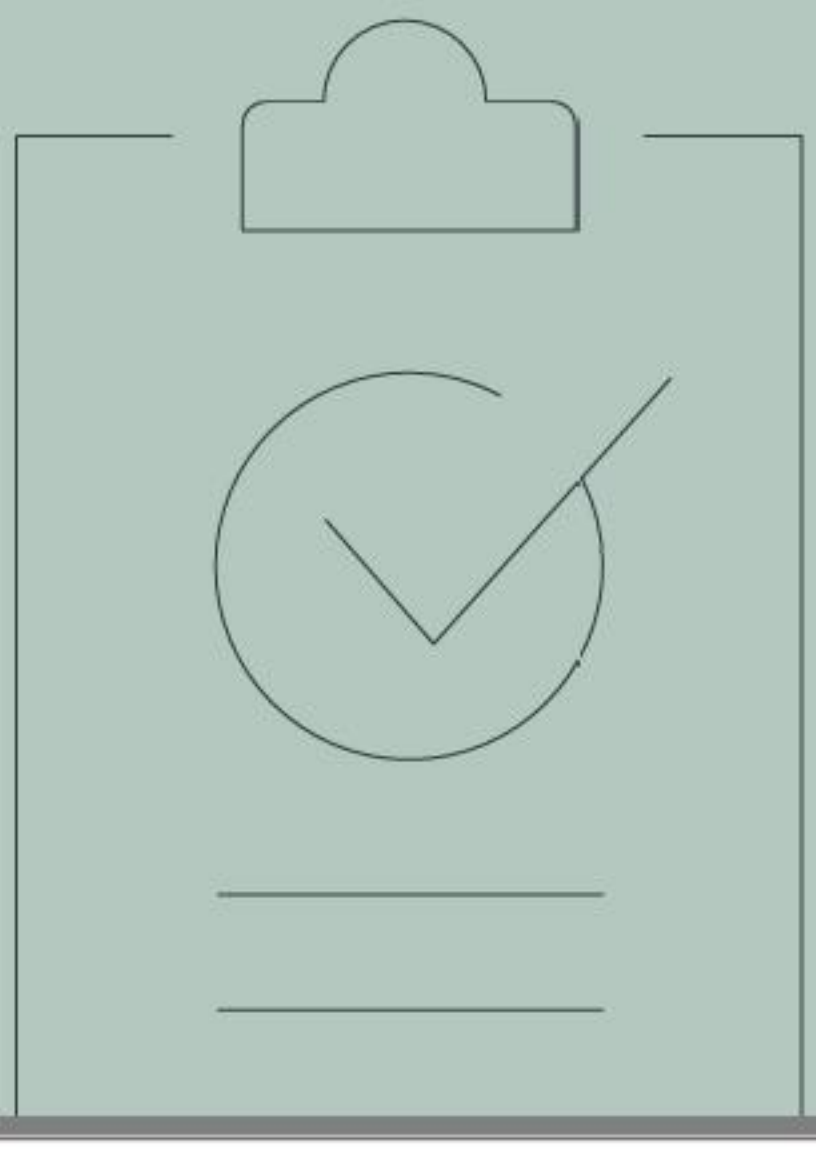
- En IT-beredskabsstrategi har fokus på, at organisationen skal rustes til at kunne håndtere IT-nedbrud eller andre nødsituationer, der har indflydelse på IT i organisationen.

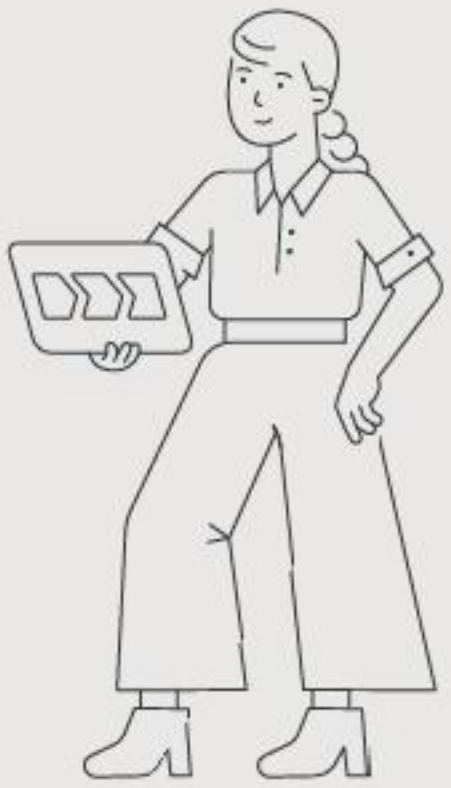
- En IT-beredskabsplan er den operationelle udmøntning af IT-beredskabs-strategien og er afgørende for, at organisationen kan reagere effektivt og rettidigt på IT-nedbrud, sikkerhedsbrud eller andre nødsituationer, der kan påvirke IT-systemerne.

- Forretningskontinuitet (business continuity) og IT-genopretning (disaster recovery) er to vigtige dele af et stærkt IT-beredskab.

- Arbejdet med IT-beredskab kan med fordel følge "plan-do-check-act", således at man kontinuerligt evaluerer og opdaterer arbejdet.

- Beredskabet kan øves kort og simpelt ved mundtlig gennemgang eller ved mere avancerede beredskabsspil eller endda øvelser, hvor man tester det hele af i virkelighedsnære scenarier. Men husk: Lidt er bedre end ingenting!





Case:

En offentlig myndighed oplever datasikkerhedsbrud

En offentlig myndighed vågner op til en ubehagelig nyhed, da en e-mail er blevet sendt til styrelsen med oplysninger om, at store mængder personlige data er tilgængelige online. Myndigheden har været offer for et vellykket phishing-angreb. Angriberne har opnået adgang til myndighedens ESDH-system (Elektronisk Sags- og Dokumenthåndtering) og mailsystem ved at stjæle en medarbejders loginoplysninger gennem en phishing-mail.

Phishing-mailen blev udformet til at se ud som en legitim besked fra myndighedens IT-afdeling og bad medarbejderne om at opdatere deres adgangskoder på en falsk loginside, der blev oprettet af angriberne. Desværre faldt en intetanende medarbejder for svindlen og indtastede sine legitimationsoplysninger, hvilket gav angriberne adgang til systemerne.

Med adgang til ESDH-systemet kan angriberne potentielt få adgang til fortrolige dokumenter og data, mens adgang til mailsystemet giver dem mulighed for at udføre yderligere phishing-angreb eller sprede malware via interne e-mails.

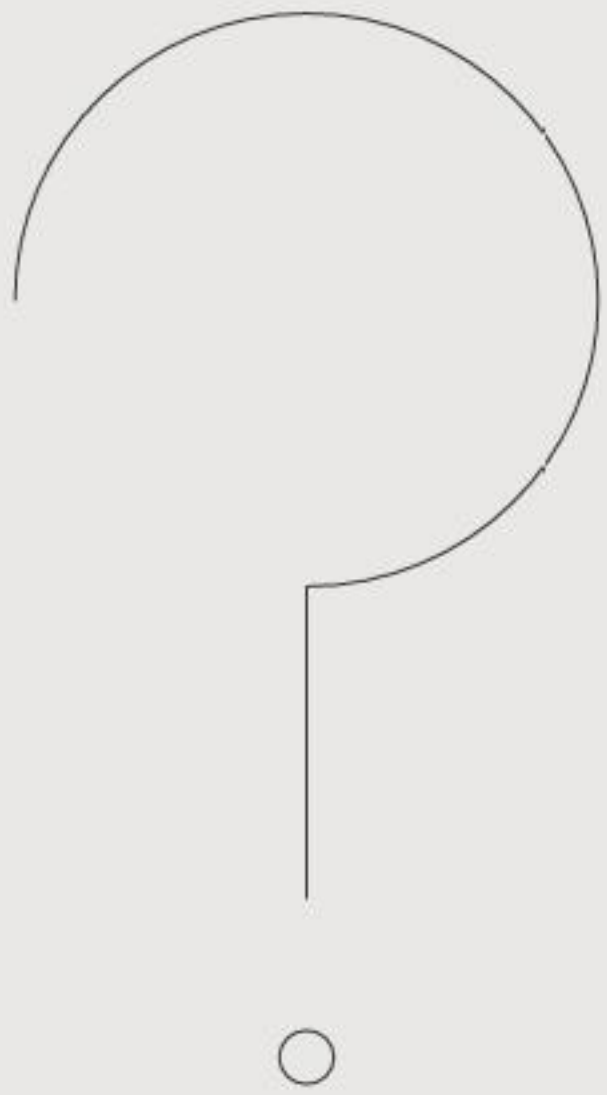
Myndighedens IT-afdeling bekræfter angrebet, da de bemærker usædvanlig aktivitet på den berørte medarbejders konto. De reagerer øjeblikkeligt ved at deaktivere kontoen, nulstille adgangskoder og gennemgå systemlogfilerne for at identificere omfanget af angrebet.

I overensstemmelse med myndighedens IT-beredskabsplan blev beredskabet aktiveret, og en tværfaglig beredskabsgruppe blev sammensat bestående af IT-sikkerhedseksperter, ledelsesrepræsentanter og juridiske rådgivere. Beredskabsgruppen evaluerer situationen, identificerer potentielle konsekvenser af angrebet og iværksætter tiltag til at begrænse skaden.

Pressen har fået færten af historien og ringer nu rundt til forskellige medarbejdere for at få mere information om "det store datalæk".

Arbejdsspørgsmål

- Hvordan opdagede myndighedens IT-afdeling angrebet, og hvilke skridt blev taget umiddelbart efter opdagelsen?
- Hvorfor blev IT-beredskabet iværksat, og hvad er formålet med at aktivere beredskabet?
- Hvem skal tale med pressen, og hvilken plan kan de følge for at holde snor i kommunikationen?
- Hvilke konsekvenser kunne angrebet have haft, hvis det ikke var blevet opdaget og håndteret hurtigt?
- Hvordan kan erfaringer fra denne hændelse bruges fremadrettet?



Litteraturliste

Alexander, A. G. (2016). A methodology for developing a business continuity strategy. ContinuityCentral. Business continuity, enterprise risk and resilience updates.

Cordero, I. (2019). IT Business Continuity Documents. Independently Published.

Digitaliseringsstyrelsen (u.å.). Beredskabsstyring. Lokaliseret på: https://www.sikkerdigital.dk/myndighed/iso-27001-implementering/beredskabsstyring/implementering

Digitaliseringsstyrelsen (2022). Vejledning i IT-beredskab. Lokaliseret på: https://www.sikkerdigital.dk/Media/638000655159015474/Vejledning-i-it-beredskab-september-2022.pdf

Ozkaya, E. (2022). Cybersecurity Leadership Demystified: A comprehensive guide to becoming a world-class modern cybersecurity leader and global CISO. Packt Publishing Ltd.

Somers, M (2018, 7. november). 8 steps to a stronger cybersecurity strategy. MIT Management. Lokaliseret på: https://mitsloan.mit.edu/ideas-made-to-matter/8-steps-to-a-stronger-cybersecurity-strategy

Industriens Fond (2024). Sådan får du en IT-beredskabsplan! Lokaliseret på: https://industriensfond.dk/vores-fokusomrader/cybersikkerhed/it-beredskabsplan/

International Organization for Standardization (2022). Information Security, cyber security and privacy protection-Information security management systems-Requirements. Reference number ISO/IEC 27001:2022(E).

International Organization for Standardization (2019). Security and resilience-Business continuity management systems-Requirements. Reference number ISO/IEC 22301:2019(en).

Kapitel 7

Kapitel 7

Cybersikkerhed:
Skab fremdrift med adfærdsdesign

> Medarbejdernes adfærd og kompetencer indgår som en aktiv og væsentlig del af et cyberforsvar der virker."
>
> Center for Cybersikkerhed, 2023

Adfærdsdesign som den hemmelige ingrediens

Som det sidste kapitel her i bogen tager vi fat i et helt centralt emne, som drejer sig om træning, uddannelse, awareness og særligt adfærdsdesign. Selv de bedste risikovurderinger og skarpeste sikkerhedsforanstaltninger kommer til kort, hvis de medarbejdere, der skal føre arbejdet ud i livet, ikke forstår *hvorfor*, ikke ved *hvordan* eller simpelthen ignorerer de nye tiltag, fordi de opleves som forstyrrende i arbejdsdagen. For eksempel har vi utallige gange observeret, at der bliver sat stole eller sko i klemme i døre, hvor der er tydeligt markeret, at disse døre bør holdes lukkede af hensyn til brandsikkerhed, eller fordi uvedkommende ikke bør få adgang. Det er samtidig vigtigt at huske, at mennesker også ofte begår fejl simpelthen på grund af stress eller afledning, og det er også ofte netop disse situationer, som hackere udnytter til deres fordel.

Alle tal og undersøgelser på området understøtter, at menneskelige fejl (hvad enten de er intentionelle eller ikke-intentionelle) bærer en stor del af ansvaret for at skabe de svagheder/revner i forsvaret, som hackere siden kan udnytte. Tallene varierer lidt, men World Economic Forum peger på, at op imod 95 % af alle cybersikkerhedshændelser sker på grund af menneskelige fejl (WEF, 2022). Tallene kan man altid diskutere, men det står ikke til diskussion, at vi og vores kollegaer er en nøglefaktor i at udføre og opretholde de sikkerhedsforanstaltninger, som cybersikkerhedsfunktionen igangsætter.

Vi ved det godt, og de fleste medarbejdere ved det også – at vi skal huske at skifte vores passwords, vi må ikke genbruge passwords på tværs af devices, vi må ikke lukke uvedkommende ind i bygningen osv. Men hånden på hjertet så har de fleste af os gjort netop disse ting, og en lang række andre handlin-

ger, der modarbejder det sikkerhedsniveau, som cybersikkerhedsfunktionen arbejder for at opretholde. Også på trods af awareness og uddannelse. Så hvad er der på spil?

"Alle risici skyldes menneskelig adfærd, enten ved at nogen gør noget, de ikke skulle gøre – trykker på et link, går fra en ulåst computer, og så videre – eller nogen ikke gør noget, som de skulle have gjort – patchet en server, sørget for kryptering på en fil, rapporteret phishing-mails og så videre. Derfor skal vi adressere den menneskelige faktor og arbejde med adfærd og sikkerhedskultur", fortæller Sarah Aalborg, Head of IT Governance og CISO i Tivoli og sikkerhedsadfærdsekspert.

Dette flugter med et syn på adfærd, som siger, at vi i stedet for at blive ved med at hælde mere information på vores medarbejdere i langt højere grad skal beskæftige os med de strukturer, der omgiver os, og de design af systemer, der gør, at vi begår fejl.

Som om dette ikke var argument nok for at arbejde seriøst med adfærd, så er der formelt fastsat krav i f.eks. ISO 27001 og NIS2 om, at awareness, træning og uddannelse er et selvstændigt emne, der skal arbejdes med i cybersikkerhed. Dette kommer til udtryk ved krav om cybersikkerhedstræning for både ledelse og medarbejdere. I ISO 27002 findes dette f.eks. under pkt. 6.3 "Awareness, uddannelse og træning vedrørende informationssikkerhed".

Awareness

- Vi definerer awareness som værende viden om eller forståelse for en given regel eller ønsket adfærd.
- Der arbejdes ofte med awareness via f.eks. kampagner, plakater, og eller oplæg på kontormøder.
- Skal være alignet med organisationens øvrige målsætninger for at være meningsfulde for medarbejderne.

Uddannelse

- Vi definerer, uddannelse som tidsbestemte aktiviteter med det mål at oplære specifikke medarbejdergrupper i udvalgte og relevante emner. For eksempel er cybersikkerhed ofte en del af onboarding for nye medarbejdere, eller medarbejdere sendes på relevante kurser for at få ny viden på området.

Træning

- Vi definerer træning som reel *afprøvning* af specifikke kompetencer, f.eks. er regelmæssig træning af beredskab et essentielt element af et stærkt cybersikkerheds-setup (se kapitel 6 om beredskab).

Krav om arbejde med disse ifølge f.eks. ISO 27001

Adfærdsdesign

- Vi definerer adfærdsdesign som et særskilt fokus på motivation og friktion, med det formål at opnå eller fjerne en bestemt adfærd.

Sjældent et krav ifølge fastsatte standarder, men et stærkt værktøj til at opnå reelle forandringer

Figur 7.1. Definition af awareness, uddannelser, træning og adfærdsdesign.

Ver store fortalere for, at man arbejder aktivt med adfærdsdesign på cybersikkerhedsområdet. Det betyder dog ikke, at vi ikke også ser værdien i både awareness, uddannelse og træning. Tværtimod. Der skal undervisning til for at

sikre, at medarbejdere har en chance for at vide, hvilke krav der stilles, og så de løbende kan blive opdateret på ændringer. Skarpe kommunikationskampagner kan være et godt middel til at få nogle grundbudskaber ud til en stor målgruppe. Vores pointe her er blot, at uddannelse og awareness ikke kan stå alene, da man så ganske enkelt risikerer, at indsatserne er uden effekt. I værste fald bliver de decideret modarbejdet som i eksemplet ovenfor med skoen i døren.

Vi ser desværre stadig indimellem virksomheder, der udarbejder uddannelser, der egentlig har til formål at ville ændre en bestemt adfærd, men uden at den ønskede adfærd understøttes. I denne genre finder man gerne e-læringskurser med fokus på håndtering af særlige typer af data (f.eks. i henhold til GDPR). Det udløser et fint grønt "flueben", at man har gennemgået denne uddannelse, men hvad rykker det *egentlig*? Gør medarbejderne herefter noget anderledes?

Det er her, adfærdsdesign kommer ind i billedet, fordi vi her rykker fra blot at tale om den ønskede adfærd til rent faktisk at undersøge konteksten nærmere og forstå vores kollegaers udfordringer bedre. Vi rykker hen imod at undersøge de barrierer, der står i vejen for den "ønskede" adfærd, og hvad der skal til for at understøtte, at det "ønskede" valg er det lette valg. På engelsk bruges ofte ordet "nudging". På dansk taler vi om adfærdsdesign.

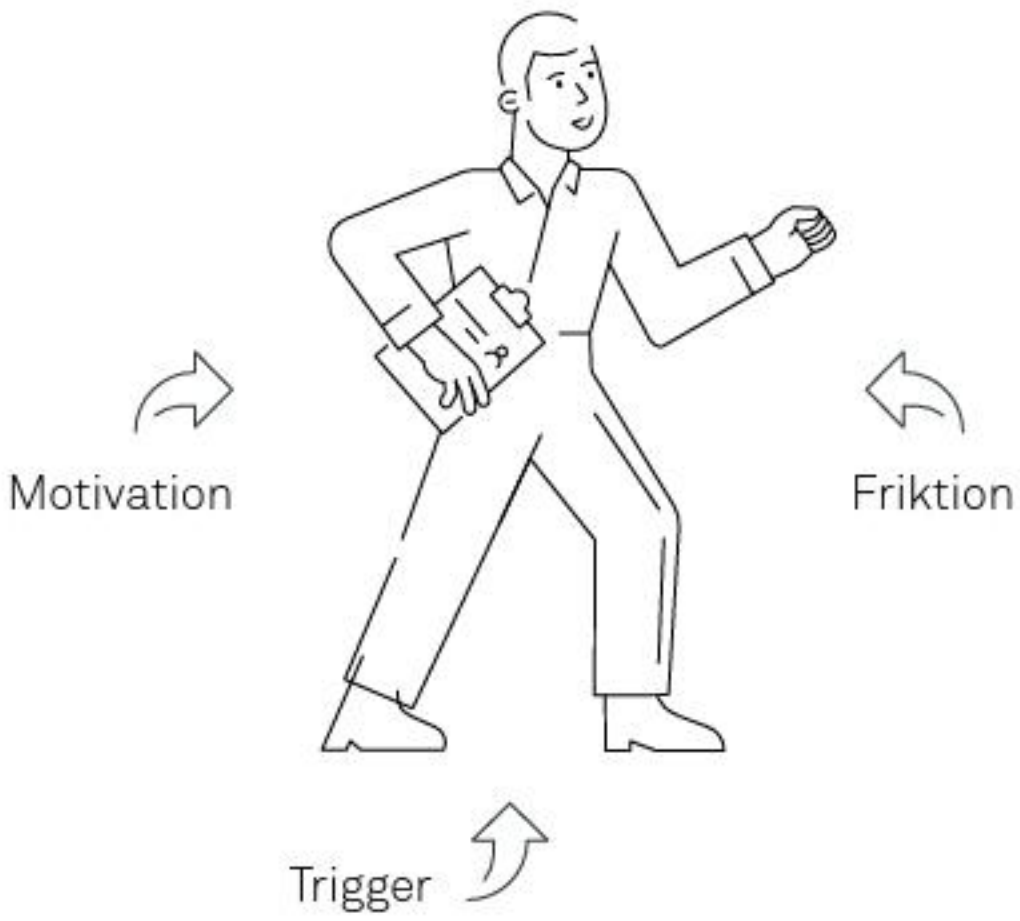
Mange medarbejdere *forstår* godt formålet med, at man f.eks. bør håndtere cpr-numre på en særlig måde, og at nogle typer af data er vigtigere end andre. Men hvis arbejdsgangene i organisationen understøtter, at det er lettest at håndtere alle data på samme vis, og man føler sig presset eller decideret modarbejdet af de systemer, der burde hjælpe en med håndtering af følsomme data, så gør medarbejderne ofte, hvad de kan, for at løse deres egentlige arbejdsopgave – også på trods af hvad der bliver sagt i et e-læringskursus. Som vores gode kollega og ekspert på området Aage Lemche-Romvig ofte siger: *"Adfærd er ligesom vand. Det render derhen, hvor det er lettest. Så hvis de handlinger og den adfærd, du ønsker, dine medarbejdere skal udvise, ikke er i nærheden af den letteste vej, så må du hellere forberede dig på at investere i store dæmninger."* Her kan et samspil mellem netop awareness, uddannelse og adfærdsdesign være vejen til succes.

Hvis målet f.eks. er, at alle i bygningen skal gå med ID-kort, kunne dette være en del af den uddannelse, som alle medarbejdere modtager, når de starter på jobbet. Der kan derudover også f.eks. være plakater ved indgangen, der giver konkrete forslag til, hvordan man kan spørge gæster om, hvorvidt de skal hjælpes på vej, eller hvordan man husker kollegaer på at tage ID-kortet frem. Der kan ligge gæstekort hos receptionen, så det er lettere at sige til nye ansigter, at her skal de huske at tjekke ind ved receptionen og bære synligt ID-kort. Der kan males fodspor eller streger på gulvet, der guider hen til receptionen. Hvis man ikke får *guidet* til den ønskede adfærd og får fulgt op på en måde, så den ønskede adfærd er *let* at følge, får man ikke ændret situationen. Så enkelt kan det siges.

Når vi i denne bog vælger at fokusere på adfærdsdesign, så er det, fordi vi oplever, at det netop er her, mange organisationer har "lavthængende frugter", som kan høstes. Det vil sige, at vi oplever, at mange organisationer overordnet set er gode til at udvikle relevant uddannelse, træning og kommunikation, men ofte har sværere ved at konkretisere den ønskede adfærd og arbejde målrettet med dette.

Når den ønskede adfærd møder motivation, friktion og trigger

Der er skrevet meget spændende og interessant litteratur om adfærdsdesign, og hvordan man kan anskue dette emne. Vi kan på ingen måde nå rundt om det hele, men tager os den frihed at anvende denne populære grove opsummering af meget adfærdsteori.



Figur 7.2. Motivation, friktion og "trigger" (på dansk ofte kaldet "situation").

Vi kommer ikke udenom, at cybersikkerhed er notorisk kendt for at være svært at få folk til at engagere sig i. Truslerne imod os kan virke utroligt fjerne, og som medarbejdere er vi dedikerede og vil gerne være færdige med de opgaver, vi *egentlig* er i gang med, og ekstra sikkerhedsforanstaltninger kan hurtigt opleves som noget, der skal "overstås".

Svaret på denne udfordringer er ofte, at der kan være stort fokus på at skabe **MOTIVATION** blandt medarbejdere for at skabe en bestemt adfærd. En kollega fortalte for eksempel, at hun på en tidligere arbejdsplads havde oplevet, at en chef ihærdigt forsøgte at få alle medarbejdere til at gennemføre det årlige e-lærings-GDPR-kursus. Til sidst tilføjede chefen desperat: "*Og så køber jeg noget slik, vi kan dele ud!*" Vores kollega kunne godt se det søde i den gestus og forsøg på motivation, men oplevede som flere andre også at tænke: "*Okay, hvis det er så slemt, at vi ligefrem skal lokkes med slik, så må det være virkelig kedeligt!*" Det, chefen gjorde her, var i virkeligheden at forsøge at øge motivationen for deltagelse. På den anden side blev der intet gjort for at mindske **FRIKTIONEN**, her kunne man f.eks. konkret fratage medarbejderne andre opgaver. Endelig kunne man sørge for en "**TRIGGER**", altså en situation, der understøttede den ønskede adfærd, som f.eks. at sætte tid af på et personalemøde til en fælles gennemgang og opsamling på den nye læring, og hvad

det betyder i deres arbejdsgange. Det er altid godt at tænke på, hvad der kan motivere folk til den ønskede adfærd, men hvis man ikke samtidig har øje for **FRIKTIONEN**, der opleves, og sørger for en gunstig "**TRIGGER**", så kommer man ofte ikke langt. Her må vi, med fokus på adfærdsdesign, arbejde metodisk, hvis vi ønsker reelle ændringer.

Anti-phishing-indsats med fokus på adfærd

"Et eksempel på en case, hvor jeg har arbejdet med uhensigtsmæssig adfærd, er indenfor phishing. Det, jeg har brugt adfærdsdesign til og arbejdet struktureret med, er spørgsmålet: Hvad er det præcis for en adfærd, jeg gerne vil have? I dette tilfælde skulle medarbejderne rapportere phishing-mails, så vi kunne forbedre vores filtre. Hvis de rapporterer, kan vi også fjerne den skadelige mail fra kollegaers mailbokse. Når vi så skal have dem til det, så kigger vi på, hvorfor de ikke allerede gør det. Har de ikke en rapporterings-'knap'? Måske de ikke ved, hvordan de skal rapportere? Eller har de måske en vane med, at de bare sletter den?

På baggrund af vores analyse gjorde vi det let at rapportere phishing-mails ved at indføre en 'fiske-knap'. Vi kørte nogle kampagner og skrev samtidig til medarbejderne, at de var med i en konkurrence, så hvis de rapporterede en mail, der kom indenfor den kommende uge, så vandt de et lod i en lodtrækning om en lille gave. Samtidigt fik de en informationsmail med f.eks.: 'Her er fem måder, du kan genkende en phishingmail på'. Alt dette baseret på adfærdsteori, der viser, at hvis vi ved, at vi skal bruge det indenfor kort tid, husker vi bedre i hjernen, end hvis vi skal bruge det på lang sigt. Vi indførte også mails, når de så rapporterede en phishing-mail, f.eks.: 'Godt spottet! Tak fordi du er med til at holde virksomheden sikker.' Man bliver lidt glad, når man får sådan en og med det samme ved, man har gjort det rigtigt. Hvis de ikke havde fanget den eller havde klikket på den, fik de en anden mail: 'Du fangede den ikke, her er et par highlights de steder, der burde have ringet nogle alarmklokker.' Jeg lavede videoer, hvor jeg på en let måde forklarede om emnet, og jeg tog rundt til fredagsmøder i de forskellige kontorer og fortalte mere. På den måde, ved at kombinere både awareness og tiltag baseret på adfærdsteori, har jeg været med til

at sikre, at rapportering gik fra 0 % nu til 67 % i den organisation, jeg arbejdede i. Det virker!"
– Sarah Aalborg, Head of IT Governance og CISO, Tivoli

Struktureret metode til adfærdsdesign

Alle, der arbejder seriøst med cybersikkerhed, bør gå lige så systematisk til værks med adfærdsdesign som ved de øvrige emner indenfor cybersikkerhed.

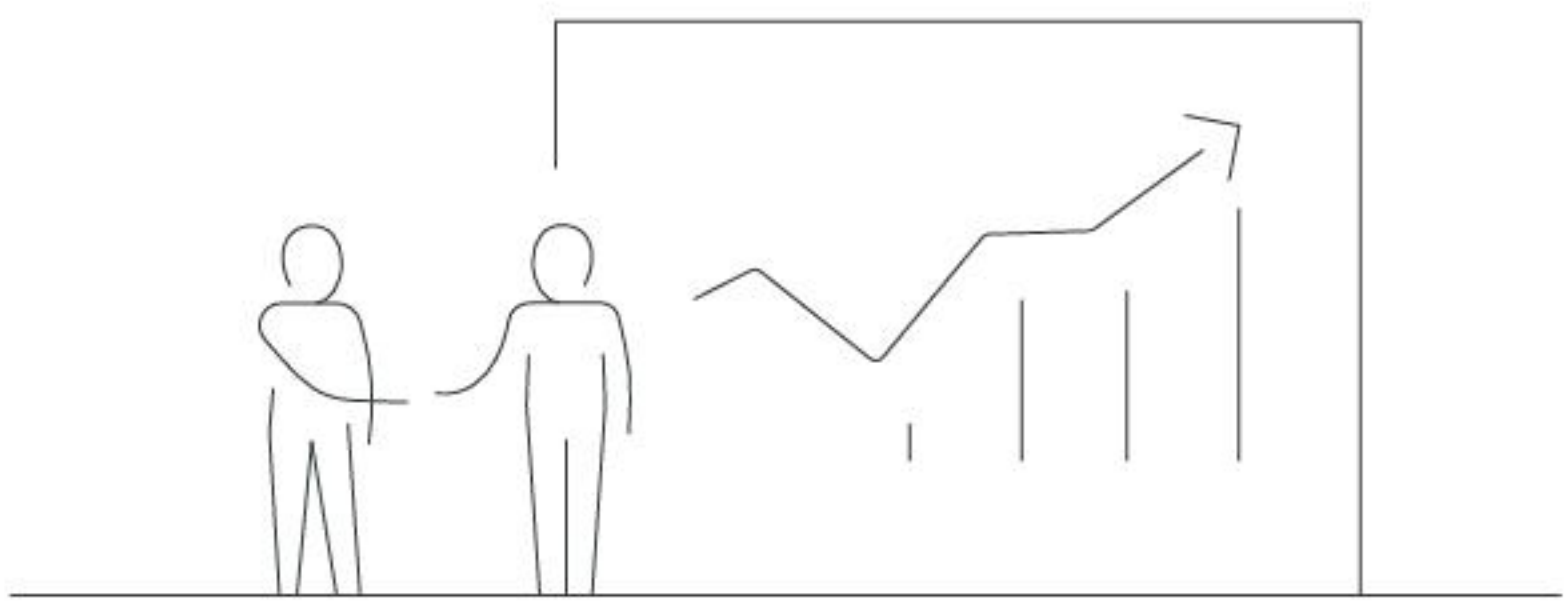
> *"... design referer til det målrettede forsøg på at forme adfærd. Præcis som designere skaber objekter og processer, der tilfredsstiller behov eller løser problemer, skaber adfærdsdesign adfærd for at øge livskvalitet og/eller løse problemer"* (Mølgaard et al., 2015).

Dette kræver, at vi reelt er nysgerrige på, *hvorfor* medarbejdere gør, som de gør, hvilke barrierer de står overfor, og hvordan vi får koblet disse til en ønsket adfærd. Der findes en række modeller og fremgangsmåder, man kan gøre brug af, men vi foretrækker at bruge 5D-modellen, som er baseret på adfærdsvidenskab og teorier fra designtænkning og videreudviklet af vores gode kollegaer i Implement (Holm et al., 2018). Vi foretrækker denne model, da den er simpel at gå til, men alligevel kommer hele vejen omkring en metodisk tilgang til adfærdsdesign.

Fem faser (og en case)

5D-modellen

1	Define	Hvad er den ønskede adfærd?	Løse det korrekte problem
2	Diagnose	Hvad motiverer og hindrer den ønskede adfærd?	
3	Design	Hvordan kan vi understøtte den ønskede adfærd?	Løse problemet korrekt
4	Document	Hvordan kan vi teste og dokumentere effekten af vores løsninger?	
5	Deliver	Hvordan kan vi implementere og skalere?	Implementere og sikre reel effekt



Figur 7.3. De fem faser i 5D-modellen.

En af grundene til, at vi gerne arbejder med 5D-modellen, er dens insisteren på at undersøge, præcis hvilken adfærd vi ønsker at ændre, *før* vi går i gang med at se på løsninger. Vi har erfaret gang på gang, at der kan være tendens til at springe meget hurtigt til tredje fase, Design. Det betyder i praksis, at man springer lige ud i at tænke på en løsning uden egentlig at have undersøgt problemet helt til bunds. Det ligger helt naturligt til mange af os, at vi har lyst til at finde en løsning og komme i gang med at implementere – vi har lyst til at *gøre* noget. Problemet er bare, at hvis man ikke er sikker på, at man har forstået udfordringen godt nok, så finder man sjældent den rigtige løsning i første forsøg.

Det er alment kendt indenfor adfærdsteori, at vi har tendens til at løse problemer med de værktøjer, vi allerede har foran os. For en hammer ligner alt et søm, som man siger. Det er derfor helt essentielt, at vi forstår udfordringen til bunds og bruger de *rette* værktøjer på de *rigtige* tidspunkter (Carpenter, 2019). Vores meget teknisk-orienterede kollegaer vil oftest foreslå meget tekniske sikkerhedsforanstaltninger som løsning på en udfordring. Kommunikationsmedarbejdere vil ty til kampagner og uddannelse. Lad os slå fast her, at det ikke er, fordi det ene er mere rigtigt end det andet, men at det handler om at vide, hvornår man skal bruge en hammer, og hvornår man hellere skal trække på andet værktøj fra værktøjskassen.

Lad os tage et eksempel. I en virksomhed, som vi arbejdede med, ønskede man at sætte fokus på, at fortrolige samtaler ikke skulle foregå i det offentlige rum, som f.eks. når man er i offentlig transport. Derudover gjorde mange medarbejdere brug af togturen til at få ordnet e-mails, men denne adfærd gjorde det let for uvedkommende at kigge over skulderen og få adgang til information, de ikke skulle have adgang til. Alt dette gav virksomheden som helhed en stor sårbarhed i forhold til potentielle læk af fortroligt materiale, samtidig med at det kunne give virksomheden et ry som værende skødesløs med deres egne og kunders informationer. I arbejdsgruppen havde det allerede været diskuteret, hvilke plakater der skulle udarbejdes og hvornår. Hypotesen her var, at medarbejderne skulle gøres opmærksom på, og forstå, vigtigheden af at beskytte virksomhedens vigtigste informationer. Med 5D-modellen tog vi dog et skridt tilbage og fik talt med flere medarbejdere om emnet. Det kom frem, at det var svært at finde gode steder, hvor de uforstyrret kunne snakke i telefon på arbejdspladsen uden samtidig at forstyrre hele det åbne kontorlandskab. Flere

medarbejdere valgte derfor at gøre dette til/fra arbejde, hvilket også indbefattede offentlige transportmidler. Derudover var de glade for at bruge netop transporten til uforstyrret at få læst op på mails, inden de mødte på kontoret. Her blev vi klogere på anden fase, Diagnose. Den ønskede adfærd blev forhindret af kontorlandskabet og medarbejdernes ønske om både at have fokustid til mails og samtidig at kunne tale i telefon uden at forstyrre kollegaer. I den tredje fase, Design, blev det derfor besluttet at teste "telefonbokse" på udvalgte kontorer samt "vil ikke forstyrres"-skilte ved computeren. Derudover fik alle udleveret "privacy-screens" til computerne, som gjorde det sværere for uvedkommende at kigge med. Disse tiltag blev lanceret samtidig med de oprindeligt udtænkte plakater, der satte fokus på, hvilken information der var passende at drøfte hvor. Til fjerde fase, Document, stillede to medarbejdere sig op med en kaffebod en morgen, når medarbejderne mødte ind. Her uddelte de kaffe, hvis medarbejderne svarede på spørgsmål om, hvorvidt de havde benyttet telefonbokse, skilte og privacy screens, og om de havde set plakaterne. Dette blev gjort i stedet for at sende survey ud på e-mail, fordi de fleste af os dagligt drukner i surveys og sjældent får svaret. Alle tilbagemeldinger blev så brugt til at gå videre med fase 5, Deliver. Projektet havde generelt en god modtagelse, og som bonus oplevede flere medarbejdere at arbejde uforstyrret i kontorlandskabet på grund af de nye telefonbokse. Selvfølgelig var projektet lidt mere komplekst end som så og ikke nær så lineært som beskrevet her. Der var derudover mange drøftelser med ledelsen omkring budgetter, da tiltagene selvsagt ikke var helt billige. Det var dog helt tydeligt for alle involverede, på baggrund af indledende analyse og tilbagemeldinger, at plakater og information ikke havde haft så stor effekt, som den samlede indsats viste sig at have.

I vores erfaring, fra blandt andet det ovenstående eksempel, får man ved en systematisk gennemgang af disse faser tænkt sit løsningsdesign godt igennem og får dermed undgået de værste faldgruber, som desværre ofte munder ud i, at ellers gode initiativer ikke opnår effekt, eller hvor designet af løsningen ikke reelt ændrer på den adfærd, der er problematisk.

Husk: Det må gerne være sjovt!

Lad os være ærlige: Cybersikkerhed er ikke altid et emne, der får alle til at juble. Nye sikkerhedsforanstaltninger kræver som oftest, at man gør noget anderledes, eller måske helt holder op med at bruge systemer, som man ellers var glad for at bruge. Grundlæggende er vi inde og arbejde med vaner, og det er en svær øvelse. Vi er derfor meget store tilhængere af at grave dybt i værktøjskassen og også gerne gøre lidt ekstra for at få skabt opmærksomhed og de ønskede ændringer. Her er et par eksempler på ideer, som vi enten er stødt på eller selv har været med til at udarbejde, som giver bare *lidt* mere opmærksomhed end endnu en e-mail fra cybersikkerhedsfunktionen.

- **Videomateriale**, f.eks. med ledelsens deltagelse, skaber altid god opmærksomhed og viser vigtigheden af emnet.
- **Sjove vinkler** på den ønskede adfærd; f.eks. havde Implement engang en indsats, der fokuserede på, at man skulle opføre sig som en detektiv, når man forlod et mødelokale – det vil sige, at ingen måtte kunne se, at man havde været der, og at alt materiale skal fjernes efter hvert møde, igen med fokus på fortrolighed. Det er lidt sjovere end at skrive: "Din mor arbejder her ikke".
- **Ugler/uventede indslag:** I Implement blev der opsat udstoppede ugler rundtomkring på kontorerne som påmindelse om, at der kan være andre, der kigger med på ens skærm. Disse gav anledning til en masse gode samtaler og grin.
- **Konkurrencer:** Med måde! Konkurrencer er meget engagerende for nogle – og direkte irriterende for andre. Brug dem på rette tidspunkt.
- **Gamification:** Kan den ønskede adfærd understøttes, så den er mere legende og dermed underholdende, så kan dette være en meget effektiv vej frem. Se mere i boksen nedenfor.

Husk, at når der er skabt en motivation og måske endda nysgerrighed hos modtagerne, så tænk nøje over, hvilken "trigger" eller situation der kan føre dem hurtigt videre til den ønskede adfærd. Med andre ord: Giv dem mulighed for at handle med det samme, fordi motivationen desværre hurtigt fordufter. Det vil sige, at når der er skabt nysgerrighed og motivation for f.eks. at deltage

i en konkurrence, så send måske en opfølgende mail direkte ud til medarbejderne på et relevant tidspunkt – i stedet for at de selv skal gå ind på en side på intranettet og finde konkurrencen. Sørg for, at adgangskort er printet og ligger klar ved indgangen osv.

Kan cybersikkerhed være sjovt?

"Compliance-emner som ISO 27001 eller GDPR er for de fleste ret utilgængeligt stof. Vi vil rigtig gerne være med til at gøre compliance-træning mere relevant, effektivt, smidigt, engagerende og ja, gerne også sjovt. Studier viser, at det at lege sig til læring har en langt større effekt, så med udgangspunkt i gamification-teorier har vi fokus på at levere træning, som enten via apps eller brætspil engagerer deltagerne på en anderledes måde. Vi har gode erfaringer med både digitale og fysiske medier at etablere den trygge, let tilgængelige og engagerende platform til at formidle viden, skabe evnen og forankre adfærd – og vi har efterhånden arbejdet med en lang portefølje af virksomheder, både store og små. Vi kan vise, at deltagerne engagerer sig både mere og længere end ved traditionel e-læring, og vi kan vise, at den nye viden rent faktisk udmønter sig i ændret adfærd."
– Aage Lemche-Romvig, adfærdsekspert, Implement Consulting Group

Hvilke roller findes der i jagten på en god sikkerhedskultur?

Som med alle andre emner indenfor cybersikkerhed er det nødvendigt at tale om roller og ansvar. Det kan nemlig, også indenfor adfærdsdesign, være en god idé at drøfte roller og ansvar i virksomheden, således at man er *helt* sikker på, at alle ser den samme fordeling. Alternativet kan være, har vi erfaret, at adfærdsdesign uddelegeres til f.eks. en kommunikationsafdeling eller enkelte personer i en cybersikkerhedsfunktion. Reelle adfærdsændringer kræver dog, som det fremgår af kapitlet her, samarbejde på tværs af organisationen, og at de prioriterede indsatser anskuer adfærd og løsninger fra mange vinkler (se 5D-modellen ovenfor).

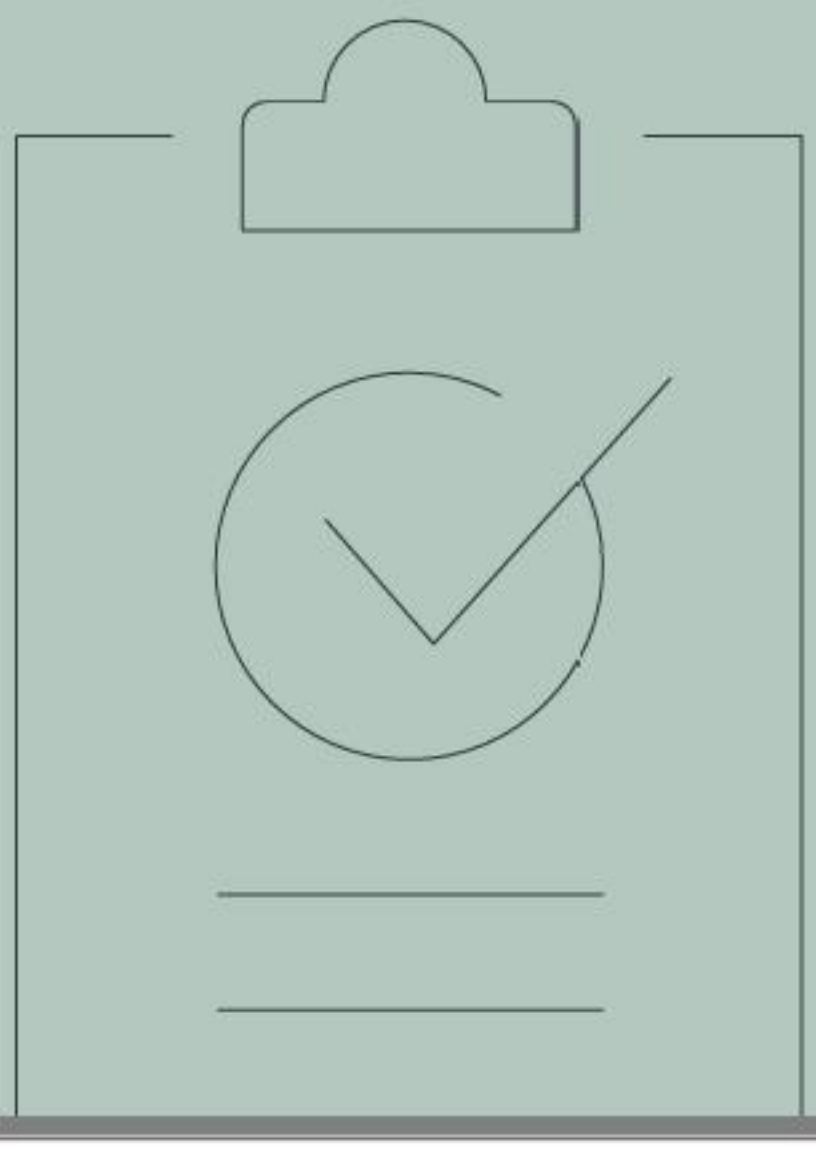
Nedenstående tabel skitserer, hvilket ansvar de forskellige roller i en virksomhed eller myndighed typisk har i forhold til at inddrage adfærdsdesign, baseret på modellen om de tre forsvarslinjer (præsenteret i kapitel 5: Roller og ansvar).

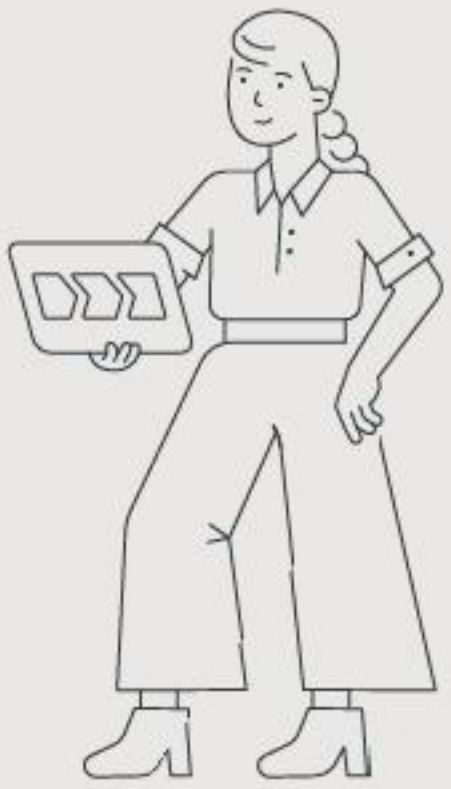
Rolle	Også kendt som ...	Har ansvar for ...	Kan bedst understøtte effektfulde løsninger ved ...
Topledelse/ Bestyrelse	Ledelse, CEO, CXO, direktionen, top management (her ses også informations-sikkerhedsudvalg og risikoforum)	... at sikkerhedskultur er en aktiv del af arbejdet for et passende cyber-sikkerhedsniveau	... at holde sig ajour med tendenser indenfor cyber-sikkerhedstrusler og -foranstaltninger (f.eks. via løbende træning) ... at være rollemodeller, der efterlever de retningslinjer, der udstikkes ... at være engageret i udarbejdelsen af relevante adfærdsfokuserede løsninger samt sikre ressourcer til dette arbejde
1. forsvarslinje	Afdelinger i myndigheden eller virksomheden med ansvar for f.eks. udvalgte systemer eller processer (dvs. proceseje-re, systemejere, systemansvarlige)	... at forstå og efterleve de fastsatte krav til cybersikkerhed i organisa-tionen samt indgå i dialog omkring, hvilke sikker-hedsforanstaltninger der kan indføres og hvordan ... at drive relevante adfærdsindsatser	... at anskue cybersikkerhed som væsentlig del af deres opgaveportefølje ... at indgå konstruktiv dialog med 2. forsvarslinje
2. forsvarslinje	Cybersikkerheds-funktionen, CISO, BISO, DPO	... at analysere og foreslå prioritering i risikohånd-tering (som kan indebære adfærdsdesign), faglig sparring i adfærdsdesign med cybersikkerheds-fokus ... at drive relevante adfærdsindsatser	... at sætte sig ind i forretningens daglige drift (herunder motivation og barrierer for den ønskede adfærd) ... at være realistisk og vedholdende i dialog og indsatser
3. forsvarslinje	Intern revision	... at udpege områder med mangler eller behov for yderligere fokus. Eventuelt give input til målemetoder. Ansvar for opfølgning	... at være til rådighed for løbende dialog ... at give konkrete input og sparring
Den "almindelige" medarbejder	Alle andre end topledelse og de tre forsvars-linjer	... at efterleve de fastsatte krav som anvist i f.eks. medarbejderhåndbog og ansættelseskontrakt ... at påpege uhensigts-mæssige løsninger samt give input til 1. forsvars-linje, når relevant	... at følge regler og anvisninger samt indgå i konstruktiv dialog, hvis der opleves mangler eller uhensigtsmæssige sikker-hedsforanstaltninger

Figur 7.4. De tre forsvarslinjer og adfærdsdesign.

En kort opsummering:
Cybersikkerhed og adfærdsdesign.
Skab forandring med effekt

- Det kan være enormt værdifuldt at arbejde aktivt med adfærdsdesign, fordi det er her, vi rent faktisk arbejder med de adfærdsændringer, der giver vores sikkerhed det nødvendige løft. Dermed undgår vi at skabe løsninger, der kun virker på papiret.
- Generelle awareness-kampagner og e-læring er godt til at få budskaber bredt ud, men det er nødvendigt at arbejde struktureret med adfærdsdesign for at opnå varig effekt. Dette kan f.eks. understøttes af 5D-modellen.
- Det må gerne være sjovt og have en anderledes vinkel! Men husk at analysere både motivation, friktion og "trigger" for den ønskede adfærd for at opnå størst mulig chance for effekt.
- Husk, at også her er det essentielt at drøfte roller og ansvar, så tiltag med fokus på adfærdsændringer rent faktisk får den ønskede effekt.





Case:

Hvem "lytter med" hos NôrdicSôund?

Virksomheden NôrdicSôund producerer headsets, hvor produktionen af dem drives af bæredygtig energi fra islandske vandkraftværker. Deres teknologi er "cutting edge", og de er i færd med at søge om patent på løsningen. NôrdicSôund har en stor konkurrent, som efter sigende snart er på markedet med et lignende produkt. Hvis konkurrenten når at komme først på markedet, vil det betyde et økonomisk tab i milliardklassen for NôrdicSôund.

NôrdicSôund indkøber løbende forskellige elektroniske dele fra hele verden til højtalere, mikrofoner osv., som bruges til udvikling og test af deres headsets. Disse elektroniske dele kan have skadelig indflydelse på virksomheden, hvis de viser sig at indeholde malicious software, altså problematisk software, eller på anden vis kunne skabe datalæk. NôrdicSôund har derfor en striks procedure for godkendelse af indkøb, hvor cybersikkerhedsafdelingen skal godkende købet, inden det kan gennemføres. Proceduren gennemføres ved brug af et indkøbt forretningsproces-program, som kun få medarbejdere er oplært i at bruge.

Det er nu kommet NôrdicSôunds CISO for øre, at flere produktudviklere i mikrofonafdelingen indkøber små dimser uden om den officielle indkøbsproces. Det viser sig, at produktudviklerne oplever indkøbsprocessen som generelt helt unødvendig og i øvrigt alt for langsommelig. Derudover er ingen af produktudviklerne i mikrofonafdelingen oplært i at bruge forretningsproces-programmet.

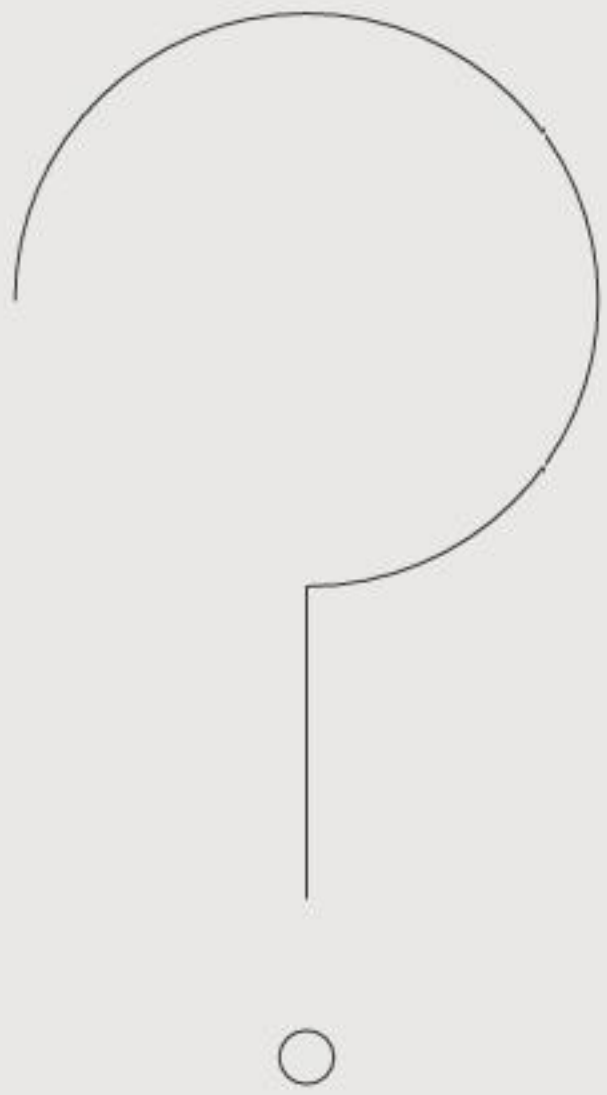
Arbejdsspørgsmål

- På baggrund af casen, hvilke barrierer ville du vurdere, at produktudviklerne oplever i forhold til at følge virksomhedens procedurer for indkøb? Hvordan ville du undersøge videre, hvilke konkrete barrierer der opleves?

- Notér 2-3 indsatser, der kunne hjælpe til med at sikre, at produktudviklerne følger indkøbsproceduren?

- Udvælg en enkelt af løsningerne, som du har foreslået i forrige spørgsmål. Hvordan ville du teste effekten af din foreslåede løsning?

- Hvilke muligheder kunne der være for at skalere resultaterne til andre steder/ områder i virksomheden?



Litteraturliste

Carpenter, P. (2019). Transformational security awareness: What neuroscientists, storytellers, and marketers can teach us about driving secure behaviors. John Wiley & Sons.

Center for Cybersikkerhed (2023, juli). Vejledning: Cyberforsvar der virker. Lokaliseret på https://www.cfcs.dk/globalassets/cfcs/dokumenter/vejledninger/-cyberforsvar-der-virker-2023-.pdf

CSO online (2023, oktober). Cybersecurity workforce shortage reaches 4 million despite recruitment drive. Lokaliseret på: https://www.csoonline.com/article/657598/cybersecurity-workforce-shortage-reaches-4-million-despite-significant-recruitment-drive.html

Holm et al. (2018). /KL.7 Company Profile. /KL.7.

Høgh, H. (2020). Model for adfærdsændring i praksis. Et kompendium til operationalisering af modellen. Metodecentret, Aarhus.

ISACA (2023, november). 'Tsunamis' to change course of security workforce. Lokaliseret på:

Mølgaard et al. (2015). Adfærdsdesign: Aben og jakkesættet. /KL.7.

WEF (2022). World Economic Forum Global Risk Report.

Tak

Først og fremmest et særligt stort tak Christian Ehlers Mikkelsen, Palle Mehlsen og Niels Ahrengot for at støtte vores idé om at skrive denne bog helt fra start. Stort tak til vores familier, som har været et stærkt heppekor og samtidig utroligt tålmodige!

Deltagere på vores kurser gennem tiden

Tak til de mange kursister, der gennem tiden har stillet gode spørgsmål og givet kommentarer til vores undervisningsmaterialer. Dette har været med til at udvikle os som undervisere og givet os ideen til denne bog.

Vores kunder og samarbejdspartnere

Vi er beærede over at få lov til at komme helt ind i cybersikkerheds-"maskinrummet" hos en lang række myndigheder og virksomheder, både i Danmark og udlandet. Tak fordi vi må blive udfordret hos jer og hele tiden lære nyt.

Dem, vi interviewede og fik input fra

Tak til

- Malene Stidsen og Nadika Bulathsinhala, Industriens Fonds Cybersikkerhedsprogram
- Jens Stener og Kirsten Hede, Bestyrelsesforeningens Center for Cyberkompetencer
- Sarah Aalborg, CISO, Tivoli
- Tine Tuxen Løvstrand, selvstændig informationssikkerhedsrådgiver
- Henning Mortensen, CISO og formand for Rådet for Digital Sikkerhed

Dem, der læste med og kommenterede

Selve titlen på bogen har været igennem mange versioner, men blev slået fast med input fra Christopher Juel Bendtsen Kassebeer.

Hvert kapitel i denne bog har været under kyndig gennemlæsning hos kollegaer, der har kapitlets emne som spidskompetence. Tak fordi vi måtte låne jeres tid og skarpe øjne: Anette Høyrup, Vera Marton, Louise Mehl, Rhianon Samuel, Anders Rømer Skøtt, Ulrich Tyndeskov, Charlotte Moeslund Saylor, og Emilie Norsk. Særligt tak til Christian Ehlers Mikkelsen, Dion Rønne-Rasmussen, Aage Lemche-Romvig, Carsten Jørgensen, Mie Lindgren og Mikkel Holm for at låne os ekstra meget af jeres tid. Derudover tak for at være et "udefra og ind"-perspektiv til Astrid Rosenvold Villadsen, Kristine Tang-Jensen og Marie Borbye Corini.

Tak til Marina Petri Poulsen for hjælp med det grafiske arbejde, og til vores redaktør Britta Østergaard for et skarpt øje på manuskriptet i sin helhed.

Har du input?

Vi er altid nysgerrige efter at høre kommentarer eller spørgsmål. Skriv gerne til os:

Nanna Gorm Boman: Nago@implement.dk

Mette Dreisler Dirac: Mrdr@implement.dk

Dem, der læste med og kommenterede

Selve titlen på bogen har været igennem mange versioner, men blev slået fast med input fra Christopher Juel Bendtsen Kassebeer.

Hvert kapitel i denne bog har været under kyndig gennemlæsning hos kollegaer, der har kapitlets emne som spidskompetence. Tak fordi vi måtte låne jeres tid og skarpe øjne: Anette Høyrup, Vera Marton, Louise Mehl, Rhianon Samuel, Anders Rømer Skøtt, Ulrich Tyndeskov, Charlotte Moeslund Saylor, og Emilie Norsk. Særligt tak til Christian Ehlers Mikkelsen, Dion Rønne-Rasmussen, Aage Lemche-Romvig, Carsten Jørgensen, Mie Lindgren og Mikkel Holm for at låne os ekstra meget af jeres tid. Derudover tak for at være et "udefra og ind"-perspektiv til Astrid Rosenvold Villadsen, Kristine Tang-Jensen og Marie Borbye Corini.

Tak til Marina Petri Poulsen for hjælp med det grafiske arbejde, og til vores redaktør Britta Østergaard for et skarpt øje på manuskriptet i sin helhed.

Har du input?

Vi er altid nysgerrige efter at høre kommentarer eller spørgsmål. Skriv gerne til os:

Nanna Gorm Boman: Nago@implement.dk

Mette Dreisler Dirac: Mrdr@implement.dk

Dem, der læste med og kommenterede

Selve titlen på bogen har været igennem mange versioner, men blev slået fast med input fra Christopher Juel Bendtsen Kassebeer.

Hvert kapitel i denne bog har været under kyndig gennemlæsning hos kollegaer, der har kapitlets emne som spidskompetence. Tak fordi vi måtte låne jeres tid og skarpe øjne: Anette Høyrup, Vera Marton, Louise Mehl, Rhianon Samuel, Anders Rømer Skøtt, Ulrich Tyndeskov, Charlotte Moeslund Saylor, og Emilie Norsk. Særligt tak til Christian Ehlers Mikkelsen, Dion Rønne-Rasmussen, Aage Lemche-Romvig, Carsten Jørgensen, Mie Lindgren og Mikkel Holm for at låne os ekstra meget af jeres tid. Derudover tak for at være et "udefra og ind"-perspektiv til Astrid Rosenvold Villadsen, Kristine Tang-Jensen og Marie Borbye Corini.

Tak til Marina Petri Poulsen for hjælp med det grafiske arbejde, og til vores redaktør Britta Østergaard for et skarpt øje på manuskriptet i sin helhed.

Har du input?

Vi er altid nysgerrige efter at høre kommentarer eller spørgsmål. Skriv gerne til os:

Nanna Gorm Boman: Nago@implement.dk

Mette Dreisler Dirac: Mrdr@implement.dk